

भारतीय बीमा विनियामक और विकास प्राधिकरण

सूचना और साइबर सुरक्षा दिशानिर्देश

संस्करण – 1.0
अप्रैल, 2023

विषय-सूची

1	सामान्य दिशानिर्देश	
1.1	प्रयोजन	
1.2	दायरा	
1.3	सिद्धांत और उद्देश्य	
1.4	प्रयोज्यता	
1.5	संचालन	
1.6	भूमिकाएँ और दायित्व	
1.7	स्वीकार्य उपयोग	
1.8	जोखिम प्रबंधन	
1.9	अपवाद	
1.10	अनुपालन	
2.0	सुरक्षा डोमेन नीतियाँ	
2.1	डाटा वर्गीकरण	
2.2	आस्ति प्रबंधन	
2.3	पहुँच नियंत्रण	
2.4	मानव संसाधन सुरक्षा	
2.5	सूचना प्रणाली अधिग्रहण और विकास	
2.6	सूचना प्रणाली अनुरक्षण	
2.7	मोबाइल सुरक्षा नीति	
2.8	अपना उपकरण लाओ (बीवाईओडी) नीति	
2.9	परिवर्तन नियंत्रण	
2.10	घटना और समस्या प्रबंधन	
2.11	नेटवर्क सुरक्षा	
2.12	क्रिप्टोग्राफिक नियंत्रण	
2.13	व्यवसाय निरन्तरता प्रबंधन और आपदा रिकवरी	
2.14	तृतीय पक्ष सेवाप्रदाता	
2.15	भौतिक और पर्यावरणीय सुरक्षा	
2.16	अनुप्रवर्तन, लॉगिंग और आकलन	
2.17	विधिक और विनियामकीय अनुपालन	
2.18	पारिस्थितिक जागरूकता	
2.19	क्लाउड सुरक्षा नीति	
2.20	साइबर अनुकूलता	
2.21	ईमेल सुरक्षा	
2.22	दूरस्थ स्थान से कार्य	
2.23	डीलिंग रूम परिचालन	
2.24	सूचना प्रौद्योगिकी (मध्यस्थ दिशानिर्देश और डिजिटल मीडिया आचार संहिता) नियम, 2021	
	अनुबंध अ	
	अनुबंध -आ	
	शब्दावली	

वितरण सूची

सं.	प्रयोक्ता का नाम
1.	मुख्य जोखिम अधिकारी (सीआरओ) – बीमा कंपनी
2.	मुख्य सूचना प्रणाली अधिकारी (सीआईएसओ) - संगठन
3.	नियंत्रण प्रबंधन समिति के सदस्य
4.	सूचना प्रौद्योगिकी (आईटी)
5.	सीआईएसओ द्वारा प्राधिकृत कोई अन्य प्रयोक्ता/ निकाय
6.	अंतिम प्रयोक्ता

सामान्य दिशानिर्देश

1. सामान्य दिशानिर्देश

1.1. प्रयोजन

संगठन की सूचना और साइबर सुरक्षा नीति में संगठन के महत्वपूर्ण डाटा और उसकी सूचना आस्तियों के निरंतर और समुचित संरक्षण के लिए जिम्मेदारियों की पहचान की गई है और लक्ष्य निर्धारित किए गए हैं। इस नीति के कार्यान्वयन से सूचना आस्तियों के दुर्घटनावश या इरादतन प्रकटन, परिवर्तन, विनाश, विलंब या दुरुपयोग की जोखिम को कम किया जा सकेगा। यह नीति सूचना सुरक्षा कार्यालय को इस बात में समर्थ बनाती है कि वह महत्वपूर्ण डाटा और सूचना आस्तियों की सुरक्षा के कार्यान्वयन, सुरक्षा बनाए रखने और उसमें सुधार लाने के लिए निर्देश उपलब्ध करा सके।

इस नीति के कार्यान्वयन से संस्थागत संरचनाओं, लोगों, प्रक्रियाओं और प्रौद्योगिकी का संयुक्त रूप से प्रयोग करते हुए सूचना तथा साइबरस्पेस में सूचना अवसंरचना को संरक्षित रखने, साइबर खतरों का निवारण करने और उनसे निपटने के लिए क्षमताओं का निर्माण करने, कमजोरियों को कम करने और साइबर घटनाओं से होने वाली क्षति को न्यूनतम करने का काम भी किया जाएगा। इस नीति के कार्यान्वयन से संगठन अपनी सभी सूचना आस्तियों की गोपनीयता, सत्यनिष्ठा और उपलब्धता सुनिश्चित करने के लिए लगातार नियंत्रणों की स्थापना करने और उन्हें बनाए रखने में भी समर्थ होगा। इसके अलावा, यह नीति अपने कर्मचारियों और साझेदारों के कार्य वातावरण को भी संरक्षित रखती है जिससे सेवाओं के लक्ष्यों को प्राप्त करने में सुविधा और सहयोग मिलता है।

विज़न: ग्राहक के डाटा सहित संगठन की डाटा आस्तियों का संरक्षण सुनिश्चित करते हुए, व्यवसाय के संचालन के लिए कर्मचारियों को प्रयोक्ता-केन्द्रित और सुरक्षित संसाधन और वातावरण उपलब्ध कराना।

मिशन: खतरों के निवारण और अनुप्रवर्तन के लिए अद्यतन सुरक्षा तंत्रों के कार्यान्वयन के माध्यम से संगठन की सभी सूचना आस्तियों की सुरक्षा सुनिश्चित करना; सभी कर्मचारियों की सूचना सुरक्षा संबंधी गतिविधियों और जागरूकता संबंधी प्रयासों का संचालन करना।

1.2. दायरा

सूचना आस्तियों के अंतर्गत संगठन की 'प्रणाली' के साथ-साथ, व्यवसाय प्रयोजनों या परिचालनों के लिए आवश्यक वे समग्र डाटा और सूचनाएँ आती हैं जो इलेक्ट्रॉनिक, मुद्रित, लिखित, फैसिमिली या अन्य प्रणालियों में अभिलिखित हैं। सूचना आस्तियों में व्यवसाय डाटा, सिस्टम लॉग, सर्वर, डेस्कटॉप, नेटवर्क उपकरण, नेटवर्क मीडिया, स्टोरेज मीडिया, कागजात, लॉग आदि शामिल हैं।

संगठन की सूचना और साइबर सुरक्षा नीति सभी सूचना आस्तियों पर उनके पूरे अस्तित्वकाल में लागू होती है जिसमें सूचना आस्ति का सृजन, वितरण, संप्रेषण, भंडारण और निपटान शामिल हैं; यथा:

- सभी रूपों में सूचना आस्तियाँ: इलेक्ट्रॉनिक, मुद्रित, लिखित, फैसिमिली या वाचिक आदि
- सूचना आस्तियों तक पहुँचने वाले व्यक्ति या संगठन, जैसे विक्रेता, सेवाप्रदाता, वितरक, फ्रेंचाइजी, ग्राहक आदि

1.3. सिद्धान्त और उद्देश्य

यह नीति और इसकी सहयोगी कार्यविधियाँ निम्नलिखित सिद्धांतों और नीचे निर्धारित उद्देश्यों पर आधारित होंगी:

1. **सूचना संरक्षण** - सूचना आस्तियों का संरक्षण संगठन के लिए आस्तियों के मूल्य और उनकी हानि की जोखिम के अनुरूप स्तर पर किया जाएगा। संरक्षण में सूचना आस्ति की गोपनीयता, सत्यनिष्ठा और उपलब्धता पर बल दिया जाएगा।
2. **प्रयोक्ता की प्रामाणिकता और उसे प्राधिकृत करना** - सभी प्रयोक्ताओं की, विशिष्ट पहुँच अनुमति के साथ अलग विशिष्ट पहचान अनिवार्य होगी और उन्हें उनकी व्यवसाय आवश्यकताओं के आधार पर अलग-अलग यानी एकल आधार पर प्राधिकृत किया जाएगा। प्रयोक्ता को पहुँच देने की पद्धतियों में प्रामाणिकता की मजबूती, उपयुक्त रूप से प्राधिकृत करने और लेखापरीक्षा-योग्य होने की विश्वसनीयता पर बल दिया जाएगा।
3. **उत्तरदायित्व** - संगठन की सूचना आस्तियों के प्रयोक्ता और अभिरक्षक इन आस्तियों के उचित उपयोग, संरक्षण और निजता के लिए उत्तरदायी हैं। संगठन प्रणाली, उपयुक्त लेखापरीक्षा पथ (ट्रेल) जेनरेट करेगी और उनका रखरखाव करेगी ताकि प्रयोक्ताओं, आईटी आस्तियों और दस्तावेजों की सुरक्षा-संबंधी घटनाओं और प्रक्रियाओं की पहचान की जा सके।
4. **उपलब्धता** - संगठन के व्यवसाय उद्देश्यों की पूर्ति में सहयोग देने के लिए सूचना आस्तियों की उपलब्धता अनिवार्य है। समग्र सूचना समय पर वापस प्राप्त हो सके और प्राधिकृत व्यक्ति की उस तक पहुँच हो, यह सुनिश्चित करने के लिए उपयुक्त उपाय करना अनिवार्य है।
5. **सत्यनिष्ठा** - पूर्णता और परिशुद्धता सुनिश्चित करने के लिए सूचना आस्तियों को पर्याप्त संरक्षित रखना अनिवार्य है। वैधकरण उपायों से यह संभव होगा कि अनुचित तरीके से आशोधित, डिलीट या खराब की गई सूचनाओं का पता लगाया जा सके।
6. **भरोसा** - साझेदारों, विक्रेताओं और सेवाप्रदाताओं को संगठन की सुरक्षा-संबंधी अपेक्षाओं को पूरा करने या उससे भी अधिक करने की योग्यता प्रदर्शित करना और संगठन की सूचना आस्तियों की सुरक्षा की अपनी योग्यता में भरोसे का औचित्य सिद्ध करना अनिवार्य है।
7. **निरंतरता** - संगठन के लिए यह अनिवार्य है कि वह व्यवसाय और प्रौद्योगिकी दोनों दृष्टियों से निरंतरता बनाए रखने की योग्यता प्रदर्शित करे। बीमा कंपनी की सभी सूचना आस्तियों और संबन्धित नीतियों और कार्यविधियों का मूल्यांकन संगठन के व्यवसाय उद्देश्यों की पूर्ति में सहयोग के लिए निरंतरता की दृष्टि से किया जाएगा। सभी साझेदारों, विक्रेताओं और सेवाप्रदाताओं को सब समय संगठन के निरंतरता-संबंधी उद्देश्यों को पूरा करने या उससे भी अधिक करने की योग्यता प्रदर्शित करनी होगी।
8. **साइबर सुरक्षा अनुकूलता** - साइबर अपराध की प्रभावी रोकथाम, जाँच और अभियोजन का सामर्थ्य लाना और समुचित विधायी हस्तक्षेप के माध्यम से कानून को लागू करने की क्षमताओं में वृद्धि करना।
9. **विनियामकीय अनुपालन** - सुरक्षित साइबरस्पेस पारिस्थितिकी सुनिश्चित करने के लिए विनियामकीय संरचना को मजबूत करना।

1.4. प्रयोज्यता

ये दिशानिर्देश भारतीय बीमा विनियामक और विकास प्राधिकरण (आईआरडीएआई) द्वारा विनियमित विदेशी पुनर्बीमा शाखाओं और बीमा मध्यस्थों सहित सभी बीमाकर्ताओं पर लागू हैं।

बीमा एजेंट (अभिकर्ता), सूक्ष्म बीमा एजेंट, बिक्री केंद्र (पॉइंट ऑफ सेल) के व्यक्ति और एकल सर्वेयर इन दिशानिर्देशों के दायरे में नहीं आते। लेकिन बीमाकर्ताओं का यह उत्तरदायित्व है कि वे इनके द्वारा इस संबंध में बीमाकर्ता के निदेशक मण्डल द्वारा अनुमोदित नीति में यथापरिभाषित न्यूनतम सुरक्षा संरचना का पालन सुनिश्चित करवाएँ।

ये दिशानिर्देश विनियमित निकायों द्वारा उनके निर्दिष्ट कर्तव्यों और कार्यों के निर्वहन के क्रम में सृजित, प्राप्त और रखे जाने वाले सम्पूर्ण डाटा पर लागू होंगे, चाहे वे जिस किसी भी स्थान पर और जिस किसी भी रूप में हों।

सभी विनियमित निकायों पर एनआईएसटी संरचना की प्रयोज्यता अनुबंध-I में दी गई है।

सकल बीमा आय-प्राप्ति के आधार पर बीमा मध्यस्थों का वर्गीकरण अनुबंध-II में दिया गया है।

लेखापरीक्षकों की रिपोर्ट अनुबंध-III में दी गई है जिसमें लेखापरीक्षा सारांश, समग्र निष्कर्ष, जोखिम श्रेणी और लेखापरीक्षा जाँचसूची शामिल हैं।

लेखापरीक्षा फर्म के पात्रता मानदंड अनुबंध-IV में दिए गए हैं।

लेखापरीक्षा फर्म द्वारा प्रमाणित किए जाने वाले लेखापरीक्षा प्रमाणपत्र का पाठ अनुबंध-V में दिया गया है।

विदेशी पुनर्बीमाकर्ता शाखाओं (एफआरबी) के मामले में लेखापरीक्षा फर्म द्वारा प्रमाणित किए जाने वाले लेखापरीक्षा प्रमाणपत्र का पाठ अनुबंध-VI में दिया गया है।

1.5. संचालन

I. लक्षित पाठक

संगठनों के वे कर्मचारी, संविदाकर्ता (ठेकेदार) और तृतीय पक्ष सेवाप्रदाता संगठन की नीति के लक्षित पाठक हैं जिनकी संगठन की सूचना प्रणालियों और किसी भी रूप में सूचनाओं तक पहुँच है या जो उनका उपयोग करते हैं।

इस नीति के कार्यान्वयन का दायित्व उन विभिन्न विभागों का होगा जिनका नाम इस नीति के विभिन्न खंडों में निर्दिष्ट किया गया है, जैसे आईटी (सूचना प्रौद्योगिकी), प्रशासन, मानव संसाधन और संबन्धित व्यवसाय विभाग। तथापि, विशिष्ट विभागों को सौंपी गई भूमिकाओं के बावजूद सभी विभागों के लिए इस नीति को जानना और इसका अनुपालन करना अनिवार्य है।

II. संचालक मण्डल

संगठन की सूचना और साइबर सुरक्षा नीति (आईसीएसपी) का संचालन सूचना सुरक्षा जोखिम प्रबंधन समिति (आईएसआरएमसी) द्वारा किया जाएगा जिसमें मुख्य जोखिम अधिकारी (सीआरओ), मुख्य सूचना सुरक्षा अधिकारी (सीआईएसओ), मुख्य आईटी सुरक्षा अधिकारी (सीआईटीएसओ), मुख्य सुरक्षा अधिकारी (सीएसओ), मुख्य मानव संसाधन अधिकारी (सीएचआरओ), मुख्य प्रौद्योगिकी अधिकारी (सीटीओ) तथा परिचालन, वित्त, विधि और अनुपालन के कार्यप्रमुख शामिल होंगे। नीति में परिवर्तनों और उनके अनुमोदन के लिए आईएसआरएमसी जिम्मेदार होगी। समिति पर यह सुनिश्चित करने का दायित्व भी होगा कि नीति सदा अद्यतन रहे। इस समिति की सभी बैठकों में सीआईएसओ और न्यूनतम दो अन्य सदस्यों की सहभागिता अनिवार्य होगी लेकिन वर्ष में कम-से-कम दो बैठकें ऐसी होंगी जिनमें सभी सदस्य सहभागी होंगे।

सूचना और साइबर सुरक्षा नीति (आईसीएसपी) के कार्यान्वयन और उसे लागू करने में सीआईएसओ सहयोग देगा और नीति का संचालन आईएसआरएमसी द्वारा किया जाएगा।

III. स्वामित्व और निर्वचन

आईसीएसपी पर सीआईएसओ का स्वामित्व होगा और उसका अनुरक्षण संगठन की “सूचना सुरक्षा टीम” (जिसे इसके बाद “आईएस टीम” कहा जाएगा) द्वारा किया जाएगा जिसमें सीआईएसओ होगा।

यदि सीआईएसओ की अनुपस्थिति में कोई निर्णय लेने की आवश्यकता होगी तो सीआरओ उसके दायित्वों का निर्वहन करेगा।

IV. समीक्षा की अवधिकता

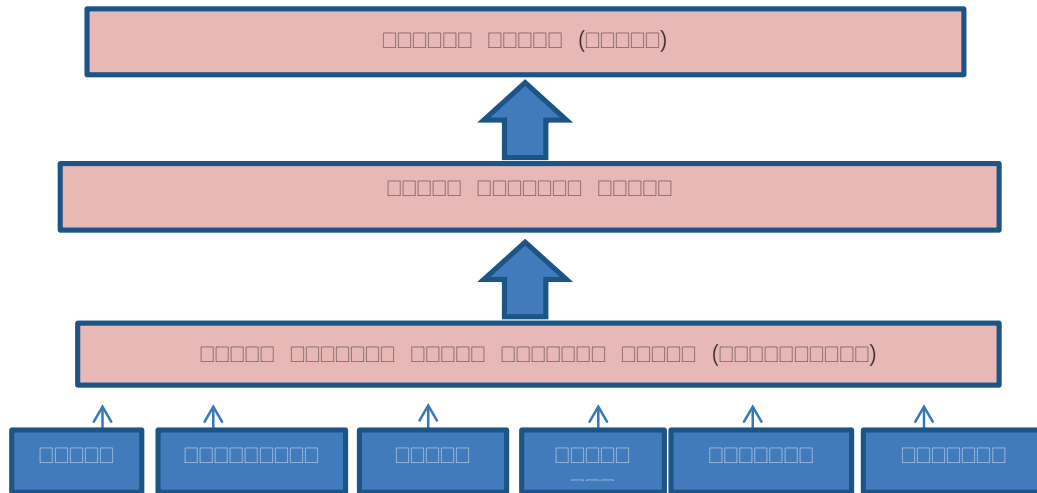
नीति की समीक्षा वार्षिक आधार पर की जाएगी और यदि आवश्यक हुआ तो आईएसआरएमसी के अनुमोदन से सीआईएसओ द्वारा उसे अद्यतन किया जाएगा। नीति की समीक्षा के लिए निम्नलिखित पहलुओं पर विचार किया जाएगा:

- सूचना सुरक्षा से संबंधित विनियामकीय या कानूनी प्रावधानों में परिवर्तन;
- उद्योग के मानकों में परिवर्तन या नए मानकों का जुड़ना;
- किसी संगठन द्वारा पिछले एक वर्ष में शुरू किया गया कोई नया व्यवसाय परिचालन;
- मानव संसाधन नीति में परिवर्तन सहित व्यवसाय परिचालन पद्धति में परिवर्तन;
- व्यवसाय टीमों द्वारा व्यवसाय/ ग्राहकों तक पहुँच के नए माध्यम के उपयोग की संभावना;
- पिछले एक वर्ष में शुरू की गई नई प्रौद्योगिकी;
- सूचना सुरक्षा के संबंध में संगठन के भीतर या बाहर रिपोर्ट की गई घटनाएँ;
- वरिष्ठ प्रबंधन या निदेशक मण्डल द्वारा अधिदेशित कोई अन्य स्थिति।

नीति के नवीकरण और नीति में परिवर्तनों से सभी कर्मचारियों को उपयुक्त माध्यमों, जैसे ई-मेल, इंटरनेट अधिसूचना, वार्षिक सूचना सुरक्षा पुनश्चर्या प्रशिक्षण, शैक्षणिक पोस्टर और निर्देश-शृंखला के जरिए अवगत कराया जाएगा।

1.6. भूमिकाएँ और उत्तरदायित्व

सूचना सुरक्षा के संचालन, कार्यान्वयन और अनुप्रवर्तन के लिए निम्नलिखित सांगठनिक संरचना तैयार की जाएगी और उसे बनाए रखा जाएगा।



1. निदेशक मण्डल

निदेशक मण्डल

- प्रभावी सूचना और साइबर सुरक्षा संचालन सुनिश्चित करने में अग्रसक्रिय भूमिका निभाएगा और संगठन की सूचना सुरक्षा के लिए अंतिम रूप से उत्तरदायी होगा।
- मुख्य सूचना सुरक्षा अधिकारी (सीआईएसओ) की नियुक्ति का अनुमोदन करेगा जो कि सूचना और साइबर सुरक्षा कार्यक्रम चलाएगा और उसका प्रबंधन करेगा।
- सूचना सुरक्षा से संबंधित मामलों में तिमाही जानकारी प्राप्त करेगा।
- सूचना और साइबर सुरक्षा नीति का अनुमोदन करेगा।
- आईटी संरचना का अनुमोदन और समीक्षा करेगा।

2. मुख्य जोखिम अधिकारी (सीआरओ)

मुख्य जोखिम अधिकारी

- संगठन के समग्र जोखिम प्रबंधन कार्यों के लिए उत्तरदायी होगा जिसमें उसके कार्यक्षेत्र में सूचना सुरक्षा जोखिम प्रबंधन भी शामिल होगा।
- सूचना सुरक्षा से संबंधित मुद्दों/ घटनाओं, अद्यतन स्थितियों, नई पहलों और सुधारात्मक/ निवारणात्मक कार्रवाइयों के बारे में नियमित रूप से ताज़ा जानकारी प्राप्त करेगा, और सूचना सुरक्षा के प्रति जागरूकता और प्रशिक्षण, सूचना सुरक्षा मूल्यांकन जैसे प्रयासों और सूचना सुरक्षा संबंधी महत्वपूर्ण घटनाओं में वृद्धि की स्थिति में सहभागी बना रहेगा।
- सीआईएसओ के साथ मिलकर नियंत्रण प्रबंधन समिति में सूचना सुरक्षा संबंधी कार्यक्रमों/ मुद्दों और नई पहलों प्रतिनिधित्व करेगा।

3. मुख्य सूचना सुरक्षा अधिकारी (सीआईएसओ)

आवश्यक तकनीकी पृष्ठभूमि और विशेषज्ञता वाले किसी पर्याप्त वरिष्ठ अधिकारी को सीआईएसओ के रूप में नामनिर्दिष्ट किया जाएगा। सीआईएसओ को एक विवेकसम्मत न्यूनतम अवधि के लिए पद पर रहना चाहिए। सीआईएसओ सीधे जोखिम प्रबंधन कार्य देखने वाले शीर्ष कार्यपालक को रिपोर्ट करेगा और उसकी अनुपस्थिति में सीधे मुख्य कार्यपालक अधिकारी (सीईओ) को रिपोर्ट करेगा और सूचना सुरक्षा के संचालन और अनुप्रवर्तन का समग्र उत्तरदायित्व धारण करेगा। सीआईएसओ निम्नलिखित कार्यों के निर्वहन के लिए उत्तरदायी होगा:

- आईएसआरएमसी से विधिवत् अनुमोदन के बाद सूचना और साइबर सुरक्षा नीति की परिभाषा और आवधिक समीक्षा;
- सूचना सुरक्षा मानकों की परिभाषा और आवधिक समीक्षा;
- सूचना सुरक्षा संबंधी आंतरिक और बाह्य समीक्षाओं और आकलनों का संचालन और समन्वय;
- आईएसआरएमसी को संक्षिप्त सार प्रस्तुत करना;
- संबंधित विनियामकों को महत्वपूर्ण या अत्यधिक गंभीर सूचना और साइबर सुरक्षा संबंधी घटनाओं की रिपोर्ट पहुँचना सुनिश्चित करने का दायित्व।
- सीआईएसओ निम्नलिखित सूचना सुरक्षा मानकों की स्थापना के लिए उत्तरदायी होगा:
 - सूचना सुरक्षा कार्यविधियाँ और उनके लिए सहायक टेम्पलेट;
 - किसी प्रक्रिया/ प्रौद्योगिकी में परिवर्तन या नई प्रौद्योगिकी ग्रहण करने के मामले में प्रौद्योगिकी जोखिम आकलन (टीआरए) के लिए मानक;
 - टीआरए के निष्पादन के लिए पद्धति/ जाँचसूची और टीआरए के परिणामों के आधार पर अनुमोदन मैट्रिक्स;
 - जोखिम आकलन (आरए) और व्यवसाय प्रभाव आकलन (बीआईए) के संचालन के लिए पद्धति सहित बीसीपी/ डीआर मानक;
 - परियोजना जोखिमों के आकलन और उन जोखिमों की आईएस टीम को रिपोर्टिंग की पद्धति सहित परियोजना संचालन और परियोजना जोखिम प्रबंधन के मानक;
 - एप्लिकेशन सुरक्षा और विक्रेता जोखिम आकलन के मानक;
 - कर्मचारियों/ संविदाकर्ताओं और आईटी/ आईएस टीमों के आईएस से संबंधित प्रशिक्षण की संख्या और अवधिकता सहित ऐसे प्रशिक्षणों के मानक;
 - विक्रेता जोखिम मानकों और विक्रेताओं की प्रत्येक श्रेणी के लिए जोखिम आकलन की अवधिकता तथा विक्रेता के महत्व के आधार पर जोखिम आकलन के लिए तृतीय पक्ष अथवा आंतरिक टीम की नियुक्ति सहित सूचना सुरक्षा आवश्यकताओं के अनुरूप विक्रेताओं के वर्गीकरण के लिए मानक।
- आस्ति वर्गीकरण के आधार पर आंतरिक और बाह्य विक्रेताओं के उपयोग को अधिदेशित करने के साथ-साथ आईटी प्रणालियों (अवसंरचना और एप्लिकेशन) के कमजोरी (वल्नरेबिलिटी) आकलन और पैठ (पेनिट्रेशन) जाँच के लिए सुरक्षा जाँच के लिए आधार-रेखाएँ;
- व्यवसाय आवश्यकताओं के हिसाब से अपने दायरे में आने वाले प्रत्येक एप्लिकेशन के भीतर भूमिकाओं को परिभाषित करने के लिए व्यवसाय टीमों के साथ संपर्क रखना।
- जब भी आवश्यक हो, सीआईएसओ द्वारा प्रमाणित और कार्य करने के लिए सक्षम बाह्य अपराध विज्ञान विशेषज्ञों की नियुक्ति की जा सकती है।
- वह एसओसी/ एलएएम/ डीएलपी टीमों के लिए प्रशिक्षण/ कौशल संबंधी आवश्यकताओं की समीक्षा करेगा।
- सीआईएसओ संसाधनों और सीआरओ को सूचना सुरक्षा संबंधी समीक्षाओं के लिए बजट आवश्यकता की प्रस्तुति/ वृद्धि हेतु उत्तरदायी होगा।
- सीआईएसओ वरिष्ठ प्रबंधन के परामर्श से संबंधित विनियामकीय प्राधिकरणों को संसूचित करने के लिए आवश्यक समझी जाने वाली सुरक्षा घटनाओं और उल्लंघनों के बारे में सीआरओ को सूचित करेगा।
- सीआईएसओ सूचना सुरक्षा नीतियों, मानकों और कार्यविधियों में अपवादों के अनुरोधों की समीक्षा और अनुमोदन करेगा।
- सीआईएसओ उसे उपलब्ध कराए गए टीआरए निष्कर्षों के विश्लेषण के लिए जिम्मेदार होगा।

- वह कर्तव्यों के पृथक्करण और सूचना सुरक्षा के अन्य संगत पहलुओं पर विचार करने के लिए व्यवसाय टीमों के परामर्श से तार्किक पहुँच प्रबंधन (एलएएम) टीम द्वारा परिभाषित भूमिकाओं की समीक्षा भी करेगा। सीआईएसओ द्वारा सामने लाई गई विसंगतियों को एलएएम टीम द्वारा व्यवसाय टीमों के परामर्श से दूर किया जाएगा।
- सूचना सुरक्षा परिचालन टीम द्वारा सामने लाई गई सभी घटनाओं के अंतिम निपटान के लिए मार्गदर्शन प्रदान करेगा और घटनाओं से संबंधित कार्रवाई की प्रगति तथा परिसमापन का पर्यवेक्षण करेगा। जो उच्च स्तरीय/ महत्वपूर्ण मामले निर्धारित एसएलए के बाद तक शेष रहेंगे उनके बारे में आईएस टीम सीआरओ और आईएसआरएमसी को सूचित करेगी।
- अपराध-विज्ञान संबंधी जिम्मेदारियाँ।

आईएस टीम

- आईएस परिचालन टीम द्वारा प्रबंधित विभिन्न सुरक्षा समाधानों की विस्तृत लॉग समीक्षा के लिए आवधिकता और नमूना आकार का निर्धारण कर सूचना सुरक्षा समीक्षा संचालित करने का दायित्व और अधिकार आईएस टीम को होगा।
- आईएस टीम सूचना सुरक्षा आवश्यकताओं के आधार पर विक्रेता वर्गीकरण मानक निर्धारित करने के लिए जिम्मेदार होगी।
- समवर्ती/ आवधिक समीक्षा के लिए तृतीय पक्ष आईएस समीक्षकों की नियुक्ति और तृतीय पक्ष के लिए समीक्षा के दायरे को परिभाषित करना।
- आंतरिक लेखापरीक्षा टीम द्वारा परिभाषित दायरे के आधार पर आवधिक समीक्षा करने के लिए आंतरिक लेखापरीक्षा टीम को सेवा पर रखना।
- आईएस परिचालन टीम द्वारा प्रबंधित सुरक्षा समाधानों (पेरीमीटर उपकरणों सहित) का किसी भी समय अपने विवेकानुसार जोखिम आकलन करना।
- समीक्षा के दायरे के आधार पर लागू होने की स्थिति में आईएस टीम द्वारा या उसके माध्यम से की गई समीक्षाओं के परिणाम आईएसआरएमसी के समक्ष रखना।
- आईएस टीम मानकों के निर्धारण और आईएस समीक्षा के संचालन के अलावा संगठन की घटना प्रबंधन प्रक्रियाओं में सीधे संलग्न रहेगी।

सुरक्षा परिचालन केंद्र (एसओसी)

- सीआईएसओ सूचना सुरक्षा संबंधी महत्वपूर्ण/ निर्बंध घटनाओं के बारे में एसओसी की अनुप्रवर्तन गतिविधियों पर आधारित एस्केलेशन प्राप्त करेगा। वह ऐसी घटनाओं की प्रगति और परिसमापन की निगरानी और मार्गदर्शन भी करेगा। वह आईएसआरएमसी को महत्वपूर्ण घटनाओं के बारे में जानकारी देने के लिए भी जिम्मेदार होगा।
- आईटी सुरक्षा परिचालन टीम द्वारा अनुप्रवर्तन, विश्लेषण और घटनाओं की गंभीरता के आधार पर रिपोर्टिंग की बारंबारता सहित रिपोर्टिंग के मानक।
- एसओसी टीम द्वारा रिपोर्ट की गई घटनाओं का विश्लेषण और आवश्यक कार्रवाई करना आवश्यक है।

तार्किक पहुँच प्रबंधन (एलएएम)

- एक पहुँच अनुमोदन मैट्रिक्स निर्धारित करना और उसे बनाए रखना;
- एप्लिकेशनों के लिए समुचित पर्यवेक्षण और आईएस टीम के अनुमोदन के साथ भूमिका-आधारित पहुँच नियंत्रण मैट्रिक्स निर्धारित करने के लिए व्यवसाय टीमों के साथ मिलकर काम करना;
- पहुँच मैट्रिक्स सिद्धांतों को बनाए रखना सुनिश्चित करने के लिए एलएएम टीम द्वारा प्रबंधित भूमिका निर्धारण की समीक्षा करना।

डाटा लीकेज निवारण (डीएलपी)

- डाटा की निजता संबंधी अपेक्षाओं के साथ-साथ डाटा वर्गीकरण मानक।
- व्यवसाय प्रक्रियाओं और डाटा वर्गीकरण को समझने के लिए व्यवसाय के साथ संपर्क स्थापित करना।

4. मुख्य प्रौद्योगिकी अधिकारी (सीटीओ)

- सीटीओ संगठन की सूचना सुरक्षा संबंधी प्रौद्योगिकी के कार्यान्वयन के लिए उत्तरदायी होगा।
- सीटीओ यह सुनिश्चित करेगा कि आयोजना और बजट चक्रों, उद्यम स्थापत्य, सूचना प्रणाली के डिजाइन, विकास एवं अधिग्रहण/ प्रणाली विकास के जीवनचक्र में सूचना सुरक्षा के मुद्दों को एकीकृत किया जाए।
- सीटीओ यह भी सुनिश्चित करेगा कि सूचना सुरक्षा/ जोखिम टीम से प्राप्त जानकारी के आधार पर सूचना सुरक्षा प्रक्रियाओं का पालन और अनुपालन किया जाए।
- सीटीओ आंतरिक/ बाह्य लेखापरीक्षाओं या जोखिम आकलन के माध्यम से पहचानी गई सूचना सुरक्षा संबंधी कमजोरियों के शमन का पर्यवेक्षण करेगा।

5. मुख्य आईटी सुरक्षा अधिकारी (सीआईटीएसओ)

- सीआईटीएसओ मूल रूप से आईटी संबंधी सूचना सुरक्षा परिचालनों के लिए उत्तरदायी होगा और सीटीओ को रिपोर्ट करेगा।
- आईटी सूचना सुरक्षा परिचालनों से संबंधित साधनों (टूल्स) का कार्यान्वयन और प्रबंधन सीआईटीएसओ द्वारा किया जाएगा और यह सुनिश्चित करना उसका दायित्व होगा कि इन साधनों के माध्यम से सामने आई घटनाओं की रिपोर्ट सीआईटीएसओ को की जाए।
- सीआईटीएसओ प्रौद्योगिकी जोखिम आकलनों (टीआरए), सुरक्षा परिचालन केंद्र (एसओसी), तार्किक पहुँच प्रबंधन (एलएएम) और डाटा लीकेज निवारण (डीएलपी) जैसे सुरक्षा संबंधी प्रौद्योगिकीय समाधानों के कार्यान्वयन, तथा संचालन जोखिम और अनुपालन (जीआरसी) एवं पेरीमीटर सुरक्षा उपकरणों के समग्र प्रबंधन और रखरखाव का पर्यवेक्षण करेगा।
- सीआईटीएसओ यह सुनिश्चित करेगा कि आईटी सुरक्षा परिचालन सूचना सुरक्षा नीति के अनुसार और दिशानिर्देशों तथा आईएस टीम द्वारा निर्धारित मानकों के अनुरूप चले।

6. आईटी सुरक्षा परिचालन टीम

आईटी सुरक्षा परिचालन टीम में सुरक्षा साधनों का प्रबंधन करने वाली उप-टीमें होंगी, यथा सुरक्षा परिचालन केंद्र (एसओसी), तार्किक पहुँच प्रबंधन (एलएएम) और डाटा लीकेज निवारण (डीएलपी), प्रौद्योगिकी जोखिम आकलन (टीआरए) आदि जो आईटी सुरक्षा परिचालनों के कार्यान्वयन और प्रबंधन के लिए सीआईटीएसओ को और सभी घटनाओं की रिपोर्टिंग तथा प्रबंधन के लिए सीआईटीएसओ के माध्यम से रिपोर्ट करेंगी। आईटी सुरक्षा परिचालन की उप-टीमों के उत्तरदायित्व निम्नानुसार होंगे:

1. एसओसी

सुरक्षा परिचालन केंद्र निम्नलिखित के लिए उत्तरदायी होगा:

- तत्समय अनुप्रवर्तन, सीआईएसओ को सुरक्षा घटनाओं की रिपोर्टिंग, विश्लेषण करने (अर्थात् अपराध-विज्ञान और जाँच) में सीआईएसओ को सहयोग और अभिलेख रखना;
- प्रथम स्तरीय विश्लेषण एसओसी टीम द्वारा किया जाना चाहिए और मिथ्या सकारात्मक तत्वों की पहचान करने की आवश्यकता है। यदि एसओसी टीम किसी घटना को संभावना वाली घटना के रूप में सोचती है तो उसकी रिपोर्ट आईएस टीम को करना आवश्यक है।
- आईएस टीम द्वारा निर्धारित घटना अनुप्रवर्तन और प्रबंधन मानकों के आधार पर सुरक्षा घटनाओं की प्रगति का अनुवर्तन और परिसमापन;
- सूचना सुरक्षा समीक्षाओं के दौरान सीधे स्रोत प्रणालियों से अपेक्षित सूचना सीआईएसओ को उपलब्ध कराना;
- सुरक्षा परिचालन केंद्र की 24X7 टीम द्वारा एप्लिकेशन आईटी अवसंरचना के लॉग एकत्र और विश्लेषित किए जाएंगे।

2. एलएएम

तार्किक पहुँच प्रबंधन (एलएएम) टीम आईएस टीम द्वारा निर्धारित तार्किक पहुँच प्रबंधन मानकों के आधार पर प्रयोक्ताओं को पहुँच उपलब्ध/ अनुपलब्ध कराने और प्रयोक्ताओं की पहुँच की समीक्षा के लिए उत्तरदायी होगी। एलएएम टीम निम्नलिखित के लिए जिम्मेदार होगी:

- निर्धारित पहुँच नियंत्रण मैट्रिक्स के अनुसार एप्लिकेशनों/ डोमेन तक प्रयोक्ता की पहुँच की अनुमति देने/ उसमें संशोधन करने और उसे निष्क्रिय करने के अनुरोध प्राप्त करना और उन पर कार्रवाई करना;
- व्यवसाय टीमों को पहुँच अधिकार रजिस्टर उपलब्ध कराकर और उसकी वैधता के लिए उनसे अनुमोदन लेकर आवधिक रूप से प्रयोक्ता पुनःप्रमाणन की प्रक्रिया चलाना;
- जो मामले निर्धारित पहुँच नियंत्रण मैट्रिक्स के अनुसार न हों, उनमें पहुँच के अधिकार की अनुमति के पहले सीआईएसओ से अपवाद का अनुमोदन प्राप्त करना;
- पहुँच नियंत्रण से संबन्धित घटनाओं को हैंडल करना और सीआईएसओ को उनकी रिपोर्ट करना;
- आईएस समीक्षाओं के दौरान सीआईएसओ को सीधे स्रोत प्रणालियों से अपेक्षित जानकारी उपलब्ध कराना।

3. डीएलपी

डाटा लीकेज निवारण (डीएलपी) टीम आईएस टीम द्वारा निर्धारित डाटा वर्गीकरण और निजता मानकों के आधार पर डाटा लीकेज निवारण तंत्र के कार्यान्वयन के लिए जिम्मेदार होगी। डीएलपी टीम निम्नलिखित के लिए उत्तरदायी होगी:

- डीएलपी टूल में सूचना वर्गीकरण नीति और कार्यविधियों के कार्यान्वयन में सहयोग देना;
- डीएलपी टूल के अस्तित्व और उपयोग के बारे में प्रशिक्षण और जागरूकता में सहयोग देना;
- सीआईएसओ को डाटा लीकेज की घटनाओं की रिपोर्ट करना और उनकी प्रगति का अनुवर्तन करते हुए उन्हें परिसमापन तक पहुँचाना;
- डाटा लीकेज की घटनाओं को प्रबंधित करना और समुचित कार्रवाई के लिए जोखिम प्रबंधन/ जाँच टीम को उनकी रिपोर्ट करना;
- सूचना समीक्षाओं के दौरान सीआईएसओ को सीधे स्रोत प्रणालियों से अपेक्षित जानकारी उपलब्ध कराना।

4. टीआरए

- किसी भी नई प्रक्रिया या प्रौद्योगिकी की शुरुआत या किसी विद्यमान प्रक्रिया या प्रौद्योगिकी में परिवर्तन के कार्यान्वयन के पहले आईटी सुरक्षा परिचालन टीम आईएस टीम द्वारा निर्धारित टीआरए मानक के आधार पर प्रौद्योगिकी जोखिम आकलन (टीआरए) के निष्पादन के लिए उत्तरदायी होगी। निष्पादित टीआरए के परिणामों के आधार पर सीआईएसओ को अपेक्षित अनुमोदनों के लिए संसूचित किया जाएगा।

7. मुख्य सुरक्षा अधिकारी (सीएसओ)/ प्रशासन/ प्रशासन प्रमुख

मुख्य सुरक्षा अधिकारी निम्नलिखित के लिए उत्तरदायी होगा:

- आईटी/ आईएस के अपेक्षित सहयोग से प्रशासन भौतिक और पर्यावरणीय सुरक्षा नियंत्रणों के कार्यान्वयन और अनुरक्षण के लिए उत्तरदायी होगा।
- भौतिक सुरक्षा के सभी पहलुओं में आईएसआरएमसी और सीआरओ को सहयोग देना;
- सभी भौतिक सुरक्षा प्रक्रियाओं का पालन सुनिश्चित करना और सीआरओ को महत्वपूर्ण घटनाओं की रिपोर्ट करना;
- सुरक्षा स्टाफ के लिए प्रशिक्षण आयोजित करना;
- कर्मचारियों के संवेदीकरण के लिए संवेदीकरण कार्यक्रमों का आयोजन करना।

8. मानव संसाधन

- संगठन के सूचना सुरक्षा संबंधी प्रयासों में मानव संसाधन (एचआर) महत्वपूर्ण भूमिका निभाएगा।
- एचआर यह सुनिश्चित करेगा कि नए जॉइन करने वाले कर्मिकों के परिचय प्रशिक्षण कार्यक्रम में सूचना सुरक्षा संबंधी दायित्वों को शामिल कर उन्हें इनकी जानकारी दी जाए। एचआर नए कर्मचारियों को सूचना सुरक्षा संबंधी अपेक्षाओं के पालन के महत्व और उनका पालन न करने के परिणामों के प्रति संवेदनशील बनाएगा।
- एचआर नए जॉइन करने वाले कर्मचारियों से इस आशय का घोषणापत्र/ वचनपत्र लेगा कि वे संगठन की सूचना सुरक्षा संबंधी अपेक्षाओं को समझ चुके हैं और उन्हें स्वीकार करते हैं, और इन घोषणापत्रों को कर्मिकों की फाइलों में रखा जाएगा।
- एचआर आईएस टीम के साथ मिलकर सभी कर्मचारियों/ विक्रेताओं के महत्वपूर्ण कर्मिकों के लिए समय-समय पर पुनश्चर्या प्रशिक्षण पाठ्यक्रम शुरू करेगा और इन पाठ्यक्रमों के पूर्ण होने तक उनकी प्रगति का अनुवर्तन करेगा।
- एचआर नए जॉइन करने वाले कर्मचारियों की पृष्ठभूमि की जाँच स्वयं करेगा या इसके लिए किसी बाह्य एजेंसी की नियुक्ति करेगा ताकि यह सुनिश्चित किया जा सके कि सही पृष्ठभूमि और स्वस्थ दृष्टिकोण वाले लोग संगठन में आएँ।
- एचआर संगठन को सूचना सुरक्षा के अनुकूल वातावरण की ओर ले जाने में सीआईएसओ का सहयोग करेगा और उन्हें इससे संबंधित प्रमाणन प्राप्त करने में भी सहयोग करेगा।
- एचआर सूचना प्रणालियों की भूमिका में आवश्यक परिवर्तनों के लिए आईएस और आईटी टीमों के साथ संगठन और कर्मचारी की भूमिका / अवस्थिति / प्रवेश और बहिर्गमन संबंधी जानकारियों से अवगत कराएगा।
- एचआर सूचना सुरक्षा का उल्लंघन करने वाले कर्मचारियों / विक्रेताओं के महत्वपूर्ण कर्मचारियों के विरुद्ध कार्रवाई के लिए एक औपचारिक अनुशासनिक प्रक्रिया दस्तावेजीकृत करेगा, उस प्रक्रिया को शामिल करेगा और संप्रेषित करेगा।

- एचआर यह सुनिश्चित करेगा कि कर्मचारियों / विक्रेताओं के कर्मचारियों को उनकी सेवा की समाप्ति/ नियोजन में परिवर्तन के समय उनकी सूचना सुरक्षा संबंधी जिम्मेदारियों को स्पष्ट रूप से परिभाषित और संप्रेषित किया जाए।

9. प्रशासनिक / प्रशासन टीम

- संगठन के सूचना सुरक्षा संबंधी प्रयासों में प्रशासन टीम महत्वपूर्ण भूमिका निभाएगी।
- प्रशासन टीम यह सुनिश्चित करेगी कि सूचना सुरक्षा के दृष्टिकोण से संगत नीतियों/ कार्यविधियों का समुचित कार्यान्वयन और उनका पालन हो, यथा -

- भौतिक सुरक्षा नीति
- साफ/ रिक्त डेस्क नीति
- आगंतुक प्रबंधन नीति

- एचआर और आईटी के निकट सहयोग से प्रशासन यह सुनिश्चित करेगा कि जो कर्मचारी संगठन से अलग हुए हैं उनके अंतिम कार्यदिवस को या उसके पूर्व कार्यालय परिसर तक उनकी भौतिक पहुँच वापस ले ली जाए।
- प्रशासन यह भी सुनिश्चित करेगा कि श्रेडर/ ताले और चाबी से सुरक्षित फाइलिंग कैबिनेट आदि उपयुक्त उपकरण उपलब्ध कराए जाएँ ताकि महत्वपूर्ण डाटा की गोपनीयता सुनिश्चित की जा सके।
- प्रशासन आवधिक आधार पर औचक दौरे करेगा ताकि यह सुनिश्चित किया जा सके कि कोई दस्तावेज़/ मीडिया किसी डेस्क पर न पड़ा हो।
- प्रशासन सूचना सुरक्षा के अनुकूल वातावरण के निर्माण में सीआईएसओ का सहयोग करेगा और उन्हें इससे संबंधित प्रमाणन प्राप्त करने में भी सहयोग करेगा।

10. ईआरएम

- ईआरएम आवधिक रूप से सीआईएसओ को सूचना सुरक्षा संबंधी विद्यमान जोखिमों की अद्यतन स्थिति, और यदि आवश्यकता हो, तो कार्रवाइयों से अवगत कराएगा।
- ईआरएम टीम सूचना सुरक्षा संबंधी घटनाओं की जाँच के लिए आईएस टीम के साथ मिलकर काम करेगी।
- ईआरएम टीम ऐसी व्यवसाय धोखाधड़ियों के बारे में फीडबैक साझा करेगी जिनका उपयोग सूचना और साइबर सुरक्षा नीति/ नियंत्रण की पुनरीक्षा के लिए किया जा सकता हो।

11. आंतरिक लेखापरीक्षा

- आंतरिक लेखापरीक्षा कार्य और सूचना सुरक्षा कार्य परस्पर तालमेल में काम करेंगे: सूचना सुरक्षा कार्य संगठन के सूचना संसाधनों के संरक्षण के लिए नीतियों और कार्यविधियों को तैयार करना है, और आंतरिक लेखापरीक्षा कार्य इन नीतियों और कार्यविधियों के कार्यान्वयन की प्रभावोत्पादकता के बारे में फीडबैक तथा सुधार के लिए सुझाव देना है।
- आंतरिक लेखापरीक्षा कार्य संगठन के सूचना सुरक्षा प्रयासों की एक स्वतंत्र समीक्षा और विश्लेषण प्रस्तुत करेगा और निदेशक मण्डल तथा कार्यपालक प्रबंधन को इस विषय में एक वस्तुनिष्ठ आश्वासन देगा कि संगठन कितने प्रभावी ढंग से अपनी जोखिमों का आकलन और प्रबंधन करता है, और साथ ही कि आईटी सुरक्षा परिचालन और सूचना सुरक्षा प्रबंधन संरचनाएँ और भूमिकाएँ कितनी प्रभावी हैं।

- आंतरिक लेखापरीक्षा कार्य उभरती जोखिमों और उनसे निपटने के प्रभावी तरीकों के बारे में लेखापरीक्षा समिति को अवगत कराएगा और स्थापित नीतियों तथा नियंत्रणों में विद्यमान कमजोरियों की पहचान करेगा ताकि जोखिमों का शमन किया जा सके।
- आंतरिक लेखापरीक्षा कार्य सूचना सुरक्षा के निम्नलिखित पहलुओं का स्वतंत्र आकलन करेगा:
- संगठन के सामने आ रही प्रमुख सूचना सुरक्षा जोखिमों और उनसे सुरक्षित रहने के लिए स्थापित नीतियाँ;
- आईटी सुरक्षा परिचालनों और सूचना सुरक्षा जोखिम प्रबंधन संरचनाओं और भूमिकाओं की प्रभावोत्पादकता;
- नीतियों के पालन के लिए प्रबंधन द्वारा स्थापित नियंत्रण;
- क्या कार्यप्रबंधक विद्यमान नियंत्रणों का उपयोग करते हैं?
- परिचालनगत नियंत्रणों के परिचालन की प्रभावोत्पादकता।

12. विधिक और अनुपालन टीम

- अनुपालन टीम यह सुनिश्चित करेगी कि संगठन अपने व्यवसाय आईआरडीएआई दिशानिर्देशों और अन्य लागू विनियमों के अनुपालन में चलाता है।
- अनुपालन टीम लागू विनियामकीय/ विधिक दिशानिर्देशों और अपेक्षाओं तथा सूचना और साइबर सुरक्षा संबंधी परिवर्तनों के बारे में निदेशक मण्डल/ जोखिम टीम/ सीआईएसओ/ सीआरओ को अवगत कराएगी।
- विधिक और अनुपालन टीम साइबर सुरक्षा की स्थिति और घटनाओं के बारे में विधिक, सांविधिक, स्थानीय प्रवर्तन एजेंसियों तथा सरकारी एजेंसियों को अवगत कराने के लिए जिम्मेदार होगी। घटना से संबंधित आवश्यक विवरण सूचना सुरक्षा टीम और आईटी टीम द्वारा उपलब्ध कराए जाएँगे।

13. कार्य प्रमुख/ व्यवसाय का स्वामी

- लागू विनिर्दिष्ट सुरक्षा नीतियों के अनुपालन का प्राथमिक स्वामित्व (अंतिम दायित्व) धारण करेगा।
- कार्य से संबंधित टीमों अपने एक उपयुक्त और अर्ह सदस्य को नामनिर्दिष्ट करेंगी जो सूचना सुरक्षा कार्य को घटनाओं और सुरक्षा नियंत्रणों की प्रभावोत्पादकता की रिपोर्टिंग के लिए जिम्मेदार होगा।
- एसपीओसी के रूप में नामनिर्दिष्ट कार्यप्रमुख जोखिम आकलन प्रक्रिया और व्यवसाय प्रभाव आकलन में सहभागिता के माध्यम से अपने नियंत्रण में स्थित आस्तियों के मूल्य तथा वर्गीकरण का प्राथमिक दायित्व रखेगा।
- वह अपने संबंधित तृतीय पक्ष साझेदारों और विक्रेताओं की जोखिम, डाटा सुरक्षा और पहुँच के लिए जिम्मेदार होगा।
- वह अपनी संबंधित तृतीय पक्ष प्रक्रियाओं/ साइटों के सुरक्षा आकलन और लेखापरीक्षा के लिए जिम्मेदार होगा।
- वह इस बात की समीक्षा और संपुष्टि करेगा कि संबंधित व्यवसाय प्रक्रियाएँ निर्धारित आईएस नीतियों और कार्यविधियों के अनुरूप चलाई जाती हैं।

14. आईएसआरएमसी

- यह समिति अपने समक्ष लाए जाने वाले आईएस जोखिम प्रबंधन संबंधी मामलों में से जो मामले आरएमसी के लिए महत्वपूर्ण होंगे, उन्हें आरएमसी को संदर्भित करेगी।
- सीआईएसओ सूचना सुरक्षा संचालन से जुड़े क्षेत्रों को आईएसआरएमसी में प्रस्तुत करेगा, और आईटी सुरक्षा परिचालनों से जुड़े क्षेत्रों को सीआईटीएसओ प्रस्तुत करेगा।
- आईएसआरएमसी आवधिक रूप से सीआईएसओ और सीआईटीएसओ से जानकारी प्राप्त करेगी जिसमें घटना के मूल कारण और उसे ठीक करने के लिए की गई कार्रवाई के साथ घटनाओं की सूची शामिल होगी।

- आईएसआरएमसी प्रस्तावित नए प्रयासों के बारे में जानकारी और सूचना सुरक्षा के दृष्टिकोण से सीआईएसओ/सीआईटीएसओ द्वारा उनके मूल्यांकन भी प्राप्त करेगा।
- समिति आवधिक रूप से नियंत्रण प्रबंधन समिति (सीएमसी) को संगत आश्वासन उपलब्ध कराएगी।
- समिति संगठन के आईएस जोखिम प्रोफाइल और जोखिम सहन क्षमता का अनुप्रवर्तन करेगी और इसके बारे में सीएमसी को अनुशंसाएँ देगी, और यह सुनिश्चित करेगी कि आंतरिक नियंत्रण का स्तर जोखिम सहन क्षमता के अनुरूप हो। साथ ही, वह आईएस जोखिमों की पहचान, प्रबंधन और उपयुक्त समितियों को आईएस जोखिमों की रिपोर्टिंग का पर्यवेक्षण भी करेगी।

15. नियंत्रण प्रबंधन समिति

- समिति के समक्ष जोखिम प्रबंधन से संबंधित जो मामले आएँगे उनमें से निदेशक मण्डल के लिए संगत मामलों को समिति निदेशक मण्डल को संदर्भित करेगी।
- नियंत्रण समिति आवधिक रूप से आईएस जोखिम से संबंधित जानकारी आईएसआरएमसी से प्राप्त करेगी।
- समिति निदेशक मण्डल को आवधिक रूप से संगत आश्वासन उपलब्ध कराएगी।
- समिति के सदस्यों के विवेक के अनुसार समिति जिन मामलों को अत्यधिक महत्व का समझेगी उन्हें निदेशक मण्डल के ध्यान में लाएगी।
- समिति संगठन के आईएस जोखिम प्रोफाइल और जोखिम सहन क्षमता का अनुप्रवर्तन करेगी और इसके बारे में निदेशक मण्डल को अनुशंसाएँ देगी, और यह सुनिश्चित करेगी कि आंतरिक नियंत्रण का स्तर जोखिम सहन क्षमता के अनुरूप हो। साथ ही, वह जोखिमों की पहचान, प्रबंधन और उपयुक्त समितियों को जोखिमों की रिपोर्टिंग का पर्यवेक्षण भी करेगी।
- यह निदेशक मण्डल का दायित्व होगा कि वह समय-समय पर नियंत्रण प्रबंधन समिति को उपयुक्त संसाधन, बजटीय अनुमोदन और मार्गदर्शन प्रदान करे।
- वरिष्ठ प्रबंध तंत्र की प्रतिबद्धता सुनिश्चित की जाएगी।

1.7. स्वीकार्य उपयोग

I. संगठन द्वारा उपलब्ध कराई गई आईटी आस्तियों का उपयोग

संगठन यह सुनिश्चित करेगा कि कर्मचारी, संविदाकर्ता और तृतीय पक्ष, संगठन द्वारा उपलब्ध कराई गई सभी सूचना आस्तियों के स्वीकार्य उपयोग के दिशानिर्देशों का पालन करें। आस्तियों का उपयोग व्यवसाय के प्रयोजन से किया जाएगा, न कि गैर-कानूनी प्रकृति की गतिविधियों के लिए जिनमें हैकिंग, साइबरचोरी, पहचान की चोरी, पाइरेसी और नग्नता (पोर्नोग्राफी) शामिल हैं लेकिन ये गतिविधियाँ इन्हीं तक सीमित नहीं हैं।

II. कार्यालयीन प्रयोजनों से व्यक्तिगत उपकरणों का स्वीकार्य उपयोग

यदि किसी कर्मचारी, संविदाकर्ता या तृतीय पक्ष के व्यक्तिगत उपकरण का उपयोग संगठन की सूचना तक पहुँचने के लिए किया जाता है, तो निम्नलिखित शर्तें लागू होंगी:

- . व्यक्तिगत उपकरण का प्रयोग करते हुए संगठन की सूचना तक पहुँच संगठन की आईएस नीति के पालन के अधीन होगी।
- . किसी व्यक्ति के कंपनी से जुड़े रहने के दौरान उसके व्यक्तिगत उपकरण में स्टोर की गई कॉर्पोरेट जानकारी, एप्लिकेशनों और डाटा तक कंपनी पहुँच सकती है।
- . उपकरण के कंपनी के आईटी वातावरण से जुड़े रहने के दौरान संगठन को उपकरण की निगरानी का अधिकार होगा।
- . कर्मचारी की यह ज़िम्मेदारी होगी कि वह व्यक्तिगत उपकरण में किसी भी रूप में रखे गए संगठन के डाटा का संरक्षण करे।
- . निम्नलिखित में से किसी भी स्थिति में संगठन को यह अधिकार होगा कि वह व्यक्तिगत उपकरण में रखे गए कंपनी डाटा को (और कर्मचारी के अनुरोध करने पर व्यक्तिगत डाटा को भी) रिमोट से ही मिटा दे:
 - उपकरण की क्षति/ खो जाना;
 - उपकरण को बदलना या उसका निपटान;
 - किसी भी पक्ष द्वारा नियोजन का समापन।
- . कंपनी की नीति के उल्लंघन की स्थिति में संगठन, अन्य कदमों के साथ-साथ निम्नलिखित में से कोई भी या सभी कदम उठा सकता है:
 - सेवा को डिसकनेक्ट करना और उपकरण की कॉर्पोरेट पहुँच को वापस लेना;
 - व्यक्तिगत उपकरण से संबंधित प्रतिपूर्ति को रोक देना;
 - उपकरण को वापस लेना और/ या रिमोट से उपकरण का डाटा हटा देना;
 - प्रबंधन द्वारा यथानिर्णीत अन्य कदम।

III. बौद्धिक सम्पदा का स्वीकार्य उपयोग

बौद्धिक सम्पदा अधिकारों और स्वामित्व वाले सॉफ्टवेयर उत्पादों के प्रयोग के संबंध में विधायी, विनियामकीय और संविदागत अपेक्षाओं का अनुपालन सुनिश्चित करने के लिए समुचित नियंत्रण कार्यान्वित किए जाएँगे।

IV. कंपनी की ईमेल सुविधा का स्वीकार्य उपयोग

कंपनी की ईमेल सुविधा का उपयोग संगठन के दिशानिर्देशों के अनुसार करना अनिवार्य होगा। दिशानिर्देशों के जानबूझ कर किए गए उल्लंघन के लिए अनुशासनिक कार्रवाई की जा सकती है।

V. सूचना प्रसंस्करण सुविधाओं के दुरुपयोग की रोकथाम

सूचना प्रसंस्करण सुविधाओं का उपयोग अनिवार्य रूप से सूचना सुरक्षा नीति, प्रयोक्ता नीति और दिशानिर्देशों में वर्णित नीतियों के अनुसार किया जाएगा। नीति के जानबूझ कर किए गए उल्लंघन के लिए अनुशासनिक कार्रवाई की जा सकती है।

VI. सोशल मीडिया का स्वीकार्य उपयोग

- . **कॉर्पोरेट कर्मचारियों द्वारा कॉर्पोरेट प्रयोजनों के लिए सोशल मीडिया का उपयोग:**

जो लोग कार्यस्थल पर सोशल मीडिया के उपयोग के लिए प्राधिकृत हैं, उनका यह दायित्व है कि वे टूल्स का उपयोग "सोशल मीडिया के स्वीकार्य उपयोग" में उल्लिखित समुचित रीति से करें।

- किसी भी कर्मचारी को व्यवसाय के लिए किसी सोशल मीडिया टूल का उपयोग तब तक नहीं करना चाहिए जब तक उसने कॉर्पोरेट संचार टीम द्वारा अनुशंसित या अनुमोदित प्रशिक्षण न लिया हो।
- "सोशल मीडिया नीति" के अनुसार समुचित प्राधिकरण से लिखित प्राधिकार प्राप्त न होने की स्थिति में कर्मचारियों को स्पष्ट रूप से कार्यालय समय में और अपनी ड्यूटी करते समय या कार्यालय नेटवर्क का या संचार की कार्यालयीन व्यवस्था के अंतर्गत उपलब्ध कराए गए साधन का इस्तेमाल करते समय सोशल मीडिया का प्रयोग प्रतिबंधित किया जाता है।
- कर्मचारी संगठन से संबंधित कोई भी असत्यापित और गोपनीय सूचना किसी ब्लॉग/ चैट फोरम/ विचार-विमर्श के फोरम/ मेसेंजर साइट/ सोशल नेटवर्किंग साइट पर प्रसारित करने से दूर रहेंगे।
- कोई भी ऐसी जानकारी जिस तक उसके कार्यालयीन/ व्यक्तिगत मेल/ मीडिया फ़ोरम या किसी अन्य तरीके से किसी कर्मचारी की पहुँच हुई है या जो उसे प्राप्त हुई है, और जिसे किसी मीडिया फोरम के माध्यम से प्रसारित या साझा करना प्रस्तावित है, उसे पहले पूर्वानुमोदन के लिए संगठन की अनुपालन टीम और कॉर्पोरेट संचार टीम को प्रेषित किया जाना चाहिए।
- मीडिया फोरम का उपयोग किसी सेवा संबंधी त्रुटि को रिपोर्ट करने या कोई शिकायत दर्ज करने के लिए नहीं किया जाना चाहिए।
- सम्पूर्ण ऑनलाइन सहभागिता किसी के नाम से और पारदर्शी होनी चाहिए अर्थात् अज्ञात नाम या छद्मनाम से कोई पोस्ट नहीं डाली जानी चाहिए।

□. कर्मचारियों द्वारा व्यक्तिगत प्रयोजनों से सोशल मीडिया का उपयोग:

किसी भी संगठन की प्रतिष्ठा उसके कर्मचारियों के व्यवहार से सीधे जुड़ी होती है, और जो कुछ भी प्रकाशित किया जाता है, वह संगठन की छवि का निर्माण करता है। सोशल मीडिया का इस्तेमाल इस प्रकार किया जाना चाहिए कि संगठन के व्यवसाय का मूल्यवर्धन हो। निम्नलिखित बिन्दुओं को ध्यान में रखने से सोशल मीडिया के व्यक्तिगत इस्तेमाल और संगठन में कर्मचारी के नियोजन के बीच किसी विवाद से बचने सहयोग मिलता है-

- किसी ऑनलाइन/ इंटरनेट नेटवर्किंग सर्विस को सबस्क्राइब करते समय या उस पर कोई जानकारी पोस्ट करते समय संगठन के कार्मिक को संगठन के ईमेल पते या संगठन के अन्य विवरणों का प्रयोग तब तक नहीं करना है, जब तक ऐसा करना व्यवसाय या प्रोफेशन के प्रयोजन से आवश्यक न हो।
- किसी भी प्रकार की व्यक्तिगत इंटरनेट पोस्टिंग या संवाद (उदाहरण के लिए ब्लॉग, संदेश, पोस्ट या ट्वीट) की पहचान आपके व्यक्तिगत और निजी संवाद के रूप में होनी चाहिए। इन व्यक्तिगत संवादों को किसी भी प्रकार से संगठन से नहीं जोड़ा जाना चाहिए और उन्हें इस तरह नहीं लिखा जाना चाहिए कि उन्हें संगठन के कॉर्पोरेट संवाद के रूप में ग्रहण किया जा सके, जब तक कि वे स्पष्ट रूप से अनुपालन टीम, कॉर्पोरेट संचार टीम या विपणन टीम द्वारा अनुमोदित न हों।

यदि किसी भी व्यक्तिगत इंटरनेट पोस्टिंग या संवाद में यह निहित हो कि आप संगठन के लिए काम करते हैं, तो आपको एक सरल और दृश्य प्रत्याख्यान (डिस्क्लेमर) शामिल करना चाहिए, यथा, "इस सेवा पर मेरे पोस्ट मेरे अपने व्यक्तिगत विचार हैं, संगठन के नहीं और ऐसा कोई इरादा नहीं है कि इन्हें संगठन के विचार समझा जाए।"

- सोशल मीडिया में व्यक्ति की जो छवि बनती है उससे उस व्यक्ति की प्रतिष्ठा प्रभावित होती है, और इससे संगठन की प्रतिष्ठा भी प्रभावित हो सकती है। व्यक्तिगत वेबसाइट या सोशल नेटवर्किंग प्लेटफॉर्म पर संगठन या उसके व्यवसाय पर किसी प्रकार की आलोचना या टिप्पणी नहीं की जानी चाहिए।
- व्यक्तिगत प्रयोजन से सोशल मीडिया का उपयोग करते समय कर्मचारियों का यह आशय नहीं होना चाहिए कि वे संगठन के लिए बोल रहे हैं। कार्यालयीन ईमेल पते, कार्यालयीन लोगो या अन्य पहचान से बचना चाहिए और यह स्पष्ट कर देना चाहिए कि जो कहा जा रहा है, वह संगठन के विचार और मत को व्यक्त नहीं करता।
- कर्मचारियों को संगठन की अन्य नीतियों का भी अनुपालन करना चाहिए। उदाहरण के लिए, स्टाफ को इस बात के लिए सतर्क रहना चाहिए कि वह संगठन की गोपनीयता और सूचना सुरक्षा, या कर्मचारी आचार संहिता को भंग न करे। यदि कोई संदेह हो, तो पोस्ट ही न डाले।
- स्टाफ को निजता संबंधी सेटिंग्स का ध्यान रखना चाहिए।
- कर्मचारियों को यह जानना चाहिए कि यदि वे सोशल मीडिया का उपयोग करते हुए कोई कानून तोड़ते हैं (जैसे मानहानि करने वाला कोई पोस्ट डालना) तो वे उसके लिए व्यक्तिगत रूप से जवाबदेह होंगे।
- कर्मचारियों को यह जानना चाहिए कि कुछ खास विवरण प्रकट करने के परिणाम में उनकी पहचान के चोरी होने की संभावना बढ़ जाती है।
- कॉर्पोरेट संचार टीम के साथ मिलकर सीआईएसओ कर्मचारियों को सूचना सुरक्षा संबंधी सोशल मीडिया दिशानिर्देशों और उद्यम के डीएलपी टूल्स के अस्तित्व और उपयोग के बारे में शिक्षित करने के लिए प्रशिक्षण और जागरूकता कार्यक्रम चलाएगा।

1.8. जोखिम प्रबंधन

एक सुरक्षित, विचारशील और विश्वसनीय संगठन के रूप में सकारात्मक छवि और प्रतिष्ठा के माध्यम से संगठन को प्रतस्पर्धा में आगे बनाए रखने के लिए सूचना सुरक्षा जोखिम प्रबंधन आवश्यक है। वित्तीय हानि, ग्राहकों के भरोसे की क्षति और/या परिचालन लाइसेन्स वापस लिए जाने से बचने के लिए जोखिम प्रबंधन अनिवार्य है। जोखिम प्रबंधन के उद्देश्य निम्नानुसार हैं:

- सूचना जोखिम के व्यवसाय को स्वीकार्य स्तर के अनुरूप प्रौद्योगिकी के किसी विशेष कन्फिगरेशन का विश्लेषण और अनुशंसा करना;
- अस्वीकार्य सुरक्षा जोखिम को बढ़ाए बिना नई व्यवसाय प्रक्रिया को संभव बनाने के लिए नई सुरक्षा प्रौद्योगिकी की पहचान करना और उसके विकास का पर्यवेक्षण करना;
- जोखिम के स्वीकृत स्तर के अनुरूप अनुशंसित सुरक्षा कन्फिगरेशन को बनाए रखना सुनिश्चित करने के लिए काम में लाई जा रही सूचना आस्तियों का अनुप्रवर्तन करना;
- संगठन के कर्मचारियों, साझेदारों और प्रबंधन वर्ग को उनके दायित्व के क्षेत्र में विद्यमान सूचना सुरक्षा के बारे में शिक्षित करना;
- किसी व्यवसाय क्षेत्र द्वारा उठाई गई सूचना सुरक्षा जोखिमों का विश्लेषण करना और उन्हें इस प्रकार प्रबंधित करना कि इससे संगठन को आगे अस्वीकार्य स्तर की जोखिमों का सामना न करना पड़े।

व्यवसाय प्रक्रियाओं और प्रणालियों में परिवर्तनों से जुड़ी सूचना सुरक्षा जोखिमों का आकलन, उनके प्रभाव और उनके शमन के लिए विभिन्न नियंत्रणों के कार्यान्वयन की लागत जानने के लिए किया जाएगा। जोखिम को स्वीकार करने और नियंत्रणों के कार्यान्वयन के संबंध में निर्णय नीचे निर्धारित प्रक्रिया के अनुसार संगठन में उपयुक्त स्तर पर लिए जाएंगे:

1. जोखिम आकलन परिदृश्य

संगठन वर्ष में न्यूनतम एक बार और निम्नलिखित परिदृश्यों/ परिस्थितियों के पूर्व जोखिम आकलन का कार्य करेगा:

- किसी बड़ी प्रौद्योगिकी और पहल को शुरू करना;
- बाह्य सेवाप्रदाताओं की सेवाएँ उपयोग में लाना (उदाहरण के लिए, आउटसोर्सिंग, ऑफशोरिंग या क्लाउड सेवाप्रदाताओं की सेवाओं का उपयोग करते समय);
- संगठन की महत्वपूर्ण प्रणालियों (नियोजित की जा रही प्रणालियों सहित) तक बाह्य व्यक्तियों (उदाहरण के लिए, परामर्शदाताओं, संविदाकर्ताओं और बाह्य पक्षकारों के कर्मचारियों) की पहुँच की अनुमति देना;
- बाहरी स्थानों (उदाहरण के लिए, कर्मचारियों के घर, बाह्य पक्षकारों के परिसर या सार्वजनिक स्थान) से पहुँच की अनुमति देना।

II. लक्षित पर्यावरण

निम्नलिखित पर्यावरणों के लिए जोखिम आकलन किया जाएगा:

- व्यवसाय पर्यावरण (उदाहरण के लिए, प्रशासनिक कार्यालय, परिचालन तल, कॉल सेंटर आदि);
- व्यवसाय प्रक्रियाएँ (उदाहरण के लिए, उच्च मूल्य के लेनदेनों का प्रसंस्करण, ग्राहकों के अभिलेखों की हैंडलिंग);
- व्यवसाय एप्लिकेशन (विकसित किए जा रहे और उत्पादन में इस्तेमाल किए जा रहे एप्लिकेशनों सहित);
- व्यवसाय प्रक्रियाओं में सहयोगी सूचना प्रणालियाँ और नेटवर्क;
- संगठन के लिए महत्वपूर्ण विशेषज्ञतामूलक प्रणालियाँ (उदाहरण के लिए, महत्वपूर्ण अवसंरचना को सहयोग देने या समर्थ बनाने वाली प्रणालियाँ);
- कर्मचारी, स्टाफ, तृतीय पक्ष विक्रेता।

लक्षित पर्यावरण निम्नलिखित स्थितियों में जोखिम आकलन के अधीन होगा:

- अपने विकास की आरंभिक अवस्था में;
- महत्वपूर्ण परिवर्तनों के पूर्व;
- किसी बाह्य पक्षकर को आउटसोर्स करने की आवश्यकता पर विचार करते समय।

III. प्रौद्योगिकी जोखिम आकलन प्रक्रिया:

- आईएस टीम विभिन्न प्रकार की सूचना आस्तियों और आईएस प्रक्रियाओं के आकलन के लिए प्रौद्योगिकी जोखिम आकलन टेम्पलेट और/या जाँचसूचियों को निर्धारित करेगी।
- प्रौद्योगिकी जोखिम आकलन टेम्पलेट को इस प्रकार डिजाइन करना है आकलन के परिणामों से निम्नलिखित जानकारियाँ सामने आएँ:
 - i. नई प्रौद्योगिकी/ प्रक्रिया या परिवर्तन के परिणामस्वरूप सूचना जोखिमें;
 - ii. पहचानी गई जोखिमों के शमन के लिए नियंत्रण, जिनमें शामिल हैं: एक कारगर नियंत्रण संरचना का प्रयोग करना, सुरक्षा नियंत्रणों की मजबूतियों और कमजोरियों का मूल्यांकन करना, सूचना सुरक्षा संबंधी गंभीर घटनाओं के होने की आशंका को कम करने वाले और यदि कोई ऐसी घटना हो ही जाती है तो उसके असर को कम करने वाले सुरक्षा नियंत्रणों का चयन करना, सुरक्षा नियंत्रणों की लागत का

- आकलन करना, किसी विशेष व्यवसाय पर्यावरण के लिए विशिष्ट क्षमता वाले सुरक्षा नियंत्रणों की पहचान करना, किसी अवशिष्ट जोखिम की पहचान कर उसके लिए साइन-ऑफ प्राप्त करना;
 - iii. नियंत्रणों की पहचान के बाद की अवशिष्ट जोखिमों को उनकी प्रकृति के अनुसार वित्तीय जोखिम, परिचालन जोखिम, विनियामकीय जोखिम या प्रौद्योगिकीय जोखिम में वर्गीकृत करना।
- . अवशिष्ट जोखिम की प्रकृति के आधार पर जोखिम का स्वामित्व रखने वालों से निम्नानुसार उपयुक्त अनुमोदन प्राप्त किए जाएंगे:
 - i. वित्तीय- सीएफओ
 - ii. परिचालनगत – सीओओ और व्यवसाय प्रक्रिया का स्वामी
 - iii. उद्यम/ सूचना सुरक्षा – सीआईएसओ/ सीआरओ
 - iv. विनियामकीय – सीआरओ
 - v. प्रौद्योगिकी – सीटीओ
- . आकलनों की उपयुक्तता के लिए सभी सूचना सुरक्षा आकलन टेम्पलेटों/ जाँचसूचियों की समीक्षा आईएस टीम द्वारा की जाएगी।
- . आईएस टीम द्वारा आवधिक आधार पर साइन-ऑफ की गई जोखिमों की समीक्षा भी की जाएगी ताकि उपलब्ध हो रहे उपयुक्त समाधानों की पहचान जोखिम स्वामियों के परामर्श से की जा सके।

IV. सूचना सुरक्षा जोखिम प्रबंधन प्रक्रिया:

सूचना सुरक्षा जोखिम प्रबंधन प्रक्रिया बार-बार दोहराई जाने वाली लागू करने योग्य प्रौद्योगिकी जोखिम आकलन (टीआरए) प्रकृति की है और इसमें निम्नलिखित कदम शामिल हैं:

- . व्यवसाय में प्रौद्योगिकी के प्लान किए गए एप्लिकेशन का विश्लेषण करना;
- . लागू करने योग्य प्रौद्योगिकी जोखिम आकलन (टीआरए) मानकों का प्रयोग करते हुए तदनुरूप सूचना सुरक्षा जोखिमों की पहचान करना;
- . संगत व्यवसाय और सहयोग क्षेत्रों के साथ उपयुक्त जोखिम स्तर को लक्षित करने के लिए सुरक्षा नियंत्रणों के कार्यान्वयन की लागत और प्रयास का विश्लेषण करना;
- . सूचना सुरक्षा जोखिम का सहमत स्तर तक समुचित रूप से शमन करने के लिए सुरक्षा प्रौद्योगिकी, नियंत्रणों और प्रक्रियाओं का कार्यान्वयन करना;
- . जहाँ आवश्यक हो, कार्यान्वित किए गए सुरक्षा नियंत्रणों का वस्तुनिष्ठ मापन और परीक्षण शुरू करना;
- . सुरक्षा नियंत्रणों को लागू करने के बाद उनकी पर्याप्तता और स्थिरता सुनिश्चित करने के लिए अनुप्रवर्तन करना।

V. जोखिम उपचार

- . सूचना सुरक्षा उपचार कार्रवाइयों (अवशिष्ट जोखिम सहित) का विवरण जोखिम उपचार योजना में दिया जाएगा जिसे संगत व्यवसाय स्वामी को प्रेषित किया जाएगा, संगत स्वामी और कार्यपालक प्रबंधन के कम-से-कम एक प्रतिनिधि द्वारा साइन-ऑफ किया जाएगा और बीमा कंपनी के अन्य क्षेत्रों में किए गए सूचना जोखिम आकलन के साथ जिसकी तुलना की जाएगी।
- . पूरे संगठन में किए गए सूचना जोखिम आकलन के परिणामों को व्यवसाय स्वामियों और कार्यपालक प्रबंधन (या समकक्ष) को रिपोर्ट किया जाएगा, उनका उपयोग सूचना सुरक्षा कार्यक्रमों (उदाहरण के लिए, सूचना सुरक्षा प्रबंधन प्रणाली – आईएसएमएस – विकसित करना, उपचारात्मक कार्रवाइयाँ निष्पादित करना और नई सुरक्षा पहलें स्थापित करना) और उन्हें व्यापकतर जोखिम प्रबंधन गतिविधियों (उदाहरण के लिए, परिचालन जोखिम प्रबंधन) के साथ समन्वित किया जाएगा।

VI. निरंतर अनुप्रवर्तन और समीक्षा

- . जोखिम आकलन पद्धति रिपोर्ट के अनुसार संगठन वर्ष में कम-से-कम एक बार जोखिम आकलन करेगा।
- . विद्यमान नियंत्रणों, अवशिष्ट जोखिम और स्वीकार्य जोखिम स्तर की पर्याप्तता के सत्यापन के लिए नियमित अंतराल पर समीक्षा की जाएगी।
- . कार्यान्वित नियंत्रणों का अनुप्रवर्तन किया जाएगा और उनकी प्रभावोत्पादकता का मापन किया जाएगा।
- . आस्तियों या व्यवसाय प्रक्रियाओं में किए गए महत्वपूर्ण परिवर्तनों के कारण सामने आई नई जोखिमों की पहचान की जाएगी।

1.9. अपवाद

I. अपवादों की आवश्यकता

जब ऐसी परिस्थितियाँ उत्पन्न होती हैं कि सूचना और साइबर सुरक्षा नीतियों में किसी अपवाद की आवश्यकता हो तो लागू प्रौद्योगिकी जोखिम आकलन मानक का अनुसरण करते हुए जोखिम को स्वीकार या अस्वीकार करने का निर्णय वरिष्ठ प्रबंधन के स्तर पर लिया जाएगा। ऐसा निर्णय लेने के पहले टीआरए निष्पादित किया जाएगा और “जोखिम प्रबंधन” खंड में उल्लिखित समुचित अनुमोदन लिए जाएंगे। अपवाद सर्वसामान्य नहीं होंगे बल्कि सूचना के स्वामी के अधिकृत अनुरोध करने पर अलग-अलग मामले में उनके लिए सहमति दी जाएगी। ऐसी प्रक्रिया स्थापित करने का प्रयोजन यह है कि किसी नीति का अनुपालन न करने से उत्पन्न जोखिम का पर्याप्त विश्लेषण करने के बाद सजगता के साथ उसे स्वीकार्य माना जाए।

II. अपवाद की अनुमति और जोखिम आकलन की पद्धति

जोखिम आकलन प्रक्रिया – संगठन की सूचना सुरक्षा नीति की किसी अपेक्षा का पालन नहीं करने के समर्थन और निर्णय के लिए जोखिम आकलन को पूरा करना और उसका अनुमोदन करना अनिवार्य है। नीति संबंधी सभी अपवादों को “जोखिम प्रबंधन” खंड में उल्लिखित रीति से पूर्ण रूप से दस्तावेजीकृत और अनुमोदित किया जाना चाहिए और जब तक अपवाद अस्तित्व में रहता है, तब तक उसे सूचना सुरक्षा टीम द्वारा बनाए रखा जाना चाहिए। दस्तावेजीकरण को अनिवार्य रूप से आईएस टीम द्वारा पूर्ण और अनुरक्षित किया जाना चाहिए और उसमें निम्नलिखित का समावेश होना चाहिए:

- i. जोखिमगत सूचना आस्ति का मूल्य और संवेदनशीलता जिसमें उसके प्रकटन, विनाश, आशोधन, विलंब या दुरुपयोग के व्यवसायगत परिणाम शामिल हैं;
- ii. वह (या वे) नीति (या नीतियाँ) जिस (या जिन) पर अपवाद लागू होता है;

- iii. अनुपालन न करने के परिणाम में संभावित जोखिम और संबंधित एक्सपोजर का विवरण;
- iv. पहचानी गई जोखिमों को स्वीकार करना;
- v. अनुपालन के लिए व्यवसायगत कारण;
- vi. ऐसे क्षतिपूरक नियंत्रण जो जोखिम को स्वीकार्य स्तर तक कम कर सकेंगे;
- vii. अनुपालन तक ले जा सकने वाली कार्रवाइयाँ और उन कार्रवाइयों के कार्यान्वयन के लिए अनुसूची।

III. कार्यपालकीय अनुमोदन

बीमा कंपनी के सूचना सुरक्षा पर्यावरण में जो भी परिवर्तन संगठन को ऐसी असाधारण जोखिम की ओर ले जाता है जिसका शमन समुचित नियंत्रणों को स्थापित कर न किया जा सके, तो उसे आईएस टीम द्वारा अनुमोदित किया जाना चाहिए जैसा कि इस नीति के विविध खंडों में निर्धारित किया गया है, कार्यपालकीय अनुमोदन का आशय निम्नानुसार है:

- i. नीति या मानकों के अनुपालन के निर्णय में शामिल जोखिम कारकों को समझना;
- ii. परिणामी जोखिम को स्वीकार करने के निर्णय से सहमति;
- iii. सुधारात्मक कार्रवाई की आयोजना किए जाने की स्थिति में सुधार की पहचान और कार्रवाई को पूर्णता तक पहुँचाने के लिए समय-सीमा का अनुमान।

IV. आपातकालीन अपवाद

महामारी, युद्ध, संकट और प्राकृतिक आपदा जैसे काल में विकट और अभूतपूर्व परिस्थितियाँ उत्पन्न होती हैं जिनका कारगर समाधान आवश्यक हो जाता है ताकि ग्राहकों और सरकारों, राजस्व प्राधिकरणों, विनियामकों और सर्वसाधारण को दी जाने वाली सेवाएँ प्रभावित न हों। इस स्थिति में यह आवश्यक हो जाता है कि नई/संशोधित आपातकालीन प्रक्रियाओं और कंपनियों की विद्यमान सूचना सुरक्षा नीतियों को चुनौती देने वाले कार्मिक सम्बन्धी व प्रौद्योगिकीय परिवर्तनों पर सावधानीपूर्वक विचार-विमर्श किया जाए। ऐसी घटनाओं के दौरान संगठन के सभी महत्वपूर्ण कार्यों से मानव संसाधन लेते हुए एक आपदा प्रबंधन समिति का गठन और निर्णयों के परिचालन तथा कार्यनिष्पादन के लिए संशोधित प्रक्रियाओं, प्रौद्योगिकी एवं कार्मिकों पर विचार-विमर्श करने की आवश्यकता होती है। सूचना सुरक्षा कार्य सहित जोखिम प्रबंधन कार्य ऐसी परिस्थितियों में जोखिमों को व्यवस्थित रूप से जोखिम प्रबंधन समिति के अनुमोदन हेतु उसके समक्ष प्रस्तुत करेगा। उसे पुष्टि, और आवश्यक हो तो आगे निर्देश हेतु निदेशक मण्डल की जोखिम प्रबंधन समिति के समक्ष प्रस्तुत किया जाएगा।

निदेशक मण्डल के समग्र निर्देशन और मार्गदर्शन में जोखिम प्रबंधन समिति में सेवाओं की निरंतरता सुनिश्चित करने के लिए प्रक्रियाओं, प्रणालियों, कार्मिक तथा प्रौद्योगिकीय नियंत्रणों में परिवर्तन की शक्तियाँ निहित की जाएँगी। सूचना सुरक्षा के साथ किए जाने वाले समझौतों को अपवाद समझते हुए उनसे निपटा जाएगा और जोखिमों को कम करने के लिए उद्यम जोखिम शमन नियंत्रण के उपाय किए जाएँगे और जब व्यवसाय/ कार्य सामान्य स्थिति प्राप्त कर लेंगे तो सूचना सुरक्षा के साथ किए गए समझौतों को समाप्त कर दिया जाएगा।

1.10. अनुपालन

लेखापरीक्षक द्वारा प्रति वर्ष एक स्वतंत्र आश्वासन लेखापरीक्षा की जाएगी। वार्षिक लेखापरीक्षा योजना और लेखापरीक्षा रिपोर्टें, यथालागू संगठन की लेखापरीक्षा समिति/ निदेशक मण्डल/ प्रधान अधिकारी के समक्ष रखी जाएँगी।

बीमा मध्यस्थ प्रति वर्ष अनुपालन को बीमाकर्ता के निदेशक मण्डल की टिप्पणियों के साथ अनुबंध – III प्रस्तुत करेगा।

बीमाकर्ता यह सुनिश्चित करेगा कि वह जिन बीमा मध्यस्थों को सेवा में रख रहा है, वे अपनी सेवा के दौरान इन दिशानिर्देशों का अनुपालन करें - बीमाकर्ता के पास इस संबंध में निदेशक मण्डल द्वारा अनुमोदित नीति होनी चाहिए।

किसी बीमा मध्यस्थ के साथ व्यवसाय शुरू करने या जारी रखने के लिए अधिकतम जोखिम रेटिंग अनुबंध - III के खंड- I के अंतर्गत भाग – इ के अनुसार बीमाकर्ता के निदेशक मण्डल द्वारा अनुमोदित नीति के अनुसरण में होगी।

जो बीमा मध्यस्थ केवल बीमाकर्ता का डाटा भौतिक रूप में ही रखते हैं और बीमाकर्ता के डाटा का कोई डाटाबेस धारित नहीं करते या बीमाकर्ता की प्रणालियों तक पहुँच नहीं बनाते, उनके मामले में बीमा मध्यस्थ के साथ व्यवसाय शुरू करने या जारी रखने के पहले बीमाकर्ता वार्षिक आधार पर इस संबंध में बीमा मध्यस्थ से स्व-प्रमाणन प्राप्त करेगा।

जिन विदेशी पुनर्बीमा शाखाओं (एफआरबी) की आईटी प्रणालियों का इंटरफेस विदेश स्थित अपनी मूल कंपनी के साथ हो, वे साइबर सुरक्षा दिशानिर्देशों का अनुपालन करेंगी। लेखापरीक्षक इसे अनुबंध – VI के अनुसार प्रमाणित करेगा और उसे प्रत्येक वित्तीय वर्ष की समाप्ति पर आईआरडीएआई को प्रस्तुत करेगा।

बीमाकर्ता लेखापरीक्षक द्वारा विधिवत् हस्ताक्षरित रिपोर्ट (अनुबंध – III) आईआरडीएआई के निदेशक मण्डल की टिप्पणियों के साथ वित्तीय वर्ष की समाप्ति से 90 दिनों के भीतर या लेखापरीक्षा के पूर्ण होने के 30 दिनों के भीतर, इनमें से जो पहले हो, प्रस्तुत करेगा।

विनियमित निकाय सूचना सुरक्षा तरीकों, कार्यविधियों, रोकथाम, प्रतिसाद और सुरक्षित तथा विश्वसनीय इन्टरनेट के लिए साइबर घटनाओं की रिपोर्टिंग के संबंध में सीईआरटी-इन द्वारा समय-समय पर जारी निर्देशों का पालन करेंगे।

विनियमित निकाय, जहाँ भी लागू हो, अपने परिचालन से संगत प्रत्येक कानून और अधिनियम का अनुपालन सुनिश्चित करेंगे। इनमें सूचना प्रौद्योगिकी अधिनियम, भारतीय बीमा विनियामक और विकास प्राधिकरण और अन्य कानून और अधिनियम शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।

सुरक्षा डोमेन नीतियाँ

2.0 सुरक्षा डोमेन नीतियाँ

नीति सं.: 2.1
नीति का नाम: 2.1. डाटा वर्गीकरण

- | | | |
|---|----------------|--|
| 1 | प्रयोजन | <p>संगठन जिन सूचनाओं का उपयोग, प्रसंस्करण और भंडारण करता है, उनके निर्धारण और उनकी संवेदनशीलता के स्तरों के वर्गीकरण के लिए सूचना के स्वामियों हेतु एक संरचना उपलब्ध कराना।</p> <p>संगठन की संवेदनशील सूचना के अप्राधिकृत प्रकटन, आशोधन, उसकी दुर्घटनावश हुई या जानबूझ कर की गई क्षति, अथवा उसके विनष्ट हो जाने से क़ानूनों और/ या विनियमों का उल्लंघन हो सकता है, ग्राहक दुष्प्रभावित हो सकते हैं, और संगठन की छवि के साथ-साथ बाज़ार में उसकी प्रतिस्पर्धात्मक स्थिति भी प्रभावित हो सकती है। इसलिए डाटा के महत्व के आधार पर उसके वर्गीकरण की आवश्यकता है ताकि डाटा की संवेदनशीलता के अनुरूप सुरक्षा नियंत्रणों का कार्यान्वयन संभव हो सके।</p> |
| 2 | दायरा | <p>यह नीति आईटी एप्लिकेशनों, आईटी अवसंरचना और भौतिक सूचना माध्यमों सहित सूचना प्रणालियों पर, और संगठन द्वारा उन प्रणालियों का उपयोग करते हुए प्रयुक्त, प्रसंस्कृत और भंडारित की जाने वाली सूचना आस्तियों पर लागू होती है। यह संगठन में डाटा प्रसंस्करण से संबंधित व्यवसाय प्रक्रियाओं और कार्यविधियों पर भी लागू होती है।</p> <p>यह नीति उन सभी व्यक्तियों पर लागू होती है जो डाटा और और उन प्रौद्योगिकी प्रणालियों को हैंडल करते हैं जिन पर संगठन की सूचना आस्तियों को भंडारित और प्रसंस्कृत किया जाता है।</p> <p>प्रौद्योगिकी प्रणालियों, संचार और नेटवर्क कनेक्शनों में राउटर तथा फायरवाल जैसे नेटवर्क उपकरण, यूएसबी और डिस्क ड्राइव, सर्वर और मेनफ्रेम, परिचालन प्रणालियों, डाटा आधार और एप्लिकेशन जैसे भंडारण उपकरण शामिल हैं लेकिन वे इन्हीं तक सीमित नहीं हैं।</p> <p>सभी व्यवसाय इकाइयाँ या विभाग इस सूचना सुरक्षा नीति का अनुपालन करेंगे।</p> |
| 3 | नीति | <p>सूचना के स्वामी वर्गीकरण के निम्नलिखित चार स्तरों में से किसी एक का उपयोग करते हुए केवल अपने कार्यक्षेत्र में आने वाली सूचना आस्तियों का वर्गीकरण करेंगे:</p> <ul style="list-style-type: none">• सार्वजनिक• आंतरिक• प्रतिबंधित• गोपनीय |

वर्गीकरण के स्तरों का निर्धारण सूचना आस्ति के सापेक्ष जोखिम, मूल्य और संवेदनशीलता के आधार पर किया जाएगा।

इसके अलावा, व्यक्तिगत रूप से पहचान-योग्य सूचना (पीआईआई) को उपर्युक्त डाटा वर्गीकरण नीति के अनुसार वर्गीकृत करने के साथ-साथ पीआईआई के रूप में भी चिह्नित और वर्गीकृत किया जाएगा। संगठन इस वर्ग की सभी सूचनाओं की सत्यनिष्ठा, गोपनीयता और सुरक्षा के संरक्षण के लिए तर्कपूर्ण और समुचित उपाय करेगा।

इस नीति के किसी भी उल्लंघन को एक घटना माना जाएगा और उसके विषय में घटना प्रबंधन नीति के अनुसार कार्रवाई की जाएगी।

3.1 डाटा का स्वामित्व

संगठन के भीतर सभी सूचना आस्तियों का एक नामनिर्दिष्ट स्वामी होगा। सूचना आस्तियों का उपयोग करने वाले, व्यवसाय प्रक्रियाओं के लिए जिम्मेदार प्रबन्धकों को सूचना का स्वामी माना जाता है। सूचना के स्वामी अपनी कुछ या सभी सूचना प्रणालियों का स्वामित्व दूसरे व्यक्तियों में प्रत्यायोजित कर सकते हैं। लेकिन स्वामी उत्तरदायी बने रहेंगे और यह देखेंगे कि जिनमें स्वामित्व प्रत्यायोजित किया गया है वे अपनी जिम्मेदारियाँ पूरी करें।

3.3 डाटा वर्गीकरण प्रक्रिया

सूचना के स्वामी यह सुनिश्चित करेंगे कि वे जिन सूचना आस्तियों के लिए जिम्मेदार हैं उन्हें ऐसी वर्गीकरण रेटिंग (गोपनीय, प्रतिबंधित, आंतरिक और सार्वजनिक) दें जो संगठन के लिए सूचना के व्यवसायगत मूल्य और महत्व को समुचित रूप से व्यक्त करती हो। व्यवसायगत मूल्य और जोखिमों में होने वाले किसी परिवर्तन से निपटने के लिए सूचना के स्वामी कम-से-कम दो वर्ष की अवधि में एक बार, या संगठन को प्रभावित करने वाले क़ानूनों और विनियमों में उल्लिखित अपेक्षा के अनुरूप वर्गीकरण में दिए गए लेबल की समीक्षा करेंगे।

3.3.1 गोपनीय:

ये वरिष्ठ प्रबंधन द्वारा या क़ानूनों और विनियमों द्वारा अत्यधिक संवेदनशील सूचना के रूप में वर्गीकृत ऐसी व्यक्तिगत या कंपनी सूचनाएँ हैं जो संगठन को प्रभावित करती हैं। सामान्य रूप से ऐसी सूचनाएँ ग्राहकों, एजेंटों, वितरकों, आपूर्तिकर्ताओं आदि जैसे व्यवसाय साझेदारों, या कर्मचारियों से संबंधित व्यक्तिगत पहचान-योग्य सूचनाओं (पीआईआई) से जुड़ी होती हैं, या ऐसी सूचनाएँ होती हैं जो संगठन की सफलता के लिए अनिवार्य या रणनीतिक महत्व की होती हैं (उदाहरण के लिए, वित्तीय विवरण) और जो संगठन को महत्वपूर्ण प्रतिस्पर्धात्मक बढ़त दिला सकती हैं (उदाहरण के लिए, नए उत्पाद डिजाइन)। गोपनीय सूचना का अप्राधिकृत प्रकटन बीमा कंपनी, उसके ब्रांड/ प्रतिष्ठा और ग्राहकों को उल्लेखनीय रूप से प्रभावित कर सकता है।

3.3.2 प्रतिबंधित:

ये ऐसी सूचना आस्तियाँ हैं, जिन्हें यदि प्रकट किया जाए तो उसके परिणामस्वरूप उल्लेखनीय प्रतिकूल प्रभाव पड़ सकता है, परेशानी हो सकती है, वित्तीय दंड लग सकता है, हितधारकों के भरोसे की हानि हो सकती है और अनुपालन संबंधी दंड लगाए जा सकते हैं।

3.3.3	केवल आंतरिक उपयोग के लिए:	इस वर्ग में ऐसी सूचनाएँ आती हैं जिनके आम जनता द्वारा उपयोग की मंशा नहीं होती। इनमें कर्मचारियों के उपयोग के लिए कंपनी के इंटरनेट पर डाली गई सूचनाएँ आती हैं, जैसे फोन डाइरेक्टरी या कर्मचारी हैंडबुक। 'केवल आंतरिक उपयोग के लिए' सूचनाओं के अप्राधिकृत प्रकटन से बीमा कंपनी, उसके ब्रांड/प्रतिष्ठा और ग्राहकों पर साधारण असर हो सकता है।
3.3.4	सार्वजनिक:	इसमें ऐसी सूचनाएँ आती हैं जिनको संगठन के वरिष्ठ प्रबंधन द्वारा आम जनता के लिए जारी करने की अनुमति दी गई हो। ऐसी सूचनाओं में सार्वजनिक या सरकारी स्रोतों से उपलब्ध सूचनाएँ, विज्ञापन या अधिकृत वेबसाइट पर दी गई सूचनाएँ शामिल हैं। सार्वजनिक सूचना के प्रकटन से बीमा कंपनी, उसके ब्रांड/प्रतिष्ठा और ग्राहकों पर अत्यल्प असर हो सकता है या बिलकुल भी असर नहीं होता।
3.3.5	तकनीकी मानक	तकनीकी मानक इस दस्तावेज़ में नीचे परिभाषित जीवनचक्र प्रक्रिया पर आधारित होने चाहिए। खंड 3.5 'जीवनचक्र प्रक्रियाएँ' में संगठन की सूचना आस्तियों की गोपनीयता के संरक्षण के लिए निर्दिष्ट नियंत्रणों की रूपरेखा दी गई है।
3.4	जीवनचक्र प्रक्रियाएँ	
3.4.1	गोपनीय सूचना	
3.4.1.1	लेबेलिंग अपेक्षाएँ	भौतिक या इलेक्ट्रॉनिक दस्तावेज़ के कम-से-कम प्रत्येक पृष्ठ पर स्पष्ट रूप से पठनीय “गोपनीय” लेबल लगाया जाएगा। 1. किसी भी उपकरण या वस्तु (साथ लेकर चलने योग्य उपकरणों सहित) पर, जिसमें गोपनीय सूचना हो, “गोपनीय” लेबल लगाया जाएगा। 2. जिन प्रणालियों में गोपनीय सूचना होगी उनकी पहचान की जाएगी और उनका उल्लेख “आस्ति लाइब्रेरी” में किया जाएगा। 3. जिन भंडारण रिपोजिटोरियों में गोपनीय सूचनाएँ रखी जाती हैं उनकी जानकारी रखी जाएगी और सूचना के प्रभावी संरक्षण के लिए नियंत्रणों का कार्यान्वयन किया जाएगा। 4. गोपनीय सूचना वाले ई-मेल के विषय वाली पंक्ति, शीर्ष (हेडर) या पाद (फूटर) में “गोपनीय” लिखा होगा।
3.4.1.2	भंडारण अपेक्षाएँ	1. भंडारण पर्यावरण के लिए यह अपेक्षित है कि प्रयोक्ता अधिकृत हो और प्रत्येक प्रयोक्ता या प्रशासक (एडमिनिस्ट्रेटर) की अलग पहचान स्पष्ट रूप से स्थापित हो। 2. भंडारण पर्यावरणों की आवधिक समीक्षा और लेखापरीक्षा की जाएगी ताकि सूचना की पर्याप्त सुरक्षा सुनिश्चित करने में सहयोग मिले। 3. भंडारण पर्यावरणों की निगरानी की जाएगी ताकि यह सुनिश्चित किया जा सके कि पहुँच नियंत्रण प्रणालियाँ सही ढंग से काम कर रही हैं। 4. गोपनीय सूचनाओं को कंपनी के स्वामित्व या नियंत्रण में स्थित प्रणालियों में या संगठन के साथ अनुमोदित साझेदारी वाली समान रूप से सुरक्षित प्रणालियों में भंडारित किया जाएगा।

3.4.1.3 अंतरण अपेक्षाएँ

1. जब **गोपनीय** सूचना को संगठन के नेटवर्क से बाहर, जिसमें इंटरनेट शामिल है, प्रेषित करना हो तो उसे सुरक्षित माध्यम से एनक्रिप्टेड रूप में संप्रेषित किया जाएगा। एनक्रिप्शन कीज़ का प्रबंधन और संरक्षण प्राधिकृत संसाधनों द्वारा किया जाएगा जैसा कि क्रिप्टोग्राफिक सुरक्षा नीति में निर्धारित किया गया है।
2. किसी तृतीय पक्षकार द्वारा संगठन में कोई सूचना न्यस्त की गई हो तो बाहरी नेटवर्क प्रणालियों पर भेजते समय उसे एनक्रिप्ट किया जाएगा।
3. संप्रेषित दस्तावेजों (अर्थात् फैसिमिली ट्रांसमिशन) के कवर वाले पन्ने पर **“गोपनीय”** निर्दिष्ट होगा।
4. जिस फोन कॉल, एसएमएस या इलेक्ट्रॉनिक सम्प्रेषण में **गोपनीय** सूचना पर बात होगी/ विचार होगा उसमें उसके पूर्व संबन्धित सूचना की संवेदनशीलता के बारे में एक अभिकथन होगा।
5. भौतिक फॉर्मेट (पेपर, डिस्क आदि) के माध्यम से गोपनीय सूचना वितरित करते समय सूचना को लिफाफे में बंद किया जाए और उस पर **“गोपनीय”** का लेबल लगाया जाए चाहे उसकी हस्ते सुपुर्दगी ही क्यों न करनी हो।
6. सूचना के स्वामी से पूर्व-प्राधिकार प्राप्त किए बिना बौद्धिक सम्पदा संप्रेषित नहीं की जाएगी।

3.4.1.4 ट्रेकिंग अपेक्षाएँ

1. ट्रेकिंग तकनीकों, प्रणालियों की क्षमताओं, या मैनुअल प्रयासों से यह निर्दिष्ट होगा कि **गोपनीय** सूचना तक किसने, कहाँ (उदाहरण के लिए, एमएसी आईडी, आईपी एड्रेस) से और कब पहुँच स्थापित की।
2. सूचना के स्वामी द्वारा पहुँच की लेखापरीक्षा की जाएगी और कमियों को समयबद्ध रीति से ठीक किया जाएगा।

3.4.1.5 निपटान अपेक्षाएँ

गोपनीय सूचना को उसकी प्रतिधारण अवधि के अंत में नष्ट कर दिया जाएगा **अथवा** किसी विवाद या लेखापरीक्षा के लिए प्रतिधारण अवधि के बाद भी सूचना को धारित किए जाने की स्थिति में विवाद आदि का निपटान हो जाने पर उसे नष्ट कर दिया जाएगा।

संगठन जिस संवेदनशील डाटा या प्रणाली तक नियमित रूप से पहुँच नहीं बनाता उसे नेटवर्क से हटा दिया जाएगा। इन प्रणालियों का उपयोग अलग-थलग एकल रूप में (नेटवर्क से अलग) उस व्यवसाय इकाई द्वारा किया जाएगा जो कभी-कभी उनका उपयोग करता है, या उन्हें तब तक के लिए पूरी तरह से वर्चुअल रूप देकर पावर्ड ऑफ रखा जाएगा जब तक उनकी जरूरत न हो।

3.4.2 प्रतिबंधित सूचना

3.4.2.1

लेबेलिंग अपेक्षाएँ

1. भौतिक या इलेक्ट्रॉनिक दस्तावेज़ के कम-से-कम प्रत्येक पृष्ठ पर स्पष्ट रूप से पठनीय **“प्रतिबंधित”** लेबल लगाया जाएगा। किसी भी उपकरण या वस्तु पर, जिसमें **प्रतिबंधित** सूचना निहित हो, **“प्रतिबंधित”** लेबल लगाया जाएगा।
2. जिन प्रणालियों, एप्लिकेशनों और डाटाबेस में **प्रतिबंधित** सूचना हो, उनके द्वारा उपयुक्त आउटपुट या डिस्प्ले पर स्पष्ट रूप से पठनीय **“प्रतिबंधित”** लेबल उपलब्ध कराया जाएगा।
3. जिन भंडारण रिपोजिटोरियों में **प्रतिबंधित** सूचनाएँ रखी जाती हैं उनकी जानकारी रखी जाएगी और सूचना के प्रभावी संरक्षण के लिए आवश्यक नियंत्रणों (अर्थात् भौतिक ताले, दरवाजों के ताले) को लागू किया जाएगा।
4. जिन संप्रेषणों में **प्रतिबंधित** सूचना निहित होगी उनमें कम-से-कम एक अभिकथन अवश्य होगा जिससे यह सुनिश्चित करने में सहयोग मिले कि प्राप्तकर्ता **प्रतिबंधित** सूचना की संवेदनशीलता और उसे हैंडल करने की कार्यविधि को समझे।
5. **प्रतिबंधित** सूचना वाले ई-मेल के विषय वाली पंक्ति, शीर्ष (हेडर) या पाद (फूटर) में **“प्रतिबंधित”** लिखा होगा।

3.4.2.2

भंडारण अपेक्षाएँ

1. **प्रतिबंधित** सूचना वाले पोर्टेबल मीडिया, हार्ड प्रति दस्तावेजों, डिस्कटों, टेपों को सब समय सुरक्षित (ताले-चाबी से या इलेक्ट्रॉनिक प्राधिकरण प्रक्रियाओं से) रखा जाएगा और उन्हें प्राधिकृत कार्मिकों के प्रत्यक्ष नियंत्रण में रखा जाएगा।
2. भंडारण पर्यावरण के लिए यह अपेक्षित है कि प्रयोक्ता अधिकृत हो और प्रत्येक प्रयोक्ता या प्रशासक (एडमिनिस्ट्रेटर) की अलग पहचान स्पष्ट रूप से स्थापित हो, चाहे वह पोर्टेबल इलेक्ट्रॉनिक उपकरण ही क्यों न हों।
3. **प्रतिबंधित** सूचनाओं को कंपनी के स्वामित्व या नियंत्रण में स्थित प्रणालियों में या संगठन के साथ अनुमोदित साझेदारी वाली समान रूप से सुरक्षित प्रणालियों में भंडारित किया जाएगा।
4. भंडारण पर्यावरणों की आवधिक समीक्षा और लेखापरीक्षा की जाएगी ताकि सूचना की पर्याप्त सुरक्षा सुनिश्चित करने में सहयोग मिले।
5. भंडारण पर्यावरणों की निगरानी की जाएगी ताकि यह सुनिश्चित किया जा सके कि पहुँच नियंत्रण प्रणालियाँ सही ढंग से काम कर रही हैं।
6. हार्ड प्रति में निहित सूचना को, जब वह उपयोग में न हो या जब सीधे आँखों के सामने न हो, सुरक्षित कंटेनर जैसे कि तालाबंद कैबिनेट या डेस्क में रखा जाएगा।

3.4.2.3

अंतरण अपेक्षाएँ

1. जब **प्रतिबंधित** सूचना संगठन के नेटवर्क से बाहर, जिसमें इन्टरनेट शामिल है, भेजनी हो तो उसे सुरक्षित माध्यम से एनक्रिप्टेड रूप में संप्रेषित किया जाएगा।
2. एनक्रिप्शन कीज़ का प्रबंधन और संरक्षण प्राधिकृत संसाधनों द्वारा किया जाएगा जैसा कि क्रिटोग्राफिक सुरक्षा नीति में निर्धारित किया गया है।
3. **प्रतिबंधित** सूचना को जब इलेक्ट्रॉनिक माध्यम से संप्रेषित किया जाएगा तो उसके साथ प्राप्तकर्ता के लिए एक चेतावनी होगी जिसमें यह बताया जाएगा कि **प्रतिबंधित** सूचना को कैसे हैंडल करना है और कैसे उसे संरक्षित करना है।

4. भौतिक फॉर्मेट (पेपर, डिस्क आदि) के माध्यम से **प्रतिबंधित** सूचना संप्रेषित करते समय सूचना को दोहरे लिफाफे में बंद किया जाएगा। भीतर के लिफाफे पर **“प्रतिबंधित”** का लेबल लगाया जाएगा। बाहरी लिफाफे पर कोई विशेष निशान नहीं होगा और उसे हस्ते या किसी अन्य उपयुक्त रीति से सुपुर्द किया जाएगा।
5. संप्रेषित दस्तावेजों (अर्थात् फैसिमिली ट्रांसमिशन) के कवर वाले पन्ने पर **“प्रतिबंधित”** निर्दिष्ट होगा।
6. **प्रतिबंधित** सूचना पर किसी के साथ विचार-विमर्श नहीं किया जाएगा, जिसमें एसोसिएट, संविदाकर्ता, या ऐसे तृतीय पक्षकार शामिल हैं जिनके लिए संबंधित सूचना को जानना आवश्यक नहीं है, और जिन्हें सूचना के स्वामी द्वारा व्यक्ति रूप से प्राधिकृत नहीं किया गया है।
7. **प्रतिबंधित** सूचना को असुरक्षित स्थानों पर मौखिक रूप से संप्रेषित नहीं किया जाएगा। संबंधित व्यक्ति बातचीत शुरू करने के पहले यह सुनिश्चित करेगा कि सुनाई दे सकने की सीमा के भीतर कोई अप्राधिकृत व्यक्ति उपस्थित नहीं है।

3.4.2.4 ट्रेकिंग अपेक्षाएँ

1. ट्रेकिंग तकनीकों, प्रणालियों की क्षमताओं, या मैनुअल प्रयासों से यह निर्दिष्ट होगा कि **प्रतिबंधित** सूचना तक किसने, कहाँ (उदाहरण के लिए, एमएसी आईडी, आईपी एड्रेस) से और कब पहुँच स्थापित की।
2. सूचना के स्वामी द्वारा पहुँच की लेखापरीक्षा की जाएगी और कमियों को समयबद्ध रीति से ठीक किया जाएगा।

3.4.2.5 निपटान अपेक्षाएँ

प्रतिबंधित सूचना और सभी संबंधित प्रतियों और सारे बैक-अप को सूचना की प्रतिधारण अवधि के अंत में नष्ट कर दिया जाएगा **अथवा** किसी विवाद या लेखापरीक्षा के लिए प्रतिधारण अवधि के बाद भी सूचना को धारित किए जाने की स्थिति में विवाद आदि का निपटान हो जाने पर उसे नष्ट कर दिया जाएगा।

3.4.3 'केवल आंतरिक उपयोग के लिए' सूचनाएँ

3.4.3.1 लेबेलिंग अपेक्षाएँ

1. इस वर्ग की सूचना के संदर्भ में लेबेलिंग संबंधी कोई अपेक्षा नहीं है। तथापि, यदि किसी सूचना या सूचना स्रोत पर कोई लेबल नहीं लगाया गया हो तो कम-से-कम यह माना जाना चाहिए कि वह सूचना **केवल आंतरिक उपयोग के लिए** है।
2. फाइल या दस्तावेज़ के पहले पृष्ठ पर या उपकरण के सामने वाले हिस्से में **केवल आंतरिक उपयोग के लिए** का स्पष्ट रूप से पठनीय लेबल होगा।

3.4.3.2 भंडारण अपेक्षाएँ

1. भंडारण पर्यावरण के लिए यह अपेक्षित है कि प्रयोक्ता अधिकृत हो और प्रत्येक प्रयोक्ता या प्रशासक (एडमिनिस्ट्रेटर) की अलग पहचान स्पष्ट रूप से स्थापित हो।
2. यह सुनिश्चित करने के लिए समुचित नियंत्रण स्थापित किए जाएँगे कि जो सूचना **केवल आंतरिक उपयोग के लिए** है उस सूचना तक केवल प्राधिकृत प्रयोक्ता ही पहुँच स्थापित कर सकें।

3.4.3.3	अंतरण अपेक्षाएँ	जो सूचना केवल आंतरिक उपयोग के लिए हो उसका अंतरण केवल उन्हीं पक्षकारों के बीच होता है जिन्हें उस सूचना के उपयोग की आवश्यकता होती है। यह सूचना के स्वामी का दायित्व है कि वह इस वर्ग की सूचना के अंतरण के संचालन की कार्यविधियों और नियंत्रणों को निर्धारित और संप्रेषित करे।
3.4.3.4	निपटान अपेक्षाएँ	जो सूचना केवल आंतरिक उपयोग के लिए हो उसे उसकी प्रतिधारण अवधि के अंत में नष्ट कर दिया जाएगा अथवा किसी विवाद या लेखापरीक्षा के लिए प्रतिधारण अवधि के बाद भी सूचना को धारित किए जाने पर विवाद आदि का निपटान हो जाने पर उसे नष्ट कर दिया जाएगा।
3.4.4	सार्वजनिक सूचना	
3.4.4.1	लेबेलिंग अपेक्षाएँ	कोई लेबल अपेक्षित नहीं
3.4.4.2	भंडारण अपेक्षाएँ	भंडारण संबंधी कोई विशिष्ट अपेक्षा नहीं
3.4.4.3	अंतरण अपेक्षाएँ	अंतरण संबंधी कोई विशिष्ट अपेक्षा नहीं
3.4.4.4	निपटान अपेक्षाएँ	सार्वजनिक सूचना का निपटान उसकी प्रतिधारण अवधि के अंत में अथवा संबंधित विवाद या लेखापरीक्षा हेतु विहित प्रतिधारण की समाप्ति पर कर दिया जाएगा।
3.5	डाटा की निजता	व्यक्तिगत रूप से पहचान-योग्य सूचना किसी व्यक्ति से संबंधित वह सूचना है जो उसकी विशिष्ट अलग पहचान स्थापित और निर्धारित करती है जिसमें नाम, ईमेल, संपर्क विवरण या विशिष्ट पहचान संख्या शामिल हैं किन्तु ऐसी सूचना इन्हीं तक सीमित नहीं है। इस प्रकार की सूचना को आगे निम्नलिखित श्रेणियों में रखा जा सकता है: 1. संवेदनशील व्यक्तिगत सूचना 2. अन्य व्यक्तिगत सूचना डाटा की निजता के उल्लंघन की किसी घटना की रिपोर्ट संबंधित प्राधिकारी को तत्काल दी जानी चाहिए ताकि उसके एक्सपोजर को सीमित किया जा सके। कृपया घटना और समस्या प्रबंधन नीति देखें।
3.5.1	व्यक्तिगत रूप से पहचान-योग्य सूचना (पीआईआई) की पहचान	किसी व्यक्ति के व्यक्तिगत डाटा या सूचना में कॉर्पोरेट निकाय या मध्यस्थ या किसी व्यक्ति द्वारा एकत्र, प्राप्त, भंडारित, संप्रेषित या प्रसंस्कृत सूचना शामिल है, जिसमें निम्नलिखित शामिल हैं: 1. पासवर्ड 2. रजिस्ट्रेशन के समय या उसके बाद उपलब्ध कराया गया प्रयोक्ता का विवरण 3. प्रयोक्ताओं की वित्तीय सूचनाएँ जैसे बैंक खाते/ क्रेडिट कार्ड/ डेबिट कार्ड/ अन्य भुगतान लिखतों का विवरण

4. शारीरिक और मानसिक स्वास्थ्य स्थितियाँ
5. चिकित्सा अभिलेख और इतिहास
6. बायोमीट्रिक सूचना
7. कॉर्पोरेट निकाय द्वारा विधिसम्मत संविदा के अंतर्गत या अन्यथा प्रसंस्करण के लिए प्राप्त, भंडारित या
8. प्रसंस्कृत सूचना
9. कॉल डाटा अभिलेख
10. जिस पीआईआई को उपर्युक्त वर्गीकरण के अनुसार एसपीआई नहीं माना गया है उसे अन्य व्यक्तिगत सूचना (ओपीआई) माना जाएगा।

3.5.2 पीआईआई का एकत्रण

ऐसी सूचना के एकत्रण के पूर्व संगठन या उसकी ओर से कोई अन्य व्यक्ति सूचना प्रदाता से प्रयोजन, साधन और उपयोग के तरीकों के बारे में उसकी सहमति प्राप्त करेगा।

संगठन या उसकी ओर से कोई अन्य व्यक्ति संवेदनशील व्यक्तिगत सूचना एकत्र/प्राप्त नहीं करेगा जब तक कि -

सूचना एजेंसी के किसी कार्य या गतिविधि से जुड़े किसी विधिसम्मत प्रयोजन के लिए नहीं ली जाती;

सूचना का एकत्रण उस प्रयोजन के लिए आवश्यक न हो।

संबन्धित व्यक्ति से सीधे सूचना लेते समय संगठन या उसकी ओर से कोई व्यक्ति ऐसे कदम उठाएगा जो उन परिस्थितियों में यह सुनिश्चित करने के लिए पर्याप्त आवश्यक हों कि संबन्धित व्यक्ति निम्नलिखित बातों को लेकर जागरूक है -

यह तथ्य कि सूचना एकत्र की जा रही है; और

1. सूचना एकत्र किए जाने का प्रयोजन; तथा
2. सूचना के आशायित प्राप्तकर्ता।
3. संगठन या उसकी ओर से कोई व्यक्ति, जिसके पास संवेदनशील व्यक्तिगत सूचना होगी, सूचना को उस अवधि के बाद अपने पास नहीं रखेगा जिस अवधि के लिए सूचना को उस विधिसम्मत प्रयोजन के लिए रखना आवश्यक हो जिसके लिए वह ली गई है।
4. एकत्र की गई सूचना का उपयोग उसी प्रयोजन के लिए किया जाएगा जिसके लिए वह एकत्र की गई है।
5. संगठन या उसकी ओर से कोई व्यक्ति प्रयोक्ताओं को यह अनुमति देगा कि वे उपलब्ध कराई गई सूचना की समीक्षा करें और जहाँ भी आवश्यक हो, उसे आशोधित करें।

3.5.3 पीआईआई का भंडारण, अंतरण और उसे नष्ट करना

1. एसपीआई को सुरक्षा का वही स्तर दिया जाएगा जो गोपनीय सूचना का होगा चाहे उस सूचना का वर्गीकरण कुछ भी क्यों न हो। एसपीआई के भंडारण, अंतरण और उसे नष्ट करने के लिए कृपया गोपनीय सूचना हेतु विहित जीवनचक्र प्रक्रियाओं को संदर्भित करें।
2. ओपीआई को सुरक्षा का वही स्तर दिया जाएगा जो प्रतिबंधित सूचना का होगा चाहे उस सूचना का वर्गीकरण कुछ भी क्यों न हो। ओपीआई के भंडारण, अंतरण और उसे नष्ट करने के लिए कृपया प्रतिबंधित सूचना हेतु विहित जीवनचक्र प्रक्रियाओं को संदर्भित करें।

3.5.4 पीआईआई का प्रसंस्करण

1. ग्राहकों/ कर्मचारियों के सम्पूर्ण डाटा को 'आस्ति प्रबंधन कार्यविधि' के अनुसार वर्गीकृत किया जाएगा।
2. ग्राहकों/ कर्मचारियों के व्यक्तिगत डाटा को मैनुअल या इलेक्ट्रॉनिक रूप में सुरक्षित तरीके से और आईटी अधिनियम के अनुसार भंडारित किया जाएगा।
3. ग्राहकों/ कर्मचारियों के व्यक्तिगत डाटा को आवश्यकता से अधिक अवधि के लिए भंडारित नहीं किया जाएगा जब तक कि किसी कानून द्वारा अन्यथा अधिदेशित न किया जाए।
4. ग्राहकों/ कर्मचारियों के व्यक्तिगत डाटा का उपयोग उसी प्रयोजन से किया जाएगा जिसके लिए उसे एकत्र किया गया है।
5. संवेदनशील डाटा तक पहुँच केवल और केवल जानने की आवश्यकता के आधार पर उपलब्ध कराई जाएगी।
6. रिमूवेबल भंडारण माध्यम पर संवेदनशील डाटा का बैक-अप सुरक्षित और तालाबंद वातावरण में रखा जाएगा।

3.5.5 पीआईआई का प्रकटन

1. यदि संगठन का कोई ग्राहक/ कर्मचारी अपने एकत्र किए गए संवेदनशील डाटा को देखने का अनुरोध करता है तो वह उसे उपलब्ध कराया जाएगा।
2. संगठन किसी व्यक्ति के व्यक्तिगत डाटा को, निम्नलिखित स्थितियों को छोड़कर संगठन के बाहर प्रकट नहीं करेगा:
 - जब संगठन ऐसा करने की सहमति व्यक्त करे, या ऐसी परिस्थितियों में जिनके बारे में संगठन और संबंधित व्यक्ति के बीच सहमति हुई हो।
 - जब आवश्यक हो, हमारे विनियामकीय निकायों और लेखापरीक्षकों को।
 - जब कानून के अंतर्गत संगठन के लिए ऐसा करना अपेक्षित या अनुमत हो।
 - बीमाकर्ताओं और उधारदाताओं सहित ऐसे व्यक्तियों को जो व्यक्ति को लाभ या सेवाएँ देते हों।
 - जहाँ आवश्यक हो, धोखाधड़ी की रोकथाम करने वाली एजेंसियों को।
3. संवेदनशील डाटा के अप्राधिकृत प्रकटन को रोकने के लिए डाटा क्षति निवारण, डिजिटल अधिकार प्रबंधन आदि जैसे डाटा संरक्षण टूल्स को कार्यान्वित किया जाएगा।

3.6 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आस्ति का स्वामी	आईएस, आईटी, सुरक्षा परिचालन टीम	जोखिम प्रबंधन टीम	आईटी, व्यवसाय विभाग, आईएस, आस्ति का स्वामी

नीति सं.:	2.2
नीति का नाम:	2.2. आस्ति प्रबंधन

1 प्रयोजन

संगठन द्वारा उपयोग में लाई जाने वाली सूचनाओं के संरक्षण और दक्षतापूर्ण तथा प्रभावी सेवा प्रदान करने के उद्देश्य से सूचना आस्तियों के उपयोग, रखरखाव और निपटान में शामिल सूचना प्रणालियों की पहचान और सूचीकरण की पद्धतियों को परिभाषित / निर्धारित करना

यह नीति संगठन द्वारा उपयोग में लाई जा रही सभी सूचना प्रणालियों, या संगठन की सूचनाओं के सृजन, भंडारण, प्रेषण या उन्हें नष्ट करने में शामिल सभी सूचना प्रणालियों पर लागू होती है जिसमें निम्नलिखित शामिल हैं लेकिन जो इन्हीं तक सीमित नहीं हैं:

- सॉफ्टवेयर आस्तियाँ
- भौतिक आस्तियाँ
- लोग
- संगणना और संचार, एयर कंडीशन, बिजली और दस्तावेजों के भंडारण जैसी सेवाएँ
- सूचना – डिजिटल और गैर-डिजिटल आस्तियाँ

संगठन की सूचना आस्तियों को किसी भी रूप में हैंडल करने वाले सभी व्यक्तियों को अनिवार्य रूप से इस नीति का अनुपालन करना होगा।

3

नीति

कंपनी के भौतिक पर्यावरण और होस्टिंग साइट जैसे वर्चुअल परिसरों, सेवाप्रदाता के परिसरों में उपयोग में लाए जाने वाले हार्डवेयर, सॉफ्टवेयर और भौतिक आस्तियों सहित संगठन की सूचना आस्तियों का प्रबंधन, उनके अधिग्रहण से लेकर निपटान तक सूचना आस्ति संरक्षण नीति के अनुसार किया जाएगा।

इस नीति के किसी उल्लंघन को घटना माना जाएगा और उसका उपचार आस्ति के पूरे जीवनचक्र के दौरान इस नीति में स्थापित उद्देश्यों के अनुरूप घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1

सूचना आस्ति का प्रोफाइल तैयार करना

सूचना आस्तियों का वर्गीकरण नीचे उल्लिखित पहलुओं को ध्यान में रखते हुए प्रबंधन द्वारा चुनी गई संख्यात्मक अथवा गुणात्मक पद्धति से किया जाएगा:

1. डाटा को मुद्रित रूप में भंडारित करने के लिए उपयुक्त पेपर फॉर्मेट सहित डाटा को रखने वाली डाटा सूचना प्रणालियाँ/ साधित्र;
2. डाटा का वर्गीकरण डाटा वर्गीकरण नीति के अनुसार किया जाएगा।

अन्य सूचना आस्तियों का वर्गीकरण निम्नलिखित मानदंडों के आधार पर इस प्रकार किया जाएगा जिससे व्यवसाय आवश्यकताएँ, कानूनी-विनियामकीय-प्रमाणनगत अपेक्षाएँ और गोपनीयता-सत्यनिष्ठा-उपलब्धता संबंधी चिंताएँ प्रदर्शित हों।

- आस्ति में निहित डाटा का वर्गीकरण
- व्यवसाय परिचालनों के लिए उस आस्ति का महत्व
- निहित डाटा के मूल्य से भिन्न आस्ति का महत्व
- निहित डाटा का रूप (हार्ड प्रति/ इलेक्ट्रॉनिक)
- आस्ति का उपयोग (भंडारण/ प्रसंस्करण/ सम्प्रेषण)
- आस्ति में निहित/ उसके माध्यम से संप्रेषित डाटा

3.2

जीवनचक्र प्रक्रियाएँ

3.2.1

आस्ति अधिग्रहण / खरीद

सभी आस्तियों के लिए औपचारिक अधिग्रहण/ खरीद कार्यविधि अपनाई जाएगी। आस्तियों का अधिप्रापण प्राधिकृत कार्मिक से समुचित अनुमोदन प्राप्त करने के

3.2.2 आस्ति की ट्रैकिंग

3.2.2.1

पहचान और इनवेंटरी नियंत्रण के लिए प्रत्येक आस्ति पर निशान लगाया जाएगा। आस्तियों की लेबेलिंग और हैंडलिंग के लिए वर्गीकरण योजना (ओं) के अनुसार कार्यविधियों का एक समुच्चय विकसित और कार्यान्वित किया जाएगा। इसमें निम्नलिखित शामिल हैं:

- वर्गीकरण और लेबेलिंग को सुनिश्चित/संपुष्ट करने और फिर लेबल के अनुरूप हैंडलिंग के लिए आस्ति के स्वामी का दायित्व;
- सभी सूचना प्रसंस्करण सुविधाओं और सभी रूपों तथा माध्यमों में उपलब्ध सूचनाओं को शामिल करते हुए वर्गीकरण;
- स्वामित्व और अभिरक्षा की श्रृंखला स्थापित करने की कार्यविधियाँ; और
- आस्तियों की सुरक्षा से जुड़ी घटनाओं की लॉगिंग और रिपोर्टिंग के लिए कार्यविधियाँ।

यह सुनिश्चित करने के लिए कि वर्गीकरण संगठन के अन्य लक्ष्यों के समक्ष व्यवसाय आवश्यकताओं, कानूनी-विनियामकीय-प्रमाणगत अपेक्षाओं और गोपनीयता-सत्यनिष्ठा-उपलब्धता से संबन्धित चिंताओं को समुचित रूप से प्रदर्शित करते हैं, आवधिक समीक्षा की बारंबारता का निर्धारण।

3.2.2.2

आस्तियों की इनवेंटरी और दस्तावेजीकरण

1. सभी सूचना आस्तियों की एक समग्र इनवेंटरी बनाए रखी जाएगी।
2. पहचान-योग्य सूचना आस्ति के निर्माण के लिए प्रत्येक आस्ति की अलग-अलग और (यदि उपयुक्त हो तो) अन्य आस्तियों के साथ संयुक्त रूप से पहचान की जाएगी।
3. आस्ति इनवेंटरी में सभी आवश्यक सूचनाओं को शामिल किया जाएगा ताकि आपदा की स्थिति में उन्हें वापस प्राप्त किया जा सके।
4. सूचना आस्ति इनवेंटरी में कम-से-कम निम्नलिखित जानकारीयाँ होंगी:

- पहचान
- विवरण
- स्थान
- स्वामित्व
- अभिरक्षक
- आस्ति का व्यवसाय मूल्य
- आस्ति वर्गीकरण
- वर्गीकरण की वैधता
- आस्ति सहयोग की जानकारी
- हार्डवेयर आस्ति – वार्षिक रखरखाव संविदा का विवरण
- सॉफ्टवेयर आस्ति – सॉफ्टवेयर लाइसेन्स का विवरण
- भौतिक आस्तियाँ (दस्तावेज़) – संग्रह/ भंडारण व्यवस्था

5. पूरे संगठन में व्यवसाय प्रणालियों पर सम्पूर्ण सॉफ्टवेयर के दस्तावेजीकरण को स्वचालित बनाने के लिए सॉफ्टवेयर इनवेंटरी टूल्स का इस्तेमाल किया जाएगा।
6. सॉफ्टवेयर के विक्रेता द्वारा समर्थित सॉफ्टवेयर एप्लिकेशनों या परिचालन प्रणालियों को संगठन की प्राधिकृत इनवेंटरी में शामिल किया जाएगा और जो

सॉफ्टवेयर समर्थित नहीं हैं उन्हें इनवेंटरी प्रणाली में अ-समर्थित सॉफ्टवेयर के रूप में जोड़ा जाएगा।

7. आस्ति इनवेंटरी सही-सही, अद्यतन और अन्य इन्वेंटरीज़ के साथ संगत तथा उनके अनुरूप होगी।
8. संगठन प्रत्येक आस्ति के लिए सर्विस कम्पोनेंट और अन्य मदें (कन्फ़िगरेशन मदें) निर्धारित करेगा जो एक या अधिक आईटी सेवाओं को डेलीवर या सपोर्ट करने के लिए आवश्यक होंगी।
9. कन्फ़िगरेशन मदें इस प्रकार समूहीकृत, वर्गीकृत और चिह्नित की जाएँगी जिससे वे अपने सेवाकाल के पूरे चक्र के दौरान प्रबंधित और ट्रेस की जाने योग्य रहें।
10. कन्फ़िगरेशन मदों में ऑर्डर देने से लेकर उनके मूल्यहास तक उन्हें ट्रैक करने की पद्धतियों को शामिल किया जाएगा। डाटा में परिवर्तन को यह सुनिश्चित करने के उद्देश्य से नियंत्रित रखा जाएगा कि कोई भी परिवर्तन प्राधिकृत व्यक्ति द्वारा ही किया जाना संभव हो।
11. कन्फ़िगरेशन मदों के रखरखाव की स्थिति को नियमित रूप से अभिलेखित किया जाएगा और अद्यतन रखा जाएगा।
12. संगठन की कन्फ़िगरेशन मदों को कन्फ़िगरेशन प्रबंधन डाटाबेस में सूचीबद्ध किया जाएगा जिसमें प्रत्येक कन्फ़िगरेशन मद के सभी संगत विवरण और कन्फ़िगरेशन मदों के बीच के महत्वपूर्ण सम्बन्धों के विवरण होंगे।

3.2.2.3

प्राधिकार इनवेंटरी

1. आस्ति इनवेंटरी में सभी सूचना आस्तियों के लिए विहित प्राधिकार तंत्र का विवरण होगा।
2. संगठन के स्वामित्व वाली आस्तियों के लिए प्राधिकार अभिलेख में सूचना के स्वामी के साथ-साथ उस आस्ति की विशेषताओं का विवरण भी होगा जिसका उपयोग उन आस्तियों को संगठन के नेटवर्क के साथ प्राधिकार देने के लिए किया जाएगा जैसे नेटवर्क इंटरफ़ेस मीडिया एक्सेस कंट्रोल (एमएसी) एड्रेस या आईएमईआई नंबर।
3. संगठन के स्वामित्व से इतर की आस्तियों के मामले में प्राधिकार अभिलेख में द्वि-कारकीय प्राधिकार के लिए उपयोग में लाए जाने वाले मानदंडों को शामिल किया जाएगा जैसे यूजरनेम और पासवर्ड, टोकेन आईडी या बायोमीट्रिक अभिलेख।

3.2.3

आस्ति उपयोग

1. संगठन की समग्र आस्तियों का उपयोग सामान्य दिशानिर्देशों के खंड 1.7 में शामिल आस्तियों के 'स्वीकार्य उपयोग' के अनुसार किया जाएगा।
2. संगठन की आस्तियों का उपयोग प्राधिकृत कार्मिकों द्वारा केवल वैध व्यवसाय प्रयोजनों के लिए किया जाएगा और उन्हें हर समय, जब वे उपयोग में न हों तब भी, भौतिक रूप से सुरक्षित रीति से भंडारित किया जाएगा।
3. प्रयोक्ताओं के बीच उनके कार्यों/ व्यवसाय आवश्यकताओं के आधार पर आस्तियों का आबंटन किया जाएगा। आईटी/ प्रशासनिक टीम ऐसे आबंटनों का अभिलेख रखेगी।
4. संगठन के प्रयोक्ताओं के बीच आस्तियों का अंतरण किया जाएगा लेकिन इसके लिए एक औपचारिक कार्यविधि अपनाई जाएगी। ऐसे अंतरणों के लिए एक रजिस्टर रखा जाएगा जिसे आईटी/ प्रशासनिक टीम अद्यतन रखेगी।
5. स्वामित्वाधीन और उपयोग की जाने वाली आस्तियों तथा उन आस्तियों पर की गई गतिविधियों का दायित्व अंतिम प्रयोक्ता (एंड यूजर), आस्तियों के प्रत्येक प्रयोक्ता और उद्यम की आस्तियों के स्वामियों का होगा।

6. परामर्शदाता/ अस्थायी स्टाफ/ तृतीय पक्ष विक्रेता को सौंपी गई आस्तियों को उनके साथ प्राथमिक प्रयोक्ता के रूप में और संगठन के एक कर्मचारी को द्वितीयक प्रयोक्ता के रूप में लिंक किया जाएगा। तथापि, प्राथमिक प्रयोक्ता की गतिविधियों के अनुप्रवर्तन का दायित्व द्वितीयक प्रयोक्ता का होगा।
7. संगठन के विश्वसनीय नेटवर्क से जुड़ने वाली हार्डवेयर आस्ति को अधिप्रमाणित करने के लिए बीमा कंपनियाँ क्लायंट प्रमाणपत्रों का उपयोग करेंगी।
8. नेटवर्क में अधिप्रमाणित कर सकने वाले उपकरणों पर नियंत्रण के लिए 802.1x मानकों का अनुसरण करते हुए पोर्ट स्तरीय पहुँच नियंत्रण का उपयोग किया जाएगा।
9. अधिप्रमाणन प्रणाली को हार्डवेयर आस्ति इनवेंटरी डाटा के साथ जोड़ा जाएगा ताकि यह सुनिश्चित किया जा सके कि केवल प्राधिकृत उपकरण ही नेटवर्क से जुड़ पाएँ।
10. चोरी होने, विनष्ट होने और/ या दुरुपयोग की जोखिम को न्यूनतम करने के लिए आस्तियों के सभी स्वामी/ प्रयोक्ता/ अभिरक्षक अच्छी निर्णय क्षमता का प्रयोग करेंगे और अपने द्वारा उपयोग की जा रही/ अपनी अभिरक्षा में स्थित सभी आस्तियों तथा उनमें निहित सूचनाओं की रक्षा करेंगे।
11. आस्तियों को बिना उपयुक्त प्राधिकार के संगठन के परिसर के बाहर नहीं ले जाया जाएगा। जब भी मरम्मत/ बदलने के लिए किसी आस्ति को संगठन के परिसर के बाहर ले जाना आवश्यक होगा तो सम्पूर्ण डाटा को सुरक्षित रीति से हटाना सुनिश्चित करने के बाद एतदर्थ उपयुक्त प्राधिकार प्राप्त किया जाएगा।
12. जिन कर्मचारियों के पास कंपनी द्वारा उपलब्ध कराए गए मोबाइल उपकरण जैसे लैपटॉप, टैबलेट, स्मार्ट फोन होंगे, उन्हें ऐसी आस्तियों को कार्यालय परिसर से बाहर ले जाने का प्राधिकार होगा।
13. आईटी आस्तियों को इस नीति के 'सूचना प्रणालियों का अधिग्रहण और विकास खंड - 3.1.1.1' में निर्धारित हार्डनिंग दिशानिर्देशों के अनुसार हार्डन किया जाएगा।
14. जिन आस्तियों के आवधिक रखरखाव की आवश्यकता होती है, उन सभी को उपयुक्त वार्षिक रखरखाव (अनुरक्षण) संविदाओं (एएमसी) में शामिल किया जाएगा जिसे नवीकृत किया जाएगा और हर समय प्रवर्तमान रखा जाएगा।
15. रखरखाव के प्रयोजन से परिसर के बाहर ले जाई जाने वाली भौतिक आस्तियों का गेट पास से मिलान किया जाएगा।
16. भौतिक आस्तियों/ हार्डवेयर को आस्ति रखरखाव वेंडरों के पास भेजने के लिए संगठन के परिसर से बाहर ले जाने के पहले आईटी टीम यह सुनिश्चित करेगी कि या तो भीतर का हार्ड ड्राइव निकाल लिया गया है और उसे सुरक्षित रखा गया है या डाटा का बैक-अप ले लिया गया है और डाटा को हार्ड ड्राइव से हटा दिया गया है।

3.2.4

आस्तियों की वापसी

1. सभी कर्मचारी और बाहरी प्रयोक्ता अपने नियोजन या संबन्धित संविदा या करार के समाप्त होने पर संगठन की अपने पास रखी सारी आस्तियों को वापस लौटा देंगे।
2. समापन की प्रक्रिया को एक औपचारिक रूप दिया जाएगा जिसमें संगठन के स्वामित्व या संगठन में न्यस्त उन सभी भौतिक और इलेक्ट्रॉनिक आस्तियों को वापस लौटाने को शामिल किया जाएगा जो उन्हें पहले निर्गत की गई हों।
3. आस्तियों की प्राप्ति और पहुँच को निष्क्रिय कर देने के बाद कार्यमुक्ति के लिए अनापत्ति उपलब्ध कराई जाएगी।

3.2.5

भौतिक मीडिया का अंतरण

1. मार्ग में रहने के दौरान महत्वपूर्ण व्यवसाय सूचना आस्तियों के अप्राधिकृत प्रकटन/ प्रसार को रोकने के लिए संबन्धित अभिरक्षक निम्नलिखित को सत्यापित करते हुए सुनिश्चित करेगा कि:

- भौतिक मीडिया की सत्यनिष्ठा और गोपनीयता सुनिश्चित करने के लिए विश्वसनीय परिवहन और नियंत्रण व्यवस्था है।
 - प्रबंधन की सहमति से प्राधिकृत कूरियरों की एक सूची तैयार है।
 - भेजी जाने वाली वस्तु को भौतिक क्षति से बचाने के लिए पैकेजिंग पर्याप्त है।
 - मीडिया के संवाहक सभी कर्मचारियों और तृतीय पक्ष स्टाफ से यह अपेक्षित है कि वे मार्ग में चोरी, खराब मौसम और किसी प्रकार की क्षति से मीडिया को बचा कर रखें।
 - मीडिया में निहित वस्तु की पहचान, अपनाए गए संरक्षण और मार्गस्थ अभिरक्षकों और गंतव्य पर उसकी प्राप्ति के समय-बिन्दुओं का लॉग (विवरण) रखा जाएगा।
2. सूचना आस्तियों के स्वामी अपने स्वामित्व में स्थित सभी आस्तियों पर विनिर्दिष्ट सुरक्षा नियंत्रणों का कार्यान्वयन सुनिश्चित करने के लिए जिम्मेदार होंगे।

3.2.6

आस्ति निपटान

1. महत्वपूर्ण और संवेदनशील सूचना रखने वाली सभी आस्तियों और मीडिया का निपटान उनको भस्मीभूत कर, या कतर कर या संगठन के भीतर ही अन्य एप्लिकेशनों द्वारा उपयोग के लिए डाटा को मिटाकर किया जाएगा।
2. आस्तियों का निपटान निम्नलिखित स्थितियों में किया जाएगा:
 - आदि आस्ति के जीवनचक्र का अंत हो गया हो।
 - यदि आस्ति पर्यावरण के लिए अनुपयुक्त हो गई हो।
3. जिन महत्वपूर्ण अवसंरचनागत तत्वों का निपटान करना आवश्यक हो गया हो उनके निपटान का अनुमोदन वैध कारण देते हुए सीटीओ और सीएफओ द्वारा किया जाएगा।
4. जब भी किसी आस्ति का निपटान किया जाएगा तब वित्त विभाग को भी सूचित किया जाएगा।
5. किसी भी उपकरण के निपटान के पहले आस्ति में निहित सूचना को मिटाने / निपटान के लिए प्रबंधन द्वारा अनुमोदित तकनीक का प्रयोग करते हुए हटाया जाएगा।
6. निपटाई गई/ स्क्रैप की गई सभी आस्तियों के लिए एक रजिस्टर रखा जाएगा।
7. मीडिया फॉर्मेटिंग के लिए एक प्रक्रिया स्थापित की जाएगी।
8. संवेदनशील डाटा रखने वाली आस्तियों के क्षतिग्रस्त हो जाने की स्थिति में यह निर्धारित करने के लिए जोखिम आकलन आवश्यक होगा कि क्या उन मर्दों को मरम्मत के लिए भेजने या छोड़ देने की अपेक्षा उन्हें भौतिक रूप से नष्ट कर देना बेहतर होगा।

3.2.7

रिमूव करने योग्य मीडिया का प्रबंधन

1. आस्ति अभिरक्षक यह सुनिश्चित करेगा कि मीडिया को भौतिक रूप से सुरक्षित रखा जाए ताकि व्यवसाय गतिविधियों में अवरोध उत्पन्न न हो और महत्वपूर्ण व्यवसाय सूचना आस्तियों को क्षति न पहुँचे।
2. मीडिया को सुरक्षित पर्यावरण में भंडारित किया जाएगा।
3. सभी कार्यालयीन मीडिया को सूचीबद्ध किया जाएगा, उनका रखरखाव किया जाएगा और नियमित आधार पर उनकी समीक्षा की जाएगी।
4. संगठन से संबंधित सूचनाएँ रखने वाले सम्पूर्ण भौतिक मीडिया के सक्रिय उपयोग के दौरान उनका कड़ाई से अनुप्रवर्तन किया जाएगा और जब उनकी आवश्यकता नहीं रहेगी तब उनका निपटान आस्ति प्रबंधन कार्यनीति का अनुसरण करते हुए कर दिया जाएगा।

5. संगठन से हटाए जाने वाले मीडिया के लिए प्राधिकार आवश्यक होगा और हटाए जाने का अभिलेख रखा जाएगा ताकि लेखापरीक्षा के लिए आवश्यक ट्रेल रखा जा सके।
6. गोपनीय डाटा के मामले में रिमूव किए जा सकने वाले मीडिया में रखे डाटा के संरक्षण के लिए क्रिप्टोग्राफिक तकनीकों का प्रयोग किया जाएगा।

3.3 आस्ति का खो जाना/ चोरी

1. संगठन की सूचना आस्तियों तक पहुँच रखने वाले व्यक्तिगत उपकरणों के खो जाने/ चोरी हो जाने की स्थिति में कर्मचारी तत्काल इसकी रिपोर्ट करेगा।
2. आईटी कार्य का यह दायित्व होगा कि वह उस उपकरण के माध्यम से संगठन की सूचना आस्तियों तक पहुँच को तत्काल वापस ले ले और यह प्रयास करेगा कि दूर से ही उस उपकरण में रखे गए संगठन के डाटा को हटा दे।
3. यदि उपकरण के खो जाने/ चोरी हो जाने की रिपोर्ट 4 घंटे से अधिक समय हो जाने के बाद दी जाए तो इसे एक घटना के रूप में रिपोर्ट किया जाएगा और इस नीति में उल्लिखित घटना प्रबंधन कार्यविधियाँ अपनाई जाएँगी।

3.4 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आस्ति का स्वामी	आईटी, प्रशासन, सभी संबंधित कार्य	सीआई एसओ	सभी संबंधित कार्य, जोखिम, वित्त, प्रशासन

नीति सं. : नीति का नाम:	2.3 2.3. पहुँच नियंत्रण
----------------------------	----------------------------

1 प्रयोजन

संगठन की सूचनाओं और सूचना प्रणालियों (परिचालन प्रणालियाँ, एप्लिकेशन, डाटाबेस, नेटवर्क उपकरण और अन्य) तक पहुँच के लिए पद्धतियों का एक समुच्चय उपलब्ध कराना।

संगठन की सूचनाओं और सूचना प्रणालियों से संबंधित पहुँच नियंत्रण 'प्रयोक्ता को प्राधिकृत करने' और 'उत्तरदायित्व' के सिद्धांतों पर आधारित होंगे और 'न्यूनतम विशेषाधिकार पहुँच', 'जिनके लिए जानना आवश्यक है, केवल उन्हीं की पहुँच (नीड टु नो)', 'कर्तव्यों के पृथक्करण' और 'व्यक्तिगत उत्तरदायित्व' जैसी सुरक्षा संबंधी अवधारणाओं को बल देने वाले होंगे।

यह नीति उन सभी पर्यावरणों पर लागू होगी जिनमें सूचना आस्तियों तक तार्किक पहुँच आवश्यक है। इन सूचना आस्तियों में सूचना के भंडारण और प्रसंस्करण की प्रणालियाँ और वे संचार तथा नेटवर्क कनेक्शन आते हैं जिनके माध्यम से सूचना संप्रेषित की जाती है, और साथ ही वे एप्लिकेशन भी आते हैं जिनके माध्यम से सूचना तक पहुँच स्थापित की जाती है।

संचार तथा नेटवर्क कनेक्शन में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं; प्रणालियों में भंडारण टेप या ड्राइव, डाटाबेस तथा एप्लिकेशन शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।

अप्राधिकृत पहुँच से सूचना आस्तियों के संरक्षण के लिए भौतिक और तार्किक पहुँच नियंत्रणों को कार्यान्वित किया जाएगा और उनका समुचित रखरखाव किया जाएगा।

यह नीति संगठन की सूचना आस्तियों तक पहुँच बनाने वाले सभी प्रयोक्ताओं, जैसे कर्मचारियों, संविदाकर्ताओं, सेवाप्रदाताओं / आगंतुकों पर लागू होगा।

3 नीति

संगठन की सभी सूचना आस्तियों तक सभी प्रयोक्ताओं की पहुँच को व्यवसाय आवश्यकता के आधार पर विशिष्ट रूप से और अलग-अलग प्राधिकृत किया जाएगा। सुरक्षा नियंत्रण सुनिश्चित करेंगे कि केवल प्राधिकृत व्यक्ति ही संगठन की सूचना आस्तियों तक पहुँच सकेंगे।

प्रत्येक प्रणाली को अप्राधिकृत पहुँच, आशोधन, प्रकटन या नष्ट होने से बचाने के लिए उपयुक्त स्तर का पहुँच नियंत्रण सुनिश्चित करने के लिए कार्यविधियों को कार्यान्वित किया जाएगा ताकि यह सुनिश्चित किया जा सके कि सूचना की परिशुद्धता और गोपनीयता बनी रहे तथा वह आवश्यकतानुसार उपलब्ध हो पाए। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 प्रयोक्ता पहचान और खाते

1. सूचना आस्ति तक निर्धारित स्तर की पहुँच को प्राधिकृत करने के लिए प्रत्येक व्यक्ति को एक यूजर आईडी या खाता दिया जाएगा और जैसे ही पहुँच का अनुरोध प्राप्त होगा, यूजर आईडी से प्रयोक्ता को अधिप्रमाणित कर उसका संरक्षण किया जाएगा।
2. संगठन की सूचना प्रणालियों पर प्रत्येक यूजर आईडी या खाता केवल एक प्रयोक्ता अथवा प्रक्रिया की सर्वथा भिन्न पहचान करेगा। प्रत्येक एकल प्रयोक्ता अपने यूजर आईडी से जुड़े समस्त कार्यों के लिए उत्तरदायी होगा। जिसे यूजर आईडी दी गई है वही उसका प्रयोग करेगा, अन्य कोई नहीं। कोई भी प्रयोक्ता अपने यूजर आईडी का प्रयोग किसी भी अन्य व्यक्ति के द्वारा किए जाने की अनुमति नहीं देगा। इसी प्रकार, किसी प्रयोक्ता के द्वारा किसी अन्य के यूजर आईडी का प्रयोग कर कोई गतिविधि करना निषिद्ध होगा।
3. जहाँ प्रौद्योगिकी की सीमाओं, या प्रक्रिया के डिजाइन के कारण प्रत्येक व्यक्ति के लिए अलग-अलग आईडी और पासवर्ड का कार्यान्वयन संभव न हो, वहाँ पहुँच के विशेष अधिकार को सीमित करने और उनकी लेखापरीक्षा करने के लिए वैकल्पिक समाधानों की व्यवहार्यता का मूल्यांकन किया जाएगा और तदनुसार उन्हें कार्यान्वित किया जाएगा।

**3.2 सामूहिक/
सामान्य यूजर
आईडी**

1. जहाँ भी संभव हो सामान्य और सामूहिक यूजर आईडी के उपयोग से बचा जाएगा। जहाँ कोई विकल्प उपलब्ध न हो या जहाँ परमावश्यक हो जाए, वहाँ सामूहिक खाते का उपयोग किया जा सकता है; लेकिन ऐसे मामले में उपयुक्त प्राधिकारियों से पूर्व-प्राधिकार प्राप्त करने की अपेक्षा रखने वाली अपवाद अनुमति तथा जोखिम आकलन पद्धति का अनुसरण किया जाएगा और एक व्यक्ति (सामूहिक आईडी का स्वामी) का स्पष्ट उत्तरदायित्व स्थापित किया जाएगा। सामूहिक आईडी का उपयोग अल्पकालिक प्रकृति का होगा जिसके समाप्त होने की तारीख पूर्व-निर्धारित होगी।
2. प्रौद्योगिकीय सीमाओं के कारण आवश्यक हो जाने आता व्यवसायगत आकस्मिक आवश्यकता की स्थितियों को छोड़कर सामान्य यूजर आईडी नहीं बनाए जाएँगे। प्रत्येक सामान्य यूजर आईडी के लिए एक स्वामी की पहचान की जाएगी और उसे उस सामान्य यूजर आईडी से जुड़े सभी कार्यों के लिए उत्तरदायी ठहराया जाएगा। जहाँ किसी एक यूजर आईडी को अनेक व्यक्तियों के बीच साझा करने की आवश्यकता हो, वहाँ उत्तरदायित्व देने और सब समय उसे निश्चित करने के लिए वैकल्पिक समाधानों की व्यवहार्यता का मूल्यांकन किया जाएगा और तदनुसार उन्हें लागू किया जाएगा।

**3.3 यूजर आईडी
बनाना और
उसका
रखरखाव**

1. यूजर आईडी अ-हस्तांतरणीय होगा और एक कम्प्यूटिंग पर्यावरण में किसी व्यक्ति का एक से अधिक खाता नहीं होगा।
2. नेटवर्क जैसे संगठन पर्यावरण तक पहुँच की अनुमति मानव संसाधन (एचआर) से इस आशय की सूचना प्राप्त होने के बाद ही दी जाएगी। सभी उपयोक्तृताओं को सूचना प्रणालियों और सेवाओं तक एक औपचारिक प्रयोक्ता रजिस्ट्रेशन प्रक्रिया के माध्यम से पहुँच की अनुमति दी जाएगी जिस प्रक्रिया के अंतर्गत पहुँच की अनुमति देने के पहले प्राधिकृत कार्मिक से पहुँच के अधिकार का अनुमोदन प्राप्त करना शामिल होगा।
3. सभी प्रयोक्ता सभी सूचना प्रणालियों और सेवाओं तक अपनी पहुँच को प्रतिसंहत करने के लिए अपने रजिस्ट्रेशन को समाप्त करने की औपचारिक प्रक्रिया का अनुसरण करेंगे जिसमें स्वचालित या सही समय पर सूचित करना और पहुँच के अधिकारों का प्रतिसंहरण शामिल होगा। पहुँच के अधिकारों के प्रतिसंहरण की सूचना एचआर से प्राप्त होगी। निकास/ बहिर्गमन अनापत्ति प्रक्रिया के एक भाग के रूप में पहुँच के प्रतिसंहरण की पुष्टि एचआर को भेजी जाएगी।
4. सभी प्रयोक्ताओं को अनुमत पहुँच के स्तरों के माध्यम से कर्तव्यों के पृथक्करण को लागू किया जाएगा और केवल जानने की आवश्यकता के अनुसार सूचना तक पहुँच के सिद्धान्त का पालन किया जाएगा। जहाँ तार्किक पहुँच नियंत्रणों के माध्यम से कर्तव्यों के पृथक्करण को लागू नहीं किया सकता वहाँ आईटी से इतर नियंत्रणों का कार्यान्वयन किया जाएगा।
5. प्रयोक्ता बनाने की प्रक्रिया के दौरान प्रयोक्ताओं को सुरक्षित तरीके से एक आरंभिक पासवर्ड उपलब्ध कराया जाएगा और प्रणाली को इस प्रकार कन्फ़िगर किया जाएगा जिससे प्रयोक्ता पहली बार लॉग-ऑन करने के तत्काल बाद आरंभिक पासवर्ड को बदलने के लिए बाध्य हो जाएँ।

6. महत्वपूर्ण सूचना प्रणालियों के प्रशासनिक पासवर्ड्स के भंडारण और प्रबंधन के लिए उपयुक्त कार्यविधियाँ स्थापित की जाएंगी। सम्प्रेषण और भंडारण के दौरान सभी प्रयोक्ता पासवर्ड्स एन्क्रिप्टेड रूप में होंगे।
7. सभी प्रयोक्ता खातों के लिए पासवर्ड संबंधी अपेक्षाएँ पासवर्ड मानक में यथापरिभाषित पासवर्ड मानकों के अनुरूप होंगी। पासवर्ड मानक के अपवाद की स्थिति में उपयुक्त प्राधिकारियों से पूर्व-प्राधिकार प्राप्त करने की अपेक्षा रखने वाली अपवाद-अनुमति और जोखिम आकलन पद्धति का अनुसरण किया जाएगा तथा परिणामी जोखिम के शमन के लिए प्रतिकार के उपाय कार्यान्वित किए जाएंगे।
8. प्रयोक्ताओं को पहले लॉग-ऑन के बाद अपने पासवर्ड को बदलना होगा और फिर 45 दिनों में एक बार उसे बदलना होगा।
9. पासवर्ड के पुनः उपयोग को रोकने के लिए पहले प्रयुक्त पासवर्ड्स का अभिलेख रखा जाएगा। इसके अलावा, पासवर्ड फाइलों को एप्लिकेशन प्रणाली डाटा से अलग भंडारित किया जाएगा।
10. सभी एकल प्रयोक्ताओं और प्रयोक्ता समूहों के संबंधित विभागाध्यक्ष अपनी प्रणाली तक पहुँच के लिए प्रदत्त अधिकारों और विशेषाधिकारों की आवधिक समीक्षा करेंगे। यदि कोई अपवाद दिखाई दे उसका शीघ्रातिशीघ्र निवारण किया जाएगा।
11. विभागाध्यक्ष सूचना प्रणालियों और सेवाओं तक पहुँच बनाने के लिए यूजर आईडी को प्रदत्त अधिकारों का एक केंद्रीय अभिलेख रखेगा।
12. एक कार्य विभाग से दूसरे कार्य विभाग में किसी कर्मचारी के स्थानांतरण के मामले में पूर्व विभाग की भूमिका के लिए प्रदत्त पहुँच के अधिकार को प्रतिसंहत कर लिया जाएगा और नई भूमिका के लिए पहुँच का अधिकार देने की आवश्यकता होगी।

3.4 प्रयोक्ता को प्राधिकृत करना

1. प्रयोक्ताओं को निम्नलिखित स्तरों पर संगठन की सूचना प्रणालियों के लिए प्राधिकृत किया जाएगा:
 - भौतिक पहुँच
 - नेटवर्क
 - अवसंरचना
 - अंतिम बिन्दु
 - एप्लिकेशन
 - क्लाउड (जहाँ लागू हो)
2. प्रत्येक स्तर पर प्रयोक्ता को प्राधिकृत करने का तंत्र उसके पहले या बाद के स्तर पर प्राधिकृत करने से स्वतंत्र होगा। उदाहरण के लिए, एप्लिकेशनों के लिए प्रयोक्ता को प्राधिकृत करने का आकलन परिचालन प्रणाली के लिए किए जाने वाले आकलन से स्वतंत्र होगा।
3. प्रयोक्ताओं को एक डोमेन पॉलिसी सर्वर द्वारा अधिप्रमाणित और प्राधिकृत किया जाएगा।
4. प्रबंधन और कर्मचारी सभी सुविधाओं तक पहुँच के नियंत्रण और यह सुनिश्चित करने के लिए उत्तरदायी होंगे कि उन सुविधाओं में प्रवेश करने वाले या पहुँच बनाने वाले लोगों की समुचित पहचान की जाती है और उन्हें प्राधिकृत किया जाता है।
5. संगठन में सभी नेटवर्क और नेटवर्क सेवाओं की पहचान की जाएगी और उन्हें दस्तावेजीकृत किया जाएगा। सभी नेटवर्क उपकरणों तक तार्किक

पहुँच केवल प्राधिकृत प्रयोक्ताओं तक सीमित होगी। संगठन की आईटी प्रणालियों तक पहुँच को सीमित करने के लिए उपयुक्त सुरक्षा नियंत्रणों का प्रयोग किया जाएगा।

6. सभी अंतिम बिन्दुओं और एप्लिकेशनों तक पहुँच की अनुमति मेजबान की परिचालन प्रणाली या स्वयं एप्लिकेशन द्वारा प्रयोक्ता की पहचान के प्रमाणों को प्राधिकृत करने के बाद ही दी जाएगी।
7. एप्लिकेशन, उद्यम पहचान प्रबंधन प्रणाली के साथ एकीकरण के अनुकूल होंगे।
8. यदि प्राधिकृत करने का अनुरोध संगठन के स्वामित्व में स्थित आस्ति (उपकरण/ नेटवर्क) से प्राप्त होता है, तो एक कारक वाला अधिप्रमाणन ही पर्याप्त होगा। यदि प्राधिकृत करने का अनुरोध ऐसी आस्ति (उपकरण/ नेटवर्क) से प्राप्त होता है, जो संगठन के स्वामित्व में स्थित नहीं है तो दो कारकों वाला अधिप्रमाणन अनिवार्य होगा।
9. क्लाउड पर होस्ट किए जाने एप्लिकेशन या तो संगठन के स्वामित्व में स्थित प्राधिकार प्रदान सेवा द्वारा वैधकृत प्रयोक्ता प्राधिकार अभिलेख को स्वीकार करेंगे या फिर उनके लिए ऊपर (6) में वर्णित द्विकारकीय प्राधिकार की आवश्यकता होगी।
10. पहुँच संबंधी अपेक्षाओं की पहचान व्यवसाय के स्वामी द्वारा की जाएगी।
11. संबंधित व्यवसाय प्रमुख यह सुनिश्चित करेंगे कि अनुमत पहुँच का स्तर संगठन के प्रयोजन की दृष्टि से उपयुक्त है।
12. प्रयोक्ताओं के लिए यह अनिवार्य होगा कि वे कोई गतिविधि न करने की एक निर्दिष्ट अवधि के बाद स्वयं को पुनः अधिप्रमाणित करें।
13. संगठन द्वारा आपात स्थिति पर आधारित पहुँच की अनुमति की प्रक्रिया की स्थापना की जाएगी।
14. व्यक्तिगत फाइलों और विभाग की साझा फाइलों तक अन्य समूहों की अप्राधिकृत पहुँच को रोकने की पद्धतियाँ संगठन द्वारा स्थापित की जाएँगी।

3.5 विशेषाधिकार-प्राप्त प्रयोक्ता खाते

1. एप्लिकेशनों, परिचालन प्रणालियों, नेटवर्क उपकरणों, डाटाबेस घटकों और अन्य सूचना प्रणालियों तक प्रशासनिक पहुँच वाले वे खाते विशेषाधिकार-प्राप्त खाते हैं जो प्रयोक्ता को मेटाडाटा सहित प्रणालीगत कन्फिगरेशनों, प्रयोक्ता अभिलेखों और अन्य कार्यों के आशोधन में समर्थ बनाते हैं और प्रणाली के भीतर जिन सुरक्षा और नियंत्रणों पर प्रशासनिक पहुँच लागू होती है उनपर अधिभावी होते हैं। विशेषाधिकार-प्राप्त खाते में प्रणाली के डिफॉल्ट प्रशासन खाते, 'एडमिनिस्ट्रेटर' या 'रूट' या समतुल्य परिचालन प्रणाली खाते या यूजर आईडी शामिल हैं जो अन्य यूजर आईडी या उसके विशेषाधिकारों या पहुँच के लॉग को सृजित करने, अशोधित करने या मिटा देने में समर्थ होते हैं, लेकिन ऐसे खाते इन्हीं तक सीमित नहीं हैं।
2. परिचालन प्रणाली, व्यवसाय एप्लिकेशन, डाटाबेस, और नेटवर्क घटक जैसी प्रत्येक प्रकार की सूचना प्रणाली से संबंधित विशेषाधिकारों की पहचान की जाएगी और उन्हें दस्तावेजीकृत किया जाएगा।
3. विशेषाधिकार-प्राप्त प्रयोक्ता खाते उस स्तर की पहुँच के लिए निर्दिष्ट व्यवसाय औचित्य वाले व्यक्तियों तक सीमित होंगे। ऐसी पहुँच की अनुमति उपयुक्त कार्मिकों से प्राधिकार प्राप्त करने के बाद ही दी जाएगी।

4. विशेषाधिकार उन्हीं व्यक्तियों को, विशेष पहुँच प्राधिकृत करने के लिए विहित प्रक्रिया का कड़ाई से पालन करते हुए आबंटित किए जाएँगे जिन्हें उन्हें रखने की आवश्यकता होगी।
5. जिन व्यक्तियों को इस स्तर की पहुँच की अनुमति दी जाएगी उनके पास अनुमत विशेषाधिकार से संबंधित प्रणाली के लिए सुरक्षा अथवा प्रशासनिक कर्तव्यों के निष्पादन के लिए उपयुक्त स्तर का कौशल होगा।
6. जहाँ तक संभव हो, विशेषाधिकार-प्राप्त यूजर आईडी का न्यूनतम उपयोग किया जाएगा। विशेषाधिकार-प्राप्त यूजर आईडी के सभी लॉग-ऑन से की जाने वाली गतिविधियों का सुरक्षित लॉग रखा जाएगा। विशेषाधिकार-प्राप्त यूजर आईडी की लॉगिंग और अनुप्रवर्तन पर आगे और जानकारी के लिए कृपया 2.16 अनुप्रवर्तन, लॉगिंग और आकलन को संदर्भित करें।
7. जहाँ भी संभव हो, विशेषाधिकार-प्राप्त गतिविधियों और दैनंदिन गतिविधियों के लिए प्रणालियों पर लॉग-ऑन करने हेतु अलग-अलग तंत्र उपलब्ध कराया जाएगा। जहाँ अलग-अलग तंत्र उपलब्ध कराया गया हो, विशेषाधिकार-प्राप्त यूजर आईडी वाला व्यक्ति विशेषाधिकार वाले पर्यावरण से पहले लॉग-आउट करेगा और उसके बाद उन दैनंदिन कार्यों का निष्पादन करेगा जिनके लिए विशेषाधिकार-प्राप्त पहुँच की आवश्यकता नहीं है।
8. विशेषाधिकार-प्राप्त प्रयोक्ताओं द्वारा की गई प्रणालीगत गतिविधियों का लेखापरीक्षा लॉग रखा जाएगा। लॉग की लेखापरीक्षा या प्रबंधन समीक्षा की जाएगी।
9. विशेषाधिकार-प्राप्त आईडी और उनके पहुँच कोड को साझा करना निषिद्ध होगा।
10. गहन पर्यवेक्षण और निगरानी के बिना विक्रेताओं और संविदाकर्ताओं को प्रणाली तक विशेषाधिकार वाली पहुँच की अनुमति नहीं होगी। इस प्रकार की पहुँच के लिए व्यवसायगत औचित्य का दस्तावेजीकरण किया जाएगा।
11. प्राधिकार देने की प्रक्रिया और सभी आबंटित विशेषाधिकारों का अभिलेख रखा जाएगा।
12. प्रयोक्ताओं द्वारा सॉफ्टवेयर इंस्टाल करने का संचालन करने वाले नियमों की स्थापना की जाएगी और उनका कार्यान्वयन किया जाएगा।

3.6 सुरक्षित लॉग-ऑन

1. लॉग-ऑन प्रक्रिया कोई ऐसी जानकारी नहीं उपलब्ध कराएगी जिससे किसी अप्राधिकृत प्रयोक्ता को सफलतापूर्वक लॉग-ऑन करने में सहयोग मिले।
2. लॉग-ऑन डाटा का वैधकरण तभी होगा जब सम्पूर्ण डाटा एंटर कर दिया जाएगा।
3. लॉग-ऑन प्रक्रिया यह जानकारी प्रकट नहीं करेगी कि लॉग-ऑन डाटा का कौन-सा भाग वैध या अवैध है।
4. प्रयासों की संख्या की सीमा पूरी हो जाने के बाद लॉग-ऑन प्रक्रिया द्वारा खाता लॉक-आउट को प्रभावी कर दिया जाएगा।

5. लॉग-ऑन प्रक्रिया एक सामान्य सूचना प्रदर्शित करेगी जिसमें यह चेतावनी निहित होगी कि केवल प्राधिकृत प्रयोक्ता को ही कंप्यूटर तक पहुँच बनानी चाहिए।
6. असफल और सफल प्रयासों का लॉग रखा जाएगा।
7. लॉग-ऑन प्रक्रिया किसी नेटवर्क पर स्पष्ट पाठ के रूप में पासवर्ड्स संप्रेषित नहीं करेगी।
8. गतिविधि-शून्यता की एक निर्धारित अवधि के बाद लॉग-ऑन प्रक्रिया निष्क्रिय सत्रों को समाप्त कर देगी, विशेष रूप से उच्च जोखिम वाले स्थानों पर, जैसे कि सार्वजनिक स्थानों पर या संगठन के सुरक्षा प्रबंधन के दायरे के बाहर के क्षेत्र में या मोबाइल उपकरणों के मामले में।

3.6.1 पहुँच के अधिकारों की समीक्षा

1. प्रयोक्ता के पहुँच अधिकारों के समीक्षा नियमित अंतराल पर या कर्मचारी की पदोन्नति, पदावनति या सेवा की समाप्ति जैसे परिवर्तनों के बाद की जाएगी।
2. समान संगठन के भीतर एक भूमिका से दूसरी भूमिका में अंतरण के समय प्रयोक्ता के पहुँच अधिकारों के समीक्षा की जाएगी और उनका पुनराबंटन किया जाएगा।
3. विशेषाधिकारयुक्त पहुँच अधिकारों की समीक्षा कम अवधि के अंतराल पर की जाएगी और आवधिक समीक्षा के लिए विशेषाधिकार-प्राप्त खातों का लॉग तैयार किया जाएगा।
4. विशेषाधिकार आबंटन की, यह सुनिश्चित करने के लिए नियमित अंतराल पर जाँच की जाएगी कि अप्राधिकृत विशेषाधिकार तो प्राप्त नहीं किया गया।

3.7 दूर से (रिमोट) पहुँच

1. केवल जानने और कार्य करने की आवश्यकता के आधार पर ही कर्मचारियों / विक्रेताओं / संविदाकर्ताओं को दूर से पहुँच की सुविधा उपलब्ध कराई जाएगी।
2. तृतीय पक्ष विक्रेता/ परामर्शदाता के लिए दूर से पहुँच का अनुरोध विक्रेता/ परामर्शदाता को सेवा में लेने के लिए जिम्मेदार संगठन के कर्मचारी द्वारा इस प्रकार की पहुँच के लिए समुचित व्यवसाय औचित्य के प्रतिपादन के साथ किया जाएगा। ऐसे अनुरोध का अनुमोदन प्रायोजक कार्य प्रबन्धक, आईटी प्रमुख और समूह के सीआईएसओ द्वारा किया जाना आवश्यक है। यदि ऐसी पहुँच संगठन से इतर के अंतिम बिन्दु से उपलब्ध कराई जाती है तो इस विषय में आईटी प्रमुख और समूह के सीआईएसओ द्वारा अपवाद लिया जाएगा।
3. रिमोट एक्सेस सॉफ्टवेयर का प्रयोग प्रतिबंधित होगा।
4. किसी भी विक्रेता प्रयोक्ता या संगठन के सामान्य प्रयोक्ता को एसएसएल वीपीएन अप्लायन्स पर प्रशासनिक विशेषाधिकार नहीं दिया जाएगा। यदि तृतीय पक्ष को विशेषाधिकार-प्राप्त आईडी की आवश्यकता है, तो उनकी गतिविधियों की निगरानी की जाएगी और बीमा कंपनी के साथ उनके जुड़ाव के समाप्त होने के तत्काल बाद पहुँच को प्रतिसंहत कर लिया जाएगा।
5. सभी तृतीय पक्ष आईडी पर 15 दिन से अनधिक या उससे कम की कालबाह्यता अवधि रखी जाएगी जब तक उपयुक्त अनुमोदन नहीं दिया जाता। अधिप्रमाणन डाटाबेस में आईडी की कालबाह्यता घटित होगी। कालबाह्य होने के बाद जो पक्षकार संगठन के लिए काम करना जारी रखना चाहेंगे उन्हें यूजर आईडी को वापस प्राप्त करने के लिए अनुमोदन प्राप्त करना चाहिए।

6. दूर से पहुँच के समाधानों का मजबूत, आद्यंत एन्क्रिप्शन के अनुकूल होना अनिवार्य है जैसा कि क्रिप्टोग्राफिक नियंत्रणों के लिए संगठन की नीति में उल्लिखित है।
7. दूर से लॉग-ऑन के लिए एक कार्यविधि तैयार की जाएगी जिसमें सम्प्रेषण के दौरान सूचना के एन्क्रिप्शन की व्यवस्था होगी। दूर से पहुँच के लिए एक सुरक्षित नेटवर्क माध्यम स्थापित किया जाएगा।
8. संगठन के सुरक्षा समाधानों को निष्क्रिय नहीं किया जाएगा और न उनसे कतरा कर निकलने का प्रयास किया जाएगा।

3.8 अनुपालन और लेखापरीक्षा

1. नीति का अनुपालन सुनिश्चित करने के लिए आवधिक लेखापरीक्षाएँ की जाएँगी।
2. दूर से पहुँच की प्रणाली के स्वामी दूर से पहुँच की अनुमति के सभी अनुरोधों का साक्ष्य रखेंगे।
3. दूर से पहुँच के प्रतिसंहरण के आरंभ के लिए अधिसूचनाएँ।
4. दूर से पहुँच की विशेष सुविधा की अनुमति, उसके प्रतिसंहरण या उनमें परिवर्तन के साक्ष्य परिवर्तन प्रबंधन प्रणाली जैसी रिपोजिटरी में रखे जाएँगे।
5. दूर से पहुँच की प्रणालियों के लिए एसओपी तथा प्रणाली डिजाइन दस्तावेज़।
6. दूर से पहुँच की प्रणाली के कन्फिगरेशन में सभी परिवर्तन।
7. दूर से पहुँच की प्रणालियों पर किए गए पैच उन्नयन।
8. प्रणाली के स्वामी मासिक आधार पर यह सुनिश्चित करेंगे कि दूर से पहुँच के समाधानों के भीतर सक्रिय खाते सही हैं। सभी विसंगतियों को शीघ्रता से दूर किया जाएगा।

3.9 प्रोग्राम सोर्स कोड तक पहुँच

1. प्रोग्राम सोर्स कोड और उससे जुड़ी मदों (जैसे डिजाइन, विनिर्देश, सत्यापन योजनाएँ और वैधकरण योजनाएँ) को कड़ाई से नियंत्रित किया जाएगा ताकि अप्राधिकृत कार्यनिष्पादन क्षमता का प्रवेश रोका जा सके और अवांछित परिवर्तनों से बचने के साथ-साथ मूल्यवान बौद्धिक सम्पदा की गोपनीयता को बनाए रखा जा सके।
2. प्रोग्राम सोर्स लाइब्रेरियाँ परिचालन प्रणालियों में नहीं रखी जाएँगी। प्रोग्राम सोर्स कोड और प्रोग्राम सोर्स लाइब्रेरियों का प्रबंधन स्थापित कार्यविधियों के अनुसार किया जाएगा।
3. आईटी सहयोग कार्मिकों को प्रोग्राम सोर्स लाइब्रेरियों तक अप्रतिबंधित पहुँच नहीं दी जाएगी।
4. प्रोग्राम सोर्स लाइब्रेरियों और उससे जुड़ी मदों के अद्यतनीकरण तथा प्रोग्रामरों को प्रोग्राम सोर्स जारी करने का काम उपयुक्त प्राधिकार प्राप्त होने के बाद ही किया जाएगा।
5. प्रोग्राम सोर्स लाइब्रेरियों तक पहुँच का लेखापरीक्षा लॉग रखा जाएगा और प्रोग्राम सूचीकरण को सुरक्षित पर्यावरण में रखा जाएगा।

3.10 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी	आईएस, व्यवसाय विभाग	आईएस	जोखिम प्रबंधन

नीति सं. :	2.4	मानव संसाधन सुरक्षा	
नीति का नाम:	2.4.		
1	प्रयोजन	- मानव संसाधन सुरक्षा के संबंध में संगठन की वांछित कार्यपद्धतियों को परिभाषित करना, ताकि यह सुनिश्चित किया जा सके कि: - संगठन की सूचनाओं और उपकरणों की सुरक्षा के लिए कॉर्पोरेट संरचना के संदर्भ में मानव संसाधन कार्य अपनी आवश्यकताओं को पूरा करता है। - कर्मचारी, संविदाकर्ता और तृतीय पक्ष प्रयोक्ता सूचना सुरक्षा संबंधी खतरों और चिंताओं को लेकर जागरूक हैं, सूचना सुरक्षा के संबंध में अपने दायित्वों और कर्तव्यों को समझते हैं और अपने सामान्य कार्य निर्वहन के समय संगठन की सुरक्षा नीति के समर्थन के लिए सुसज्ज हैं। - कर्मचारियों, संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं के प्रवेश, निकास और नियोजन में परिवर्तन व्यवस्थित तरीके से संचालित होते हैं।	
2	दायरा	मानव संसाधन, संगठन की सुरक्षा संरचना का अविभाज्य अंग है। सूचना संसाधनों की सुरक्षा के लिए यह अपेक्षित है कि संगठन में समुचित प्रौद्योगिकी समर्थित नियंत्रणों के साथ जानकारी और सचेत कार्मिकों को शामिल किया जाए। यदि मानव संसाधन सुरक्षा प्रक्रियाएँ कमजोर होंगी तो सुरक्षा में सेंध, वित्तीय धोखाधड़ी, कंपनी की प्रतिष्ठा में हानि और ग्राहक की गोपनीयता भंग होने के रूप में विनियामकीय अननुपालन जैसे परिणाम होंगे। यह नीति सभी कर्मचारियों, संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं पर लागू होगी जो संगठन के सूचना प्रौद्योगिकी संसाधनों का उपयोग करेंगे। मानव संसाधन (एचआर) सुरक्षा, कार्मिक प्रबंधन का एक भाग है और यह नियोजन के पूर्व, नियोजन के दौरान और नियोजन के परिसमापन पर लागू होती है।	
3	नीति	संगठन यह सुनिश्चित करेगा कि उसके नेटवर्क को जॉइन करने वाले, उसमें विचरण करने वाले और उसे छोड़ने वाले सभी प्रयोक्ता (कर्मचारी, संविदाकर्ता और तृतीय पक्ष सेवाप्रदाता) सूचना सुरक्षा के संबंध में अपनी भूमिकाओं और दायित्वों के प्रति सचेत होंगे। संगठन की मानव संसाधन कार्यपद्धतियाँ सब समय अर्थात् नियोजन के पूर्व, ऑनबोर्डिंग के समय, नियोजन अवधि के दौरान और संगठन से निकलते समय, संगठन के सूचना सुरक्षा उद्देश्यों के लिए सहयोगी होंगी। इस नीति का लक्ष्य है सूचना और नेटवर्क आस्तियों/ सुविधाओं की चोरी, धोखाधड़ी या दुरुपयोग से उत्पन्न जोखिम को कम करना। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।	

3.1 नियोजन के पूर्व

सभी कार्यों की भूमिकाओं और दायित्वों को दस्तावेजीकृत किया जाएगा और दस्तावेज़ में सूचना सुरक्षा के कार्यान्वयन या अनुरक्षण से संबंधित सामान्य और विनिर्दिष्ट दायित्वों को शामिल किया जाएगा। सभी कर्मचारी, संविदाकर्ता और तृतीय पक्ष सेवाप्रदाता अपने कार्य की भूमिकाओं और दायित्वों को समझेंगे।

संवेदनशील या महत्वपूर्ण कार्य भूमिकाएँ निष्पादित करने वाले सभी कार्मिकों (अस्थायी और संविदागत कार्मिकों सहित) के ऐसे कार्यों के लिए चयन या स्थानांतरण के पूर्व उनकी पृष्ठभूमि की जाँच कराई जाएगी। इसके अलावा, तृतीय पक्ष सेवाप्रदाताओं के कार्मिकों की पृष्ठभूमि जाँच उनसे संबंधित संगठन द्वारा कराई जाएगी और इसके विषय में सेवा ग्रहण करने वाले संगठन को आश्वस्ति दी जाएगी। कार्मिकों द्वारा भर्ती के समय दी गई जानकारी सत्यापन कार्यविधियों के अधीन होगी।

3.2 ऑनबोर्डिंग के समय और नियोजन के दौरान

1. संगठन की सूचना आस्तियों का उपयोग करने वाले सभी कर्मचारी, संविदाकर्ता और तृतीय पक्ष प्रयोक्ता अपनी नियोजन संविदा पर हस्ताक्षर करेंगे जिसमें गोपनीयता करार/ अ-प्रकटन करार (एनडीए) शामिल होगा और जो यह निर्दिष्ट करेगा कि उन्होंने संविदागत निबंधनों और शर्तों को स्वीकार कर लिया है जिनमें संगठन के गोपनीय और संवेदनशील डाटा का संरक्षण शामिल होगा। इन निबंधनों और शर्तों में सूचना सुरक्षा के संबंध में संगठन और कर्मचारी के दायित्वों का उल्लेख होगा।
2. कुछ मामलों में, सभी संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं की ओर से उनका एक प्राधिकृत प्रतिनिधि करार पर हस्ताक्षर करेगा जिसमें सुरक्षा संबंधी विषयों को समुचित रूप से विवरणित किया जाएगा। यदि इस करार में निर्धारित सुरक्षा संबंधी प्रावधान मानक कर्मचारी/ संविदाकर्ता/ तृतीय पक्ष संविदा से भिन्न होगा तो उसे अपवाद की अनुमति और जोखिम आकलन पद्धति के माध्यम से लेना आवश्यक होगा।
3. गोपनीयता करारों के उल्लंघन की रिपोर्टिंग के लिए प्रक्रियाओं और कार्यविधियों को परिभाषित किया जाएगा।
4. सभी पर्यवेक्षकीय भूमिकाएँ उन्हें रिपोर्ट करने वाले स्टाफ कार्मिकों के कार्यनिष्पादन और आचार के लिए तथा नियोजन संविदा के भाग के रूप में एवं संगठन की नीतियों में निर्धारित सूचना सुरक्षा अपेक्षाओं के लिए जिम्मेदार होंगी। प्रबन्धकों और पर्यवेक्षकों से यह अपेक्षित होगा कि वह अपने प्रत्येक स्टाफ के कार्यनिष्पादन और आचार का अनुप्रवर्तन करें तथा स्टाफ की पहुँच वाली सूचना आस्तियों की सुरक्षा पर उनके कार्यनिष्पादन और आचार के प्रभाव का आकलन करें।
5. गोपनीय सूचना और सूचना प्रणाली तक पहुँच की अनुमति देने से पहले सभी कर्मचारियों तथा संविदाकर्ताओं को सूचना सुरक्षा से संबंधित उनकी भूमिकाओं एवं दायित्वों के बारे में समुचित रूप से जानकारी दी जाएगी। प्रयोक्ता सूचना सुरक्षा प्रबंधन नीति में अपनी भूमिकाओं एवं दायित्वों से संगति रखने वाली अन्य अनुषंगी नीतियों को समझेंगे और उनका अनुपालन करेंगे।
6. बीमा कंपनियाँ यह सुनिश्चित करेंगी कि कर्मचारी और जहाँ भी अपेक्षित हो, तृतीय पक्ष प्रयोक्ता, उनकी भूमिकाओं एवं दायित्वों से संगति रखने वाले उपयुक्त जागरूकता/ कौशल प्रशिक्षण और संगठन की नीतियों तथा कार्यविधियों की अद्यतन जानकारी प्राप्त करें।

7. सभी अंतिम प्रयोक्ता संदिग्ध सूचना सुरक्षा घटनाओं और कमजोर पहलुओं की रिपोर्ट शीघ्रातिशीघ्र अपने नियंत्रक, पदनामित अधिकारी/ प्रणाली अधिकारी को करेंगे। जब तक कानून के अंतर्गत सुरक्षा घटनाओं को प्रकट करना अपेक्षित न हो तब तक कर्मचारी प्राधिकार के बिना किसी बाह्य व्यक्ति/ निकाय को घटना रिपोर्ट नहीं करेंगे।
8. कंप्यूटर से जुड़े भरोसे के पदों पर कर्मचारियों की पदस्थापना रोटेशन से होगी।
9. प्रमुख क्षेत्रों में किसी एक व्यक्ति पर भरोसे/ निर्भरता से बचा जाएगा। महत्वपूर्ण स्थानों पर तैनात तकनीकी कार्मिकों के लिए उत्तराधिकार योजना विकसित की जाएगी। विकास/ रखरखाव गतिविधियों के लिए दूसरी पंक्ति तैयार करना सुनिश्चित किया जाएगा।
10. नियोजन संविदा अथवा इस सूचना सुरक्षा नीति में निहित सूचना सुरक्षा अपेक्षाओं के उल्लंघन के लिए, सामान्य सूचना सुरक्षा नीति में अनुपालन खंड के एक भाग के रूप में निर्धारित 'दंडात्मक कार्रवाई' के अनुसार दंडात्मक कार्रवाई की जाएगी।
11. सूचना सुरक्षा नीतियों और प्रक्रियाओं के बारे में चेतना उत्पन्न करने के उद्देश्य से सभी कर्मचारियों, संविदाकर्ताओं और संगठन की प्रणालियों के तृतीय पक्ष प्रयोक्ताओं के लिए सूचना सुरक्षा प्रशिक्षण और जागरूकता कार्यक्रम चलाए जाएंगे।
12. संगठन आवधिक रूप से राष्ट्रीय / सेक्टरल/ सांठनिक साइबर सुरक्षा अभ्यासों में सहभागिता करेगा।
13. सूचना सुरक्षा कार्य सूचना सुरक्षा प्रशिक्षण और जागरूकता कार्यक्रम विकसित करेगा जिसमें कार्यक्रम की विषय-वस्तु के साथ-साथ उसकी समयावधि तथा उसमें उपस्थिति की अवधिकता भी निर्धारित की जाएगी।
14. प्रशिक्षण और जागरूकता कार्यक्रम में प्रत्येक स्टाफ-सदस्य की उपस्थिति को ट्रैक करने के लिए अपेक्षित तंत्र की स्थापना भी की जाएगी। जो भी कर्मचारी निर्धारित अवधिकता के अनुरूप प्रशिक्षण और जागरूकता कार्यक्रम में सहभागिता नहीं करेगा उसे कार्यक्रम में उपस्थित होने के लिए एक निश्चित समय-सीमा दी जाएगी जिसके भीतर उसके उपस्थित न होने को नीति का अननुपालन माना जाएगा। प्रशिक्षण की विषय-वस्तु और उसके विभिन्न संस्करणों का अभिलेख रखा जाएगा।
15. नेतृत्वकर्ताओं को अतिरिक्त प्रशिक्षण दिया जाएगा ताकि वे किसी सुरक्षा घटना की स्थिति में अपनी भूमिका को समझ सकें।
16. कर्मचारियों को 'क्या करें, क्या न करें' के रूप में संगठन में उनके अधिकारों और कर्तव्यों की जानकारी आवधिक रूप से दी जाएगी। इसमें कर्मचारियों को कंपनी की आस्तियों के व्यक्तिगत उपयोग से दूर रहने के लिए भी सूचित किया जाएगा।
17. जो प्रयोक्ता कंपनी छोड़ने की प्रक्रिया में होंगे, संगठन उनकी गतिविधियों (विशेष रूप से ईमेल, प्रशासनिक और महत्वपूर्ण प्रणालियाँ) के उच्चतर स्तर के अनुप्रवर्तन पर विचार करेगा।

18. सभी कर्मचारियों को एक बेनामी रिपोर्टिंग माध्यम उपलब्ध कराया जाएगा ताकि वे सूचना सुरक्षा नीति या कार्यविधियों के उल्लंघनों को रिपोर्ट कर सकें।

3.3 निकास/ बहिर्गमन कार्यविधियाँ

1. संगठन यह सुनिश्चित करेगा कि कर्मचारियों, संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं की सेवा के परिसमापन का निष्पादन व्यवस्थित रीति से हो, दायित्व परिभाषित हों और इसे सुनिश्चित करने के लिए संगठन के भीतर उन्हें संप्रेषित करने के लिए परिचालित किया जाए।
2. जिन व्यक्तियों की सेवा परिसमाप्त कर दी गई है उनके पास उपलब्ध संगठन की आस्तियों को वापस ले लिया जाएगा और पहुँच के उनके सभी अधिकार (भौतिक और तार्किक) तत्काल हटा दिए जाएँगे।
3. संगठन दायित्व में परिवर्तन या कर्मचारियों, संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं के स्थानांतरण को ध्यान में रखेगा और जब भी ऐसे अवसर आएँगे उन्हें अपलब्ध कराई गई पहुँच के औचित्य का आकलन किया जाएगा।
4. कर्मचारियों, संविदाकर्ताओं और तृतीय पक्ष प्रयोक्ताओं के लिए यह अनिवार्य होगा कि वे अपने नियोजन, संविदा या करार के परिसमापन पर अपने कब्जे में स्थित संगठन की सम्पूर्ण आस्तियों को वापस कर दें।
5. यह सुनिश्चित करने लिए उपयुक्त तंत्र स्थापित किया जाएगा कि किसी कर्मचारी या संविदाकर्ता को दी गई पहुँच की अनुमति संगठन में उसके नियोजन/संगठन के साथ उसकी संविदा के परिसमापन के पूर्व प्रतिसंहृत कर ली जाए। यह सुनिश्चित करने के लिए उपयुक्त नियंत्रण भी स्थापित किए जाएँगे कि नियोजन/संविदा के परिसमापन के बाद भी संबन्धित कर्मचारी या संविदाकर्ता की पहुँच को हटाया नहीं गया है, तो समय से इसका पता चल जाए और तत्काल आवश्यक कार्रवाई की जाए।
6. कर्मचारी की सेवा-अवधि के दौरान सूचना सुरक्षा के उल्लंघन की समीक्षा उसके अंतिम साइन-ऑफ के पहले कर ली जाएगी।

3.4 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
एचआर	एचआर	आईएस, आईटी, जोखिम	व्यवसाय विभाग

नीति सं.: 2.5

नीति का नाम: 2.5. सूचना प्रणाली का अधिग्रहण और विकास

- 1 **प्रयोजन** वांछित कार्यपद्धतियों को परिभाषित करना और यह सुनिश्चित करना कि सूचना सुरक्षा सूचना प्रणालियों के सम्पूर्ण जीवनचक्र में उनका एक अविभाज्य हिस्सा रहे।
- 2 **दायरा** यह नीति उन सभी सूचना प्रणालियों पर लागू होगी जहाँ सूचना अस्तियाँ भंडारित और प्रसंस्कृत की जाती हैं, और उन सभी संचार तथा नेटवर्क कनेक्शनों पर लागू होगी जिनके माध्यम से संगठन की सूचना आस्तियाँ संप्रेषित की जाती हैं। सूचना प्रौद्योगिकी का इस्तेमाल करने वाली सभी व्यवसाय इकाइयों या विभागों द्वारा इस सूचना सुरक्षा नीति का अनुपालन किया जाएगा।

यह नीति नया सॉफ्टवेयर विकसित करने, सॉफ्टवेयर को ग्राहक-अनुकूल बनाने और ऐसे सॉफ्टवेयरों को विकसित करने पर भी लागू होगा जिन पर किसी वेबसाइट के जरिए पहुँचा जा सके या जिन्हें वेबसाइट पर प्रस्तुत किया जा सके। संगठन की सूचना प्रणाली के डिजाइन में ही यह व्यवस्था होगी कि प्रणाली में निहित डाटा की गोपनीयता, सत्यनिष्ठा और उपलब्धता को बनाए रखा जाए। इस लक्ष्य को पूरे प्रणाली विकास जीवनचक्र में यानी अधिग्रहण से शुरू करते हुए विकास और रखरखाव तक प्रक्रियाओं के माध्यम से हासिल किया जाएगा। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3 नीति

3.1 प्रौद्योगिकी मानक

3.1.1 अवसंरचना मानक

3.1.1.1 सुरक्षा अपेक्षाओं का विश्लेषण और विनिर्देश

1. सूचना प्रणाली के अधिग्रहण, विकास या परिवर्तन के चरणों में आवश्यकताओं के एकत्रण और विश्लेषण के दौरान सुरक्षा संबंधी आवश्यकताओं की पहचान की जाएगी और उनका दस्तावेजीकरण किया जाएगा; उनके औचित्य का प्रतिपादन किया जाएगा और व्यवसाय प्रक्रिया के स्वामियों के साथ सहमति हासिल की जाएगी।
2. प्रणाली सुरक्षा आवश्यकताएँ संबंधित सूचना आस्तियों के व्यवसाय मूल्य के साथ-साथ उस संभावित क्षति को भी प्रतिबिम्बित करेंगी जो पर्याप्त सुरक्षा के अभाव के कारण हो सकती है।
3. न्यूनतम आधारस्तरीय सुरक्षा मानक (एमबीएसएस) विकसित किए जाएंगे और बनाए रखे जाएंगे और इन्हीं मानकों के अनुरूप सभी सूचना प्रणालियों को कन्फ़िगर किया जाएगा।
4. एमबीएसएस में सूचना प्रणाली में निहित डाटा के साथ-साथ उस प्रणाली के परिचालन के लिए प्रयुक्त प्रणाली सॉफ्टवेयर भी शामिल होगा।
5. सभी सूचना प्रणालियों (सर्वर, राउटर और फायरवाल) को उत्पादन पर्यावरण में उपयोग के लिए कमीशन किए जाने के पहले एमबीएसएस के अनुसार हार्डनिंग की प्रक्रिया से गुजारा जाएगा।
6. संगठन के सुरक्षा डोमेन में आने वाली सभी संबंधित प्रणालियों का समय सहमति-प्राप्त प्रमाणिक समयस्रोत से मिलाया जाएगा।

3.1.2 एप्लिकेशन सुरक्षा मानक

3.1.2.1 सुरक्षा अपेक्षाओं का विश्लेषण और विनिर्देश

1. उत्पादन पर्यावरण में उपयोग के लिए कमीशन किए जाने के पहले सुरक्षा समीक्षाओं के माध्यम से एप्लिकेशनों का आकलन उनकी सुरक्षा परिस्थिति के लिए किया जाएगा।
2. एप्लिकेशन सुरक्षा समीक्षाएँ सूचना सुरक्षा टीम द्वारा परिभाषित एप्लिकेशन सुरक्षा के आधार पर की जाएगी जिनमें समीक्षा में देखे जाने वाले पहलुओं और साथ ही बाहरी एजेंसियों द्वारा ऐसी समीक्षाओं की अपेक्षाओं के संबंध में दिशानिर्देशों को शामिल किया जाएगा।

3.1.2. एप्लिकेशन विकास

2

1. आईएस टीम द्वारा एक औपचारिक सॉफ्टवेयर विकास सुरक्षा संरचना विकसित की जाएगी।
2. इस सॉफ्टवेयर विकास सुरक्षा संरचना में एक सॉफ्टवेयर जोखिम आकलन प्रक्रिया परिभाषित की जाएगी ताकि यह सुनिश्चित किया जा सके कि संबंधित व्यवसाय और प्रौद्योगिकी जोखिमों को ध्यान में रखते हुए सॉफ्टवेयर सुरक्षा संबंधी आवश्यकताओं का आकलन किया जा सके।
3. सुरक्षित डिजाइन शैलियों की एक लाइब्रेरी (संग्रह) तैयार की जाएगी। सभी परियोजनाओं में उनका सुसंगत उपयोग लागू किया जाएगा ताकि शैलियों का विकास नई शैलियों की आवश्यकता से संचालित हो। सुरक्षा समीक्षाओं में शैलियों की समीक्षा और उनका उपयोग लागू करने पर ध्यान केन्द्रित किया जाएगा।
4. सॉफ्टवेयर पैकेजों में आशोधन को हतोत्साहित किया जाएगा। विक्रेताओं द्वारा आपूर्त सॉफ्टवेयर पैकेजों का उपयोग न्यूनतम आशोधन के साथ किया जाएगा जब तक सूचना सुरक्षा नीति के समक्ष सॉफ्टवेयर पैकेज की सुरक्षागत परिस्थिति प्रभावित न हो।
5. सॉफ्टवेयर पैकेजों में सभी आशोधन (कन्फिगरेशन में परिवर्तन, रिपोर्टों में परिवर्तन आदि सहित) औपचारिक प्रोग्राम परिवर्तन नियंत्रण कार्यविधियों के अनुसार किए जाएंगे।
6. यदि सॉफ्टवेयर का विकास तृतीय पक्ष द्वारा किया जा रहा हो तो निम्नलिखित को सुनिश्चित किया जाएगा—
 - संगठन द्वारा सॉफ्टवेयर विकास के लिए अपनाई जा रही प्रक्रियाएँ संगठन की प्रणाली अधिग्रहण और विकास नीति का अनुपालन करती हैं।
 - जहाँ तक संभव और व्यावहारिक हो विक्रेताओं द्वारा आपूर्त सॉफ्टवेयर पैकेजों का उपयोग बिना आशोधन के किया जाएगा।
 - संगठन के पास गुणवत्ता और कार्यनिष्पादन के लिए उपयुक्त लाइसेंसिंग करार और संविदागत अपेक्षाएँ अस्तित्व में होंगी।
 - तृतीय पक्ष से उत्पाद मैनुअलों और डाटा शीटों के रूप में उपयुक्त दस्तावेजीकरण प्राप्त किया जाना चाहिए ताकि सूचना सुरक्षा नीति की सुरक्षा अपेक्षाओं का पालन सुनिश्चित किया जा सके।
 - यदि किसी सॉफ्टवेयर पैकेज में आशोधन आवश्यक हो जाता है तो इसके लिए विक्रेता की सहमति प्राप्त की जाएगी और यदि आशोधन के बाद सॉफ्टवेयर के भविष्यगत रखरखाव का दायित्व संगठन का होने वाला है तो परिवर्तन के परिणामी प्रभाव का आकलन किया जाएगा।
 - उपलब्ध कराए गए सॉफ्टवेयर के उपयोग के दौरान स्रोत कोड का स्वामित्व संगठन को अंतरित किया जाएगा या संगठन को स्रोत कोड की उपलब्धता सुनिश्चित करने के लिए उपयुक्त एस्करो व्यवस्था की जाएगी।
 - उत्पादन पर्यावरण में उपयोग के लिए सॉफ्टवेयर को कमीशन करने के पहले उपयुक्त जाँच निष्पादित की जाएगी ताकि यह सुनिश्चित किया

जा सके कि सॉफ्टवेयर, सुरक्षा आवश्यकताओं सहित अनुरोध की कार्यक्षमता पर खरा उतरता है।

- जब एप्लिकेशन विकास और अनुरक्षण प्रक्रिया आंतरिक रूप से की जाती है, तब सुरक्षा आवश्यकताओं सहित एक औपचारिक पद्धति परिभाषित और दस्तावेजीकृत की जाएगी।
- विकास प्रक्रियाओं और नियंत्रणों की लेखापरीक्षा के लिए संविदागत अधिकार सुनिश्चित किया जाएगा। अपेक्षित परिणामों की गुणवत्ता और परिशुद्धता के लिए स्वीकरण जाँच की जाएगी।
- सुरक्षा और निजता की गुणवत्ता के न्यूनतम स्वीकार्य स्तरों की स्थापना के लिए न्यूनतम सुरक्षा स्तर का प्रयोग किया जाएगा।

3.1.2. एप्लिकेशनों में सही 3 प्रसंस्करण

1. एप्लिकेशनों के डाटा इनपुट का वैधकरण किया जाएगा ताकि डाटा की परिशुद्धता और उपयुक्तता सुनिश्चित की जा सके।
2. एप्लिकेशन के भीतर ऐसी जाँचों को सन्निहित किया जाएगा जिससे प्रसंस्करण की भूलों के कारण या जानबूझ कर किए गए कृत्यों के कारण सूचना में आई किसी खराबी का पता लग सके।
3. एप्लिकेशन में प्रामाणिकता सुनिश्चित करने और संदेश की सत्यनिष्ठा का संरक्षण करने संबंधी अपेक्षाओं की पहचान की जाएगी और उपयुक्त नियंत्रणों की पहचान कर उन्हें कार्यान्वित किया जाएगा।
4. एप्लिकेशन से प्राप्त डाटा आउटपुट का भी वैधकरण किया जाएगा ताकि यह सुनिश्चित किया जा सके कि भंडारित डाटा का प्रसंस्करण सही है और परिस्थितियों के लिए उपयुक्त है।
5. केंद्रीय स्तर से लागू की जाने वाली नीति के माध्यम से अननुमोदित सॉफ्टवेयर और यूटिलिटीज़ को इन्स्टाल करने पर रोक होगी।
6. प्रयोक्ता केवल संगठन द्वारा अनुमोदित कोलैबोरेशन सॉफ्टवेयर का इस्तेमाल करेंगे।

3.1.3 उपलब्धता मानक

1. व्यवसाय परिचालनों के लिए महत्वपूर्ण प्रणाली के रूप में वर्गीकृत सूचना प्रणालियों को इस प्रकार डिजाइन किया जाएगा कि प्रणाली का डिजाइन उच्च उपलब्धता परिचालनों या उनकी तैनाती में सहयोगी हो।
2. उच्च उपलब्धता की आवश्यकता वाली सभी सूचना प्रणालियों के लिए प्रबंधन निम्नलिखित कार्य संपादित करेगा:
 - आस्ति के अधिप्रापण (खरीद) के समय यह सुनिश्चित किया जाएगा कि आस्ति के कन्फिगरेशन में त्रुटि को सहने की क्षमता का प्रावधान है।
 - खरीद के बाद प्रणाली को, महत्व के स्तर के आधार पर उपलब्धता मोड में कन्फिगर किया जाएगा।
 - उपलब्धता के अनुप्रवर्तन, रिपोर्टिंग और प्रबंधन के लिए एक योजना विकसित करेगा।
 - उपकरण के कार्यनिष्पादन के अनुप्रवर्तन और रिपोर्टिंग के माध्यम से उपलब्धता को इष्टतम स्तर तक ले जाएगा।

3.2 नई प्रौद्योगिकी का जोखिम आकलन

3.2.1 परिस्थितियाँ

1. निम्नलिखित परिस्थितियों में प्रौद्योगिकी जोखिम आकलन किया जाएगा:
 - . नई प्रक्रिया या प्रौद्योगिकी का आरंभ;
 - . विद्यमान प्रक्रिया या प्रौद्योगिकी में परिवर्तन।
2. प्रौद्योगिकी जोखिम आकलन का कार्य नई प्रक्रिया या प्रौद्योगिकी के आरंभ/ उनमें परिवर्तन के लिए जिम्मेदार संबंधित आईटी या व्यवसाय टीम द्वारा किया जाएगा।
3. प्रौद्योगिकी जोखिम आकलन का निष्पादन आईएस टीम द्वारा परिभाषित प्रौद्योगिकी जोखिम आकलन टेम्पलेटों और/ या जाँचसूचियों के आधार पर किया जाएगा।

3.2.2 प्रौद्योगिकी जोखिम आकलन प्रक्रिया

प्रौद्योगिकी जोखिम आकलन का निष्पादन 'आईएस नीति – सामान्य दिशानिर्देश 1.8 जोखिम प्रबंधन' में निहित दिशानिर्देशों के अनुसार किया जाएगा।

3.2.3 स्थापत्य और परस्पर निर्भरता

1. संगठन द्वारा विकसित किसी भी नई सूचना प्रणाली/ कार्यविधि के तकनीकी और कार्यपरक स्थापत्य की, सूचना सुरक्षा के दृष्टिकोण से समीक्षा और अनुमोदन का कार्य आईएस टीम के द्वारा किया जाएगा।
2. विकसित की जा रही नई सूचना प्रणाली/ कार्यविधि की परस्पर निर्भरता का आकलन संगठन के समग्र पर्यावरण के साथ सूचना सुरक्षा के दृष्टिकोण से किया जाएगा।

3.2.4 प्रणाली परिवर्तन नियंत्रण और कार्यविधियाँ

1. प्रणाली, एप्लिकेशनों और उत्पादों की सत्यनिष्ठा सुनिश्चित करने के लिए डिजाइन के आरंभिक चरणों से लेकर बाद के सभी अनुरक्षण प्रयासों के दौरान औपचारिक परिवर्तन नियंत्रण कार्यविधियों को दस्तावेजीकृत और लागू किया जाएगा।
2. नई प्रणालियों के आरंभ और विद्यमान प्रणालियों में परिवर्तन के लिए दस्तावेजीकरण, विनिर्देश, परीक्षण, गुणवत्ता नियंत्रण और प्रबंधित कार्यान्वयन की एक औपचारिक प्रक्रिया का अनुगमन किया जाएगा।
3. परिवर्तन नियंत्रण कार्यविधियों में निम्नलिखित शामिल होंगे लेकिन ये इन्हीं तक सीमित नहीं होंगी:
 - क) सहमति-प्राप्त प्राधिकार स्तरों का अभिलेख रखना;
 - ख) प्राधिकृत प्रयोक्ताओं से परिवर्तनों की प्रस्तुति सुनिश्चित करना;
 - ग) यह सुनिश्चित करने के लिए नियंत्रणों और सत्यनिष्ठा कार्यविधियों की समीक्षा करना कि परिवर्तनों के कारण कार्यविधियों के साथ समझौता न हो;
 - घ) संशोधन की आवश्यकता वाले सभी सॉफ्टवेयरों, सूचनाओं, डाटाबेस अस्तित्वों और हार्डवेयरों की पहचान करना;
 - ङ) ज्ञात सुरक्षा कमजोरियों की संभावना को न्यूनतम करने के लिए सुरक्षा के महत्वपूर्ण कोडों की पहचान और जाँच;
 - च) कार्य के आरंभ से पहले विस्तृत प्रस्तावों के लिए औपचारिक अनुमोदन प्राप्त करना;
 - ज) कार्यान्वयन से पहले प्राधिकृत प्रयोक्ता परिवर्तनों को स्वीकार करें, यह सुनिश्चित करना;
 - झ) यह सुनिश्चित करना कि प्रत्येक परिवर्तन के पूर्ण होने पर प्रणाली दस्तावेजीकरण समुच्चय को अद्यतन किया जाता है और पुराने दस्तावेजीकरण को संग्रह में डाल दिया जाता है या उसका निपटारा कर दिया जाता है।

ज) सभी सॉफ्टवेयर अपडेटों के लिए संस्करण (वर्जन) नियंत्रण बनाए रखना;
 ट) परिवर्तन के सभी अनुरोधों के लिए लेखापरीक्षा ट्रेल बनाए रखना।

3.2.5 एप्लिकेशनों की तकनीकी समीक्षा

1. एप्लिकेशन नियंत्रण और सत्यनिष्ठा कार्यविधियों की समीक्षा की जाएगी ताकि यह सुनिश्चित किया जा सके कि परिचालन प्लेटफॉर्म परिवर्तनों के कारण उनसे कोई समझौता नहीं किया गया है।
2. यह सुनिश्चित किया जाएगा कि परिचालन प्लेटफॉर्म परिवर्तनों की अधिसूचना समय से उपलब्ध कराई जाए ताकि कार्यान्वयन के पहले उपयुक्त परीक्षण और समीक्षाएँ की जा सकें।
3. यह सुनिश्चित करना कि व्यवसाय निरंतरता योजना में उपयुक्त परिवर्तन किए जाएँ।

3.2.6 प्रणाली सुरक्षा परीक्षण

1. नई और अद्यतनीकृत प्रणालियों के लिए विकास प्रक्रियाओं के दौरान सम्पूर्ण परीक्षण और सत्यापन की आवश्यकता होगी जिसमें गतिविधियों की विस्तृत अनुसूची तैयार करना और विभिन्न स्थितियों में परीक्षण इनपुट तथा अपेक्षित आउटपुट का विवरण शामिल होगा।
2. संगठन द्वारा आंतरिक रूप से तैयार की जाने वाली प्रणालियों के लिए विकास टीम द्वारा आरंभिक परीक्षण किए जाएँगे। उसके बाद स्वतंत्र स्वीकरण परीक्षण (प्रणाली विकास के आंतरिक और बाह्य दोनों मामलों में) किए जाएँगे ताकि यह सुनिश्चित किया जा सके कि प्रणाली अपेक्षानुसार और केवल अपेक्षानुसार काम करती है।
3. प्रणाली स्वीकरण परीक्षण में सूचना सुरक्षा आवश्यकताओं और सुरक्षित प्रणाली विकास कार्यपद्धतियों के पालन का परीक्षण शामिल होगा। प्राप्त घटकों और एकीकृत प्रणालियों का परीक्षण भी किया जाएगा।
4. परीक्षण कार्य यथार्थपरक पर्यावरण में किया जाएगा ताकि यह सुनिश्चित किया जा सके कि प्रणाली के कारण संगठन के पर्यावरण में कमजोरियाँ नहीं आतीं और यह कि परीक्षण विश्वसनीय है।
5. परीक्षण के प्रयोजन से व्यक्तिगत पहचान-योग्य सूचना या अन्य गोपनीय सूचनाओं वाले परिचालन डाटा के उपयोग से बचा जाएगा।

3.3 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी	आईटी	आईएस	व्यवसाय प्रयोक्ता

नीति सं. :	2.6
नीति का नाम:	2.6. सूचना प्रणाली अनुरक्षण

1	प्रयोजन	गोपनीयता, निजता और उपलब्धता के संरक्षण के संदर्भ में सूचना प्रणालियों के अनुरक्षण के लिए कार्यपद्धतियों को परिभाषित करना। किसी सूचना प्रणाली के परिचालन के दौरान, उसके अनुरक्षण और उसे सेवा से हटाने सहित, सुरक्षा पर विचार करना अनिवार्य है, ताकि □. सभी उपयुक्त सुरक्षा अपेक्षाओं के साथ अनुकूलता सुनिश्चित की जा सके; □. सूचना प्रणाली में निहित सूचना आस्तियों का संरक्षण किया जा सके; □. नई उभरती जोखिमों से प्रणाली को संरक्षित किया जा सके; □. जब प्रणाली में आशोधन किया जाए, तब नई जोखिमों के आगमन को रोका जा सके; □. जब प्रणाली को सेवा से हटाया जाए, तब डाटा को समुचित रूप से हटा लेना सुनिश्चित किया जाए। यह नीति सूचना प्रणाली के जीवनचक्र में उसके अनुरक्षण के दौरान सूचना सुरक्षा पर विचार करना सुनिश्चित करने के लिए मार्गदर्शन उपलब्ध कराएगी। यह नीति सूचना प्रणालियों के अनुरक्षण के संबंध में संगठन की वांछित कार्यपद्धतियों को परिभाषित करती है।
2	दायरा	यह नीति उन सभी सूचना प्रणालियों पर लागू होती है, जिनमें संगठन की सूचना आस्तियाँ भंडारित या प्रसंस्कृत की जाती हैं, और उन सभी संचार तथा नेटवर्क कनेक्शनों पर लागू होती है जिनके माध्यम से संगठन की सूचना आस्तियाँ संप्रेषित की जाती हैं। प्रौद्योगिकी प्रणालियों, संचार और नेटवर्क कनेक्शनों में राउटर तथा फायरवाल, सर्वर तथा मेनफ्रेम, और प्रणालियाँ, डाटाबेस तथा एप्लिकेशन आते हैं लेकिन ये इन्हीं तक सीमित नहीं हैं। सूचना प्रणालियों का उपयोग करने वाली सभी व्यवसाय इकाइयाँ या विभाग इस नीति का अनुपालन करेंगे।
3	नीति	सूचना प्रणालियों में निहित सूचनाओं की गोपनीयता और सत्यनिष्ठा के संरक्षण तथा सूचना प्रणालियों की उपलब्धता को बनाए रखने के लिए समुचित अनुरक्षण गतिविधियाँ संपादित की जाएँगी। इस नीति के किसी उल्लंघन को घटना के रूप में माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।
3.1	बैक-अप और पुनर्प्राप्ति	1. आईएस टीम द्वारा परिभाषित बैक-अप और पुनर्प्राप्ति मानक के अनुसार बैक-अप किए जा रहे डाटा के वर्गीकरण के आधार पर बैक-अप की बारंबारता, पुनर्प्राप्ति परीक्षण की बारंबारता तथा बैक-अप की भंडारण-संबंधी अपेक्षाओं को परिभाषित किया जाएगा। डाटा पुनर्प्राप्ति परीक्षण कम-से-कम छह माह में एक बार या व्यवसाय की आवश्यकता के अनुसार इससे भी कम अवधि पर किया जाना अनिवार्य है। 2. जिन एप्लिकेशनों, परिचालन प्रणाली सॉफ्टवेयर, डाटा (डाटाबेस सहित), एप्लिकेशन और परिचालन प्रणाली के कन्फिगरेशन संबंधी सूचनाओं, हार्डवेयर कन्फिगरेशन संबंधी सूचनाओं (जहाँ लागू हो) तथा लॉग फाइलों के बैक-अप की आवश्यकता हो, उनकी, बैक-अप के माध्यम और भंडारण एवं अपेक्षित प्रणाली के लिए, ऑफ-साइट मीडिया के स्थान (यदि आवश्यकता हो) सहित पहचान की जाएगी और उनका दस्तावेजीकरण किया जाएगा। 3. सम्पूर्ण बैक-अप मीडिया एन्क्रिप्टेड रूप में होगा। 4. बैक-अप मीडिया से पुनर्प्राप्त डाटा का लॉग रखा जाएगा। 5. रखे जाने वाले बैक-अप सेटों की संख्या का निर्णय सूचना प्रणालियों में निहित सूचना के महत्व को ध्यान में रखते हुए लिया जाएगा।

6. निम्नलिखित मामलों में अनुसूचित बैक-अप के अतिरिक्त भी बैक-अप लिए जाएंगे:
 - किसी प्रणाली के कन्फिगरेशन में परिवर्तन
 - किसी परिचालन प्रणाली का उन्नयन
7. ऑफ-साइट और ऑन-साइट स्थानों के बीच टेपों के सम्पूर्ण आवागमन का ट्रैक और अभिलेख रखा जाएगा।
8. बैक-अप मीडिया की पठनीयता के सत्यापन के लिए आवधिक रूप से बैक-अप और पुनर्प्राप्ति मानक में यथापरिभाषित मॉक परीक्षण आयोजित किया जाएगा। परीक्षण योजना, की गई गतिविधियों और परीक्षण के परिणामों के विवरण के साथ पूरी प्रक्रिया का दस्तावेजीकरण किया जाएगा। परीक्षण प्रक्रिया के दौरान सामने आए अपवादों की पहचान कर उनका दस्तावेजीकरण किया जाएगा और उनकी रिपोर्ट की जाएगी।
9. बैक-अप डाटा की पुनर्प्राप्ति की क्षमता का परीक्षण इसी कार्य के लिए निर्दिष्ट अलग परीक्षण मीडिया पर किया जाएगा, न कि मूल मीडिया को ओवर-राइट करते हुए, ताकि बैक-अप अथवा पुनर्प्राप्ति की असफलता की स्थिति में डाटा की अपूरणीय क्षति या पूर्णतः नष्ट होने की आशंका से बचा जा सके।
10. संगठन की वेबसाइट की विषय-वस्तु का बैक-अप रखा जाएगा ताकि साइट के खराब होने की स्थिति में उसकी व्यवस्थित पुनर्प्राप्ति की जा सके।
11. बंद हो जाने के रूप में पड़ने वाले प्रभाव को न्यूनतम करने के उद्देश्य से बैक-अप की आवधिक समीक्षा की जाएगी और कार्यविधियों को तदनुसार ठीक किया जाएगा।
12. परिचालनात्मक कार्यविधियों के माध्यम से बैक-अप कार्यनिष्पादन का अनुप्रवर्तन किया जाएगा और अनुसूचित बैक-अप की असफलता का निवारण किया जाएगा ताकि बैक-अप नीति के अनुरूप बैक-अप की पूर्णता सुनिश्चित की जा सके।
13. मूलभूत व्यवसाय सूचनाओं की प्रतिधारण अवधि का निर्धारण संग्रह की प्रतियों को सदा के लिए प्रतिधारित करने आवश्यकता को ध्यान में रखते हुए किया जाएगा।

3.2 पैच प्रबंधन

- सूचना प्रणालियों के अनुरक्षण और अनुप्रवर्तन का दायित्व रखने वाली टीम आईटी पर्यावरण के सॉफ्टवेयर घटकों की एक इनवेंटरी रखेगी। कृपया आस्ति इनवेंटरी पर आस्ति प्रबंधन नीति का संदर्भ लें।
- सूचना प्रणालियों के अनुरक्षण और अनुप्रवर्तन का दायित्व रखने वाली टीम सॉफ्टवेयर (एप्लिकेशन और परिचालन प्रणाली तथा डाटाबेस जैसे प्रणाली सॉफ्टवेयर सहित) के प्रदाताओं की सॉफ्टवेयर 'पैचेज़' से संबंधित घोषणाओं का अनुप्रवर्तन करेगी जो सुरक्षागत कमजोरियों को दूर करने के लिए उपलब्ध कराए जाएंगे।
- पहचान किए गए प्रत्येक पैच को निम्नलिखित प्रक्रिया के माध्यम से लिया जाएगा।
- प्रत्येक पैच का मूल्यांकन कर यह देखा जाएगा कि वह बीमा कंपनी के प्रयोजन का है या नहीं और यह भी निर्धारित किया जाएगा कि पैच सामान्य परिवर्तन से संबंधित है या आकस्मिक परिवर्तन से।
- जिन पैचों की पहचान की गई है वे कितने दिनों के भीतर फिक्स किए जाएंगे, यह निर्धारित करने के लिए एक प्रक्रिया परिभाषित की जाएगी।
- पैचों के वर्गीकरण के लिए मानदंड निर्धारित किए जाएंगे।

- संगठन के उत्पादन पर्यावरण में पैचों की साध्यता के लिए संगठन द्वारा परिचालित परीक्षण पर्यावरण में सभी पैचों का परीक्षण किया जाएगा।
- यदि विनियामक/ परामर्श सूचना/ उत्पाद ओईएम के निर्देशानुसार तत्काल/ प्राथमिकता के आधार पर महत्वपूर्ण सुरक्षा पैच लगाने की आवश्यकता हो, तो संगठन उसका आकलन कर सीआईएसओ और सीटीओ से अपवाद के लिए आवश्यक अनुमोदन प्राप्त करेगा।
- परिचालन प्रणाली या डाटाबेस पैच को इन्स्टाल करने से पहले परीक्षण पर्यावरण में व्यवसाय के लिए महत्वपूर्ण एप्लिकेशनों की समीक्षा और परीक्षण कर यह सुनिश्चित किया जाएगा कि परिचालन प्रणाली में परिवर्तन के कारण एप्लिकेशन पर प्रतिकूल प्रभाव तो नहीं होगा।
- एंड-कम्प्यूटिंग (अंतिम संगणना करने वाले) उपकरणों के लिए पैचों या अपडेटों का एप्लिकेशन इस प्रकार किया जाएगा कि संगठन के नेटवर्क या उद्यम सूचना आस्तियों तक उपकरण के पहुँच प्राप्त करने के बाद एक उचित समय के भीतर पैच प्रभावी तरीके से जुड़ जाएँ।

3.3 कार्य अनुसूची बनाना

1. दैनिक, साप्ताहिक, मासिक, तिमाही और वार्षिक बैच रनों या उत्पादन पर्यावरण में रन किए जाने के लिए अनुसूचित बैक-अप सहित अनुसूचीबद्ध कार्यों की एक समग्र इनवेंटरी रखी जाएगी जिसमें कार्यों के बीच की परस्पर निर्भरता को भी शामिल किया जाएगा।
2. उत्पादन पर्यावरण में रन किए जाने वाले सभी कार्य सूचना प्रणाली के स्वामियों द्वारा अनुमोदित किए जाएँगे।
3. सभी अनुसूचीबद्ध कार्यों का उनके कार्यनिष्पादन, सफलता/ विफलता के लिए अनुप्रवर्तन किया जाएगा और परिणामों को दस्तावेजीकृत किया जाएगा।
4. अनुसूचीबद्ध कार्य के परिणामों की समीक्षा एक उचित समय-सीमा के भीतर की जाएगी और उस अनुसूचीबद्ध कार्य या उसके किसी भाग की विफलता सहित किसी मानकेतर व्यवहार के आधार पर कार्रवाई की जाएगी।
5. अनुसूचियाँ सुनियोजित या आकस्मिक अनुरोधों के माध्यम से परिवर्तन के अधीन होंगी।
6. सूचना प्रणालियों के अनुरक्षण और अनुप्रवर्तन के लिए जिम्मेदार टीम का यह दायित्व होगा कि वह कार्यों की अनुसूची तैयार करे और उनका अनुप्रवर्तन करे।
7. विफलता सहित किसी मानकेतर व्यवहार को घटना के रूप में लिया जाएगा और घटना प्रबंधन नीति के अनुसार उसके परिसमापन के लिए उसे ट्रैक किया जाएगा।
8. सभी अनुसूचीबद्ध कार्यों को इस प्रकार डिजाइन किया जाएगा कि कार्यनिष्पादन के दौरान जो अस्थायी फाइलें जेनरेट होंगी और कार्य के पूरे होने के बाद जिनकी आवश्यकता नहीं होगी, वे डिलीट हो जाएँगी।
9. यह सुनिश्चित करने के लिए नियंत्रण स्थापित किए जाएँगे कि विभिन्न कार्यों के बीच निर्भरता को ध्यान में रखा जाए और निर्भरता को प्रभावित करने वाली विफलताओं की ओर ध्यान खींचने के लिए चेतावनी (अलर्ट) मिले जिसका अनुप्रवर्तन किया जा सके।

सूचना प्रणालियों की उपयोगिता और कार्यनिष्पादन के अनुप्रवर्तन के लिए नियंत्रण स्थापित किए जाएंगे ताकि हर समय उपलब्धता संबंधी आवश्यकताओं को पूरा करना सुनिश्चित किया जा सके।

-) सुरक्षा घटना के घटित होने का पता लगाने के लिए अनुप्रवर्तन गतिविधि के परिणामों और लॉग का विश्लेषण किया जाएगा और घटनाओं के परिसमापन के लिए उन्हें घटना प्रबंधन नीति के अनुसार ट्रैक किया जाएगा।
-) अनुप्रवर्तन गतिविधि के परिणामों और लॉग का इस्तेमाल ऐसी प्रवृत्तियों की पहचान करने के लिए भी किया जाएगा जिनके कारण आईटी पर्यावरण में परिवर्तन या आईटी संसाधनों में वृद्धि की आवश्यकता हो। विश्लेषण के परिणामों का उपयोग एक क्षमता प्रबंधन योजना तैयार करने के लिए भी किया जाएगा जिसका उद्देश्य कार्यनिष्पादन लक्ष्यों को पूरा करने या उनसे आगे बढ़ने में संगठन को सहयोग करना होगा।
-) क्षमता योजना में सामान्य कार्यभार, विशेष आकस्मिकताओं और भंडारण संबंधी आवश्यकताओं जैसे पहलुओं को ध्यान में रखा जाएगा।
-) बीमा कंपनियाँ उपयोग की प्रवृत्तियों की पहचान करेंगी, विशेष रूप से व्यवसाय एप्लिकेशनों या सूचना प्रणाली प्रबंधन टूल्स के संदर्भ में।
-) न्यूनतम सीमाओं का दस्तावेजीकरण और अनुप्रवर्तन किया जाएगा।
-) क्षमता की भविष्यगत आवश्यकताओं का अनुमान लगाया जाएगा ताकि पर्याप्त प्रसंस्करण और भंडारण क्षमता की उपलब्धता सुनिश्चित की जा सके।
-) प्रणाली सामंजस्य और अनुप्रवर्तन को लागू किया जाएगा ताकि प्रणालियों की उपलब्धता और दक्षता सुनिश्चित की जा सके और जहाँ आवश्यक हो, उनमें सुधार लाया जा सके।

1. मैलिसस कोड या मैलिसस सॉफ्टवेयर, जैसे वायरस, ट्रोजन, वर्म, लॉजिक बॉम्ब आदि के नियंत्रण और प्रबंधन के लिए संगठन औपचारिक तथा दस्तावेजीकृत कार्यविधियाँ विकसित करेगा। इन कार्यविधियों में मैलिसस कोड या मैलिसस सॉफ्टवेयर के लिए निवारण, अन्वेषण और पुनर्प्राप्ति नियंत्रण भी शामिल हैं।
2. सभी सर्वर, डेस्कटॉप, वर्कस्टेशन, हैंड-हेल्ड उपकरण, गेटवे और संगठन के नेटवर्क तक पहुँचने के अन्य मार्गों को मैलिसस गतिविधियों (इनमें वायरस, ट्रोजन, मालवेयर, एडवेयर, स्पाइवेयर आदि शामिल हैं) से संरक्षित किया जाएगा और संरक्षण के उपाय किए जाएंगे।
3. मैलिसस कोड का शीघ्र पता लगाने, उस पर नियंत्रण पाने और उसका उन्मूलन करने में सहयोग के लिए ऐन्टी-वायरस एप्लिकेशन और प्रक्रियाएँ स्थापित की जाएँगी। इसके लिए उपयुक्त प्रयोक्ता जागरूकता उपाय भी लागू किए जाएँगे।
4. अप्राधिकृत सॉफ्टवेयर निष्पादन की रोकथाम के लिए नियंत्रणों पर विचार किया जाएगा।
5. संगठन द्वारा नियंत्रित/ उपयोग की जाने वाली सूचना प्रणालियों में ऐन्टी-वायरस, ऐन्टी-मालवेयर, ऐन्टी-स्पाइवेयर, ऐन्टी-एडवेयर जैसे संरक्षण सॉफ्टवेयर इन्स्टाल करने की आवश्यकता होगी और साथ ही यह सुनिश्चित किया जाएगा कि पहले से ही कम्प्यूटरों और मीडिया को स्कैन करने के लिए मालवेयर का पता लगाने और उसे ठीक करने के सॉफ्टवेयर को नियमित रूप से अपडेट किया जाए।
6. सॉफ्टवेयर आवधिक आधार पर प्रामाणिक मैलिसस सॉफ्टवेयर सूचना स्रोत से अपडेट किए जाने के लिए सक्षम होगा।
7. यह अनिवार्य है कि सॉफ्टवेयर तत्समय संरक्षण उपलब्ध कराए।
8. सॉफ्टवेयर द्वारा पता लगाई गई मैलिसस गतिविधि की रिपोर्ट एक उद्यम प्रणाली को की जाएगी और इस प्रणाली का अनुप्रवर्तन किया जाएगा। जिस

मैलिसस गतिविधि का समाधान नहीं हो पाएगा उसे घटना के रूप में लिया जाएगा और उसे घटना प्रबंधन नीति के अनुसार परिसमापन तक ट्रेक किया जाएगा।

9. महत्वपूर्ण व्यवसाय प्रक्रियाओं में सहयोग करने वाली प्रणालियों के सॉफ्टवेयरों और डाटा कंटेन्ट की नियमित समीक्षा की जाएगी और अननुमोदित फाइलों की उपस्थिति और अप्राधिकृत संशोधनों की औपचारिक जाँच की जाएगी।
10. मालवेयर आक्रमणों से बच निकलने के लिए उपयुक्त व्यवसाय निरंतरता योजना विकसित की जाएगी जिसमें समग्र आवश्यक डाटा और सॉफ्टवेयर बैक-अप और पुनर्प्राप्ति व्यवस्थाएँ शामिल होंगी।
11. डाक सूची के लिए अभिदान या नए मालवेयर की सूचना देने वाली वेबसाइटों के सत्यापन जैसी सूचनाएँ नियमित रूप से प्राप्त करने के लिए उपयुक्त कार्यविधियाँ कार्यान्वित की जाएँगी।

3.6 कमजोरी प्रबंधन

1. संगठन सूचना प्रणालियों और नेटवर्क उपकरणों की तकनीकी कमजोरियों की पहचान करेगा। प्रणालियों की स्कैनिंग के माध्यम से आवधिक रूप से यह पहचान की जाएगी।
2. संगठन तकनीकी कमजोरी प्रबंधन से जुड़ी भूमिकाओं और दायित्वों को परिभाषित और स्थापित करेगा जिसमें कमजोरी अनुप्रवर्तन, कमजोरी जोखिम आकलन, पैचिंग, आस्ति की ट्रैकिंग और अपेक्षित समन्वय संबंधी आवश्यकताएँ शामिल हैं।
3. सॉफ्टवेयर आधारित स्वचालित संरक्षण के अतिरिक्त आईएस टीम परिचालन प्रणाली और एप्लिकेशन विक्रेताओं की सुरक्षा मेल सूचियों को अभिदान कर, एन्टी-वायरस विक्रेताओं से प्राप्त वायरस अलर्ट को ट्रैक कर, सीईआरटी, एनसीआईआईपीसी, आईआरडीएआई जैसे स्वतंत्र सुरक्षा संगठनों से प्राप्त चेतावनियों का ट्रैक रखकर ऐसी नई कमजोरियों का ट्रैक रखने के लिए जिम्मेदार होगी जिनके परिणामस्वरूप वर्म या वायरस आक्रमण हो सकता है।
4. संगठन को सीईआरटी-आईएन, एनसीसीसी, एनसीआईआईपीसी, आईआरडीएआई जैसे सुरक्षा निकायों से प्राप्त साइबर सुरक्षा अधिसूचनाओं और चेतावनियों की मैपिंग को ट्रैक करना चाहिए।
5. संभावनात्मक रूप से संगत तकनीकी कमजोरियों की अधिसूचनाओं पर प्रतिक्रिया के लिए एक समय-सीमा परिभाषित की जाएगी।
6. संगठन की आईएस परिचालन टीम कमजोरियों में निहित जोखिम और उसके प्रभाव के स्तर का आकलन करेगी और कमजोरी की चोट की स्थिति में वास्तविक जोखिम और उसके प्रभाव के स्तर का मूल्यांकन भी करेगी। सहबद्ध जोखिमों के शमन के उपयुक्त उपाय किए जाएंगे।
7. क्लायंट की प्रणाली की कमजोरियों का मापन भी किया जाएगा और सहबद्ध जोखिमों के शमन के उपयुक्त उपाय किए जाएँगे।
8. संगठन आवधिक रूप से रेड टीम अभ्यास भी करेगा ताकि आक्रमणों को रोक पाने की संगठन की तैयारी के स्तर या शीघ्र या प्रभावी ढंग से प्रत्युत्तर देने की क्षमता का परीक्षण किया जा सके।
9. ओपेन, मशीन-रीडेबल मानकों (उदाहरण के लिए, एससीएपी) का उपयोग करते हुए रेड टीम अभ्यास के परिणामों का दस्तावेज़ तैयार किया जाएगा। रेड टीम अभ्यासों के परिणामों के निर्धारण के लिए एक स्कोरिंग पद्धति तैयार की जाएगी ताकि अलग-अलग समय के परिणामों की तुलना की जा सके।
10. अपनाई जाने वाली सभी कार्यविधियों के लिए लेखापरीक्षा लॉग रखा जाएगा।

11. तकनीकी कमजोरी प्रबंधन प्रक्रिया का नियमित अनुप्रवर्तन और मूल्यांकन किया जाएगा ताकि उसकी प्रभावोत्पादकता और दक्षता सुनिश्चित की जा सकें।
12. तकनीकी कमजोरी प्रबंधन प्रक्रिया का घटना प्रबंधन गतिविधियों के साथ सामंजस्य स्थापित किया जाएगा ताकि कमजोरियों से संबंधित डाटा को घटना प्रतिसाद कार्य को संप्रेषित किया जा सके और किसी घटना के होने की स्थिति में अपनाई जाने वाली तकनीकी कार्यविधियाँ उपलब्ध कराई जा सकें।

3.7 आईटी सेवा प्रबंधन

1. संगठन अपनी आईटी सेवाओं के लिए एक परिभाषित और दस्तावेजीकृत सेवा कैटलॉग रखेगा जिसमें संगठन में वर्तमान आईटी सेवाओं की जानकारी दी जाएगी ताकि सभी प्राधिकृत प्रयोक्ताओं को एक ही स्रोत से संगठन-सहमत आईटी सेवाओं की संगत जानकारी उपलब्ध हो सके।
2. व्यवसाय आवश्यकताओं के आधार पर प्रत्येक सूचना प्रणाली के लिए सेवा स्तरों को परिभाषित किया जाएगा।
3. सेवा स्तरों के अनुप्रवर्तन और सेवा स्तरों के उल्लंघन के विश्लेषण के लिए तंत्र स्थापित किया जाएगा। सूचना सुरक्षा को प्रभावित करने वाले उल्लंघन को घटना के रूप में लिया जाएगा और घटना प्रबंधन नीति के अनुसार परिसमापन के लिए उसे ट्रैक किया जाएगा।

3.7 विकास, परीक्षण और परिचालन पर्यावरणों का पृथक्करण

1. परिचालन पर्यावरण में अप्राधिकृत पहुँच और परिवर्तन की जोखिम को कम करने के लिए विकास, परीक्षण और परिचालन पर्यावरणों का पृथक्करण किया जाना चाहिए।
2. किसी सॉफ्टवेयर के विकास से लेकर परिचालन तक की स्थितियों में अंतरण के नियम परिभाषित और दस्तावेजीकृत होंगे।
3. विकास और परिचालन सॉफ्टवेयर अलग-अलग प्रणालियों या कंप्यूटर प्रोसेसरों पर तथा अलग-अलग डोमेनों या डायरेक्टोरियों में रन करेंगे।
4. परिचालन प्रणालियों में परिवर्तनों और एप्लिकेशनों को परिचालन प्रणालियों में लागू करने के पहले परीक्षण या स्टेजिंग पर्यावरण में उनका परीक्षण किया जाएगा।
5. जब आवश्यक न हो, कंपाइलर, एडिटर और अन्य टूल्स या प्रणाली यूटिलिटीज़ तक परिचालन प्रणालियों से पहुँच स्थापित नहीं की जा सकेगी।

6. संवेदनशील डाटा को परीक्षण प्रणाली पर्यावरण में कॉपी नहीं किया जाएगा जब तक परीक्षण प्रणाली के लिए समान नियंत्रण उपलब्ध न कराए गए हों।
7. परिचालन और परीक्षण प्रणालियों के लिए प्रयोक्ता अलग-अलग यूजर प्रोफाइल का उपयोग करेंगे और मेनू में उपयुक्त संदेश प्रदर्शित होंगे ताकि भूल की जोखिम कम हो।

3.8 परिचालन सॉफ्टवेयर का नियंत्रण

1. परिचालन प्रणालियों पर सॉफ्टवेयर के इन्स्टालेशन पर नियंत्रण के लिए कार्यविधियाँ कार्यान्वित की जाएँगी।
2. परिचालन सॉफ्टवेयर, एप्लिकेशनों और प्रोग्राम लाइब्रेरियों का अद्यतनीकरण प्रबंधन से समुचित प्राधिकार प्राप्त करने के बाद प्रशिक्षित प्रशासकों द्वारा किया जाएगा।
3. सम्पूर्ण कार्यान्वित सॉफ्टवेयर और साथ ही प्रणाली दस्तावेजीकरण पर नियंत्रण रखने के लिए एक कन्फिगरेशन नियंत्रण प्रणाली का उपयोग किया जाएगा।
4. परिवर्तनों के कार्यान्वयन के पहले एक रोलबैक रणनीति स्थापित कर ली जाएगी और परिचालन प्रोग्राम लाइब्रेरियों के सभी अपडेटों का लेखापरीक्षा लॉग रखा जाएगा।
5. एप्लिकेशन सॉफ्टवेयर के पूर्व संस्करणों को आकस्मिकता उपाय के रूप में रखा जाएगा और सॉफ्टवेयर के पुराने संस्करणों को सभी सूचनाओं और मानदंडों, कार्यविधियों, कन्फिगरेशन विवरणों के साथ तब तक आर्काइव में रखा जाएगा जब तक डाटा को आर्काइव में रखा जाना है।

3.8 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी टीम	आईएस टीम	सॉफ्टवेयर विक्रेता और ओईएम	अंतिम प्रयोक्ता

नीति सं.:	2.7
नीति का नाम:	2.7 मोबाइल सुरक्षा नीति

1 प्रयोजन

इस नीति का प्रयोजन यह सुनिश्चित करना है कि संगठन के जो संवेदनशील तथा महत्वपूर्ण डाटा कर्मचारियों के मोबाइल उपकरणों पर उनके द्वारा पहुँच-योग्य हैं उन्हें अप्राधिकृत पहुँच तथा अप्राधिकृत सूचना प्रकटन के विरुद्ध संरक्षित किया जा सके।

- कर्मचारियों के स्मार्टफोन और टैबलेट कंप्यूटर जैसे मोबाइल उपकरण जो संगठन के नेटवर्क, डाटा और प्रणालियों तक पहुँच सकते हैं।
- कर्मचारियों द्वारा उपकरणों पर प्रयुक्त एप्लिकेशन जिनमें कंपनी का डाटा भंडारित है या जो कंपनी के डाटा तक पहुँच बना सकते हैं, चाहे वे उपकरण संगठन के स्वामित्व वाले हों या कर्मचारी के।
- फ्लैश ड्राइव, बाह्य हार्ड डिस्क, सीडी आदि जैसे पोर्टेबल उपकरण।

3 नीति

व्यवसाय सूचना तक पहुँच तभी उपलब्ध कराई जाएगी जब प्रयोक्ता एक अंतिम प्रयोक्ता करार हस्ताक्षरित करेगा जिसमें वह अपने कर्तव्यों (भौतिक संरक्षण, सॉफ्टवेयर अद्यतनीकरण आदि) को स्वीकार करेगा, व्यवसाय डाटा के स्वामित्व का त्याग करेगा, उपकरण के चोरी या गुम होने की स्थिति में या सेवा के उपयोग के लिए प्राधिकृत न रह जाने की स्थिति में संगठन द्वारा डाटा को हटाए जाने की अनुमति देगा। यह नीति निजता संबंधी विधान को ध्यान में रखेगी।

यह नीति उपकरण के निजी और व्यवसायगत उपयोग के पृथक्करण को भी शामिल करती है और साथ ही इसमें पृथक्करण तथा निजी उपकरण पर व्यवसाय डाटा के संरक्षण में सहयोगी सॉफ्टवेयर का उपयोग भी शामिल है।

3.1 मोबाइल उपकरण प्रबंधन

1. मोबाइल उपकरण रजिस्ट्रेशन – संगठन की अवसंरचना और एप्लिकेशनों के साथ कनेक्ट होने या उस तक पहुँचने की अनुमति देने के पहले सभी मोबाइल उपकरणों को रजिस्ट्रीकृत और अधिप्रमाणित किया जाएगा।
2. उपकरण का भौतिक संरक्षण – मोबाइल उपकरण के भौतिक संरक्षण का दायित्व प्रयोक्ता का होगा। बीवाईओडी सुरक्षा अपेक्षाओं के लिए बीवाईओडी सुरक्षा नीति को संदर्भित करें।
3. केंद्रीकृत मोबाइल उपकरण प्रबंधन – प्रणाली प्रशासक सभी रजिस्ट्रीकृत मोबाइल उपकरणों के प्रबंधन के लिए एक केंद्रीकृत मोबाइल उपकरण प्रबंधन (एमडीएम) समाधान का प्रयोग करेंगे।
4. प्रयोक्ता पहुँच प्रोफाइल – संगठन के संसाधनों तक पहुँच की अनुमति व्यवसायगत आवश्यकता के आधार पर दी जाएगी।
5. गुम/ चोरी हुए उपकरण – जब संवेदनशील डाटा या संगठन के कनेक्शन की सूचना रखने वाला मोबाइल उपकरण या रिमूवेबल मीडिया गुम या चोरी हो जाता है तो तत्काल एक रिपोर्ट फाइल की जाएगी। विवरण के लिए इस नीति के 'घटना प्रबंधन' खंड को संदर्भित करें।
6. एमडीएम सॉफ्टवेयर की विशेषताएँ - एमडीएम समाधान में कम-से-कम निम्नलिखित विशेषताएँ होंगी:
 - उपकरण और अन्य सम्बद्ध भंडारण उपकरण में निहित सम्पूर्ण सूचना को सुरक्षित रूप से नष्ट करने के लिए डिलीट करना (जिसे प्रायः दूर से हटा देना कहते हैं)।
 - डाटा एन्क्रिप्शन – मोबाइल उपकरण हार्डवेयर एन्क्रिप्शन का उपयोग करेंगे और फाइल-आधारित एन्क्रिप्शन सॉफ्टवेयर लगाएँगे।
 - मोबाइल उपकरणों का उपयोग करने वाले कर्मिकों के लिए प्रशिक्षण की व्यवस्था की जाएगी ताकि इस तरीके से काम करने से संभावित अतिरिक्त जोखिम के बारे में और कार्यान्वित किए जाने वाले नियंत्रणों को लेकर उनकी जागरूकता में वृद्धि हो।

3.2 घटना की रिपोर्टिंग

1. अपने उपकरण के खो जाने या चोरी हो जाने के मामले में एमडीएम प्रयोक्ता डाटा को हटाने के लिए तत्काल प्रणाली प्रशासक को रिपोर्ट करेंगे।
2. यदि कोई हेरफेर करने या भंडारित डाटा को डिलीट करने के लिए कोई उपकरण हैक कर लिया जाता है तो उपकरण का स्वामी तत्काल कार्रवाई करेगा और प्रणाली प्रशासक को रिपोर्ट करेगा।

3.3 लॉग प्रबंधन

एमडीएम के लिए विस्तृत लॉग विवरण अभिलिखित और प्रबंधित किया जाएगा।

3.8 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी टीम	आईएस टीम	सॉफ्टवेयर विक्रेता और ओईएम	अंतिम प्रयोक्ता

नीति सं.:

2.8

नीति का नाम:

2.8 अपना उपकरण लाओ (बीवाईओडी) नीति

1 प्रयोजन

बीवाईओडी नीति कॉर्पोरेट ईमेल, एप्लिकेशनों और डाटा तक पहुँच स्थापित करने के लिए कर्मचारी के स्वामित्व वाले उपकरणों (उदाहरण के लिए टैबलेट, स्मार्टफोन और अन्य समतुल्य) के उपयोग को संचालित करती है।

इस नीतिगत दस्तावेज़ के प्रयोजन निम्नानुसार हैं:

i) कॉर्पोरेट डाटा तक पहुँच स्थापित करने के लिए अपने व्यक्तिगत स्वामित्व वाले टैबलेट/ स्मार्टफोन के उपयोग के लिए कर्मचारी की पात्रता को परभाषित करना।

ii) व्यक्तिगत स्वामित्व वाले उपकरणों के उपयोग से संबंधित दायित्वों, दिशानिर्देशों और निबंधनों को परिभाषित करना।

इस नीति को नीचे विभिन्न खंडों में यथासंदर्भित संगठन सूचना सुरक्षा नीतियों के प्रावधानों के अंतर्गत परिभाषित किया गया है। तथापि, इस नीति और सूचना सुरक्षा नीतियों के बीच संघर्ष की स्थिति में सीआईएसओ उसके समाधान के लिए जिम्मेदार होगा। अधिक जानकारी के लिए 'सामान्य दिशानिर्देश संचालन iii) स्वामित्व और निर्वचन' का संदर्भ लें।

2 दायरा

यह नीति निम्नलिखित पर लागू होती है:

- कर्मचारियों के स्वामित्व में स्थित सभी मोबाइल उपकरण जो संगठन के नेटवर्क, डाटा और प्रणाली तक पहुँच रखते हैं। इन उपकरणों में स्मार्टफोन, मोबाइल या सेल्यूलर फोन, पीडीए और टैबलेट कम्प्यूटर शामिल हैं।
- कर्मचारियों द्वारा अपने व्यक्तिगत उपकरणों पर उपयोग किए जाने वाले एप्लिकेशन, जो कॉर्पोरेट डाटा को भंडारित करते हैं या उन तक पहुँच रखते हैं।
- कार्यालय समय के दौरान, पहले और बाद में उपकरण का उपयोग चाहे वह उपयोग सामान्य कार्यस्थल पर हो या अन्यत्र।

यह नीति लैपटॉप पर लागू नहीं होती।

यह दस्तावेज़, संगठन के कर्मचारियों द्वारा संगठन के संसाधनों और/ या सेवाओं तक पहुँच स्थापित करने के लिए अपने स्वामित्व वाले स्मार्ट फोन और/ या टैबलेट के उपयोग के लिए नीतियाँ और व्यवहार के नियम उपलब्ध कराता है। पहुँच और उसे जारी रखने की अनुमति इस शर्त पर दी जाएगी कि प्रत्येक प्रयोक्ता इन संसाधनों और/ या सेवाओं के उपयोग से संबंधित संगठन की नीतियों को पढ़ ले, उन पर हस्ताक्षर करे, उनका आदर करे और उनका अनुसरण करे। इस नीति का आशय यह है कि संगठन के डाटा और प्रौद्योगिकीय अवसंरचना की सुरक्षा और सत्यनिष्ठा का संरक्षण किया जाए। उपकरणों और प्लेटफॉर्मों में भिन्नताओं के कारण नीति में सीमित अपवादों की गुंजाइश होती है।

3.1 पात्रता और स्वामित्व

1. सभी पूर्णकालिक कर्मचारियों को यह अनुमति दी जाएगी कि वे अपने व्यक्तिगत स्वामित्व वाले उपकरणों को कॉर्पोरेट ईमेल, एप्लिकेशन और डाटा तक पहुँच के लिए कन्फ़िगर करें (बीवाईओडी कार्यक्रम)।
2. प्रबंधन के विधिवत् अनुमोदन (अलग-अलग मामले की गुणवत्ता के आधार पर) के बाद संविदाकर्ता या तृतीय पक्ष कर्मचारी बीवाईओडी कार्यक्रम के अंतर्गत व्यक्तिगत उपकरणों को एनरोल कर सकते हैं।

3.2 स्वीकार्य उपकरण

1. संगठन का आईटी कार्य उपकरणों के ऐसे मॉडलों की एक 'श्वेत सूची' बनाकर रखेगा जिन्हें प्रौद्योगिकीय अनुकूलता के अनुसार और सुरक्षा संबंधी तथ्यों को ध्यान में रखते हुए बीवाईओडी कार्यक्रम के अंतर्गत कन्फ़िगर किया जा सकता है। आईटी कार्य द्वारा इस सूची को आवधिक रूप से अद्यतन किया जाएगा।
2. संगठन निम्नलिखित ओएस प्लेटफॉर्मों वाले उपकरणों का समर्थन करेगा लेकिन ये प्लेटफॉर्म इन्हीं तक सीमित नहीं हैं:
 - ☐ एन्ड्रॉयड – ओएस वर्जन 8.0 और उससे अधिक
 - ☐ एप्पल – आईओएस 12 और उससे अधिक
 - ☐ विंडोज़ - ओएस वर्जन 8.0 और उससे अधिक
3. संगठन का बीवाईओडी कार्यक्रम परिचालन प्रणालियों के ग्राहक-अनुकूल बनाए गए, "रूटेड" या "जेल ब्रोकेन" वर्जनों का उपयोग करने वाले व्यक्तिगत उपकरणों (मोबाइल/ लैपटॉप) का समर्थन नहीं करता।
4. उपकरण में परिचालन प्रणाली का लाइसेंसीकृत वर्जन इंस्टाल होना अनिवार्य है।

3.3 उपकरण का सेट-अप

संगठन का आईटी कार्य बीवाईओडी एनरोलमेंट के लिए एक सेल्फ-कन्फ़िगरेशन पोर्टल स्थापित करेगा। पात्र कर्मचारियों को इस पोर्टल तक पहुँच उपलब्ध कराई जाएगी ताकि वे अपने उपकरणों को सेट-अप और कन्फ़िगर कर सकें। यदि कोई समस्या आती है तो संगठन का आईटी कार्य कन्फ़िगरेशन में सहयोग करेगा।

3.4 निरंतर सहयोग और उपकरण का रखरखाव	1. संगठन के आईटी कार्य बीवाईओडी कार्यक्रम के भाग के रूप में एनरोल किए गए उपकरणों पर कॉर्पोरेट एप्लिकेशनों और कॉर्पोरेट डाटा के लिए सहयोग प्रदान करेंगे। 2. संगठन का आईटी कार्य कर्मचारियों के व्यक्तिगत उपकरणों के हार्डवेयर / सॉफ्टवेयर संबंधी गैर-कॉर्पोरेट मामलों के प्रबंधन में सहयोग की ज़िम्मेदारी नहीं उठाएगा।
3.5 कर्मचारी / उपकरण निकास (बहिर्गमन) प्रक्रिया	1. संगठन से कर्मचारी का त्यागपत्र / बहिर्गमन – कृपया 'सुरक्षा नीतियाँ – मानव संसाधन सुरक्षा' को संदर्भित करें। 2. फरार कर्मचारी के मामले में मानव संसाधन कार्य शीघ्रातिशीघ्र आईटी कार्य को सूचित करेगा। आईटी कार्य उसके उपकरण से कॉर्पोरेट डाटा को दूर से ही मिटा देगा। यदि डाटा को दूर से हटाना संभव न हो तो इसकी रिपोर्ट 'सुरक्षा नीतियाँ – घटना और समस्या प्रबंधन' के अनुसार सूचना सुरक्षा घटना के रूप में की जाएगी। 3. उपकरण के गुम हो जाने के मामले में कर्मचारी 4 घंटे के भीतर आईटी कार्य को सूचित करेगा। आईटी कार्य नीचे परिभाषित अनुबंध 1 के अनुसार उपकरण से कॉर्पोरेट डाटा को दूर से ही मिटा देगा। 4. संगठन 'सुरक्षा नीतियाँ – पहुँच नियंत्रण' में परिभाषित उपयुक्त पहुँच नियंत्रणों को लागू करने के लिए बीवाईओडी कार्यक्रम के अंतर्गत एनरोल किए गए उपकरणों पर उपयुक्त सूचना सुरक्षा नियंत्रण तैनात करेगा। 5. इसमें एक मोबाइल उपकरण प्रबंधन (एमडीएम) टूल का इन्स्टालेशन शामिल हो सकता है।
3.6 आवधिक लेखापरीक्षा और अनुपालन का उपचार	आईटी कार्य 'सामान्य दिशानिर्देश: स्वीकार्य उपयोग – (II) कार्यालयीन प्रयोजनों के लिए व्यक्तिगत उपकरण का स्वीकार्य उपयोग बिन्दु (ग)' के अनुसार उपकरण कन्फिगरेशन का अनुप्रवर्तन या आवधिक समीक्षा करने के लिए प्राधिकृत होगा ताकि संगठन की नीतियों के अपवादों की पहचान की जा सके। मोबाइल उपकरण का अनुप्रवर्तन और गतिविधियों की लॉगिंग का कार्य 'सुरक्षा नीतियाँ: अनुप्रवर्तन, लॉगिंग और आकलन' के अनुपालन में किया जाएगा।
3.7 अनुबंध 1	
3.7.1 प्रमुख परिभाषाएँ	
3.7.1. 1 डाटा वर्गीकरण	1. कॉर्पोरेट डाटा – कॉर्पोरेट डाटा से संगठन या उससे सहबद्ध संस्थाओं के एप्लिकेशन और डाटा अभिप्रेत हैं जिनमें ईमेल, कैलेंडर, संपर्क विवरण, कॉर्पोरेट एप्लिकेशन, दस्तावेज़, चित्र आदि शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं। इनका वर्गीकरण 'सुरक्षा नीतियाँ: डाटा वर्गीकरण' के अनुसार किया जाएगा। 2. व्यक्तिगत डाटा – कर्मचारी के उपकरण पर मौजूद कॉर्पोरेट डाटा से इतर कोई डाटा/ एप्लिकेशन।

**3.7.1. उपकरण का
2 प्रकार**

1. स्मार्टफोन - स्मार्टफोन किसी मोबाइल परिचालन प्रणाली पर निर्मित एक मोबाइल फोन है जिसमें हैंडहेल्ड कंप्यूटर से अधिक सामान्य फीचर होते हैं और किसी फीचर फोन से अधिक उन्नत कम्प्यूटिंग क्षमता और कनेक्टिविटी होती है।
2. टैबलेट - टैबलेट एक वायरलेस, पोर्टेबल व्यक्तिगत कंप्यूटर है जिसमें टचस्क्रीन इंटरफेस होता है। टैबलेट का आकार सामान्य रूप से स्मार्टफोन से बड़ा होता है।
3. मोबाइल उपकरण प्रबंधन (एमडीएम) का अर्थ है वह विशिष्ट सॉफ्टवेयर जिसका उद्देश्य है मोबाइल एप्लिकेशनों, डाटा कन्फिगरेशन सेटिंग का वितरण और मोबाइल फोन, स्मार्टफोन और टैबलेट कंप्यूटर जैसे मोबाइल उपकरणों में आईटी संचालन का कार्यान्वयन। एमडीएम की मंशा है लागत और उपकरण के डाउन रहने के समय को न्यूनतम रखते हुए सुविधाजनक कन्फिगरेशन, सेल्फ-सर्विस और सक्षम सुरक्षा उपलब्ध कराने के साथ-साथ तत्समय प्रबंधन क्षमता प्रदान करना।

**3.7.2 व्यक्तिगत
उपकरणों की
सुरक्षा**

कॉर्पोरेट डाटा तक पहुँच रखने वाले व्यक्तिगत उपकरणों पर निम्नलिखित न्यूनतम सुरक्षा नियंत्रण कन्फिगर किए जाएँगे:

**3.7.2. उपकरण सुरक्षा
1**

1. उपकरण पास-कोड: उपकरण तक पहुँच को या तो 4 अंक वाले उपकरण पास-कोड या शैली पहचान प्रणाली के माध्यम से संरक्षित किया जाएगा। उपकरण में निहित कॉर्पोरेट डाटा 10 असफल लॉग-ऑन प्रयासों के बाद स्वतः ही हट/ मिट जाएगा।
2. संगठन के एप्लिकेशनों/ डाटा तक पहुँच: जैसा कि 'सुरक्षा नीतियाँ: पहुँच नियंत्रण' में परिभाषित है, संगठन के समस्त एप्लिकेशनों और/ या डाटा तक पहुँच द्विकारकीय अधिप्रमाणन पर आधारित होगी।
3. उपकरण का लॉक होना: कोई गतिविधि न होने की स्थिति में उपकरण 5 मिनट बाद स्वतः लॉक हो जाएगा।
4. उपकरण की ट्रैकिंग: किसी कर्मचारी का हैंडसेट किस स्थान पर है, यह निर्धारित करने के लिए उपकरणों में उसकी अवस्थिति को ट्रैक करने वाला सॉफ्टवेयर इन्स्टाल किया जाएगा।
5. दूर से लॉक करना: किसी फोन या टैबलेट के गुम होने या चोरी हो जाने की स्थिति में स्वयं कर्मचारी या संगठन का आईटी कार्य उसे दूर से ही लॉक कर पाएगा या निर्दिष्ट उपकरण को ही मिटा देगा।
6. जेलब्रेक का पता लगाना: उपकरणों पर ऐसे खोजी टूल इन्स्टाल किए जाएँगे जो इस बात के साक्ष्य के लिए एक समग्र खोज संपादित कर सकेंगे कि उपकरण में अंतर्निर्मित प्रणाली-संरक्षणों को अक्षम बना दिया गया है।

**3.7.2. डाटा सुरक्षा
2**

1. दूर से डाटा हटाना: इस नीति के अंतर्गत एनरोल किए गए उपकरणों को एमडीएम सॉफ्टवेयर जैसे उपयुक्त साधन के माध्यम से दूर से ही मिटाए जा सकने की क्षमता के साथ कन्फिगर किया जाएगा।
2. डाटा एन्क्रिप्शन और कंटेनराइजेशन: कृपया 'सुरक्षा नीतियाँ: क्रिप्टोग्राफिक नियंत्रण' को संदर्भित करें।
3. एप्लिकेशन को काली सूची में डालना: संगठन का आईटी कार्य ऐसे एप्लिकेशनों की सूची तैयार करेगा जिन्हें प्रणाली तक पहुँच उपलब्ध कराने से मना करना है और उन्हें इन्स्टाल करने या रन करने से रोकना है।

**3.8 स्वीकार्य
उपयोग**

कृपया 'सामान्य दिशानिर्देश: स्वीकार्य उपयोग नीति' का संदर्भ लें।

**3.9 आरएसीआई
मैट्रिक्स**

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
कर्मचारी	व्यवसाय प्रक्रिया के स्वामी	आईएस और आईटी	सीआरओ/ सीटीओ

नीति सं.:	2.9
नीति का नाम:	2.9 परिवर्तन नियंत्रण

- 1 **प्रयोजन** संगठन के सूचना संसाधनों में सभी परिवर्तनों की दक्षतापूर्ण और त्वरित हैंडलिंग के लिए संगत और प्रणालीबद्ध कार्यपद्धतियाँ परिभाषित करना ताकि सूचना आस्तियों पर परिवर्तनों के प्रभाव को न्यूनतम किया जा सके।
- 2 **दायरा** संगठन की सूचना प्रणालियों में कोई भी परिवर्तन, जो उन संसाधनों को प्रभावित कर सकता है जिन पर संगठन अपने सामान्य व्यवसाय के परिचालन के लिए निर्भर करता है, इस नीति के दायरे में आता है। नीचे सूची में सामान्य प्रकार के परिवर्तनों का उल्लेख किया गया है, लेकिन यह सूची सम्पूर्ण नहीं है:
 - सॉफ्टवेयर का उन्नयन, अद्यतनीकरण या उसमें कुछ अतिरिक्त जोड़ना
 - आईटी अवसंरचना में परिवर्तन
 - निवारणात्मक अनुरक्षण
 - सुरक्षा पैच
 - प्रणाली के स्थापत्य और कन्फिगरेशन में परिवर्तन
 - हार्डवेयर उन्नयन
 - उत्पाद प्रबंधन

3	नीति	संगठन के सूचना संसाधनों में किए जाने वाले सभी परिवर्तन नियंत्रित रीति से किए जाएंगे ताकि यह सुनिश्चित किया जा सके कि परिवर्तनों से सम्बद्ध जोखिमों को स्वीकार्य स्तर पर रखने का प्रबंध किया जा सके। परिवर्तन प्रबंधन की कार्यविधियों को दस्तावेजीकृत किया जाएगा और संगठन की सूचना आस्तियों में सभी परिवर्तन मानक परिवर्तन प्रबंधन कार्यविधियों का अनुसरण करेंगे। जिन परिवर्तनों में ऐसी आपातकालीन कार्रवाइयों और प्रतिसाद प्रक्रिया की आवश्यकता होती है जिनमें निर्धारित नीतियों और कार्यविधियों की उपेक्षा करनी पड़ती है, उनके लिए उपयुक्त कार्यविधियाँ स्थापित की जाएंगी। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।
3.1	परिवर्तन संचालन	आईटी संचालन संरचना के अनुसार परिवर्तन संचालन का अनुसरण किया जाएगा।
3.2	परिवर्तन वर्गीकरण का	1. निम्नलिखित कारकों के आधार पर सभी परिवर्तनों का वर्गीकरण किया जाएगा: • परिवर्तन से प्रभावित डाटा; • संगठन के आईटी पर्यावरण पर परिवर्तन का प्रभाव। 2. सभी परिवर्तन नीचे उल्लिखित परिवर्तन जीवनचक्र का अनुसरण करेंगे और परिवर्तन के वर्गीकरण के आधार पर उपयुक्त अनुमोदनों की आवश्यकता होगी। प्रमुख परिवर्तनों और “पहचाने गए सीआर प्रकारों” को प्रौद्योगिकी जोखिम आकलन (टीआरए) से गुजारा जाएगा जिसका निष्पादन आईएस टीम द्वारा परिभाषित टीआरए मानकों के अनुसार आईटी टीम द्वारा किया जाएगा। आईएस टीम द्वारा आवधिक रूप से टीआरए के परिणामों की समीक्षा की जाएगी।
3.3	परिवर्तन जीवनचक्र	1. सूचना प्रणाली में परिवर्तनों के विकास और परीक्षण के लिए अलग पर्यावरण सृजित और अनुरक्षित किए जाएंगे। 2. परीक्षण और विकास पर्यावरणों को कम-से-कम उत्पादन प्रणालियों से भौतिक और तार्किक रूप से पृथक्कृत किया जाएगा और साथ ही यह सुनिश्चित किया जाएगा कि कोई भी प्रयोक्ता एक साथ दोनो पर्यावरणों तक पहुँच स्थापित नहीं करेगा। 3. उत्पादन डाटा को परीक्षण/ विकास पर्यावरण में अंतरित करने से बचा जाएगा। जिन मामलों में उत्पादन डाटा को परीक्षण/ विकास पर्यावरण में अंतरित करना आवश्यक होगा, उन मामलों में उत्पादन पर्यावरण के समतुल्य स्तर का संरक्षण लागू किया जाएगा, और ऐसा नहीं होने पर किसी भी स्थिति में उत्पादन डाटा को इन पर्यावरणों में अंतरित नहीं किया जाएगा। 1. संगठन की सूचना आस्तियों में किए जाने वाले सभी परिवर्तन निम्नलिखित परिवर्तन जीवनचक्र का पालन करेंगे: • परिवर्तन के लिए अनुरोध - परिवर्तन के लिए अनुरोध को औपचारिक रूप से आगे बढ़ाया जाएगा और अभिलिखित किया जाएगा। इसके बाद यथालागू औपचारिक व्यवसाय आवश्यकता परिभाषा, प्रभाव और साध्यता विश्लेषण किया जाएगा।

- प्रभाव विश्लेषण परिवर्तन का अनुरोध करने वाले द्वारा किया जाएगा और उसमें संभावित वित्तीय, परिचालनगत, विनियामकीय, प्रौद्योगिकीय और अन्य प्रभावों का आकलन शामिल किया जाएगा।
 - परिवर्तन का अनुमोदन – सभी परिवर्तनों का विधिवत् अनुमोदन आईएस टीम द्वारा परिभाषित परिवर्तन को प्राधिकृत करने के मैट्रिक्स के अनुसार समुचित व्यक्तियों द्वारा किया जाएगा।
 - परिवर्तनों की प्राथमिकता तय करना – परिवर्तन कार्यान्वयन टीम(मों) द्वारा परिवर्तन के महत्व और सूचना आस्ति पर परिवर्तन के प्रभाव के आधार पर परिवर्तनों की प्राथमिकता निर्धारित की जाएगी।
 - परिवर्तनों का परीक्षण – परीक्षण पर्यावरण में सभी परिवर्तनों का परीक्षण किया जाएगा जिसमें आईएस टीम द्वारा परिवर्तन प्रबंधन कार्यविधि में यथापरिभाषित परिवर्तन-प्रकार के आधार पर अलग-अलग स्तर के परीक्षण शामिल हैं जैसे, प्रणाली स्वीकरण परीक्षण (एसएटी), प्रणाली एकीकरण परीक्षण (एसआईटी), प्रयोक्ता स्वीकरण परीक्षण (यूएटी) आदि।
 - रोलबैक – सभी परिवर्तनों में परिवर्तन को बीच में ही रोक देने और असफल परिवर्तनों के बाद रिकवर करने के लिए एक रोलबैक कार्यविधि शामिल की जानी चाहिए।
 - माइग्रेशन – उपयुक्त अनुमोदनों के बाद और प्राधिकृत व्यक्तियों द्वारा सभी परिवर्तनों को उत्पादन पर्यावरण पर माइग्रेट कराया जाएगा। यह सुनिश्चित करने के लिए प्रतिबंध रखे जाएंगे कि उत्पादन और विकास/ परीक्षण पर्यावरणों तक पहुँच को विधिवत् पृथक्कृत किया गया है।
 - दस्तावेजीकरण को अद्यतन रखना – समग्र संगत दस्तावेजीकरण को अद्यतन रखा जाएगा ताकि उसमें परिवर्तन का प्रभाव परिलक्षित हो। सभी परीक्षण अभिलेखों का भी औपचारिक दस्तावेज़ तैयार कर उसका रखरखाव किया जाएगा।
2. परिवर्तन प्रबंधन कार्यविधि में यथापरिभाषित आपातकालीन परिवर्तनों को उनकी अत्यावश्यक प्रकृति के कारण ऊपर उल्लिखित परिवर्तन जीवनचक्र के अनुसरण से छूट दी जाएगी।
 3. वेबसाइट के सभी अपडेटों की समीक्षा, अनुमोदन और परीक्षण के कार्य स्वतंत्र रूप से किए जाएंगे।
 4. लेकिन सभी आपातकालीन परिवर्तनों का समुचित दस्तावेजीकरण किया जाएगा और संगत प्राधिकारियों से कार्योत्तर अनुमोदन प्राप्त किया जाएगा।
जब भी परिवर्तन किए जाते हैं, एक लेखापरीक्षा लॉग प्रतिधारित किया जाएगा जिसमें सभी संगत सूचनाएँ रखी जाएँगी।
 5. आपातकालीन नियंत्रण कार्यविधियों का दस्तावेज़ तैयार किया जाएगा ताकि किसी मौखिक अनुमोदन के दिए जाने के बाद परिचालन प्रमुख से ईमेल पर प्राप्त अनुमोदनों को कैप्चर किया जा सके।

3.4 निर्गम प्रबंधन

1. संगठन के भीतर पहले से तैयार (पैकेज्ड) और आवश्यकता के हिसाब से तैयार कराए गए (बिस्पोक) एप्लिकेशनों के निर्गम के लिए औपचारिक निर्गम प्रबंधन प्रक्रिया का अनुसरण किया जाएगा।
2. संगठन की निर्गम प्रबंधन प्रक्रिया में निम्नलिखित को ध्यान में रखा जाएगा:
3. तृतीय पक्ष द्वारा जारी निर्गमों के लिए किसी नए निर्गम के कार्यान्वयन के पूर्व समुचित अवधि के विलंब की अनुमति होगी ताकि निर्गम के साथ जुड़ी आरंभिक समस्याओं के प्रदाता द्वारा समाधान के लिए समय मिल सके।

4. सभी निर्गमों से संबंधित जानकारी सभी संगत हितधारकों को निर्गम से पर्याप्त पूर्व संप्रेषित की जाएगी।
5. उपयुक्त संस्करण नियंत्रण कार्यविधियों का अनुसरण किया जाएगा ताकि निर्गम और उसके समर्थक दस्तावेजीकरण का संस्करण नियंत्रण सुनिश्चित किया जा सके।
6. एक निर्गम दस्तावेज़ तैयार किया जाएगा और प्रत्येक निर्गम के साथ उपलब्ध कराया जाएगा। इस दस्तावेज़ में निर्गम से संबंधित विवरण होंगे, जैसे कि लक्ष्य और उद्देश्य, प्रक्रिया प्रवाह, निर्गम योजना, निर्गम निर्माण, स्वीकरण परीक्षण, निर्गम की तैयारी, निर्गम की तैनाती और भूमिकाएँ तथा दायित्व।

3.5 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	संपर्क किससे	सूचित किसको
परिवर्तन का अनुरोधकर्ता	आईटी	जोखिम प्रबंधन टीम	व्यवसाय प्रयोक्ता

नीति सं.: 2.10

नीति का नाम: 2.10 घटना और समस्या प्रबंधन

- 1 **प्रयोजन** घटना से ऐसी आपवादिक स्थिति अभिप्रेत है जिसके कारण संगठन की सूचना आस्तियों की गोपनीयता, सत्यनिष्ठा या उपलब्धता के साथ समझौते की सम्भावना हो। समस्या प्रबंधन में वे गतिविधियाँ शामिल हैं जो घटना के मूल कारण के निदान के लिए और समस्याओं के समाधान के लिए आवश्यक होती हैं। यह नीति घटना और समस्या प्रबंधन के संबंध में संगठन की वांछित कार्यपद्धतियों को परिभाषित करती है।
- 2 **दायरा** यह नीति सूचना सुरक्षा नीतियों या इस नीति के आधार पर आईएस टीम द्वारा परिभाषित प्रक्रियाओं/ मानकों के उल्लंघन के परिणामस्वरूप हुई सभी घटनाओं पर लागू होती है। इसमें निम्नलिखित शामिल हैं लेकिन यह इन्हीं तक सीमित नहीं है:
 - किसी प्रणाली या उसके डाटा तक अप्राधिकृत पहुँच के प्रयास (सफल या असफल);
 - सेवा में अवांछित अवरोध या सेवा की मनाही;
 - डाटा प्रसंस्करण या भंडारण के लिए किसी अप्राधिकृत प्रणाली का उपयोग;
 - प्रणाली हार्डवेयर, फर्मवेयर या सॉफ्टवेयर की विशेषताओं में स्वामी की जानकारी, अनुदेश या सहमति के बिना परिवर्तन।
 सूचना प्रौद्योगिकी का उपयोग करने वाली सभी व्यवसाय इकाइयों या विभागों को अनिवार्य रूप से इन सूचना सुरक्षा नीतियों का अनुपालन करना होगा।
- 3 **नीति** संगठन सूचना सुरक्षा के दैनंदिन प्रशासन में होने वाली घटनाओं का पता लगाने, उनकी रिपोर्ट करने और उन पर प्रतिक्रिया करने तथा उनका विश्लेषण करने और उन्हें परिसमापन तक ट्रैक करने की कार्यविधियों का कार्यान्वयन करेगा। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 परिभाषाएँ

1. सुरक्षागत/ परिचालनगत घटना:

- सुरक्षागत/ परिचालनगत घटना ऐसी प्रतिकूल घटना है,
- जिसमें आईटी संसाधन पर आक्रमण होता है या आक्रमण का खतरा होता है;

- जिसमें बिना प्राधिकार के आईटी संसाधन तक पहुँच स्थापित की जाती है/ उसका अनुप्रवर्तन किया जाता है/ उसमें आशोधन किया जाता है; और
- जिसमें आईटी संसाधन का उपयोग संगठन की स्थापित नीति/ विनियामकीय नीति से असंगत रीति से किया जाता है जिसके परिणामस्वरूप आईटी संसाधन या सूचना की गोपनीयता, सत्यनिष्ठा और उपलब्धता की वास्तविक या संभावित हानि होती है।

सुरक्षागत घटनाओं के उदाहरण निम्नानुसार हैं:

- आईटी प्रणाली या उसके डाटा तक अप्राधिकृत पहुँच स्थापित करने के आंतरिक या बाह्य प्रयास (सफल या असफल);
- डीएलपी उल्लंघन;
- प्रोक्सी नियमों के अनुसार ब्लॉक की गई साइटों तक पहुँच स्थापित करने के प्रयास (सफल या असफल);
- सेवा की मनाही (डीओएस) या आईटी प्रणाली और अवसंरचना में अप्राधिकृत अवरोध;
- संगठन के मालिकाना, गोपनीय या न्यास के रूप में रखी गई सूचना की वास्तविक या संदिग्ध हानि;
- विभाग प्रमुख की जानकारी, अनुदेश या सहमति के बिना प्रणाली हार्डवेयर, फर्मवेयर या सॉफ्टवेयर की विशेषताओं में परिवर्तन;
- मैलिसस कोड (वायरस, ट्रोजन हॉर्स) आक्रमण;
- सोशल इंजीनियरिंग (किसी चक्कर में डाल कर किसी से पासवर्ड जैसी गोपनीय/ मालिकाना सूचना हासिल कर लेना जिससे प्रणाली की सुरक्षा भंग हो सकती हो);
- हस्ताक्षर अद्यतन करने में विफलता; और
- छलपूर्ण कार्य (जानबूझ कर ऐसे चक्कर में डालना जिससे कोई लाभ उठाया जा सके - उदाहरण के लिए, वायरस की झूठी चेतावनी के परिणामस्वरूप कुछ प्रयोक्ता वायरस संबंधी सभी चेतावनियों को नज़रअंदाज कर सकते हैं और वास्तविक विनाशकारी वायरस के शिकार हो सकते हैं।)

परिचालनगत घटनाओं के उदाहरण निम्नानुसार हैं:

- फायरवाल हार्डवेयर विफलता;
- एंटी-वायरस अप्लायन्स हार्डवेयर विफलता; और
- आईडीएस हार्डवेयर विफलता।

2. समस्या / घटना:

घटना किसी प्रणाली, नेटवर्क या दैनिक परिचालनों में घटित होती है और वह देखी गई होती है या देखी जा सकने योग्य होती है।

किसी सामान्य घटना को घटना तब कहते हैं जब वह आईटी प्रणाली/ अवसंरचना पर 'प्रतिकूल' प्रभाव डाले या पूर्व-स्थापित ऐसे मानदंडों के माध्यम से घटित हो जो ऐसी परिस्थितियों का विवरण देते हैं जिनके अंतर्गत घटनाएँ स्वतः ही प्रतिकूल मान ली जाती हैं।

कोई विशेष परिस्थिति तब घटना में रूपांतरित होगी जब घटना प्रतिसाद टीम द्वारा उसका विश्लेषण कर उसे 'प्रतिकूल' के रूप में वर्गीकृत किया जाए।

जब तक किसी विशेष परिस्थिति को 'प्रतिकूल नहीं' के रूप में वर्गीकृत नहीं किया जाता, तब तक उन्हें 'संदिग्ध घटना' माना जाएगा।

3. घटना प्रतिसाद टीम (आईआरटी)

घटनाओं और उनके समाधान के लिए तत्काल कार्रवाई शुरू करने हेतु घटना प्रतिसाद टीम (आईआरटी) का गठन किया जाता है। यह टीम अग्रसक्रिय होकर घटनाओं से उत्पन्न खतरों/ जोखिमों के निवारण के लिए दिशानिर्देश जारी करती है। यद्यपि घटनाओं की गंभीरता तथा प्रभाव के आधार पर उन्हें विभिन्न स्तरों पर हैंडल किया जाएगा, लेकिन अधिकांश घटनाओं को घटना प्रतिसाद टीम के नेतृत्वकर्ता के स्तर पर ही हैंडल किया जाएगा।

इस टीम में निम्नलिखित सदस्य होंगे:

- घटना प्रबंधन नेतृत्वकर्ता (आईएमएल):
सीआरओ और सीओओ मिलकर संगठन में आईएमएल की भूमिका निभाते हैं। घटना प्रबंधन समन्वयक घटनाओं की कार्रवाइयों के बारे में आईएमएल को अवगत रखेंगे और उसकी रिपोर्ट नियंत्रण प्रबंधन समिति को की जाएगी। किसी भी घटना की स्थिति में आईएमएल या उसके द्वारा नामनिर्दिष्ट व्यक्ति ही आधिकारिक रूप से मीडिया से संवाद करेगा।
- घटना प्रबंधन समन्वयक (आईएमसी):
सीआईएसओ और सीटीओ मिलकर संगठन में आईएमसी की भूमिका निभाएंगे। आईएमसी घटना के परिणामस्वरूप होने वाली क्षति को रोकने के लिए घटना प्रतिसाद टीम के साथ मिलकर काम करेंगे और वे रिकवरी के प्रयासों के लिए केंद्रीय बिन्दु होंगे।
- घटना प्रतिसाद टीम नेतृत्वकर्ता (आईआरटीएल):
व्यवसाय निरंतरता से संबंधित सभी घटनाओं के लिए बीसीएम प्रबन्धक घटना प्रतिसाद टीम का नेतृत्वकर्ता होगा। आईटी से संबंधित सभी समस्याओं और घटनाओं को आईटी प्रबन्धक द्वारा हैंडल किया जाएगा। आईएस से संबंधित सभी मामलों के लिए सीआईएसओ टीम का नेतृत्वकर्ता होगा। भौतिक सुरक्षा जैसी गैर-आईटी घटनाओं को प्रशासनिक प्रमुख द्वारा प्रबंधित किया जाएगा। घटनाओं पर कार्रवाई का कार्य आईआरटीएल द्वारा घटना प्रतिसाद टीम के सदस्यों में प्रत्यायोजित किया जाएगा।
- घटना प्रतिसाद टीम के सदस्य:
किसी भी घटना पर कार्रवाई से पहले घटना प्रतिसाद टीम के सदस्यों को आईआरटीएल द्वारा विस्तृत जानकारी दी जाएगी। आगे और जानकारी प्राप्त करने के लिए उन्हें उस व्यक्ति से भी मिलना चाहिए जिसने घटना की रिपोर्ट की हो। आईआरटीएल और आईआर टीम के सदस्यों के पास सम्पूर्ण घटना प्रतिसाद टीम, विक्रेताओं, आपूर्तिकर्ताओं, सेवाप्रदाताओं आदि के आपातकालीन संपर्क विवरण अनिवार्य रूप से होने चाहिए। घटना प्रतिसाद टीम के संपर्क नंबरों का एक आपातकालीन जेबी कार्ड तैयार कर सभी कर्मचारियों को वितरित किया जाएगा।
- सहायता डेस्क टीम:
सहायता डेस्क टीम की जिम्मेदारियाँ निम्नानुसार हैं:
 - हार्डवेयर, सॉफ्टवेयर, नेटवर्किंग, सुरक्षा और कंप्यूटर-संबंधी अन्य प्रौद्योगिकियों के संबंध में समस्या अनुभव करने वाले प्रयोक्ताओं से सहायता के लिए प्राप्त होने वाले फोन कॉल, ईमेल और स्वयं उपस्थित होकर किए जाने वाले अनुरोधों का उत्तर देना, उनका मूल्यांकन करना और उनकी प्राथमिकता निर्धारित करना;
 - समस्याओं को सहायता डेस्क से जुड़े इंजीनियरों तक भेजना;
 - सुरक्षा से जुड़ी घटनाओं/ समस्याओं को आईटी और प्रणाली सुरक्षा विभागों तक त्वरित गति से पहुंचाना;
 - त्रुटिपूर्ण उत्पादों के संबंध में सेवा के अनुरोध के लिए सॉफ्टवेयर और हार्डवेयर विक्रेताओं को कॉल करना; और
 - उपाय / समस्या प्रबंधन डाटाबेस का उपयोग करते हुए कॉल का लॉग तैयार करना और उन्हें ट्रैक करना और साथ ही ऐतिहासिक अभिलेख / संबंधित समस्या का

3.1 आईएस घटनाओं और कमजोरियों की रिपोर्टिंग

1. सभी प्रयोक्ताओं से यह अपेक्षित होगा कि वे समयबद्ध रीति से घटनाओं की रिपोर्ट करें। सूचना प्रणालियों के सभी प्रयोक्ताओं द्वारा घटनाओं की रिपोर्टिंग के लिए तंत्र स्थापित किए जाएंगे।
2. सूचना प्रणालियों के अनुप्रवर्तन के लिए तंत्र स्थापित किए जाएंगे ताकि किसी मालफंक्शन (असामान्य फंक्शन या फंक्शनिंग से विचलन) का पता लग सके। इस प्रकार सभी मालफंक्शनों को अभिलिखित और विश्लेषित किया जाएगा और जिन मालफंक्शनों के परिणामस्वरूप संगठन की नीतियों या कार्यविधियों का उल्लंघन होता हो, उन्हें घटना माना जाएगा।
3. घटनाओं की रिपोर्ट उचित समय के भीतर स्थापित तंत्रों के माध्यम से की जाएगी।
4. सभी संविदाकर्ताओं और तृतीय पक्षकारों को भी सूचना आस्तियों की सुरक्षा को प्रभावित कर सकने वाली विभिन्न प्रकार की घटनाओं (जैसे सुरक्षा का उल्लंघन, खतरा, कमजोरी या मालफंक्शन) की रिपोर्टिंग की कार्यविधियों के बारे में जागरूक किया जाएगा।
5. रिपोर्ट की गई सभी घटनाओं को पूर्व-परिभाषित मानदंडों के अनुसार लॉग किया जाएगा और विश्लेषित तथा वर्गीकृत किया जाएगा।

3.2 घटना अभिलेखन और वर्गीकरण

1. रिपोर्ट की गई सभी घटनाओं को आईएस टीम द्वारा अधिदेशित विवरणों के साथ अभिलिखित किया जाएगा, जिसमें निम्नलिखित शामिल होंगे किन्तु यह सूची सम्पूर्ण नहीं है:
 - घटना का स्रोत – प्रयोक्ता द्वारा रिपोर्ट की गई या अनुप्रवर्तन तंत्र से प्राप्त
 - प्रभावित सूचना आस्ति(याँ)
 - घटना का विवरण (मालफंक्शन रिपोर्ट, चेतावनी और आंतरिक संवाद)
 - घटना के होने, पता लगने और अभिलिखित किए जाने की तारीख और समय
2. सभी घटनाओं को, आईएस टीम द्वारा परिभाषित मानकों के अनुसरण में निम्नलिखित मानदंडों के आधार पर उच्च, मध्यम और निम्न गंभीरता वाली घटनाओं में वर्गीकृत किया जाएगा:
 - सूचना आस्तियों पर प्रभाव (गोपनीयता, सत्यनिष्ठा और उपलब्धता का भंग होना)
 - प्रभाव का दायरा (प्रयोक्ता, विभाग, स्थान, सूचना प्रणाली)
 - प्रभावित डाटा का वर्गीकरण
3. सभी घटनाओं को आईएस घटना, आईटी घटना और गैर-आईटी घटना में श्रेणीकृत किया जाएगा।
4. सूचना सुरक्षा घटनाओं पर प्रतिसाद किसी नामांकित संपर्क बिन्दु और संगठन के अन्य संबन्धित व्यक्तियों द्वारा या बाह्य पक्षकारों द्वारा दिया जाएगा।
5. आवश्यकतानुसार घटना के स्रोत की पहचान के लिए घटनोपरांत विश्लेषण किया जाएगा।

3.3 आगे बढ़ाना और ट्रैक करना

1. संबन्धित प्राधिकारियों तक आगे बढ़ाने के लिए आवश्यकतानुसार संगत प्राधिकार के साथ समुचित संपर्क की व्यवस्था की जाएगी।
2. उच्च, मध्यम और निम्न गंभीरता की सभी घटनाएँ सीआईएसओ को रिपोर्ट की जाएँगी।
3. एसओसी टीम द्वारा पूरे उद्यम में 24x7 आधार पर सूचना सुरक्षा घटनाओं का अनुप्रवर्तन किया जाएगा।
4. सूचना सुरक्षा और घटना अनुप्रवर्तन (एसआईईएम) के माध्यम से प्रयोक्ताओं द्वारा अप्राधिकृत लॉग-इन/ लॉग-आउट, पहुँच के

उल्लंघन आदि की समीक्षा के लिए निरंतर अनुप्रवर्तन किया जाएगा और सुरक्षा परिचालन केंद्र इसका अनुप्रवर्तन करेगा।

5. बाद में विश्लेषण के लिए सभी प्रतिसाद गतिविधियों का समुचित लॉग तैयार किया जाएगा।

3.4 आईएस घटनाओं का प्रबंधन और सुधार

1. सूचना सुरक्षा घटनाओं के प्रति त्वरित, प्रभावी और व्यवस्थित प्रतिसाद सुनिश्चित करने के लिए प्रबंधन दायित्वों और कार्यविधियों की स्थापना की जाएगी।
2. उचित समय-सीमा के भीतर सभी घटनाओं के विश्लेषण के लिए और घटना के प्रभाव को न्यूनतम संभव दायरे में सीमित रखने के लिए उपयुक्त तंत्रों की स्थापना की जाएगी।
3. आईएस टीम द्वारा घटना के वर्ग के अनुसार यथा-परिभाषित समय-सीमा के भीतर सभी घटनाओं के समाधान के लिए उपयुक्त तंत्रों की स्थापना की जाएगी।
4. घटना के परिणामस्वरूप सूचना आस्ति को हुई किसी हानि या क्षति को रिकवर करने के लिए उपयुक्त तंत्रों की स्थापना की जाएगी।
5. घटनाओं से सीखने और घटनाओं तथा मालफंक्शनों के प्रकारों, प्रभावों, और लागतों के परिमाण को जानने और अनुप्रवर्तन को संभव बनाने के लिए उपयुक्त तंत्रों की स्थापना की जाएगी।
6. सीआईएसओ को यह सुनिश्चित करना चाहिए कि ऐसी परिस्थितियों की पहचान के लिए जिनके परिणाम में घटना हो सकती है, निम्नलिखित में से एक या अधिक उपाय कार्यान्वित किए जाएँ:
 - सभी महत्वपूर्ण अवसंरचना सूचना प्रणालियों पर लॉग तैयार करने और अनुप्रवर्तन करने की व्यवस्था;
 - कार्यालयीन फाइलों और प्रणालियों पर फाइल इंटीग्रिटी मॉनीटर्स, एमडी5हैश जैसे अन्वेषण नियंत्रणों की व्यवस्था।

3.5 विनियामकीय प्राधिकारियों को अधिसूचना

1. संगठन आंतरिक पक्षकारों और बाह्य संगठनों (उदाहरण के लिए, विनियामक, मीडिया, कानून को लागू कराने वाले, ग्राहक, आईआरडीएआई, सीईआरटी-इन, सीएसआईआरटी-फिन, साइबर स्वच्छता केंद्र) को घटना को रिपोर्ट करने के तरीके की पहचान करेगा।
2. घटना की रिपोर्ट बाह्य संगठनों को करने के लिए निर्धारित समय-सीमाओं का कड़ाई से पालन किया जाएगा।
3. संगठन के लिए यह अनिवार्य होगा कि वह साइबर घटना की सूचना प्राप्त होने या उसके संज्ञान में लाए जाने के 6 घंटे के भीतर सीईआरटी-इन को रिपोर्ट करे और उसकी एक-एक प्रति आईआरडीएआई और अन्य संबंधित विनियामकों/प्राधिकारियों को दे। साइबर घटना को रिपोर्ट करने की पद्धति और फॉर्मेट सीईआरटी-इन की वेबसाइट पर प्रकाशित है।
4. संगठन यह सुनिश्चित करेगा कि घटना के समाधान के लिए उसके पास मंत्रालयों, हितधारकों, विक्रेताओं और एनसीआईआईपीसी तथा सीईआरटी-इन जैसी एजेंसियों के संपर्क विवरण अद्यतन और दस्तावेजीकृत होंगे।

- 3.6 मूल कारण का विश्लेषण और समस्या प्रबंधन**
1. अग्रसक्रिय रूप से प्रवृत्तियों की पहचान के लिए समस्याओं की पहचान या मूल कारण और कुछ सहयोगी कारणों का पता लगाने के लिए घटना के अभिलेखों का विश्लेषण किया जाएगा ताकि घटना के फिर से होने की आशंका को कम करने के लिए निवारणात्मक उपाय किए जा सकें।
 2. अनुशासनिक और कानूनी कार्रवाई के प्रयोजन से साक्ष्य के संबंध में आंतरिक कार्यविधियाँ विकसित की जाएंगी और उनका अनुसरण किया जाएगा।
 3. समस्याओं की स्रोत-घटनाओं के महत्व के आधार पर सहमत समय-सीमा के भीतर समाधान या समाधान की पहचान के लिए चिह्नित समस्याओं का दायित्व व्यक्तियों को सौंपा जाएगा।
 4. चिह्नित समस्याओं के समाधान के निर्धारण के बाद उपयुक्त नियंत्रण कार्यविधियों के माध्यम से, विशेष रूप से परिवर्तन प्रबंधन प्रक्रियाओं के माध्यम से सुधारात्मक उपाय कार्यान्वित किए जाएंगे।

- 3.6 ज्ञान प्रबंधन**
1. घटनाओं और समस्याओं के समाधान और उनके ज्ञात कारणों को एक ज्ञान आधार में अभिलिखित करने के लिए उपयुक्त तंत्र स्थापित किया जाएगा।
 2. घटना प्रबंधन टीमों को इस ज्ञान आधार तक पहुँच उपलब्ध कराई जाएगी ताकि घटनाओं के प्रतिसाद में लगने वाले समय को घटाया जा सके।
 3. सूचना सुरक्षा घटनाओं के मूल्यांकन से प्राप्त जानकारी का उपयोग बार-बार होने वाली या अत्यधिक प्रभाव वाली घटनाओं की पहचान के लिए किया जाएगा।

3.7 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईएस, आईटी, संबंधित व्यवसाय कार्य, प्रशासन, एचआर	संबन्धित व्यवसाय कार्य	सीआरओ	व्यवसाय कार्य, आईएस

नीति सं.: 2.11

नीति का नाम: 2.11 नेटवर्क सुरक्षा

- 1 प्रयोजन** संगठन द्वारा प्रयुक्त या नियंत्रित आईटी नेटवर्क के संरक्षण के लिए संगठन हेतु वांछित सुरक्षा आवश्यकताओं को परिभाषित करना।
- 2 दायरा** यह नीति उन सभी संचार और नेटवर्क कनेक्शनों पर लागू होगी जिनके माध्यम से संगठन की सूचना आस्तियों को संप्रेषित किया जाता है।
संचार और नेटवर्क कनेक्शनों में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।
सूचना प्रौद्योगिकी का उपयोग करने वाली सभी व्यवसाय इकाइयों या विभागों के लिए इन सूचना सुरक्षा नीतियों का अनुपालन अनिवार्य है।
- 3 नीति** संगठन के संचार के लिए प्रयुक्त या संगठन के नियंत्रण में स्थित नेटवर्कों (कनेक्टिविटी की अवसंरचना और अन्य संबंधित उपकरण) को समुचित रूप से सुरक्षित रखा जाएगा ताकि संगठन की सूचना तक अप्राधिकृत पहुँच, उसके प्रकटन, उसकी अनुलिपि,

संगठन के नेटवर्क का उपयोग केवल और केवल वैध व्यवसाय प्रयोजनों के लिए ही किया जाएगा। इसका अभिप्राय यह है कि कोई वैध व्यवसायगत औचित्य न हो तब तक किसी व्यक्ति के लिए पहुँच के अधिकार को प्राधिकृत नहीं किया जाएगा। प्रयोक्ताओं को संगठन के नेटवर्क तक पहुँच की सुविधा औपचारिक अनुमोदन के बाद ही प्रदान की जाएगी।

तृतीय पक्षकारों के या उनके नियंत्रणाधीन जिन नेटवर्क संसाधनों को संगठन को सौंपा गया हो, उनकी सुरक्षा भी संगठन के अपने संसाधनों की तरह और करार के अनुसार की जाएगी। यदि इस नीति और तृतीय पक्षकार के साथ हस्ताक्षरित करार के बीच कोई विवाद होता है तो जोखिमों के शमन के लिए उस करार में उपयुक्त प्रावधान जोड़े जाएँगे और उसके बाद करार अधिभावी होगा।

इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 नेटवर्क कनेक्टिविटी

1. नेटवर्किंग उपकरण के प्रबंधन के लिए दायित्वों और कार्यविधियों की स्थापना की जाएगी।
2. सार्वजनिक नेटवर्कों या वायरलेस नेटवर्कों से गुजरने वाले डाटा की गोपनीयता और सत्यनिष्ठा की रक्षा और कनेक्टेड प्रणालियों और एप्लिकेशनों के संरक्षण के लिए विशेष नियंत्रणों की स्थापना की जाएगी।
3. सूचना सुरक्षा को प्रभावित कर सकने वाले, या सूचना सुरक्षा से संगत कार्रवाइयों की रिकॉर्डिंग और अन्वेषण को संभव बनाने के लिए उपयुक्त लॉगिंग और अनुप्रवर्तन लागू किया जाएगा।
4. नेटवर्क पर प्रणालियाँ अधिप्रमाणित होनी चाहिए और नेटवर्क से प्रणालियों का कनेक्शन प्रतिबंधित होगा।
5. यह निश्चित किया जाएगा कि नेटवर्क सेवाप्रदाता सहमत सेवाएँ सुरक्षित तरीके से उपलब्ध कराए और इसका निरंतर अनुप्रवर्तन किया जाएगा, और लेखापरीक्षा के अधिकार पर भी सहमति होगी।

3.1.1 कनेक्टिविटी के तरीके

1. संगठन के आंतरिक नेटवर्क के साथ किसी बाहरी स्थान से कनेक्टिविटी केवल प्राधिकृत एमपीएलएस क्लाउड, पॉइंट टु पॉइंट, या वर्चुअल प्राइवेट नेटवर्क (वीपीएन) के माध्यम से होगी। प्राधिकृत प्रयोक्ता निम्नलिखित में से किसी तंत्र के माध्यम से ही नेटवर्क के साथ कनेक्ट कर पाएगा:
 - एमपीएलएस
 - ब्रोडबैंड और वीपीएन
 - वाई-फाई
 - वायर्ड नेटवर्क
2. संगठन की सूचना आस्ति तक पहुँच की अनुमति देने वाला नेटवर्क कनेक्शन, फायरवाल या राउटर जैसे पेरिमीटर उपकरणों या अन्य समतुल्य अवसंरचना के माध्यम से संरक्षित होगा ताकि यह सुनिश्चित किया जा सके कि कंप्यूटर कनेक्शन और सूचना प्रवाह संगठन की नीति की पहुँच नियंत्रण संबंधी अपेक्षाओं का उल्लंघन न करें।
3. नेटवर्क इंजीनियर सभी प्रशासनिक कार्यों या उच्चतर पहुँच की अपेक्षा वाले कार्यों के लिए एक अलग समर्पित मशीन का प्रयोग करेंगे। वह मशीन संगठन

के मूल नेटवर्क से अलग होगी और उसमें इन्टरनेट पहुँच की अनुमति नहीं होगी। उस मशीन का प्रयोग ईमेल पढ़ने, दस्तावेज़ तैयार करने और इन्टरनेट की सर्फिंग के लिए नहीं किया जाएगा।

3.1.2 कनेक्टिविटी के प्रकार

1. केवल भरोसेमंद निकायों को ही संगठन के नेटवर्क तक पूर्ण पहुँच की अनुमति दी जाएगी।
2. संगठन के नेटवर्क में प्रवेश के सभी बिन्दुओं की समीक्षा की जाएगी और उन्हें अनुमोदित किया जाएगा।
3. नेटवर्क तक पहुँच एक सुरक्षित लॉग-ऑन कार्यविधि से होगी जिसे इस तरह डिजाइन किया जाएगा कि अप्राधिकृत पहुँच का मौका न्यूनतम हो।
4. पहुँच नियंत्रण नीति के अंतर्गत उल्लिखित सभी नीतियाँ नेटवर्क कनेक्टिविटी पर लागू होंगी।
5. कॉर्पोरेट कंप्यूटर और संचार प्रणाली के माध्यम से स्थापित किए जाने वाले सभी कनेक्शन कनेक्ट हुए प्रयोक्ताओं, उपकरणों या सेवाओं के अधिप्रमाणन के माध्यम से संरक्षित होंगे।
6. व्यवसाय लेनदेन प्रणाली और उच्च गंभीरता प्रणाली के रूप में वर्गीकृत की गई संगठन की आईटी आस्ति के साथ, संगठन के स्वामित्व या नियंत्रण वाले बाह्य नेटवर्क (उदा. रिमोट कनेक्शन) से कनेक्शन के लिए, पहुँच नियंत्रण प्रणाली में यथापरिभाषित द्वि-कारकीय अधिप्रमाणन की आवश्यकता होगी और अनुपालन परीक्षण कनेक्टिंग उपकरण का वैधकरण करेगा।
7. सभी वेब ब्राउजर्स और ईमेल क्लायंटों में केवल प्राधिकृत स्क्रिप्टिंग भाषाएँ ही रन करेंगी।
8. बीमा कंपनियाँ यह सुनिश्चित करेंगी कि केवल पूर्णतः समर्थित वेब ब्राउजर्स और ईमेल क्लायंटों को ही संगठन के भीतर निष्पादन की अनुमति दी जाए, आदर्श स्थिति में विक्रेता द्वारा उपलब्ध कराए गए वेब ब्राउजर्स और ईमेल क्लायंटों के अद्यतन संस्करण का उपयोग करते हुए।
9. संगठन सर्वरों में भंडारित सूचना के लेबल या वर्गीकरण के स्तर के आधार पर नेटवर्क को अलग सेगमेंट करेगा, समग्र संवेदनशील सूचना को पृथक्कृत वर्चुअल लोकल एरिया नेटवर्क (वीलैन) पर लोकेट करेगा।
10. फायरवाल/ नेटवर्क सुरक्षा उपकरणों पर अप्राधिकृत कोलैबोरेशन टूल्स को ब्लॉक करने के लिए निवारणात्मक नियंत्रण स्थापित किया जाएगा।

3.2 पेरीमीटर सुरक्षा

3.2.1 पेरीमीटर उपकरणों की पहचान

1. संगठन पेरीमीटर सुरक्षा प्रणालियों (फायरवाल, आईडीएस आदि) की तैनाती करेगा और नेटवर्क के स्तर पर अप्राधिकृत या गैर-कानूनी पहुँच से सभी सूचना आस्तियों के संरक्षण के लिए कार्यविधियाँ विकसित और कार्यान्वित करेगा।
2. सभी पेरीमीटर उपकरणों की एक इनवेंटरी रखी जाएगी और आवधिक आधार पर तथा नेटवर्क कन्फिगरेशन में प्रत्येक परिवर्तन के बाद उसे अद्यतन करने के लिए कार्यविधियाँ स्थापित की जाएँगी।

3.2.2 आधारस्तरीय सुरक्षा मानक

1. पेरीमीटर सुरक्षा उपकरणों के सभी प्रकारों और सभी रूपों (मेक/ मॉडल/ वर्जन) के लिए न्यूनतम आधारस्तरीय सुरक्षा मानक (एमबीएसएस) परिभाषित किए जाएंगे।
2. आधारस्तरीय सुरक्षा मानक में किए जाने वाले सभी परिवर्तन, परिवर्तन प्रबंधन नीति के अधीन होंगे।
3. यह सुनिश्चित करने के लिए तंत्र स्थापित किए जाएंगे कि नेटवर्क सुरक्षा संसाधन आधारस्तरीय सुरक्षा मानकों का पालन करें और वास्तविक कन्फिगरेशन और आधारस्तरीय सुरक्षा मानक में हुए विचलनों का पता लग सके और उनका समाधान किया जा सके या यदि उन्हें प्रतिधारित करना अपेक्षित हो तो अपवाद के रूप में अनुमोदित किए जाएँ।
4. आधारस्तरीय सुरक्षा मानकों की आवधिक समीक्षा की जाएगी।
5. एप्लिकेशनों की श्वेत सूची तैयार करने वाला सॉफ्टवेयर यह सुनिश्चित करेगा कि केवल प्राधिकृत सॉफ्टवेयर लाइब्रेरियों (जैसे *.dll, *.ocx, *.so, आदि) को ही प्रणाली प्रक्रिया में लोड होने की अनुमति दी जाए।
6. एप्लिकेशनों की श्वेत सूची तैयार करने वाला सॉफ्टवेयर यह भी सुनिश्चित करेगा कि किसी प्रणाली पर केवल प्राधिकृत, डिजिटल रूप में हस्ताक्षरित स्क्रिप्ट (जैसे *.ps1, *.py, macros, आदि) को ही रन करने की अनुमति दी जाए।

3.3 नेटवर्क प्रबंधन

1. सभी नेटवर्क उपकरणों और संचार लाइनों की पहचान की जाएगी, उनका दस्तावेजीकरण किया जाएगा और उन्हें नियमित रूप से अद्यतन किया जाएगा।
2. लोकल और वाइड एरिया नेटवर्कों के लिए नेटवर्क डायग्राम रखे जाएंगे और उन्हें नियमित रूप से अद्यतन किया जाएगा।
3. सार्वजनिक और संगठन के नेटवर्कों के भीतर तथा उनके बीच परिचालित प्रणालियों को आंतरिक और बाह्य अनधिकृत प्रवेशकर्ताओं से संरक्षण प्रदान किया जाएगा। प्रणालियों को भौतिक रूप से सुरक्षित और प्रतिबंधित पहुँच वाले क्षेत्र में इन्स्टाल किया जाएगा।
4. रिमोट कंट्रोल सॉफ्टवेयर के साथ पर्सनल कम्प्यूटरों से सीधे जुड़े व्यक्तिगत संचार उपकरणों (मॉडेम, आईएसडीएन कार्ड, 3डी डाटा सिम आदि) का प्रयोग करना निषिद्ध होगा।
5. सभी संचार उपकरणों तक पहुँच सामान्य प्रयोक्ता खातों की उपेक्षा सहित पहुँच नियंत्रण नीति के अधीन होगी।
6. ऑन-साइट अवस्थित या किसी दूरस्थ सेवाप्रदाता के पास अवस्थित प्रणालियों सहित संगठन की प्रौद्योगिकी प्रणालियों में भंडारित, प्रसंस्कृत या संप्रेषित संवेदनशील सूचनाओं की पहचान के लिए और उनकी इनवेंटरी को अद्यतन रखने के लिए एक सक्रिय डिस्कवरी टूल का प्रयोग किया जाएगा।
7. मौद्रिक लेनदेन एप्लिकेशनों/ प्रक्रियाओं को रन करने वाले सर्वरों के पेरीमीटर और कनेक्टिविटी को अलग करने और सुरक्षित रखने के लिए पर्याप्त उपाय किए जाएंगे।

3.4 बाह्य नेटवर्क

- 1.
2. पहुँच नियंत्रण नीतियों के अनुसार पहुँच नियंत्रणों और संबंधित सुरक्षा तंत्रों के कार्यान्वयन के लिए इंटरनेट जैसे सार्वजनिक नेटवर्क की दिशा में जाने वाला नेटवर्क ट्रैफिक समुचित पेरीमीटर सुरक्षा प्रणालियों के अतिरिक्त प्रॉक्सी सर्वर जैसी गेटवे प्रणालियों के माध्यम से गुजरेगा।
3. बाह्य नेटवर्क संसाधनों तक पहुँच व्यवसाय आवश्यकताओं पर आधारित होगी जिसमें पहुँच नियंत्रण कार्यविधियों का पालन भी शामिल होगा।
4. संगठन की मोबाइल आस्तियों को अप्राधिकृत वाई-फ़ाई पहुँच बिन्दुओं और हॉटस्पॉट से जोड़ना निषिद्ध होगा।
5. प्रयोक्ता जागरूकता प्रशिक्षण में स्वीकार्य उपयोग और सावधानियों, कॉपीराइट मामलों तथा स्वीकार्य उपयोग नीति एवं सामान्य इंटरनेट आचार के उल्लंघन के लिए अनुशासनिक कार्रवाई जैसे विषय शामिल किए जाएंगे।
6. संगठन के पास यह अधिकार सुरक्षित होगा कि वह सार्वजनिक नेटवर्कों पर प्रयोक्ता के कार्यों का अनुप्रवर्तन करे, जब ऐसे नेटवर्कों तक बीमा कंपनी के स्वामित्व में स्थित या उसके द्वारा नियंत्रित सूचना प्रणालियों के माध्यम से पहुँच स्थापित की जाए ताकि संगठन की सूचना आस्तियों का संरक्षण किया जा सके।
7. नेटवर्क से जुड़ी सेवाएँ देने वाले या संगठन के नेटवर्क संसाधनों तक (या उसके किसी हिस्से तक) पहुँच रखने वाले तृतीय पक्षकारों द्वारा नेटवर्क नीति के पालन के लिए संगठन पर्याप्त नियंत्रणों या संविदागत प्रावधानों का कार्यान्वयन करेगा।
8. संगठन सामान्य वेब एप्लिकेशन आक्रमणों के लिए वेब एप्लिकेशन की ओर आने वाले समस्त ट्रैफिक का निरीक्षण करने वाले वेब एप्लिकेशन फायरवाल (डब्ल्यूएफएफ) की तैनाती के माध्यम से वेब एप्लिकेशनों का संरक्षण करेगा। जो एप्लिकेशन वेब-आधारित नहीं हैं उनके लिए एप्लिकेशन-विशिष्ट फायरवाल तैनात किए जाएंगे यदि ऐसे टूल संबंधित प्रकार के एप्लिकेशन के लिए उपलब्ध हों। यदि ट्रैफिक एन्क्रिप्टेड हो तो उपकरण एन्क्रिप्शन के पीछे रहेगा या ट्रैफिक को विश्लेषण के पूर्व डिंक्रीट करने में सक्षम होगा। यदि कोई विकल्प उपयुक्त न हो तो एक होस्ट-आधारित वेब एप्लिकेशन फायरवाल तैनात किया जाएगा।
9. संगठन यूआरएल श्रेणीकरण सर्विसेज को सबस्क्राइब करेगा ताकि यह सुनिश्चित किया जा सके कि वे उपलब्ध अधुनातन वेबसाइट श्रेणीकरण परिभाषाओं के अनुरूप अद्यतन हैं। अश्रेणीकृत साइटों को स्वतः ब्लॉक किया जाएगा।

3.5 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	संपर्क किससे	सूचना किसको
आईटी	आईटी और व्यवसाय विभाग	आईएस	उद्यम की आस्तियाँ – सीटीओ; अन्य मामले – अंतिम प्रयोक्ता का स्वामी

नीति सं.:

2.12

नीति का नाम:

2.12 क्रिप्टोग्राफिक नियंत्रण

1	प्रयोजन	संगठन की आस्तियों की गोपनीयता और सत्यनिष्ठा के संरक्षण के लिए क्रिप्टोग्राफिक नियंत्रणों के उपयोग हेतु वांछित कार्यपद्धतियों को परिभाषित करना।
2	दायरा	क्रिप्टोग्राफी तृतीय पक्षकारों की उपस्थिति में सुरक्षित सम्प्रेषण की तकनीकों की कार्यपद्धति है और इसमें सूचना को कूटबद्ध करने के लिए एन्क्रिप्शन का तंत्र के रूप में इस तरह उपयोग किया जाता है कि ताक-झाँक करने वाले उसे नहीं पढ़ सकते लेकिन प्राधिकृत पक्षकार पढ़ सकते हैं। यह नीति क्रिप्टोग्राफी के सभी रूपों पर लागू होगी जिसका उपयोग मार्गस्थ सूचना या कहीं रखी गई सूचना को एन्क्रिप्ट करने के लिए किया गया हो। यह नीति उन सभी सूचना प्रणालियों पर लागू होगी जिनका उपयोग संगठन की सूचना आस्तियों का भंडारण या प्रसंस्करण किया जाता है और उन सभी संचार और नेटवर्क कनेक्शनों पर लागू होगी जिनके माध्यम से सूचना आस्तियों का सम्प्रेषण किया जाता है जो सूचना आस्ति की सुरक्षा के लिए क्रिप्टोग्राफी की व्यवस्था का उपयोग करती हैं।
3	नीति	संगठन यह सुनिश्चित करेगा कि डाटा वर्गीकरण नीति में यथापरिभाषित एन्क्रिप्शन अपेक्षाओं के अनुसार किए गए डाटा वर्गीकरण के आधार पर डाटा पर उपयुक्त क्रिप्टोग्राफिक नियंत्रण लागू किया जाएगा। इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।
3.1	क्रिप्टोग्राफिक नियंत्रणों का उपयोग	1. पूरे संगठन में क्रिप्टोग्राफिक नियंत्रणों के उपयोग के प्रति प्रबंधन का दृष्टिकोण, जिसमें वे सामान्य सिद्धान्त शामिल हैं जिनके अंतर्गत व्यवसाय सूचना का संरक्षण किया जाएगा। 2. एन्क्रिप्शन या क्रिप्टोग्राफी की आवश्यकता, पद्धति, व्यवसाय क्षेत्र और उपयोग की पहचान के लिए जोखिम का आकलन किया जाएगा। 3. गोपनीय या प्रतिबंधित और मोबाइल या रिमूवेबल मीडिया उपकरणों या संचार लाइनों के माध्यम से आवागमन करने वाली सूचना को सुरक्षित रखने के लिए क्रिप्टोग्राफिक नियंत्रणों का प्रयोग किया जाएगा। 4. गोपनीय और प्रतिबंधित सूचना की परिभाषा डाटा वर्गीकरण नीति के अनुसार संपुष्ट किए गए संबन्धित वर्गीकरण पर आधारित होगी। 5. जो महत्वपूर्ण सूचना सक्रिय उपयोग में नहीं होगी, वह कंप्यूटर-पठनीय भंडारण मीडिया (जैसे सर्वर, मैग्नेटिक टेप, फ्लॉपी डिस्क या सीडी, लैपटॉप जैसी मोबाइल आस्तियों के हार्ड डिस्क या मोबाइलों के मेमोरी चिप) में भंडारित या ट्रांसपोर्टेड स्थिति में, जहाँ भी साध्य और लागू होगा, एन्क्रिप्टेड रूप में होगी। 6. दूरस्थ टर्मिनलों की पहचान के सत्यापन के लिए प्रयुक्त सूचना का समुचित संरक्षण किया जाएगा। अधिप्रमाणन संबंधी स्थिर या पुनः उपयोग की जाने योग्य सूचनाओं को भंडारण के दौरान और नेटवर्क से गुजरते समय एन्क्रिप्शन सॉफ्टवेयर या हार्डवेयर का उपयोग करते हुए एन्क्रिप्ट किया जाएगा। 7. की (कुंजी) प्रबंधन पद्धति, एन्क्रिप्टोग्राफिक कीज़ के संरक्षण की पद्धति, कीज़ के गुम होने, उनके साथ कोई अवांछित समझौता होने या उनके क्षतिग्रस्त होने के मामले में एन्क्रिप्टेड सूचना की पुनःप्राप्ति की पद्धति को परिभाषित किया जाएगा।

नीति सं.:	2.13
नीति का नाम:	2.13 व्यवसाय निरंतरता प्रबंधन और आपदा रिकवरी

3.2 की (कुंजी) प्रबंधन

1. क्रिप्टोग्राफिक कीज़ के उपयोग, संरक्षण और जीवनावधि पर एक नीति विकसित और उनके सम्पूर्ण जीवनचक्र के दौरान कार्यान्वित की जाएगी।
2. सभी क्रिप्टोग्राफिक कीज़ आशोधन और हानि के समक्ष संरक्षित किए जाएँगे।
3. किसी विशेष परिस्थिति में किस प्रकार और क्षमता के एन्क्रिप्शन अलगोरिथम का उपयोग किया जाएगा, यह हैंडल की जाने वाली व्यवसाय सूचना के महत्व पर आधारित होगा।
4. क्रिप्टोग्राफिक कीज़ की लंबाई के मामले में संविदागत अपेक्षाओं और सक्षम प्राधिकारियों द्वारा निर्धारित विनियमों का अनुपालन किया जाएगा।
5. जहाँ संभव हो, एन्क्रिप्शन कीज़ नेटवर्क पर संप्रेषित नहीं किए जाएँगे। यदि एन्क्रिप्शन प्रक्रिया को संचालित करने वाले कीज़ को नेटवर्क पर संप्रेषित करना हो तो उन्हें सुरक्षित संचार माध्यमों से संप्रेषित किया जाएगा।
6. कीज़ को सक्रिय और निष्क्रिय करने की तारीखों को इस प्रकार परिभाषित किया जाएगा कि कीज़ का उपयोग सम्बद्ध की-प्रबंधन नीति में यथापरिभाषित समयावधि के लिए ही किया जा सके।
7. की-प्रबंधन जीवनचक्र के छह चरण होंगे। प्रत्येक चरण में प्रक्रियाओं का एक समुच्चय होगा जिन्हें दस्तावेजीकरण और व्यवहार दोनों में अमल किया जाएगा:
 - . सृजन – कीज़ का सृजन सुरक्षित पर्यावरण (हार्डेन्ड प्रणाली) में किया जाएगा, और इसमें कर्तव्यों के पृथक्करण के लिए समरूपता की आवश्यकता को भी शामिल किया जाएगा।
 - . बैक-अप – बैक-अप का अभिप्राय है कीज़ को बाहरी मीडिया (उदाहरण-सीडी, डीवीडी, यूएसबी ड्राइव) में लिखना और उन्हें किसी भौतिक तिजोरी में भंडारित करना।
 - . तैनाती – नए कीज़ को तैनात कर एक पूर्व-निर्धारित अवधि के लिए उनका परीक्षण किया जाएगा ताकि डाटा आउटेज की जोखिम उठाने के पहले यह सुनिश्चित किया जा सके कि नए कीज़ के साथ परिचालन सफल है।
 - . अनुप्रवर्तन – क्रिप्टो प्रणालियों तक अप्राधिकृत प्रशासनिक पहुँच के अनुप्रवर्तन के माध्यम से यह सुनिश्चित किया जाएगा कि अननुमोदित की-प्रबंधन परिचालन निष्पादित नहीं होते।
 - . समय-सीमा की समाप्ति - एन्क्रिप्शन की संख्या के चयन में उस समय-सीमा को ध्यान में रखा जाएगा जब तक डाटा की वैधता बनी रह सकती है।
 - . नष्ट करना – कीज़ को नष्ट करने में सुरक्षित डिलीशन कार्यविधि का अनुसरण किया जाएगा ताकि यह सुनिश्चित किया जा सके कि वह ठीक प्रकार से विनष्ट हो गया है।
 - . की-प्रबंधन से जुड़ी गतिविधियों का लॉग तैयार करना और उनकी लेखापरीक्षा करना।

3.3 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी	आईएस	आईएस	उद्यम आस्तियाँ: सीटीओ, अन्य मामले: अंतिम प्रयोक्ता/ की का स्वामी

1	प्रयोजन	एक लाभप्रद व्यवसाय अस्तित्व के रूप में परिचालन जारी रखने की संगठन की योग्यता उचित आकस्मिकता योजनाओं और कार्यविधियों की स्थापना पर निर्भर करती है। यदि व्यवसाय में व्यवधान आता है तो संगठन के पास यह क्षमता होना अनिवार्य है कि वह सुरक्षा से समझौता किए बिना एक उचित समय-सीमा के भीतर अपने व्यवसाय को फिर से आरंभ कर सके। यह नीति सूचना प्रौद्योगिकी सेवाओं में व्यवधान से उत्पन्न जोखिमों का पर्याप्त शमन सुनिश्चित करने के लिए संगठन की वांछित आपदा रिकवरी कार्यपद्धति को परिभाषित करती है।
2	दायरा	यह नीति उन सभी कार्यालय स्थलों और प्रणालियों पर लागू होगी जिनके माध्यम से संगठन की सूचना आस्तियों को भंडारित या प्रसंस्कृत किया जाता है, और उन संचार और नेटवर्क कनेक्शनों पर लागू होगी जिनके माध्यम से संगठन की सूचना आस्तियों को संप्रेषित किया जाता है। प्रौद्योगिकी प्रणालियों और संचार तथा नेटवर्क कनेक्शनों में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण तथा सभी परिचालन प्रणालियाँ, डाटाबेस और एप्लिकेशन शामिल हैं, लेकिन ये इन्हीं तक सीमित नहीं हैं।
3	नीति	संगठन की सभी सूचना प्रणालियों और आस्तियों को एक औपचारिक व्यवसाय निरंतरता योजना और आपदा रिकवरी योजना के माध्यम से संभावित विफलता या सेवा व्यवधान के विरुद्ध संरक्षित किया जाएगा और ये औपचारिक योजनाएँ: • संगठन की व्यवसाय प्रक्रियाओं के लिए प्रणाली या आस्ति के महत्व के अनुसार आस्तियों को फिर से बहाल करती हैं; • व्यवधान की स्थिति में संगठन की सूचना आस्तियों की सुरक्षा का अपेक्षित स्तर बनाए रखती हैं। इस नीति के किसी उल्लंघन को घटना माना जाएगा और उनका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 आईटी उपलब्धता प्रबंधन

3.1.1 क्षमता अनुप्रवर्तन और आयोजना संगठन उपयोग का निरंतर अनुप्रवर्तन करेगा और सूचना प्रसंस्करण ससाधनों की भविष्यगत आवश्यकता का अनुमान लगाएगा और तदनुसार योजना तैयार करेगा ताकि संगठन की व्यवसाय आवश्यकताओं को पूरा करने के लिए पर्याप्त सूचना प्रसंस्करण ससाधन उपलब्ध हों।

3.1.2 प्रणाली स्वीकरण

1. नई सूचना प्रणालियों, उनमें उन्नयन और नए संस्करणों के स्वीकरण मानदंडों में उपयुक्त डिजाइन तथा कन्फिगरेशन के माध्यम से व्यवधानों या त्रुटियों से निपटने की क्षमता शामिल होगी और क्षमता के निर्धारण के लिए उन्हें स्वीकार करने के पहले उपयुक्त परीक्षण किए जाएँगे।
2. जहाँ उपयुक्त डिजाइन तथा कन्फिगरेशन के माध्यम से व्यवधानों से निपटने की क्षमता उपलब्ध नहीं कराई गई हो, वहाँ व्यवधानों से निपटने के वैकल्पिक तंत्र की साध्यता का मूल्यांकन किया जाएगा और जहाँ साध्य होगा, वहाँ कार्यान्वित किया जाएगा।

3.2 आईटी निरंतरता प्रबंधन

3.2.1 डाटा बैक-अप बैक-अप और रिकवरी नीति के अनुसार नियमित आधार पर समग्र डाटा का बैक-अप लिया जाएगा और सूचना की हानि या व्यवधान की स्थिति में डाटा की पुनःप्राप्ति के लिए बैक-अप अनिवार्य रूप से उपलब्ध होना चाहिए ताकि संगठन के परिचालनों की निरंतरता सुनिश्चित की जा सके। बैक-अप प्रबंधन और

पुनःप्राप्ति के संबंध में विस्तृत विवरण के लिए सूचना प्रणाली अनुरक्षण नीति को संदर्भित करें। आपदा रिकवरी (डीआर) पर्यावरण को हमेशा उत्पादन पर्यावरण के समय के साथ समय मिलाकर रखा जाएगा। साथ ही, उत्पादन पर्यावरण में लागू किए जाने वाले परिवर्तनों को डीआर पर्यावरण में भी लागू किया जाएगा ताकि दोनों के बीच समकालिकता सुनिश्चित की जा सके।

3.2.2 आईटी निरंतरता आयोजना

उपयुक्त जोखिम आकलन और व्यवसायगत आवश्यकताओं के आधार पर प्रत्येक संगठन या प्रणाली के लिए एक आईटी निरंतरता योजना या आपदा रिकवरी योजना विकसित की जाएगी और उसे आईएसआरएमसी से अनुमोदित कराया जाएगा।

3.3 बीसीएम संरचना

संगठन की बीसीएम संरचना में दस्तावेजीकृत व्यवसाय निरंतरता और आपदा रिकवरी योजनाएँ होंगी। एकल संरचना बनाए रखी जाएगी ताकि सभी व्यवसायों और प्रक्रियाओं के लिए बनाई गई योजनाओं में सुसंगति सुनिश्चित की जा सके, सूचना सुरक्षा संबंधी आवश्यकताओं को सुसंगत रीति से पूरा किया जा सके और परीक्षण एवं अनुरक्षण के लिए प्राथमिकताओं की पहचान की जा सके। बीसीपी/ डीआर योजनाओं में कम-से-कम निम्नलिखित पर विचार किया जाएगा:

- उद्यम-व्यापी व्यवसाय निरंतरता;
- महत्वपूर्ण एप्लिकेशनों को जारी रखना;
- संगठन की डाटा केंद्र आपदा रिकवरी योजना;
- नेटवर्क कनेक्शन/ लिंक;
- व्यवसाय निरंतरता और आपदा रिकवरी योजनाओं में सभी व्यक्तियों की भूमिका और दायित्व।

i. व्यवसाय प्रभाव विश्लेषण

- व्यवसायगत आवश्यकताओं के आधार पर सभी एप्लिकेशनों के लिए आरटीओ और आरपीओ परिभाषित किए जाएँगे।
- आईटी प्रणालियों पर व्यवसाय कार्यों की सभी निर्भरताओं स्पष्ट रूप से दस्तावेजीकृत किया जाएगा।

ii. जोखिम प्रबंधन और मूल्यांकन

- संगठन यह सुनिश्चित करेगा कि उन खतरों की पहचान में पर्याप्त कवरेज उपलब्ध कराया जाए जो व्यवसाय परिचालनों को सहयोग देने वाली आईटी आस्तियों की उपलब्धता में व्यवधान का कारण बन सकते हैं।
- जोखिम आकलन कार्य के लिए एक परिभाषित और दस्तावेजीकृत पद्धति का उपयोग किया जाएगा।
- जोखिम विश्लेषण कम-से-कम वार्षिक आधार पर किया जाएगा।
- जोखिम के स्वीकार्य स्तरों को परिभाषित और दस्तावेजीकृत तथा प्रबंधन से अनुमोदित कराया जाएगा।
- विद्यमान नियंत्रणों की सक्षमता और प्रभावोत्पादकता का आकलन किया जाएगा। नियंत्रण की सक्षमता और नियंत्रण की प्रभावोत्पादकता के मूल्यांकन के निर्धारण में विद्यमान नियंत्रणों के कारण किसी जोखिम के शमन को ध्यान में रखा जाएगा।
- जोखिम आकलन आवश्यकतानुसार नमूना आधार पर किया जाएगा। ऐसे मामले में नमूना लेने की बारंबारता को दस्तावेजीकृत किया जाएगा।
- स्वीकार्य स्तर से अधिक जोखिम रेटिंग वाली जोखिमों के लिए जोखिम शमन योजनाएँ तैयार की जाएँगी। ये योजनाएँ प्रबंधन से अनुमोदित कराई जाएँगी।
- जोखिम शमन योजनाओं में कार्रवाई बिन्दुओं का स्वामित्व स्पष्ट रूप से परिभाषित किया जाएगा।
- तिमाही आधार पर जोखिम शमन योजना की समीक्षा की जाएगी और परिसमापन तक उसे ट्रैक किया जाएगा।

iii. आईटी डीआर रणनीति

- आईटी डीआर रणनीति यह सुनिश्चित करेगी कि आकस्मिक स्थितियों में डाटा की क्षति नगण्य हो, रिकवरी त्वरित हो और महत्वपूर्ण व्यवसाय परिचालन जारी रहें।
- चुनी गई रणनीतियाँ संगठन की व्यवसाय निरंतरता में सहयोग देंगी और उसके साथ एकीकरण में समर्थ होंगी।
- प्रौद्योगिकी घटकों के लिए रणनीतिगत विकल्पों का मूल्यांकन किया जाएगा और रिकवरी की प्राथमिकता के हिसाब से आईटी प्रणालियों की रिकवरी तथा उन्हें फिर से बहाल करने के लिए उपयुक्त रणनीतियाँ परिभाषित की जाएँगी।
- जहाँ भी उचित होगा, बाह्य (तृतीय पक्ष) उत्पादों और सेवाओं को चुने गए रणनीतिक विकल्पों से कवर किया जाएगा।
- आपदा के समय परस्पर संबंधित एप्लिकेशनों के बीच समकालिकताजन्य समस्या न उत्पन्न हो इसके लिए आईटी डीआर योजना में ऑफ-साइट स्थान और अतिरिक्त कम्प्यूटिंग और दूरसंचार पर निरंतर परिचालन-डाटा मिररिंग को शामिल किया जाएगा।

iv. आईटी डीआर रिकवरी आयोजना

- प्रतिसाद और रिकवरी योजना संक्षिप्त होगी और इसके लिए जिम्मेदार व्यक्तियों की पहुँच में होगी।
- प्रत्येक आईटी डीआर योजना के प्रयोजन और दायरे को परिभाषित और अनुमोदित किया जाएगा और समझा जाएगा।
- योजना में निम्नलिखित के संदर्भ में प्राथमिकता-प्राप्त उद्देश्यों को निश्चित किया जाएगा:
 - रिकवर की जाने वाली महत्वपूर्ण आईटी सेवाएँ
 - रिकवर किए जाने की समयावधि
 - योजनाओं को आरंभ करने की परिस्थिति
 - प्रत्येक महत्वपूर्ण आईटी सेवा के लिए रिकवरी के स्तर
- आईटी डीआर योजना में यह सुनिश्चित किया जाएगा कि डीसी और डीआर में सर्वरों, नेटवर्क उपकरणों और अन्य उत्पादों के कन्फिगरेशन हर समय एक जैसे हों।
- आईटी डीआर योजना में डीसी और डीआर के बीच डाटा और लेनदेन की सत्यनिष्ठा सुनिश्चित करने के लिए आवधिक जाँच की व्यवस्था शामिल होगी।
- आईटी डीआर योजना में यह सुनिश्चित किया जाएगा कि डीसी और डीआर की सहयोगी अवसंरचना में विफलता का एक भी बिन्दु नहीं है और संसाधनों के लगातार अनुप्रवर्तन के लिए निर्माण प्रबंधन एवं अनुप्रवर्तन प्रणालियाँ मौजूद हैं।
- आईटी डीआर योजना में पालन किए जाने वाले डाटा रेप्लिकेशन मेकानिज़्म से महत्वपूर्ण एप्लिकेशनों का आरपीओ अनुपालन सुनिश्चित होगा।
- एस्केलेशन के विभिन्न चरणों और टिगर घटनाओं (व्यवधान, विफलता का एकल बिन्दु) को स्पष्ट रूप से परिभाषित किया जाएगा।
- प्रत्येक एप्लिकेशन के लिए विशिष्ट आईटी डीआर योजना दस्तावेजीकृत और अनुमोदित की जाएगी। आईटी डीआर योजना में प्रत्येक एप्लिकेशन के लिए आईटी प्रक्रियाओं की रिकवरी और पुनः बहाली के लिए विस्तृत अनुदेश होंगे।
- आईटी सेवाओं की रिकवरी के लिए प्रौद्योगिकी रिकवरी कार्यविधियाँ विकसित की जाएँगी और उसमें निम्नलिखित क्षेत्रों को शामिल किया जाएगा:
 - परिवर्तित पर्यावरण को ध्यान में रखते हुए वैकल्पिक स्थान पर एप्लिकेशन, डाटाबेस और सहबद्ध हार्डवेयर को फिर से बहाल करने की विस्तृत कार्यविधियाँ;
 - नेटवर्क तक पहुँच की योग्यता को फिर से बहाल करने की विस्तृत कार्यविधियाँ;
 - डाटा का समय एक समान करने में व्यवधान के कारण उत्पन्न सूचना बैकलॉग को हैंडल करने की कार्यविधियाँ;

- एप्लिकेशन तक पहुँच के लिए अंतिम प्रयोक्ता से अपेक्षित परिवर्तन।

- आईटी डीआर योजनाओं की समीक्षा कम-से-कम वर्ष में एक बार की जाएगी।

v. प्रशिक्षण और जागरूकता

- संबन्धित स्टाफ के लिए लक्षित पाठ्यक्रमों और जागरूकता सत्रों वाला एक औपचारिक प्रशिक्षण कार्यक्रम विकसित किया जाएगा।
- आईटी प्रणालियों की रिकवरी में प्रमुख भूमिका निभाने के लिए चिह्नित स्टाफ की प्रशिक्षण आवश्यकताओं के मूल्यांकन के लिए एक प्रक्रिया स्थापित की जाएगी। स्टाफ को विहित कार्य को पूरा करने में समर्थ बनाने के लिए अपेक्षित कौशलों और दक्षता के स्तर के आधार पर उपयुक्त प्रशिक्षण कार्यक्रम आयोजित किए जाएँगे।
- व्यवसाय निरंतरता मीट्रिक्स का पालन सुनिश्चित करने के लिए डीआर ड्रिल का आयोजन किया जाएगा।
- व्यवसाय निरंतरता योजना के एक भाग के रूप में वैकल्पिक स्थल और संसाधन उपलब्धता की आयोजना की जाएगी और उसका परीक्षण किया जाएगा।
- राष्ट्रीय/ सेक्टरल/ सांगठनिक साइबर सुरक्षा अभ्यासों में संगठन की सहभागिता सुनिश्चित की जाएगी।

**3.3.1 आउटसोर्सड
संबंध प्रबंधन**

किसी तृतीय पक्ष सेवाप्रदाता को आउटसोर्सड सूचना और एप्लिकेशनों में सेवा की निरंतरता के लिए उचित योजनाएँ शामिल होंगी जिन्हें तृतीय पक्ष सेवाप्रदाता द्वारा विकसित किया जाएगा और उनका परीक्षण किया जाएगा तथा संगठन द्वारा अनुमोदित किया जाएगा। तृतीय पक्ष सेवाप्रदाता के साथ संगठन का एक संपर्क अधिकारी सेवा में व्यवधान की स्थिति में आपदा रिकवरी गतिविधियों के निष्पादन का पर्यवेक्षण करेगा।

**3.3.2 बीसीएम में
आईएस पर
विचार**

1. पूरे संगठन में व्यवसाय निरंतरता के लिए एक प्रबंधित प्रक्रिया विकसित की जाएगी और बनाए रखी जाएगी जो संगठन की व्यवसाय निरंतरता के लिए आवश्यक सूचना सुरक्षा अपेक्षाओं का ध्यान रखेगी।
2. महत्वपूर्ण व्यवसाय प्रक्रियाओं में व्यवधान या उनकी विफलता के बाद व्यवसाय परिचालनों को बनाए रखने या अपेक्षित समय के भीतर पुनः बहाल करने के उद्देश्य से एक समग्रतामूलक व्यवसाय निरंतरता योजना (बीसीपी) विकसित और कार्यान्वित की जाएगी। बीसीपी में प्रभावी आपदा रिकवरी कार्यविधियाँ शामिल होंगी ताकि कंपनी के परिचालनों पर कम-से-कम प्रभाव के साथ आपात स्थिति से शीघ्र रिकवरी हो सके।
3. व्यवसाय निरंतरता योजना को महत्वपूर्ण व्यवसाय प्रक्रियाओं और व्यवधान डालने वाली संभावित घटनाओं के साथ-साथ, व्यवसाय प्रभाव विश्लेषण के माध्यम से सूचना सुरक्षा के दृष्टिकोण से चिह्नित कर उनके घटित ही सकने की परिस्थितियों, प्रभाव और परिणामों के आधार पर विकसित किया जाएगा।
4. यह सुनिश्चित किया जाएगा कि संगठन के आईटी पर्यावरण में अगर कोई नया एप्लिकेशन लाया जाता है तो उसमें दस्तावेजीकृत आईटीडीआर प्रक्रियाएँ हों जो महत्व-आधारित हों और विद्यमान रिकवरी प्रक्रियाओं के साथ एकीकरण में समर्थ हों। उसमें व्यवसाय-परिभाषित आरटीओ और आरपीओ भी होना चाहिए।
5. जो भी परिवर्तन विकसित की गई रिकवरी कार्यविधियों पर प्रभाव डाल सकते हैं उन्हें विधिवत् परिवर्तन नियंत्रण प्रक्रिया के भाग के रूप में चिह्नित किया जाएगा और उन्हें कार्यान्वयन के पहले आईटीडीआर प्रबन्धक से अनुमोदित कराया जाएगा।

**3.3.3 बीसीपी
परीक्षण का**

1. व्यवसाय निरंतरता और डीआर योजनाओं का परीक्षण वर्ष में कम-से-कम एक बार या उल्लेखनीय परिवर्तन किए जाने पर गलत मान्यताओं,

ओवरसाइटों की पहचान के लिए या उपकरण और कार्मिकों में परिवर्तन पर होने पर किया जाएगा।

2. परीक्षण के परिणाम आईएसआरएमसी को रिपोर्ट किए जाएंगे और बीसीपी/ डीआरपी में संशोधन के लिए उनका इस्तेमाल किया जाएगा।
3. आईटी डीआर परीक्षण संरचना में डीआर ड्रिल भी शामिल होंगे जो न केवल प्लान शटडाउन का बल्कि वास्तविक आपदा परिदृश्यों का भी प्रतिनिधित्व करेंगे।
4. सभी आईटी डीआर परीक्षण सावधानीपूर्वक आयोजना के बाद संचालित किए जाएंगे ताकि व्यवसाय परिचालनों में कोई व्यवधान न पड़े।

3.3.4 बीसीपी समीक्षा

की

बीसीपी की समीक्षा बीसीपी में ही परिभाषित आवधिकता के अनुसार और प्रत्येक परीक्षण के बाद की जाएगी और उसका अद्यतनीकरण किया जाएगा ताकि बीसीपी में व्यवसाय प्रक्रियाओं, अवसंरचना, कार्मिक आदि की वर्तमान प्रकृति को ध्यान में रखना सुनिश्चित किया जा सके।

3.4 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी	आईएस	जोखिम	व्यवसाय प्रयोक्ता

नीति सं.: 2.14

नीति का नाम: 2.14 तृतीय पक्ष सेवा प्रदाता

1 प्रयोजन

तृतीय पक्षकारों और उनके द्वारा हैंडल किए जाने वाले परिचालनों के चयन, एनरोलमेंट और सेवासमाप्ति से संबंधित वांछित कार्यपद्धतियों को परिभाषित करना।

2 दायरा

यह नीति संविदाकर्ताओं, विक्रेताओं और परामर्शदाताओं जैसे सभी तृतीय पक्ष सेवाप्रदाताओं पर लागू होती है जो किसी भी रूप में संगठन की सूचनाओं और सूचना संसाधनों हैंडल करते हैं, भंडारित करते हैं और संप्रेषित करते हैं। यह नीति उन सभी सूचना प्रणालियों, सूचना आस्तियों और संचार तथा नेटवर्क कनेक्शनों पर भी लागू होती है जो तृतीय पक्षकारों के स्वामित्व में हैं, परिचालित या प्रबंधित हैं और जिनके माध्यम से सूचना आस्तियाँ संप्रेषित, भंडारित या प्रसंस्कृत की जाती हैं।

प्रौद्योगिकी प्रणालियों, संचार और नेटवर्क कनेक्शनों में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण, सभी परिचालन प्रणालियाँ, डाटाबेस और एप्लिकेशन शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।

व्यवसाय परिचालनों के लिए किसी तृतीय पक्षकार की सेवाओं का उपयोग करने वाली सभी व्यवसाय इकाइयों या विभागों द्वारा इस नीति का अनुपालन किया जाएगा।

तृतीय पक्ष सेवाप्रदाताओं के साथ निष्पादित सभी संविदाओं के मामले में यह अपेक्षित होगा कि संगठन की जो सूचना आस्तियाँ उनकी पहुँच के भीतर हैं उनके लिए वे सूचना सुरक्षा नीति के प्रावधानों के अनुपालन के लिए नियंत्रण उपलब्ध कराएँ।

यह माना जाएगा कि तृतीय पक्षकार उसी स्तर की सुरक्षा उपलब्ध कराएगा जिस स्तर की सुरक्षा संगठन आंतरिक रूप से उपलब्ध कराएगा। इसके अलावा:

- यदि गोपनीय सूचना का मामला हो तो एक अ-प्रकटन करार हस्ताक्षरित किया जाएगा।
- अनुपालन के लिए तृतीय पक्ष सेवाप्रदाता का आकलन करार में शामिल किया जाएगा। संगठन और किसी तृतीय पक्षकार के बीच सूचना आस्तियों का आदान-प्रदान तब तक नहीं होगा जब तक एक लिखित करार की समीक्षा कर उसे हस्तारित नहीं किया जाता।
- संगठन की सूचना आस्तियों तक पहुँच की अनुमति देने के पहले सभी तृतीय पक्ष सेवाप्रदाताओं और संविदाकर्ताओं को संविदा निष्पादित करनी होगी।
- इस नीति के किसी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1

विक्रेता आईएस वर्गीकरण

1. सभी तृतीय पक्ष सेवाप्रदाताओं को आईएस टीम द्वारा परिभाषित तृतीय पक्ष सेवाप्रदाता वर्गीकरण मानक के आधार पर सूचना सुरक्षा के संदर्भ में वर्गीकृत किया जाएगा। तृतीय पक्ष सेवाप्रदाता वर्गीकरण मानक में निम्नलिखित मानदंडों को ध्यान में रखा जाएगा:
 - सेवाप्रदाता द्वारा निष्पादित गतिविधि की प्रकृति;
 - तृतीय पक्ष की पहुँच वाली सूचना आस्तियों का वर्गीकरण;
 - संगठन के परिसर सहित सूचना से इतर आस्तियों तक पहुँच;
 - तृतीय पक्ष के परिचालनों का महत्व;
 - संगठन की बौद्धिक सम्पदा तक पहुँच;
 - विनियामकीय महत्व वाली सेवाएँ उपलब्ध कराना;
 - समान सेवा या भौगोलिक क्षेत्र में किसी सेवाप्रदाता का अकेले होना या अनेक सेवाप्रदाताओं का होना।
2. तृतीय पक्ष सेवाप्रदाता वर्गीकरण मानक में तृतीय पक्ष विक्रेताओं की प्रत्येक श्रेणी के लिए सूचना सुरक्षा संबंधी आवश्यकताओं, अनुपालन आकलन की आवश्यकता तथा तंत्र और संविदागत अपेक्षाओं (जैसे एस्करो या सेवास्तरीय अपेक्षाएँ) को परिभाषित किया जाएगा।

3.2

संविदाओं और एसएलए में आईएस प्रावधान

1. संगठन और तृतीय पक्षकार के बीच संविदा पर हस्ताक्षर होने के बाद ही किसी भी तृतीय पक्ष सेवाप्रदाता को संगठन की सेवा के लिए पैनाल में शामिल किया जाएगा।
2. संगठन के हितों की सुरक्षा के लिए संविदागत निबंधनों और शर्तों का प्रारूप अनुपालन विभाग, जोखिम विभाग और आईएस विभाग के परामर्श से संगठन के विधि विभाग द्वारा तैयार किया जाएगा।
3. तृतीय पक्षकारों के साथ सभी करार/ दस्तावेज़ एक विशेष टूल का उपयोग करते हुए डिजिटली हस्ताक्षरित किए जाएंगे।
4. संविदा में, सेवाप्रदाता द्वारा निष्पादित की जाने वाली सेवाओं के अतिरिक्त, तृतीय पक्ष सेवाप्रदाता मानक में यथापरिभाषित तृतीय पक्ष सेवाप्रदाता वर्गीकरण के आधार पर सेवा के निष्पादन के दौरान पालन की जाने वाली सूचना सुरक्षा अपेक्षाओं को भी परिभाषित किया जाएगा।

5. सेवास्तरीय करार का प्रारूप सेवाप्रदाता को पैनल में शामिल करते व्यवसाय विभाग द्वारा तैयार किया जाएगा और तृतीय पक्ष सेवाप्रदाता मानक में यथापरिभाषित आवधिकता के अनुसार उसका अनुप्रवर्तन किया जाएगा।
6. विक्रेताओं के साथ संविदा के भाग के रूप में संगठन को लेखापरीक्षा का अधिकार होगा ताकि संगठन आउटसोर्सिंग जोखिमों के निपटने के लिए कार्यनिष्पादन, सूचना सुरक्षा और अन्य नियंत्रणों को लागू कराने में समर्थ हो।
7. यदि विक्रेता आईएसओ27001 मानक के अंतर्गत प्रमाणित विक्रेता हो और संगठन को दी जाने वाली सेवाओं का दायरा प्रमाणन की प्रयोजनीयता के दायरे/ अभिकथन में शामिल हो तो विक्रेता को संगठन द्वारा दी जाने वाली आवधिक लेखापरीक्षा की अपेक्षा से छूट दी जा सकती है। लेकिन ऐसे परिदृश्य में विक्रेता को निम्नलिखित दस्तावेज़ प्रस्तुत करने होंगे:
 - सभी संविदागत आईएस प्रावधानों के अनुपालन का स्व-प्रमाणपत्र;
 - वैध आईएसओ27001 प्रमाणन की एक प्रति जो यह प्रदर्शित करता हो कि संगठन को दी जाने वाली सेवाओं का दायरा प्रमाणन की प्रयोजनीयता के दायरे/ अभिकथन में शामिल है।

3.3 एनरोलमेंट और परिवर्तन

1. किसी गतिविधि को आउटसोर्स करने का प्रस्ताव देने वाला व्यवसाय विभाग चुने गए विक्रेताओं के मामले में 'यथोचित सावधानी' निष्पादित करेगा ताकि संविदागत करार में निहित सूचना सुरक्षा संबंधी बाध्यकारी दायित्वों का अनुपालन करने की विक्रेता की योग्यता का आकलन किया जा सके। यथोचित सावधानी का निष्पादन तृतीय पक्ष सेवाप्रदाता मानक वर्गीकरण के आधार पर निम्नलिखित में से किसी एक साधन के माध्यम से किया जाएगा:
 - विक्रेता द्वारा स्व-मूल्यांकन;
 - संगठन के कार्मिक द्वारा ऑन-साइट दौरा;
 - अन्य सार्वजनिक स्रोतों से एकत्र की गई जानकारी।
2. यथोचित सावधानी प्रक्रिया के अंतर्गत सेवाप्रदाता के बारे में उपलब्ध समस्त जानकारी का मूल्यांकन किया जाएगा, जैसे:
 - संविदागत अवधि के दौरान प्रस्तावित गतिविधि के कार्यान्वयन और सहयोग के क्षेत्र में विगत अनुभव और क्षमता;
 - व्यवसायगत प्रतिष्ठा और व्यवसाय संस्कृति, अनुपालन, शिकायतें और बकाया या संभावित मुकदमा;
 - सुरक्षा नीति, कार्यविधियाँ और आंतरिक नियंत्रण, लेखापरीक्षा कवरेज, रिपोर्टिंग और अनुप्रवर्तन पर्यावरण, व्यवसाय निरंतरता प्रबंधन;
 - सेवाप्रदाता के परिचालन कार्यक्षेत्र का राजनीतिक, आर्थिक, सामाजिक और विधिक पर्यावरण तथा सेवाप्रदाता की सुरक्षा स्थिति को प्रभावित कर सकने वाली घटना जैसे बाह्य कारक;
 - सेवाप्रदाता के यहाँ अपने कर्मचारियों के संबंध में यथोचित सावधानी सुनिश्चित करने के लिए स्थापित कार्यविधियाँ।
3. किसी नए सेवाप्रदाता को एनरोल करते समय या किसी विद्यमान सेवाप्रदाता द्वारा दी जा रही सेवाओं में परिवर्तन की स्थिति में यथोचित सावधानी का निष्पादन किया जाएगा।
4. यदि कोई तृतीय पक्ष विक्रेता उप-संविदा की व्यवस्था करता है तो उसके सत्यापन के लिए उपयुक्त यथोचित सावधानी निष्पादित की जाएगी।

3.4

आवधिक आकलन

1. तृतीय पक्ष सेवाप्रदाता मानक में यथापरिभाषित आवधिकता के अनुसार प्रत्येक तृतीय पक्ष सेवाप्रदाता का आवधिक आधार पर आकलन किया जाएगा ताकि यह सुनिश्चित किया जा सके कि वे करार और बीमा कंपनी की सूचना सुरक्षा अपेक्षाओं का अनुपालन करते रहें।
2. आवधिक आकलन में निम्नलिखित को शामिल किया जाएगा:
 - संविदा में उल्लिखित सेवाओं को एसएलए के अनुसार निष्पादित किया जाना;
 - सेवाप्रदाताओं द्वारा नियोजित कार्मिकों का उत्पाद की जानकारी और हैंडल की जाने वाली प्रक्रियाओं में दक्ष होना;
 - सेवाप्रदाताओं द्वारा नियोजित कार्मिकों का विनियामक/अन्य कानूनी प्राधिकारियों द्वारा निषिद्ध नहीं होना;
 - सेवाओं के निष्पादन के लिए पर्याप्त अवसंरचना;
 - ग्राहकों, बैंक और सेवा अभिलेखों का समुचित दस्तावेजीकरण;
 - हितों के टकराव की संभावना;
 - संविदा में यथापरिभाषित आईएस प्रावधान;
 - संविदा में यथापरिभाषित गोपनीयता और अ-प्रकटन करार।

3.5

परिसमापन

1. संगठन के पास यह अधिकार सुरक्षित होगा कि वह संगठन की सूचना सुरक्षा अपेक्षाओं सहित संविदागत अपेक्षाओं का निष्पादन न होने या निष्पादन के अपेक्षाओं के अनुरूप न होने पर किसी भी तृतीय पक्ष सेवाप्रदाता की सेवाओं को परिसमाप्त कर दे। सेवाप्रदाता के साथ निष्पादित संविदा में परिसमापन संबंधी खंड स्पष्ट रूप से निर्धारित किए जाएंगे।
2. संविदा की अवधि के स्वाभाविक रूप से समाप्त हो जाने या किसी भी पक्षकार द्वारा परिसमापन खंडों को आहूत कर संविदा को परिसमाप्त कर देने के बाद निम्नलिखित अपेक्षाओं का पालन अनिवार्य होगा:
3. सेवाप्रदाता से यह अपेक्षित होगा कि वह सेवा की अवधि में अपने कब्जे में रखी संगठन की आस्तियों को वापस कर दे।
4. संगठन की जिन सूचना आस्तियों और परिसरों को उपयोग के लिए तृतीय पक्ष सेवाप्रदाता के कार्मिकों या प्रणालियों को दिया गया होगा उन तक पहुँच को तत्काल प्रभाव से या संविदा की अवधि के समाप्त होने की तारीख को प्रतिसंहत कर लिया जाएगा ताकि यह सुनिश्चित किया जा सके कि सेवाप्रदाता की पहुँच संगठन की सूचना आस्तियों/परिसरों तक जारी न रह सके।

1. तृतीय पक्ष सेवाप्रदाता के साथ जो डाटा साझा करना हो उसके व्यवसाय प्रयोजन को अनिवार्य रूप से परिभाषित किया जाना चाहिए।
2. संगठन के लिए निष्पादित परिचालनों के क्रम जो डाटा जेनरेट होगा वह संगठन का होगा और संगठन की नीतियों का अनुसरण करेगा।
3. संगठन का जो डाटा तृतीय पक्ष के नियंत्रण में होगा वह आईएस नीति में निर्धारित अपेक्षाओं के अनुसार किए गए डाटा वर्गीकरण पर आधारित नियंत्रणों के समान या उनसे भी कठोर नियंत्रणों के अधीन होगा।
4. संगठन को यह अधिकार होगा कि वह संगठन की गतिविधि के लिए प्रयुक्त विक्रेता की आस्ति से कंपनी से संबन्धित सूचना को डिलीट कर दे और इसे डाटा प्रतिधारण नीति के अनुसार प्रमाणित करे।
5. परिसमापन के बाद संगठन द्वारा संप्रेषित किया गया डाटा या तृतीय पक्ष द्वारा बीमा कंपनी के लिए जेनरेट किया गया डाटा संगठन को सौंप दिया जाएगा।
6. मार्गस्थ डाटा आईएस नीति में निर्धारित अपेक्षाओं के अनुसार किए गए डाटा वर्गीकरण पर आधारित नियंत्रणों के समान या उनसे भी कठोर नियंत्रणों के अधीन होगा।
7. डाटा को तृतीय पक्ष द्वारा संगठन के सुस्पष्ट अनुमोदन के बिना और संगठन की नीतियों के तृतीय पक्ष द्वारा अनुपालन को अनिवार्य बनाने वाली सुस्पष्ट संविदा के बिना संगठन के अलावा किसी के साथ भी साझा नहीं किया जाएगा।

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
तृतीय पक्ष सेवाप्रदाता	सेवाओं को आउटसोर्स करने की प्रस्तावकर्ता इकाई	विधिक, अनुपालन, आईएस, जोखिम	वित्त

नीति सं.: 2.15
नीति का नाम: 2.15 भौतिक और पर्यावरण सुरक्षा
1 प्रयोजन

संगठन के कर्मचारियों और उसकी मूर्त तथा अमूर्त आस्तियों के लिए एक सुरक्षित पर्यावरण सुनिश्चित करने हेतु भौतिक एवं पर्यावरणीय सुरक्षा से संबंधित वांछित कार्यपद्धतियों को परिभाषित करना। संगठन की भौतिक सुरक्षा नीति का लक्ष्य होगा अपने कर्मचारियों और अपनी मूर्त तथा अमूर्त आस्तियों के लिए एक सुरक्षित पर्यावरण सुनिश्चित करना।

2 दायरा

भौतिक सुरक्षा लोगों और आस्तियों (परिसर और अवसंरचना सहित) की रक्षा, सुरक्षा और रखरखाव पर नियंत्रण की मूलभूत परत उपलब्ध कराती है। भौतिक खतरे उल्लेखनीय व्यवसाय जोखिम हैं क्योंकि व्यवसाय परिचालनों की निरंतरता लोगों और अवसंरचना (परिचालन परिसर और सूचना प्रणालियों सहित) की रक्षा पर निर्भर करती है। यह नीति संगठन की सभी आस्तियों पर लागू होती है, अर्थात्

- संगठन की सुविधाओं तक पहुँचने वाले लोग, जैसे कर्मचारी, संविदाकर्ता, सेवाप्रदाता/ आगंतुक;

- भवन परिसर, उपस्कर और जुड़नार, कार्यालय उपकरण, भौतिक दस्तावेज़ और अन्य इलेक्ट्रो-मैकानिकल इन्स्टालेशन।

3	नीति	संगठन की सभी आस्तियों (लोग और अवसंरचना) को अप्राधिकृत या गैर-कानूनी पहुँच और साथ ही व्यवसायगत तथा पर्यावरणीय खतरों से संरक्षित रखा जाएगा। इस नीति के किसी भी उल्लंघन को घटना के रूप में लिया जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।
3.1	ज़ोनिंग और पेरीमीटर परिभाषा	संगठन की सुविधाओं को उनमें निष्पादित गतिविधियों या उनमें पाए जाने वाले इन्स्टालेशनों के आधार पर अलग-अलग ज़ोन में श्रेणीकृत किया जाएगा। तदनुरूप प्रत्येक ज़ोन में सुरक्षा के अलग-अलग स्तर होंगे। ज़ोन वर्गीकरण का विवरण नीचे के उपखंडों में दिया गया है:
3.1.1	ज़ोन 1 या अर्ध-सार्वजनिक ज़ोन	ज़ोन 1 वस्तुतः भवन परिसर के प्रवेश द्वार और पहुँच नियंत्रण प्रणाली से संरक्षित प्रवेश बिन्दु के बीच का क्षेत्र है। इस क्षेत्र तक नगण्य प्रतिबंधों के साथ पहुँचा जा सकेगा। आम तौर पर सामने का हॉल, बैठक कक्ष और स्वागत कक्ष जो आम जनता के लिए खुले रहते हैं, अर्ध-सार्वजनिक ज़ोन में आएँगे।
3.1.2	ज़ोन 2 या नियंत्रित ज़ोन	ज़ोन 2 मूल रूप से काम-काज का वह क्षेत्र होगा जहाँ पहचान को अच्छी तरह से सत्यापित करने के बाद ही किसी व्यक्ति की पहुँच हो सकती है। ज़ोन 2 केवल उन्हीं प्राधिकृत व्यक्तियों के लिए खुला होगा जिनकी विधिवत् पहचान की गई हो और जिनके पास उस क्षेत्र में प्रवेश करने का व्यवसायगत प्रयोजन हो।
3.1.3	ज़ोन 3 या सुरक्षित ज़ोन	ज़ोन 3 एक चिह्नित क्षेत्र होगा जहाँ गोपनीय डाटा, संवेदनशील या मूल्यवान् आस्तियाँ (इलेक्ट्रॉनिक आस्तियों से इतर) हों जिनकी विशेष सुरक्षा आवश्यक हो। ज़ोन 3 तक पहुँच पर उच्चस्तरीय प्रतिबंध होगा और वहाँ पहुँच की अनुमति नितांत आवश्यक होने पर ही दी जाएगी। इस ज़ोन तक पहुँच रखने वाले विशिष्ट व्यक्ति निम्नानुसार हो सकते हैं: • बीमा कंपनी के भीतर एक विशेष टीम; • बाह्य सेवाप्रदाता जिनका व्यवसाय प्रयोजन से सुरक्षित ज़ोन में पहुँचना आवश्यक हो। • ज़ोन 3 के भीतर कुछ क्षेत्रों में निम्नलिखित शामिल होंगे: • डीलिंग कक्ष/ ट्रेडिंग कक्ष; • परिचालन क्षेत्र जहाँ नकदी और मूल्यवान् वस्तुएँ रखी जाती हैं। • कॉम्पैक्टर कक्ष।
3.1.4	ज़ोन 4 या इलेक्ट्रॉनिकली संवेदनशील ज़ोन	1. ज़ोन 4 एक चिह्नित, इलेक्ट्रॉनिकली संवेदनशील ज़ोन होगा जहाँ संगठन के डाटा को होस्ट करने वाली इलेक्ट्रॉनिक आस्तियाँ होती हैं। इसमें संवेदनशील आस्तियाँ या प्रणालियाँ होंगी जिनके अत्यधिक उच्च स्तर के संरक्षण की आवश्यकता होती है। ज़ोन 4 तक पहुँच पर उच्चस्तरीय प्रतिबंध होगा और वहाँ पहुँच की अनुमति नितांत आवश्यक होने पर ही दी जाएगी। इस ज़ोन तक पहुँच रखने वाले विशिष्ट व्यक्ति निम्नानुसार हो सकते हैं: • बीमा कंपनी के भीतर एक विशेष टीम;

- बाह्य सेवाप्रदाता जिनका व्यवसाय प्रयोजन से सुरक्षित ज़ोन में पहुँचना आवश्यक हो।
 - ज़ोन 3 के भीतर कुछ क्षेत्रों में निम्नलिखित शामिल होंगे:
 - सर्वर कक्ष;
 - डाटासेंटर;
 - हब कक्ष।
2. संगठन यह सुनिश्चित करेगा कि ज़ोन 3 और ज़ोन 4 वाले स्थान भवन के प्रवेश/निकास द्वार से दूर हों। यह अनिवार्य है कि उनकी अवस्थिति को प्रदर्शित नहीं किया जाए।
 3. प्रत्येक सुरक्षित ज़ोन का एक पदनिर्दिष्ट स्वामी होगा जिसके दायित्व निम्नानुसार होंगे:
 - सुरक्षित ज़ोन में पहुँचने वाले व्यक्तियों (आंतरिक स्टाफ, बाहरी संविदाकर्ता, आपूर्तिकर्ता और आगंतुक) की पहचान करना;
 - आवधिक आधार पर सुरक्षित ज़ोन में प्रवेश करने वाले व्यक्तियों की सूची का वैधकरण करना;
 - सुरक्षित ज़ोन में पहुँच के सभी अनावश्यक/अप्राधिकृत हो गए अधिकारों को प्रतिसंहत करना।
 4. यदि सुरक्षा कार्मिकों द्वारा किसी कर्मचारी को ज़ोन 3 और ज़ोन 4 के लिए निर्धारित नीति का उल्लंघन करते हुए पाया जाता है तो इसकी रिपोर्ट उस स्थल-विशेष के लिए अपनाई जाने वाली अनिवार्य कार्यविधि के अनुसार कार्रवाई करने के लिए स्थल प्रभारी (प्रशासनिक कार्मिक) और सीआईएसओ को की जाएगी। यदि कोई कार्यविधि परिभाषित नहीं है तो सीआईएसओ मामले को आईएसआरएमसी तक आगे बढ़ाएगा और और उसके बाद आवश्यक समझी जाने वाली उपयुक्त कार्रवाई करेगा और यदि आवश्यक समझा जाए तो एक औपचारिक कार्यविधि भी स्थापित करेगा।

3.2 ज़ोनों के लिए भौतिक पहुँच के मानक

3.2.1 ज़ोन 1

1. भवन/परिसर (जिसे आगे 'परिसर' कहा जाएगा) से वे सारे क्षेत्र संदर्भित होंगे जो संगठन के प्रबंधन के प्रत्यक्ष नियंत्रण में होंगे, जैसा कि नीचे परिभाषित किया गया है:
 - यदि सम्पूर्ण ढाँचा संगठन के प्रबंधन के स्वामित्व में हो या उसके द्वारा पट्टे लिया गया हो तो आम रास्ते के पास ढाँचे के प्रवेश/निकास द्वार से लेकर पूरे ढाँचे को संगठन के प्रबंधन नियंत्रण के अंतर्गत परिसर के रूप में संदर्भित किया जाएगा।
 - यदि किसी भवन के एक हिस्से पर ही संगठन का स्वामित्व है या उसे ही संगठन ने पट्टे पर लिया है तो प्रबंधन नियंत्रण के अंतर्गत परिसर से उस फ्लोर/विंग या उस निर्दिष्ट कार्य क्षेत्र को संदर्भित किया जाएगा जिसे स्वामित्व/पट्टे के प्रयोजन से शेष भवन से भौतिक रूप से अलग कर दिया गया हो। संगठन अपनी अस्तियों की सुरक्षा सुनिश्चित करने के लिए परिसर प्राधिकारियों से इन नीतियों का यथासंभव अनुपालन करने का अनुरोध करेगा।
2. उन सभी लोगों को परिसर तक पहुँच की अनुमति दी जाएगी जो अपने कर्तव्यों के निर्वहन (कर्मचारी/संविदाकर्ता/सेवाप्रदाता) या संगठन से सेवाएँ प्राप्त करने (ग्राहक) जैसे व्यावसायिक प्रयोजन से परिसर तक पहुँच की आवश्यकता रखते हैं।

3. परिसर में प्रवेश से किसी को स्वतः ही कामकाज के क्षेत्र या प्रतिबंधित क्षेत्र में प्रवेश का अधिकार नहीं मिल जाता बल्कि उसकी पहुँच ज़ोन 1 (व्यावसायिक प्रयोजन से आम जनता के लिए पहुँच-योग्य क्षेत्र) तक ही सीमित रहती है। इसमें निम्नलिखित शामिल होंगे (लेकिन यह सूची सम्पूर्ण नहीं है):
 - लॉबी/ स्वागत;
 - प्रवेश लॉबी में बैठक कक्ष;
 - कैफेटेरिया, यदि वह प्रवेश/ निकास के लिए बिल्ले (बैज) की आवश्यकता वाले क्षेत्र से बाहर हो।
4. परिसर के प्रवेश/ निकास द्वार पर संतरियों की तैनाती जैसे सुरक्षा उपायों से ज़ोन 1 तक अप्राधिकृत पहुँच को रोका जाएगा।
5. परिसर को अप्राधिकृत पहुँच से सुरक्षित रखने के लिए मुख्य प्रवेश स्थल पर सुरक्षा गार्ड तैनात किए जाएँगे। गार्ड 24x7 ड्यूटी पर रहेंगे। संगठन के प्रत्येक परिसर के लिए प्रशासनिक टीम के एक सदस्य को प्रभारी बनाया जाएगा जो परिसर में इस नीति के कार्यान्वयन के लिए जिम्मेदार होगा। यदि परिसर के लिए ऐसा कोई अलग व्यक्ति प्रभारी नहीं बनाया जा सकता तो संबंधित शाखा प्रबन्धक/ व्यवसाय प्रमुख उस परिसर में इस नीति के कार्यान्वयन के लिए जिम्मेदार होगा।
6. संगठन के प्रबंधन द्वारा अधिसूचित कुछ व्यक्तियों को भी आम जनता के लिए मुक्त परिसर में प्रवेश से प्रतिबंधित किया जा सकता है। लेकिन इस प्रकार के प्रतिबंध को सीआईएसओ और प्रत्येक भवन के परिसर प्रभारी द्वारा अधिसूचित किए जाने और आईएसआरएमसी द्वारा अनुमोदित किए जाने की आवश्यकता होगी।
7. कर्मचारियों और दीर्घावधि संविदाकर्ताओं के लिए:
परिसर में प्रवेश के लिए प्राधिकृत सभी कर्मचारियों और संविदागत स्टाफ को पहुँच कार्ड (बैज/ बिल्ला) दिया जाएगा जो संगठन में उनकी पहचान होगा। कर्मचारियों और दीर्घावधि संविदाकर्ताओं को जारी किए गए पहचान बैज को प्रदर्शित करने पर उन्हें परिसर में प्रवेश की अनुमति मिलेगी। कर्मचारियों/ दीर्घावधि संविदाकर्ताओं के पास का पहुँच कार्ड स्वतः ही उन्हें पहुँच की अनुमति देगा।
8. सेवाप्रदाताओं/ आगंतुकों के लिए:
कार्यालयीन प्रयोजन से परिसर में पहुँच की आवश्यकता वाले सेवाप्रदाताओं/ आगंतुकों को स्वागत कक्ष/ क्षेत्र के पास स्वागत स्टाफ/ सुरक्षा गार्ड के पास पहुँच कर अपनी पहचान दिखानी होगी। उन्हें अपने आगमन का प्रयोजन भी घोषित करना होगा और उसके बाद उन्हें पहुँच की अनुमति दी जाएगी।

3.2.2 ज़ोन 2

1. कामकाज के क्षेत्र वे हैं जहाँ किसी व्यक्ति की पूर्ण पहचान के सत्यापन के बाद ही पहुँच की अनुमति दी जा सकती है और इसमें वे भाग शामिल हैं जहाँ कर्मचारी अपनी दैनंदिन गतिविधियाँ संपादित करते हैं।
2. किसी व्यक्ति को इन क्षेत्रों तक पहुँच की अनुमति केवल व्यावसायिक कारणों से और उसकी पहचान के विधिवत् स्थापित होने के बाद दी जाएगी।
3. कामकाज के क्षेत्र में प्रवेश से स्वतः ही संवेदनशील क्षेत्र या प्रतिबंधित क्षेत्र में पहुँच का अधिकार नहीं मिल जाता बल्कि केवल उन्हीं क्षेत्रों तक पहुँचा जा सकता है जहाँ सभी कर्मचारी या दीर्घावधि संविदाकर्ता पहुँच सकते हैं, लेकिन जहाँ आम लोग स्वतः नहीं पहुँच सकते।

4. कामकाज के क्षेत्र में पहुँच को पहुँच कार्डों (बैज) या समतुल्य सुरक्षा उपाय के माध्यम से नियंत्रित किया जाएगा। पहुँच कार्ड व्यक्ति की विधिवत् पहचान स्थापित करेंगे और उसे उसके जॉब प्रोफ़ाइल या दायित्व के अनुसार संबंधित क्षेत्रों में पहुँचने की अनुमति देंगे।
5. कामकाज के क्षेत्र में प्रवेश को प्रतिबंधित करने के उद्देश्य से ज़ोन 2 के लिए स्वचालित पहुँच नियंत्रण (उदाहरण के लिए, निकटता-आधारित पहुँच नियंत्रण के साथ-साथ प्रदर्शित करने योग्य बैज) प्रणालियों को अधिमानता दी जाएगी। स्वचालित प्रणाली के अभाव में कामकाज के क्षेत्र में पहुँच को प्रवेश/निकास द्वारों पर सुरक्षा गार्डों की तैनाती के माध्यम से नियंत्रित किया जाएगा।

क) कर्मचारियों/ दीर्घावधि संविदाकर्ताओं के लिए:

- I. संगठन के जिन कर्मचारियों और दीर्घावधि संविदाकर्ताओं को दीर्घावधि आधार पर परिसर में प्रवेश के लिए प्राधिकृत किया गया हो उन्हें व्यक्ति-विशिष्ट पहचान से युक्त पहुँच कार्ड (बैज) दिए जाएँगे जो संगठन में उनकी पहचान स्थापित करेंगे। कर्मचारियों/ दीर्घावधि संविदाकर्ताओं को जारी किए गए पहचान बैज को प्रदर्शित करने पर उन्हें परिसर में पहुँच की अनुमति दी जाएगी।
- II. कुछ दीर्घावधि संविदाकर्ताओं के पास भी व्यक्तिगत पहुँच कार्ड होंगे जिसमें सामने उनका नाम और फोटो मुद्रित होंगे। अन्य दीर्घावधि संविदाकर्ताओं को सामान्य प्रयोजन दीर्घावधि कार्ड जारी किए जाएँगे।
- III. सामान्य रूप से ज़ोन 2 के लिए पहुँच कार्ड हस्तांतरण के योग्य नहीं होंगे। लेकिन जब शिफ्ट में काम करने वाले संविदाकर्ताओं के बीच हस्तांतरण आवश्यक हो तो कार्ड के स्वामित्व का शिफ्ट एंट्री रजिस्टर में अभिलेख रखा जाएगा ताकि ऐसे कार्ड के उपयोग के उत्तरदायित्व को स्थापित किया जा सके।
- IV. बैजधारक निम्नलिखित के लिए उत्तरदायी होंगे:
 - नियंत्रित/ सुरक्षित ज़ोन में प्रवेश के लिए बैज का उपयोग करना;
 - बैज को दिकाई देने योग्य तरीके से पहनना;
 - किसी दूसरे व्यक्ति को बैज न सौंपना;
 - किसी अन्य व्यक्ति को प्रवेश दिलाने के लिए अपने बैज के उपयोग की अनुमति न देना;
 - बैज को अपने पास रखने के अधिकार के समाप्त होने के बाद बैज को वापस कर देना।

ख) सीमित समय के लिए प्रवेश के प्राधिकार वाले सेवाप्रदाता/ अन्य व्यक्ति

- I. जिन सेवाप्रदाताओं को एक से अधिक कार्यदिवस की अवधि के लिए कार्यालयीन प्रयोजन से परिसर में पहुँच की आवश्यकता हो, उन्हें सामान्य प्रयोजन दीर्घावधि कार्ड जारी किया जाएगा जिस पर 'सी' अंकित होगा।
- II. सीमित अवधि के लिए प्रवेश हेतु प्राधिकृत व्यक्तियों को आगंतुक (विजिटर) बैज जारी किया जाएगा जिस पर 'वी' अंकित होगा।
- III. दोनों मामलों में पहुँच की अनुमति की अवधि बैज में ही कन्फ़िगर होगी। समान्यतः पहुँच की अनुमति मुख्य प्रवेश द्वार, कैफेटेरिया और उस फ्लोर के लिए कन्फ़िगर किया जाएगा जहाँ संविदाकर्ता/ अन्य आगंतुक की पहुँच की आवश्यकता होगी।
- IV. परिसर में पहुँच की अनुमति व्यक्ति को जारी पहचान बैज को प्रदर्शित करने पर और उसके अतिरिक्त स्वचालित पहुँच नियंत्रण

ग) एक बार ही परिसर में प्रवेश के लिए प्राधिकृत आगंतुकों के लिए:

1. जिन आगंतुकों को केवल एक बार परिसर में पहुँच की आवश्यकता होगी उन्हें सामान्य प्रयोजन वन टाइम विजिट कार्ड जारी किया जाएगा। आगंतुकों को संगठन परिसर के स्वागत कक्ष या वहाँ तैनात सुरक्षा गार्डों को अपनी पहचान दिखानी होगी और अपने आगमन का प्रयोजन बताना होगा। आगंतुकों को कामकाज के क्षेत्रों में पहुँच की अनुमति निम्नानुसार दी जाएगी:
 -) स्वागत/ सुरक्षा स्टाफ आगंतुक की प्रविष्टि दर्ज करेंगे और उसका नाम, आगमन की तारीख और समय, जिससे मिलना है यानी मेजबान का नाम, आगमन का प्रयोजन, साथ में लाए सामान, जैसे लैपटॉप, मोबाइल, पेन ड्राइव और अन्य पोर्टेबल मीडिया का विवरण कैप्चर करेंगे।
 -) पहचान और सत्यापन के बाद स्वागत स्टाफ/ गार्ड संबंधित स्टाफ से आगमन के प्रयोजन का सत्यापन करेगा और आगंतुक को एक अस्थायी विजिटर पास देगा।
 -) जब तक विशेष रूप से अनुरोध न किया जाए और उस अनुरोध को अनुमोदित न किया जाए, 'वी' कार्ड पहुँच के अधिकारों के बिना होगा।
 -) स्वागत कक्ष का स्टाफ मेजबान को सूचित करेगा और आगंतुक को अपेक्षित क्षेत्रों तक स्वयं लेकर जाएगा।
2. आगंतुक के दायित्वों में निम्नलिखित शामिल होंगे:
 -) बैज को दिखाई देने योग्य तरीके से पहनना;
 -) मेजबान के साथ के बिना भवन में इधर-उधर नहीं घूमना;
 -) आगमन का प्रयोजन पूरा होने के बाद निकास पर विजिटर पास/ बैज को वापस लौटाना।
3. मेजबान के दायित्वों में निम्नलिखित शामिल होंगे:
 -) यदि पहले से जानकारी हो तो अपने आगंतुक के बारे में पूर्व-घोषणा;
 -) अपने आगंतुक के लिए उपयुक्त पहुँच अधिकार के लिए अनुरोध;
 -) परिसर के भीतर और बाहर जाते समय तथा कंपनी के भवन में आगंतुक की उपस्थिति के दौरान उसके साथ रहना;
 -) परिसर में घूमने के संबंध में कंपनी के नियमों के बारे में आगंतुक को अवगत कराना;
 -) आगमन के समापन के बाद आगंतुकों से बैज की वापसी सुनिश्चित करवाना।

3.2.3 संवेदनशील क्षेत्र (ज़ोन 3 और 4)

1. संवेदनशील क्षेत्र वे हैं जहाँ व्यक्ति की पहचान और प्रयोजन के पूर्ण सत्यापन के बाद ही पहुँच की अनुमति दी जाती है। इन क्षेत्रों में पहुँच पर अत्यधिक प्रतिबंध होगा और केवल अत्यावश्यक होने पर ही किसी व्यक्ति को पहुँच की अनुमति दी जाएगी।
2. इन क्षेत्रों में की जाने वाली गतिविधियों और भंडारित आस्तियों की मूर्त तथा अमूर्त मूल्यवत्ता के कारण इन क्षेत्रों में पहुँच के लिए कार्यान्वित सुरक्षा नियंत्रणों का स्तर बहुत उच्च होगा।

3. इन क्षेत्रों में पहुँच की अनुमति केवल और केवल व्यावसायिक कारणों से दी जाएगी। जब तक व्यवसाय प्रयोजन के लिए आवश्यक नहीं होगा तब तक आगंतुकों की इन क्षेत्रों में पहुँच नहीं होगी।
4. संवेदनशील क्षेत्रों में पहुँच के लिए एक स्वचालित पहुँच नियंत्रण प्रणाली को अधिमानता दी जाएगी। स्वचालित पहुँच नियंत्रण प्रणाली के अभाव में संवेदनशील क्षेत्रों की आस्तियों को ताला-चाबी का उपयोग कर सुरक्षित किया जाएगा। स्वचालित पहुँच नियंत्रण न होने पर प्रवेश/निकास बिन्दुओं पर तैनात सुरक्षा गार्ड संवेदनशील क्षेत्रों में पहुँच को नियंत्रित करेंगे।
5. केवल और केवल अत्यावश्यकता के आधार पर ही पहुँच की अनुमति दी जाएगी। यदि संवेदनशील क्षेत्र में पहुँच के लिए प्राधिकृत व्यक्तियों से इतर किसी व्यक्ति को उसके काम की प्रकृति के कारण संवेदनशील क्षेत्रों में पहुँच उपलब्ध कराना आवश्यक हो तो संवेदनशील क्षेत्र के नामनिर्दिष्ट स्वामी से स्पष्ट अनुमोदन आवश्यक होगा।
 - I. कर्मचारियों/ दीर्घावधि संविदाकर्ताओं के लिए:
जिन कर्मचारियों/ दीर्घावधि संविदाकर्ताओं को अपने काम की प्रकृति के कारण इन क्षेत्रों में पहुँच की आवश्यकता है उन्हें पहुँच बैजों का उपयोग कर इन क्षेत्रों में पहुँच की अनुमति दी जाएगी। ऐसे कर्मचारियों और दीर्घावधि संविदाकर्ताओं (जो सामान्यतः तकनीकी अनुरक्षण स्टाफ होते हैं) के पहुँच बैजों को पहुँच की अनुमति के लिए कन्फ़िगर किया जाएगा। ऐसे व्यक्तियों के पहुँच के अधिकार की समीक्षा पदनिर्दिष्ट प्रबन्धक/ सुरक्षित क्षेत्र के स्वामी द्वारा अर्धवार्षिक आधार पर की जाएगी ताकि पहुँच के अधिकारों का आवश्यकता के हिसाब से बने रहना सुनिश्चित किया जा सके।
 - II. सेवाप्रदाताओं के लिए:
संवेदनशील क्षेत्र में एक बार पहुँच की आवश्यकता वाले सेवाप्रदाताओं को स्वागत कक्ष में अपनी पहचान दिखानी होगी। पहचान के स्थापित होने और संवेदनशील क्षेत्र के पदनिर्दिष्ट स्वामी का स्पष्ट अनुमोदन प्राप्त होने के बाद उन्हें अस्थायी पहुँच की अनुमति वाला पास दिया जाएगा। संवेदनशील क्षेत्र में प्रवेश का प्राधिकार रखने वाला एक कर्मचारी ऐसे सेवाप्रदाताओं के आगमन के दौरान हमेशा उनके साथ रहेगा।
 - III. आगंतुकों के लिए:
आगंतुकों को संवेदनशील क्षेत्र में पहुँच की अनुमति नहीं दी जाएगी। यदि किसी अपवाद की स्थिति आती है तो संवेदनशील क्षेत्र के पदनिर्दिष्ट स्वामी का स्पष्ट अनुमोदन आवश्यक होगा। ऐसे मामलों में भी संवेदनशील क्षेत्र में प्रवेश का प्राधिकार रखने वाला एक कर्मचारी आगंतुकों के आगमन के दौरान हमेशा उनके साथ रहेगा।

3.3 ज़ोनों के लिए पर्यावरणीय मानक

भौतिक और पर्यावरणीय खतरों से अपने लोगों और अवसंरचना को संरक्षित रखने के लिए संगठन द्वारा पर्यावरणीय सुरक्षा नियंत्रण कार्यान्वित किए जाएँगे। सुरक्षा की समग्र सहयोगी संरचना की समग्र प्रभावोत्पादकता के लिए लोगों और अवसंरचना को संरक्षित रखना अनिवार्य है। इस नीति के माध्यम से यह सुनिश्चित किया जाएगा कि लोगों और अवसंरचना को अग्निकांड, बाढ़, बिजली आपूर्ति में व्यवधान, अत्यधिक ऊँचे तापमान और भूकंप जैसी घटनाओं से संरक्षित रखा जाए।

पर्यावरणीय नियंत्रणों को डिजाइन और कार्यान्वित करने की ज़िम्मेदारी प्रशासनिक टीमों की होगी और सीआईएसओ की ज़िम्मेदारी होगी कि वह इन नियंत्रणों का पालन और अनुपालन सुनिश्चित करे।

3.3.1 ज़ोन 1

1. भवन में प्रवेश के स्थान बहुत कम होंगे ताकि अप्राधिकृत कार्मिक भवन में प्रवेश न कर पाएँ।
2. आग लगने पर प्रयोग किए जाने वाले निकास द्वारों में ताला नहीं लगाया जाएगा और उनमें केवल एकतरफा क्रैश बार होगा, दरवाजे को आसानी से खोलने की व्यवस्था होगी और जहाँ संभव हो वहाँ किसी द्वार के दुरुपयोग को रोकने के उद्देश्य से द्वार के खुलते ही उपयुक्त तेज आवाज वाले अलार्म के ट्रिगर हो जाने की व्यवस्था होगी। यदि ताला लगाया जाता है तो बगल में ही टूट सकने वाली काँच के एक बॉक्स में उसकी चाबी रखी जाएगी जिसका उपयोग आपातकालीन स्थिति में द्वार खोलने के लिए कर्मचारी कर सकते हैं।
3. भवनों में आकाशीय बिजली से बचाव की व्यवस्था होगी जिसकी जाँच आवधिक आधार पर की जाएगी।
4. न्यूनतम आवश्यक परिचालनों को जारी रखने के लिए भवनों में बैक-अप पावर सोर्स होगा। बिजली गुल होने के समय पावर के लिए एक डीजी सेट के इन्स्टालेशन को प्राथमिकता दी जाएगी। जहाँ भी संभव होगा, डीजी सेट के परिचालन में नहीं रहने की स्थिति में बिजली की अबाध आपूर्ति के लिए महत्वपूर्ण संसाधनों हेतु यूपीएस पावर बैक-अप इन्स्टाल किए जाएँगे।
5. एक तकनीकी टीम उपलब्ध होगी जो पर्यावरणीय मानदंडों का अनुप्रवर्तन करेगी/ अनुप्रवर्तन स्टाफ द्वारा रिपोर्ट की जाने वाली विसंगति को, विशेष रूप से यदि विसंगति सर्वर रूम/ डाटा सेंटर से संबंधित हो, ठीक करने का काम करेगी।

3.3.2 ज़ोन 2

1. कामकाज के क्षेत्र में पहुँच नियंत्रण कार्डों के माध्यम से पहुँचा जा सकेगा ताकि किसी कार्मिक के अप्राधिकृत प्रवेश को प्रतिबंधित किया जा सके।
2. कोई लीकेज या जलरिसाव न हो इसके लिए कामकाज के क्षेत्र की निगरानी की जाएगी।
3. कामकाज के क्षेत्र के तापमान की निगरानी अनुप्रवर्तन स्टाफ द्वारा की जाएगी और एक प्रभारी द्वारा तापमान को नियंत्रित किया जाएगा।
4. कामकाज के क्षेत्र में पर्याप्त संख्या में फायर एक्विट (आग लगने की स्थिति में निकलने के द्वार) होंगे और कर्मचारियों को आपात स्थिति में भवन को खाली करने की कार्यविधि का प्रशिक्षण दिया जाएगा। भवन को खाली करने की ड्रिल वर्ष में कम-से-कम एक बार की जाएगी।
5. प्रत्येक फ्लोर पर फायर एक्सटिंग्विशर (आग बुझाने वाले यंत्र) लगाए जाएँगे। प्रत्येक फ्लोर पर उपस्थित ईआरटी सदस्यों को यह प्रशिक्षण दिया जाएगा कि आपात स्थिति में फायर एक्सटिंग्विशर का प्रयोग कैसे किया जाए।
6. कामकाज के क्षेत्र में जगह-जगह धूम्र अनुसंधान यंत्र लगाए जाएँगे ताकि आग लगने की घटना का तुरंत पता चल सके और तत्काल चेतावनी का अलार्म बज सके।
7. प्रत्येक फ्लोर पर खास-खास स्थानों पर फ्लोर प्लान प्रदर्शित किए जाएँगे।

8. कर्मचारियों से अपेक्षित है कि ज्वलनशील मदें अपने साथ न रखें।

3.3.3 संवेदनशील क्षेत्रों (ज़ोन 3 ज़ोन 4) के लिए पर्यावरणीय सुरक्षा

1. संवेदनशील क्षेत्रों को जल के रिसाव से संरक्षित किया जाएगा और बीएमएस टीम द्वारा उनकी निगरानी की जाएगी।
2. आग लगने का पता चले, इसके लिए धूम्र अनुसंधान यंत्र लगाए जाएँगे।
3. किसी अवांछित वस्तु/ कार्मिक की आधिकारिक सूचना देने के लिए अलार्म और अनधिकृत प्रवेश का पता लगाने की प्रणालियाँ स्थापित की जाएँगी। किसी भी अनधिकृत प्रवेश को सूचना सुरक्षा के उल्लंघन के समतुल्य माना जाएगा और तदनुसार ही उसकी जाँच की जाएगी। इस प्रकार के अनधिकृत प्रवेश/ उल्लंघन के मामले में सुधारात्मक और दंडात्मक कार्रवाई की जाएगी और उसके बारे में सभी को बताया भी जाएगा।
4. संवेदनशील क्षेत्रों (डाटा सेंटर, सर्वर रूम) में समुचित अग्निरोधी उपकरण लगाए जाएँगे। स्वचालित अग्नि-अनुसंधान और अग्निशमन उपकरणों को अधिमानता दी जाएगी। संवेदनशील क्षेत्रों के दरवाजों और दीवारों को अग्निरोधी बनाया जाएगा ताकि आग से संभावित क्षति से बचा जा सके।
5. संवेदनशील क्षेत्रों के तापमान की निगरानी अधिक बार की जाएगी। संवेदनशील क्षेत्रों के लिए बिजली के उपयुक्त बैक-अप की व्यवस्था की जाएगी।
6. सर्वर रूम, नेटवर्क रूम जैसी सूचना प्रणालियों और उपकरणों के लिए एकदम सही स्तर की एयरकन्डीशनिंग की व्यवस्था की जाएगी और आपदा रिकवरी साइट स्थापित की जाएगी।
7. बिजली आपूर्ति की निरंतरता सुनिश्चित करने के लिए दोहरे बिजली आपूर्ति नियंत्रण की व्यवस्था की जाएगी।

3.4 मार्गस्थ सुरक्षा

ज़ोन 3 और 4 में रखी गई सूचना आस्तियों के सुरक्षित स्थानांतरण के लिए उपयुक्त उपाय किए जाएँगे। संगठन के उपकरण, डाटा और सॉफ्टवेयर को समुचित प्राधिकार के बिना स्थान से दूर नहीं ले जाया जाएगा। सूचना आस्तियों के सुरक्षित विनिमय के लिए हर समय प्रावधान किया जाएगा। परिवहन सुविधा का प्रबंध ऐसे सेवाप्रदाता द्वारा किया जाएगा जिसके साथ संगठन ने संविदा की हो और जो संगठन द्वारा अनुमोदित हो। कर्मचारियों और सुरक्षा कार्मिकों के लिए यह अनिवार्य होगा कि वे उन्हें दिए गए दिशानिर्देशों का पालन करें और वे स्थानांतरण के दौरान आस्ति की सुरक्षा के लिए समान रूप से उत्तरदायी होंगे।

3.5 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
प्रशासन	आईएस टीम	व्यवसाय कार्य	कर्मचारी

नीति सं.: 2.16

नीति का नाम: 2.16 अनुप्रवर्तन, लॉगिंग और आकलन

1

प्रयोजन

अनुप्रवर्तन, लेखापरीक्षा और लॉग के आकलन के संबंध में संगठन की वांछित कार्यपद्धतियों को परिभाषित करना।

यह नीति उन सभी सूचना प्रणालियों, सूचना आस्तियों और उन सभी संचार तथा नेटवर्क कनेक्शनों पर लागू होती है जिनके माध्यम से सूचना आस्तियों को संप्रेषित, भंडारित या प्रसंस्कृत किया जाता है। सूचना प्रणालियों, संचार तथा नेटवर्क कनेक्शनों में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण, सभी परिचालन प्रणालियाँ, डाटाबेस और एप्लिकेशन शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।

संगठन द्वारा सूचना के प्रसंस्करण, भंडारण और सुरक्षा के लिए लगाई गई सभी सुरक्षा प्रणालियों का अनुप्रवर्तन निम्नलिखित साधनों से किया जाएगा:

- मैनुअल तरीके से तत्समय अनुप्रवर्तन या चेतावनी (अलर्ट) देने में समर्थ प्रौद्योगिकीय प्रणालियाँ;
- सूचना प्रणालियों पर की गई सभी गतिविधियों की लॉगिंग और लॉग का आवधिक विश्लेषण;
- सुरक्षा की स्थिति का आवधिक या एक बार आकलन जिसमें उपकरण के कन्फिगरेशन की समीक्षा, सूचना प्रणालियों का सुरक्षा परीक्षण और तत्समय या आवधिक अनुप्रवर्तन के लिए आईटी प्रक्रियाओं की समीक्षा शामिल होगी लेकिन यह आकलन इन्हीं तक सीमित नहीं होगा।

इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

सभी सूचना प्रणालियों को आस्ति प्रबंधन नीति के अनुसार वर्गीकृत किया जाएगा और निम्नानुसार अनुप्रवर्तन प्रक्रियाएँ स्थापित की जाएँगी:

- प्रणालियों के लिए सामान्य गतिविधि से विचलन का तत्समय पता लगाने के लिए और उसके संबंध में प्रणालियों के सुरक्षा प्रशासकों को चेतावनी जारी करने के लिए स्वचालित सुविधाएँ कार्यान्वित की जाएँगी।
- सभी व्यवसाय लेनदेनों और उच्च जोखिम प्रणालियों के लिए लॉगिंग को लागू किया जाएगा और लॉग की तत्समय या आवधिक, मैनुअल या स्वचालित समीक्षा के लिए प्रक्रियाएँ स्थापित की जाएँगी।
- निम्न जोखिम प्रणालियों के लिए कार्यनिष्पादन प्रभाव के आधार पर लॉगिंग पर विचार और उसका कार्यान्वयन किया जाएगा और लॉग की आवधिक समीक्षा के लिए प्रक्रियाएँ स्थापित की जाएँगी।

1. सभी सूचना प्रणालियों को इस प्रकार कन्फ़िगर किया जाएगा कि वे प्रणाली गतिविधियों को लॉग करें और किसी भी असामान्य गतिविधि के बारे में प्रणाली प्रशासकों को चेतावनी (अलर्ट) जनरेट कर सकें।
2. प्रणाली प्रशासक और प्रणाली परिचालक जैसे विशेषाधिकार-प्राप्त प्रयोक्ताओं की गतिविधियों को लॉग किया जाएगा और उनकी समीक्षा नियमित आधार पर स्वतंत्र रूप से की जाएगी।
3. पहुँच, स्वीकार्य उपयोग और/ या इस नीति में वर्णित किसी अन्य पहलू के संबंध में सूचना सुरक्षा नीति का उल्लंघन करने वाली गतिविधि का पता लगाने और उसे रिपोर्ट करने के लिए उपयुक्त तंत्र की स्थापना की जाएगी।
4. स्वचालित चेतावनी के अभाव में सूचना प्रणाली के महत्व के आधार पर निर्धारित अवधि पर गतिविधि लॉग की मैनुअल समीक्षा के लिए प्रक्रिया स्थापित की जाएगी।
5. संगठन या सुरक्षा डोमेन के भीतर सभी संगत सूचना प्रसंस्करण प्रणालियों की घड़ियों का समय किसी सहमत प्रमाणिक समय-स्रोत से एक साथ मिलाया जाएगा।
6. समय बताने, समय मिलाने और समय की परिशुद्धता की बाह्य और आंतरिक आवश्यकताओं को दस्तावेजीकृत किया जाएगा।
7. संगठन के भीतर उपयोग के लिए एक मानक संदर्भ समय परिभाषित किया जाएगा।
8. नेटवर्क उपकरण और नेटवर्क गतिविधि के अनुप्रवर्तन के लिए जिम्मेदार आईएस परिचालन टीम चेतावनियों और लॉग का विश्लेषण करेगी और जिस गतिविधि के लिए कार्रवाई की आवश्यकता होगी उसे, आपातकालीन परिस्थितियों को छोड़कर, कार्रवाई करने के पहले घटना प्रबंधन नीति के अनुसार घटना के रूप में उठाया जाएगा।
9. जहाँ कार्रवाई के अंतर्गत सूचना प्रणाली के कन्फ़िगरेशनों में परिवर्तन अपेक्षित हों, वहाँ ये परिवर्तन, परिवर्तन प्रबंधन नीति के अधीन होंगे।
10. गतिविधि लॉग और लेखापरीक्षा ट्रेल को अभिलेख प्रतिधारण अपेक्षाओं और लागू विनियामकीय अपेक्षाओं के आधार पर भंडारित/ प्रतिधारित किया जाएगा।
11. लॉगिंग सुविधाओं और लॉग सूचना को छेड़छाड़ और अप्राधिकृत पहुँच से संरक्षित रखा जाएगा।
12. जब भी आवश्यक हो, कानून प्रवर्तक एजेंसियों, आईआरडीएआई, सीईआरटी-इन और सीएसआईआरटी-फिन को लॉग उपलब्ध कराए जाएँगे।
13. विनियामकीय दिशानिर्देशों के अनुसार आईसीटी अवसंरचना लॉग रखे जाएँगे।
14. आईसीटी अवसंरचना लॉग सीईआरटी-इन द्वारा समय-समय पर जारी निर्देशों के अनुसार 180 दिनों की रोलिंग अवधि के लिए और भारतीय क्षेत्राधिकार में रखे जाएँगे।
15. लेखापरीक्षा लॉगिंग के माध्यम से निष्क्रिय किए जा चुके खातों तक पहुँच के प्रयासों की निगरानी की जाएगी।
16. प्रणाली प्रशासक और प्रणाली परिचालक की गतिविधियों का लॉग तैयार किया जाएगा और लॉग का संरक्षण और नियमित समीक्षा की जाएगी।

3.3.1
**नेटवर्क पहुँच
और गतिविधि**

1. बाह्य नेटवर्कों को प्रेषित और उनसे प्राप्त सम्पूर्ण संवाद को लॉग किया जाएगा और लॉग की आवधिक समीक्षा की जाएगी या इस प्रयोजन से स्वचालित अनुप्रवर्तन तंत्र स्थापित किया जाएगा।
2. बाह्य नेटवर्कों तक पहुँच के संबंध में संगठन की स्वीकार्य उपयोग नीति के पालन के लिए इन्टरनेट एक्सेस फ़िल्टर जैसे तंत्र स्थापित किए जाएँगे और उनका अनुप्रवर्तन तथा समीक्षा की जाएगी।

3.3.2 एप्लिकेशन पहुँच और गतिविधि

सभी एप्लिकेशनों पर प्रयोक्ता गतिविधियों, अपवादों और सुरक्षा से जुड़ी घटनाओं का लॉग तैयार किया जाएगा और उसका अनुप्रवर्तन किया जाएगा। लॉग में निम्नलिखित को शामिल करना अनिवार्य है:

1. प्रणाली के शुरू और बंद होने का समय;
2. प्रणाली की त्रुटियाँ या भूलें और की गई सुधारात्मक कार्रवाई;
3. महत्वपूर्ण डाटा फाइलों और कंप्यूटर आउटपुट की सही ढंग से हैंडलिंग की पुष्टि;
4. लॉग में प्रविष्टिकर्ता व्यक्ति/ प्रक्रिया/ प्रणाली का नाम;
5. जहाँ से डाटा या प्रणाली तक पहुँच बनाई जा रही हो, उस स्रोत का पता (यह आईपी एड्रेस या मैक आईडी हो सकता है);
6. प्रयोक्ता एक से अधिक वर्कस्टेशन से एक ही समय में एक यूजर आईडी का प्रयोग करते हुए किसी एप्लिकेशन में लॉग नहीं कर सकता, ऐसी व्यवस्था उस एप्लिकेशन में ही होगी।
7. सेकंडरी नेटवर्क कनेक्टिविटी और आईटी अवसंरचना की व्यवस्था की जाएगी और महत्वपूर्ण एप्लिकेशनों और सेवाओं के लिए उनका परीक्षण किया जाएगा।

3.4 आस्तियों का स्थानांतरण और संचलन

आस्तियों को खरीद के समय या नष्ट करने के लिए भेजते समय एक संगठन से किसी अन्य संगठन को या फिर किसी संगठन के भीतर या बाहर स्थानांतरित किया जाएगा।

खरीदी गई नई आस्तियों के संगठन के परिसर में प्रवेश के लिए और मरम्मत/ नष्ट करने/ बिक्री करने के लिए संगठन के परिसर से आस्तियों के निकास के लिए कार्यविधियाँ विकसित की जाएँगी।

3.5 प्रयोक्ता गतिविधि अनुप्रवर्तन

1. प्रयोक्ता खातों का नियमित अनुप्रवर्तन किया जाएगा ताकि अवांछित विशेषाधिकारों, अनाथ खातों और निष्क्रिय खातों का पता लगाया जा सके। यदि संगठन की नीतियों के उल्लंघन में कोई खाता पाया जाता है तो उसे निलंबित या समाप्त कर दिया जाएगा।
2. फालतू/ निष्क्रिय यूजर आईडी अन्य प्रयोक्ताओं को जारी नहीं किए जाएँगे।
3. खातों की आवधिक समीक्षा की जाएगी और संबंधित प्रबन्धक वर्तमान प्रयोक्ता अधिकारों का मिलान व्यवसाय आवश्यकताओं के साथ करेंगे।

3.6 सूचना सुरक्षा आकलन

3.6.1 अवसंरचना और एप्लिकेशनों के लिए सुरक्षा आकलन

1. आईएस टीम अवसंरचना की सुरक्षा समीक्षा के कमजोरी आकलन के लिए मानकों को परिभाषित करेगी। इन मानकों में निम्नलिखित शामिल होंगे:
 - ☐ एप्लिकेशनों के महत्व के आधार पर आकलन की बारंबारता;
 - ☐ सुरक्षा आकलनों का कवरेज;
 - ☐ एप्लिकेशनों के महत्व के आधार पर सुरक्षा आकलन दृष्टिकोण (आंतरिक बनाम बाह्य)।

2. इंटरनेट-फेसिंग एप्लिकेशनों या अवसंरचना घटकों का वीएपीटी आवधिक रूप से लेकिन वर्ष में कम-से-कम एक बार अवश्य किया जाएगा।
3. इंटरनेट-फेसिंग सूचना आस्तियों या प्रणालियों में किए जाने वाले परिवर्तनों के लिए अनिवार्य सुरक्षा परीक्षण किया जाएगा और जो कमियाँ पाई जाएँगी उन्हें उत्पादन के पूर्व दूर किया जाएगा।
4. एपीआई या वेब सेवाओं आदि सहित व्यवसाय एप्लिकेशनों के वीएपीटी परीक्षण और साथ ही सुरक्षा कोड की समीक्षा का कार्य आवधिक रूप से, और लाइव करने के पहले किया जाएगा।
5. सभी इंटरनेट-फेसिंग सूचना आस्तियों और प्रणालियों का एक्सटर्नल ब्लैकबॉक्स पेनिट्रेशन परीक्षण 6 माह में एक बार किया जाएगा।
6. एपीआई या वेब सेवाओं सहित व्यवसाय एप्लिकेशनों की सुरक्षा लेखापरीक्षा या वीएपीटी परीक्षण का कार्य, सुरक्षा कोड की समीक्षा सहित आवधिक रूप से, और लाइव होने के पहले किया जाएगा।
7. नेटवर्क और एप्लिकेशनों की कमजोरियों का आकलन सक्षम कार्मिकों द्वारा निरंतर आधार पर किया जाएगा। जिन जोखिमों की पहचान की जाएगी आकलन रिपोर्ट में उनका दस्तावेजीकरण किया जाएगा।
8. सूचना प्रणाली का रखरखाव करने के लिए जिम्मेदार टीम द्वारा आकलन रिपोर्ट के परिणामों का विश्लेषण किया जाएगा और उन पर कार्रवाई की जाएगी।
9. वीएपीटी में रिपोर्ट की गई उच्च जोखिम वाली कमियों को एक माह के भीतर दूर कर दिया जाएगा और उसके बाद वैधकरण परीक्षण किया जाएगा।
10. लेखापरीक्षा में पाई गई कमियों को दूर करने की प्राथमिकता प्रत्येक कमी के साथ जुड़ी जोखिम पर आधारित होगी। तथापि, इसके लिए अधिकतम समय-सीमा दो माह होगी।
11. सूचना सुरक्षा टीम द्वारा सभी सुरक्षा आकलन रिपोर्टों और की गई कार्रवाइयों की समीक्षा की जाएगी।
12. सुरक्षा आकलनों के माध्यम से पहचानी गई जिन जोखिमों का शमन प्रौद्योगिकीय सीमाओं या व्यवसायगत आवश्यकताओं के कारण नहीं किया जा सकेगा, उन्हें समाधान या अपवाद अनुमोदन के लिए विशेष रूप से आईएसआरएमसी के ध्यान में लाया जाएगा।
13. आकलन के परिणामों से विक्रेताओं/ तृतीय पक्ष सेवाप्रदाताओं को अवगत कराया जाएगा।

3.6.2 आईएस टीम द्वारा आंतरिक आईएस आकलन

1. सूचना सुरक्षा नीतियों, कार्यविधियों और आईएस टीम द्वारा परिभाषित आंतरिक मानकों का अनुपालन सुनिश्चित करने के उद्देश्य से संगठन या तो आईएस टीम से या आईएस टीम द्वारा नियुक्त किसी सक्षम स्वतंत्र पक्षकार से सूचना सुरक्षा कार्यविधियों की वार्षिक समीक्षा करवाएगा।
2. समीक्षाओं की आयोजना और उनके निष्कर्षों की रिपोर्टिंग के लिए तथा उपयुक्त औपचारिक कार्रवाई सुनिश्चित करने के लिए आईएस टीम द्वारा औपचारिक कार्यविधियाँ विकसित की जाएँगी।

3.6.3 बाह्य आईएस आकलन

1. संगठन सूचना सुरक्षा नीतियों, कार्यविधियों और बाह्य उद्योग मानकों का अनुपालन सुनिश्चित करने के उद्देश्य से सूचना सुरक्षा टीम द्वारा परिभाषित आवधिकता के अनुसार सक्षम स्वतंत्र पक्षकार द्वारा औपचारिक बाह्य आईएस समीक्षा करवाएगा।
2. लेखापरीक्षाओं की आयोजना और उनके निष्कर्षों की रिपोर्टिंग के लिए और त्वरित तथा उपयुक्त औपचारिक कार्रवाई सुनिश्चित करने

के लिए आईएस टीम द्वारा औपचारिक कार्यविधियाँ विकसित की जाएंगी।

3. समीक्षा के दायरे को परिभाषित करने और व्यवसाय तथा सहयोग टीमों के साथ समन्वय के लिए सूचना सुरक्षा टीम जिम्मेदार होगी।
4. जिन लेखापरीक्षागत आवश्यकताओं और गतिविधियों में परिचालन प्रणालियों की जाँच शामिल होगी उनकी आयोजना सावधानीपूर्वक की जाएगी और व्यवसाय प्रक्रियाओं में व्यवधान न्यूनतम हो, इसके लिए एक सहमति पर पहुँचा जाएगा।
5. स्वतंत्र आश्वासन लेखापरीक्षक को प्रत्येक तीन वर्ष में बदल दिया जाएगा।

3.7 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी और प्रशासनिक टीम	आईएस	सीआरओ	कार्यपालक प्रबंधन

नीति सं.:

2.17

नीति का नाम:

2.17 विधिक और विनियामकीय अनुपालन

1 प्रयोजन

- सभी संगत विधानों और कानूनों (आपराधिक और सिविल), विनियमों, मानकों/दिशानिर्देशों और संहिताओं का अनुपालन सुनिश्चित करना; और साथ ही साथ सांविधिक, विनियामकीय और संविदागत बाध्यताओं को पूरा करना।
- विधिक, विनियामकीय, सांविधिक या संविदागत बाध्यताओं के उल्लंघन से बचना जिसके परिणामस्वरूप सूचना सुरक्षा या किसी भी अन्य सुरक्षा से संबंधित अपेक्षा प्रभावित होती हो।
- इस नीति की यह अपेक्षा है कि संगठन यह सुनिश्चित करे कि सभी कर्मचारी, और तृतीय पक्षकार व्यवसाय को प्रभावित कर सकने वाली विधिक, सांविधिक, विनियामकीय, संविदागत और सुरक्षा संबंधी अपेक्षाओं को अच्छी तरह समझते हैं और उनका पालन करते हैं।

2 दायरा

यह नीति संगठन के सभी क्षेत्रों और गतिविधियों पर लागू होती है। संगठन के प्रत्येक कर्मचारी, संविदाकर्ता, उप-संविदाकर्ता, एजेंट और आपूर्तिकर्ता से यह अपेक्षित है कि वह हर समय कानून के सभी पहलुओं का अनुपालन करे और सदाचरण करे। इस नीति में कानून के संदर्भ में निम्नलिखित शामिल हैं:

- अधिनियम, विनियम, संहिताएँ और अन्य अधीनस्थ विधायन;
- परिचालन लाइसेंस और अन्य प्राधिकार;
- सरकार और उद्योग के दिशानिर्देश और कार्यविधि अभिकथन;
- अनुमोदनों और अन्य लाइसेंसों में लगाई गई शर्तें;
- भविष्य में जारी किए जाने वाले अन्य नए संगत दिशानिर्देश।

3 नीति

संगठन अपने ऊपर यथालागू कानूनों के अनुपालन और सदाचरण के प्रति प्रतिबद्ध है। संगठन:

- सभी विधानों, कानूनों, मानकों, संहिताओं और आंतरिक नीतियों का अनुपालन करेगा;
- अपने विधिक और सदाचरणगत बाध्यकारी दायित्वों का अनुपालन करेगा; और
- अनुपालन में विफलता को दुबारा घटित होने से रोकने के लिए उपयुक्त सुधारात्मक कार्रवाई करेगा।

3.1 विधिक और विनियामकीय अपेक्षाएँ

1. सभी संगत विधायी, सांविधिक और संविदागत अपेक्षाओं और उन्हें पूरा करने के संगठन के तरीकों को सुस्पष्ट रूप से चिह्नित और दस्तावेजीकृत किया जाएगा तथा उन्हें अद्यतन रखा जाएगा। (कृपया अनुबंध अ देखें।)
2. बौद्धिक संपदा अधिकारों और मालिकाना सॉफ्टवेयर उत्पादों के उपयोग से संबंधित विधायी, विनियामकीय और संविदागत अपेक्षाओं का अनुपालन सुनिश्चित करने के लिए उपयुक्त कार्यविधियाँ कार्यान्वित की जाएँगी।
3. संविधि-समर्थित विनियमों को अनिवार्य बनाया जाएगा।
4. एक औपचारिक जोखिम विश्लेषण किया जाएगा ताकि नीति से ऐसे नियंत्रणों को चुना जा सके जो प्रधान विनियामकों और कानूनी बाध्यताओं द्वारा अपेक्षित लागू नियंत्रणों की स्थापना करवा सकें।
5. यह सुनिश्चित किया जाएगा कि स्थानीय विधायी, विनियामकीय और संविदागत नियंत्रण संबंधी अपेक्षाओं को चिह्नित किया जाता है और सभी चिह्नित विधायी, विनियामकीय और संविदागत नियंत्रण संबंधी अपेक्षाओं की सूची में शामिल किया जाता है।
6. संगठन के कार्यालय की सांविधिक, विनियामकीय और संविदागत अपेक्षाओं के संबंध में परामर्श और अनुमोदन विधि विभाग से प्राप्त किए जाएँगे। सीआईएसओ अपेक्षाओं और प्रत्येक विनियामकीय और कानूनी अपेक्षा से संबंधित तदनु रूप नियंत्रणों को एक रजिस्टर में दर्ज करेगा।
7. विधि विभाग कर्मचारियों को विधिक अपेक्षाओं के बारे में और उन अपेक्षाओं के अनुपालन के बारे में अनुदेश देगा।
विधि विभाग यह भी सुनिश्चित करेगा कि अनुपालन सुनिश्चित करने के लिए नियंत्रणों को तत्काल कार्यान्वित किया जाए। विधि विभाग अनुपालन की नियमित समीक्षा करेगा।

3.2 आईआरडीएआई दिशानिर्देशों का पालन

1. आईआरडीएआई सुरक्षा संबंधी अपेक्षाओं/ कार्यविधियों में संशोधनों का उल्लेख करते हुए परिपत्र जारी करता है। संगठन आईआरडीएआई द्वारा जारी सभी लागू दिशानिर्देशों का पालन करेगा।
2. आईआरडीएआई परिपत्रों के माध्यम से जारी दिशानिर्देशों को बीमा कंपनी के परिचालन में शामिल किया जाएगा।

3.3 आईटी अधिनियम, 2000 और नियमावली, आईटी (संशोधन) अधिनियम, 2008 और अन्य लागू अधिनियमों का पालन

1. संगठन अधिनियम के अनुसार ग्राहक-डाटा/ सूचना की गोपनीयता के संरक्षण के लिए निवारणात्मक कदम उठाएगा। आईटी अधिनियम, 2000 में संशोधन किए गए हैं, अधुनातन संशोधनों को उसमें शामिल कर लिया गया है और संगठन आईटी अधिनियम, 2008 में उल्लिखित दिशानिर्देशों का पालन करेगा।
2. आईटी अधिनियम, 2000 के आलोक में ईमेल संदेशों, इंटरनेट बैंकिंग और संचार नेटवर्क से संबंधित समस्याओं को समुचित रूप से दूर किया जाएगा।
3. आईटी अधिनियम, 2000 के प्रावधानों को स्पष्ट रूप से समझा जाएगा ताकि संगठन में डाटा पर्यावरण का संरक्षण किया जा सके और धोखाधड़ी की रोकथाम की जा सके।
4. आईटी अधिनियम, 2000 के संशोधनों या समर्थनकारी साइबर कानूनों या निजता संबंधी कानूनों के अनुपालन के लिए कार्यविधियाँ तैयार जाएँगी।
5. संगठन द्वारा आधार अधिनियम दिशानिर्देशों, नियमों, अधिनियमों और उनके संशोधनों में उल्लिखित लागू दिशानिर्देशों का पालन किया जाएगा।

3.4 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
विधिक टीम	सीआईएसओ (सूचना सुरक्षा)	जोखिम, लेखापरीक्षा और अनुपालन टीमों	कार्यपालक प्रबंधन

- 1 प्रयोजन** अपने साइबर खतरों के पर्यावरण और साइबर जोखिम शमन उपायों की पर्याप्तता को लेकर संगठन की समझ ही पारिस्थितिक जागरूकता है।
- 2 दायरा** यह नीति बीमा कंपनी के साइबर सुरक्षा नियंत्रणों पर लागू होती है जो पहले से ही सुस्थापित हैं या उभरती साइबर जोखिमों के शमन के लिए जिनके कार्यान्वयन की योजना है।
- 3 नीति** संगठन एक साइबर खतरा आसूचना प्रक्रिया और विश्लेषण तथा सूचना के आदान-प्रदान की प्रक्रिया स्थापित करेगा और और उनका अनुसरण करेगा जिसमें निम्नलिखित शामिल हैं (यह सूची सम्पूर्ण नहीं):
- 3.1 संभावित साइबर खतरों की पहचान**
1. निम्नलिखित साइबर खतरों की पहचान की जाएगी:
 - जो परिचालन कार्यनिष्पादन को प्रभावित कर सकते हैं;
 - संगठन के उद्देश्यों और बाध्यताओं को पूरा करने की योग्यता पर उल्लेखनीय प्रभाव डाल सकते हैं;
 - महत्वपूर्ण व्यवसाय प्रक्रियाओं और प्रतिष्ठा के लिए खतरा पैदा कर सकते हैं।
- 3.2 खतरा आसूचना प्रक्रिया**
2. संगठन आंतरिक और बाह्य व्यवसाय एवं प्रणाली सूचना स्रोतों के साथ मिलकर साइबर खतरे से संबंधित सूचनाओं को एकत्र और विश्लेषित करने की एक प्रक्रिया स्थापित करेगा।
- 3.3 सूचना साझा करना**
1. किसी घटना के होने की स्थिति में, साइबर आक्रमण के लिए संगठन के प्रतिसाद कार्यक्रमों के भाग के रूप में विश्वसनीय माध्यमों से सूचना साझा करने के लिए एक योजना परिभाषित की जाएगी।
 2. साइबर घटनाओं से संबंधित संकेतकों को प्राप्त और साझा करने के लिए संगठन सूचना साझा करने वाले समूहों के साथ सक्रिय सहभागिता करेगा।
 3. किसी बड़ी घटना के मामले में सूचना साझा करने की व्यवस्थाओं को साइबर संकट प्रबंधन योजना (सीसीएमपी) में दस्तावेजीकृत किया जाएगा ताकि सेक्टर-व्यापी प्रतिसाद में सुविधा हो। सूचना साझा करने की व्यवस्थाओं सहित साइबर संकट प्रबंधन योजना (सीसीएमपी) तैयार करने के लिए सीईआरटी-इन/ एनसीआईआईपीसी दिशानिर्देशों का उपयोग किया जाएगा।

3.4 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
सूचना सुरक्षा टीम	सीआईएसओ (सूचना सुरक्षा)	सीपीओ	कार्यपालक प्रबंधन

- 1 प्रयोजन** क्लाउड सुरक्षा से संबंधित संगठन की वांछित कार्यपद्धतियों को परिभाषित करना।
- 2 दायरा** यह नीति क्लाउड कम्प्यूटिंग सेवाओं या क्लाउड अवसंरचना सेवाओं का उपयोग करने वाले या उपयोग करने की योजना वाले सभी व्यवसाय कार्यों और उनकी सूचना प्रणालियों, सूचना आस्तियों तथा सभी संचार एवं नेटवर्क कनेक्शनों पर लागू होती है।

सूचना प्रणालियों तथा संचार एवं नेटवर्क कनेक्शनों में राउटर और फायरवाल, सर्वर और मेनफ्रेम जैसे नेटवर्क उपकरण तथा परिचालन प्रणालियाँ, डाटाबेस और एप्लिकेशन शामिल हैं लेकिन ये इन्हीं तक सीमित नहीं हैं।

- ☐ डाटा
- ☐ एप्लिकेशन
- ☐ कार्य
- ☐ प्रक्रिया
- ☐ नेटवर्क कनेक्शन
- ☐ अंतर्निहित हार्डवेयर

आस्तियों का मूल्यांकन निम्नलिखित कारकों के आधार पर किया जाएगा:

- I. बीमा कंपनी के लिए डाटा या कार्य के महत्व का निर्धारण;
- II. परिदृश्यों के प्रभाव का विश्लेषण:
 - i. आस्ति का व्यापक रूप से सार्वजनिक और वितरित होना,
 - ii. क्लाउड सेवाप्रदाता के किसी कर्मचारी द्वारा आस्ति का आकलन,
 - iii. किसी बाह्य पक्षकार द्वारा प्रक्रिया या कार्य का दुरुपयोग,
 - iv. अपेक्षित परिणाम देने में प्रक्रिया या कार्य का विफल होना,
 - v. सूचना/ डाटा में अनपेक्षित परिवर्तन,
 - vi. आस्ति का किसी समयावधि के लिए अनुपलब्ध होना।

3 नीति

इस नीति के उद्देश्य निम्नानुसार हैं:

- ☐ यह सुनिश्चित करना कि क्लाउड सेवा, व्यवसाय और सुरक्षा संबंधी अपेक्षाओं और निम्नलिखित से संबंधित कानूनों और विनियमों के अनुरूप है:
- ☐ क्लाउड सेवाओं के लिए प्रावधान और उन्हें कमीशन करना,
- ☐ क्लाउड सेवाओं का परिचालन और प्रबंधन,
- ☐ क्लाउड सेवाओं को डिकमीशन करना,
- ☐ क्लाउड को अपनाने के निर्णय में निम्नलिखित कारकों का मूल्यांकन करना:
 - i. एप्लिकेशन को क्लाउड पर पोर्ट करने के लिए तकनीकी पर्याप्तता – एप्लिकेशन के प्रोफाइल का आकलन कर यह सुनिश्चित करना कि वह क्लाउड पर पोर्ट किए जाने योग्य है।
 - ii. उपलब्धता संबंधी अपेक्षाओं, विनियामकीय अनुपालन व सांविधिक अपेक्षाओं, डाटा संवेदनशीलता सहित जोखिम;
 - iii. अनधिकृत प्रवेश संबंधी निर्णयों, कमजोरी के अनुप्रवर्तन और सेवा आक्रमणों को न मानने पर नियंत्रण।

इस नीति से किसी विचलन को जोखिम प्रबंधन और अपवाद प्रबंधन के माध्यम से उपचारित किया जाएगा जैसा कि आईसीएसपी में परिभाषित किया गया है।

3.1 क्लाउड सेवा मॉडल

क्लाउड सेवा प्रदाय को चार मूल प्रकारों में विभक्त किया जाता है:

सेवा के रूप में क्लाउड सॉफ्टवेयर (एसएएस)

1. सेवाप्रदाता के, क्लाउड अवसंरचना पर रन करने वाले एप्लिकेशनों का उपयोग करने के लिए उपभोक्ता को उपलब्ध कराई गई क्षमता।
2. वेब ब्राउजर (जैसे वेब-आधारित ईमेल) जैसे विरल ग्राहक इंटरफ़ेस के माध्यम से विविध ग्राहक उपकरणों से एप्लिकेशनों तक पहुँचा जा सकता है।
3. उपभोक्ता अंतर्निहित क्लाउड अवसंरचना को प्रबंधित या नियंत्रित नहीं करता। इस अवसंरचना में नेटवर्क, सर्वर, परिचालन प्रणालियाँ, भंडारण और यहाँ तक कि व्यक्तिगत एप्लिकेशन क्षमता शामिल हैं, हालाँकि उपभोक्ता को अपवादस्वरूप सीमित प्रयोक्ता-विशिष्ट एप्लिकेशन कन्फिगरेशन सेटिंग्स का प्रबंधन और नियंत्रण उपलब्ध कराना संभावित है।

सेवा के रूप में क्लाउड प्लेटफॉर्म (पीएएस)

1. क्लाउड अवसंरचना पर प्रदाता-समर्थित प्रोग्रामिंग भाषाओं और टूल्स का उपयोग करते हुए उपभोक्ता-निर्मित या अधिगृहीत एप्लिकेशनों को नियोजित करने के लिए उपभोक्ता को प्रदान की गई क्षमता।
2. उपभोक्ता अंतर्निहित क्लाउड अवसंरचना को प्रबंधित या नियंत्रित नहीं करता। इस अवसंरचना में नेटवर्क, सर्वर, परिचालन प्रणालियाँ और भंडारण शामिल हैं लेकिन नियोजित एप्लिकेशनों पर और संभवतः एप्लिकेशन को होस्ट करने वाले पर्यावरण के कन्फिगरेशनों पर उपभोक्ता का नियंत्रण होता है।

सेवा के रूप में क्लाउड अवसंरचना (आईएएस)

1. उपभोक्ता को प्रसंस्करण, भंडारण, नेटवर्क और अन्य मूलभूत कम्प्यूटिंग संसाधनों के प्रावधान के लिए प्रदान की गई क्षमता जहाँ उपभोक्ता यादृच्छिक सॉफ्टवेयर नियोजित और रन करने में समर्थ होता है जिनमें परिचालन प्रणालियाँ और एप्लिकेशन भी शामिल हो सकते हैं।
2. उपभोक्ता अंतर्निहित क्लाउड अवसंरचना को प्रबंधित और नियंत्रित नहीं करता लेकिन परिचालन प्रणालियों, भंडारण, नियोजित एप्लिकेशनों पर उसका नियंत्रण होता है और संभवतः चुने हुए नेटवर्किंग घटकों पर भी सीमित नियंत्रण होता है।

सेवा के रूप में व्यवसाय प्रक्रिया (बीपीएस)

1. उपभोक्ता को प्रदान की गई ऐसी क्षमता जिसमें व्यवसाय प्रक्रिया की आउटसोर्सिंग (बीपीओ) सेवाएँ शामिल होती हैं जिन्हें ऐसे क्लाउड से प्राप्त किया जाए जो बहु-पट्टेदारी के लिए निर्मित किया गया हो।
2. सेवाएँ स्वचालित होती हैं और जहाँ मानवीय प्रक्रिया संचालक अपेक्षित हों, वहाँ प्रति ग्राहक कोई प्रकट रूप से समर्पित श्रमिक समूह न हो।

3.2 क्लाउड नियोजन मॉडल

1. **सार्वजनिक क्लाउड** – यह किसी तृतीय पक्ष संगठन के स्वामित्व में स्थित और परिचालित क्लाउड अवसंरचना है जो क्लाउड सेवाओं की बिक्री करता है और जहाँ पट्टा के आधार पर क्लाउड सेवाएँ आम जनता या किसी बड़े उद्योग समूह को उपलब्ध होती हैं।
2. **निजी क्लाउड** – यह क्लाउड संरचना एकल संगठन के पूर्ण स्वामित्व में स्थित और परिचालित होती है। यह स्वयं संगठन द्वारा या किसी तृतीय पक्ष द्वारा प्रबंधित हो सकती है और परिसर में ही या परिसर से दूर स्थित हो सकती है।
3. **मिश्रित क्लाउड** – यह क्लाउड अवसंरचना दो या अधिक अवसंरचनाओं (निजी, सामुदायिक या सार्वजनिक) का मिश्रण होती है और इसमें सबका अस्तित्व अलग-अलग बना रहता है लेकिन वे ऐसी मानकीकृत या मालिकाना प्रौद्योगिकी के माध्यम से जुड़ी होती हैं जो डाटा और एप्लीकेशन पोर्टेबिलिटी (उदाहरण के लिए, क्लाउडों के बीच भार का संतुलन) को संभव बनाती है।

3.3 अनुपालन

संगठन विभिन्न आईआरडीएआई दिशानिर्देशों, संबंधित कानूनों और विनियमों, तथा भारत में स्थित विनियामक प्राधिकरणों द्वारा जारी दिशानिर्देशों का, जो संगठन पर लागू होते हैं, अनुपालन सुनिश्चित करेगा।

3.4 क्लाउड सुरक्षा जीवनचक्र

संचालन और जोखिम प्रबंधन, जबकि नियोजन मॉडल उत्तरदायित्वों और अपेक्षाओं को परिभाषित करेगा।
क्लाउड सेवाप्रदाता के करार पर हस्ताक्षर करने के पहले संगठन यह सुनिश्चित करेगा कि सभी अधिदेशित नियंत्रण पूर्णतः अनुमोदित हैं।

3.4.1 अधिप्रमाणन

यह सुनिश्चित किया जाएगा कि क्लाउड सेवाप्रदाता विभिन्न बहु-कारकीय अधिप्रमाणन तंत्रों का समर्थन करता है।
प्राधिकार देने में, विद्यमान "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.2 – 'आस्ति प्रबंधन', उप-खंड 3.2.2.3 – 'प्राधिकार इनवेंटरी'" का अनुसरण किया जाएगा।
संगठन यह पुष्टि करेगा कि क्लाउड सेवाप्रदाता की अधिप्रमाणन प्रक्रिया, पहुँच नियंत्रण, उत्तरदायित्व और लॉगिंग लागू विनियामकीय और कानूनी अपेक्षाओं के अनुरूप हैं।
ग्राहक-डाटा को किसी भी अप्राधिकृत पहुँच से संरक्षित रखा जाएगा।

3.4.2 भौतिक सुरक्षा नियंत्रण

भौतिक सुरक्षा नियंत्रण में विद्यमान "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.15 – 'भौतिक और पर्यावरण सुरक्षा'" का अनुसरण किया जाएगा।
अतिरिक्त भौतिक सुरक्षा नियंत्रण निम्नानुसार हैं:

- संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता अवसंरचना के उपयुक्त सुरक्षा नियंत्रणों का अनुपालन करता है। प्रभावी भौतिक सुरक्षा के माध्यम से यह सुनिश्चित किया जाएगा कि केन्द्रीकृत प्रबंधन प्रणाली, संपत्ति और प्राधिकृत कर्मचारियों सहित विभिन्न स्रोतों से प्राप्त निविष्टियों के सह-संबंध को अनुमत करेगी।
- यह अनुशंसा की जाएगी कि उन्हीं क्लाउड सेवाप्रदाताओं का चयन किया जाएगा जो भौतिक और पर्यावरण सुरक्षा के लिए आईएसओ 27001 मानक के अनुरूप हों।

3.4.3 अवसंरचना सुरक्षा (निजी क्लाउड के लिए और सार्वजनिक क्लाउड हेतु आईएएस के लिए)

क्लाउड पर्यावरण का डिजाइन क्लाउड सिक्योरिटी अलायंस के क्लाउड सुरक्षा मैट्रिक्स जैसे उपयुक्त सुरक्षा दिशानिर्देशों अथवा आईएस टीम द्वारा परिभाषित दिशानिर्देशों पर आधारित होगा। आईएस टीम उद्योग के मानकों और आईएस नीति के प्रावधानों के आधार पर रोल-आउट के पहले निजी क्लाउड सेवाओं का आकलन करेगी।

सर्वरों और नेटवर्क उपकरणों सहित क्लाउड अवसंरचना को कमीशन करने के लिए एक अवसंरचना मानक परिभाषित किया जाएगा और उसे कार्यान्वित किया जाएगा। मानक में परंपरागत अवसंरचना या आवश्यकतानुसार उसके दुरुपयोग या उसे सेवा से हटाने पर विचार किया जाएगा। मानक में न्यूनतम आधार-स्तरीय मानक को भी शामिल किया जाएगा।

भंडारण के उपयोग, आबंटन के लिए प्रावधान बनाम वास्तविक उपयोग, होस्ट मशीन अपटाइम, वर्चुअल मशीन अपटाइम, नेटवर्क अपटाइम और अवसंरचना तथा एप्लिकेशन प्रतिसाद समय, पैच प्रबंधन, परिवर्तन प्रबंधन, घटना प्रबंधन, एंटी-वायरस प्रबंधन जैसी क्लाउड विशेषताओं सहित अवसंरचना परिचालनों के प्रबंधन और अनुप्रवर्तन के लिए उपयुक्त टूल्स/ कार्यविधियों की स्थापना की जाएगी।

डाटासेंटर के भीतर और अनेक डाटासेंटर्स के बीच एकीकरण के लिए अवसंरचना एकीकरण स्थापत्य परिभाषित किया जाएगा।

माइग्रेशन के पूर्व सभी एप्लिकेशनों और अवसंरचना घटकों का मूल्यांकन क्लाउड पर्यावरण में परिचालन हेतु उनकी उपयुक्तता के लिए किया जाएगा; साथ ही, अनुकूलता और सूचना सुरक्षा बेसलाइन के लिए भी जाँच की जाएगी। माइग्रेशन के निष्पादन के लिए एक कार्यविधि दस्तावेज उपलब्ध कराया जाएगा। माइग्रेशन के दौरान विभिन्न चरणों में सुरक्षा और व्यवसाय से आवश्यक अनुमोदन प्राप्त किए जाएंगे जैसा कि "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.5 – 'सूचना प्रणाली का अधिग्रहण और विकास'" में परिभाषित किया गया है।

क्लाउड अवसंरचना में पहुँच नियंत्रण, परिवर्तन प्रबंधन, डाटा सुरक्षा, बैक-अप और रेस्टोरेशन, पैच प्रबंधन, कार्य अनुसूचीकरण, क्षमता और कार्यनिष्पादन प्रबंधन, मैलिसस सॉफ्टवेयर प्रबंधन, कमजोरी प्रबंधन और आईटी सेवा प्रबंधन सहित संगठन की विद्यमान सूचना प्रणाली अनुरक्षण नीति का अनुसरण किया जाएगा।

3.4.4 नेटवर्क सुरक्षा

नेटवर्क सुरक्षा में वे सुरक्षा सेवाएँ आती हैं जो पहुँच को प्रतिबंधित या आबंधित करती हैं और अंतर्निहित संसाधन सेवाओं का वितरण, अनुप्रवर्तन, उन्हें लॉग और संरक्षित करती हैं।

इसमें "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.11 – 'नेटवर्क सुरक्षा'" का अनुसरण किया जाएगा।

सतह ही, संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता ने निम्नलिखित के लिए प्रक्रियाओं को दस्तावेजीकृत और परीक्षित किया है:

- . नेटवर्क अवसंरचना प्रबंधन के लिए पहुँच नियंत्रण;
- . फायरवाल द्वारा उपलब्ध कराई गई ट्रैफिक फिल्टरिंग;
- . सुरक्षित वर्चुअल प्राइवेट नेटवर्क सृजित करना (यदि वीपीएन प्रस्तावित है);
- . अनधिकृत प्रवेश का पता लगाना/ उसे रोकना;
- . डीडीओएस (डिस्ट्रीब्यूटेड डिनायल ऑफ सर्विस) के प्रभावों का शमन;
- . लॉगिंग और नोटिफिकेशन ताकि प्रणालीबद्ध आक्रमणों की समीक्षा की जा सके।

3.4.5 डाटा को अलग करना

क्लाउड सेवाओं के उपयोग के मामले में संगठन यह सुनिश्चित करेगा कि डाटा को क्लाउड पर्यावरण में समुचित रूप से अलग रखा जाए।

क्लाउड पर संगठन के डाटा को इस प्रकार अलग किया जाएगा कि वह अलग से प्रबंधित अस्तित्व के रूप में परिचालन करे।

नेटवर्क, परिचालन प्रणाली, एप्लिकेशन लेयर और डाटाबेस के स्तर पर समुचित अलगाव सुनिश्चित करने के लिए तंत्र स्थापित किए जाएँगे।

बहु-पट्टेदार क्लाउड पर्यावरण के लिए निम्नलिखित सुनिश्चित किए जाएँगे:

- भंडारण, मेमोरी और रूटिंग के उपयोग के पृथक्करण के लिए तंत्र परिभाषित किए जाएँगे। एप्लिकेशनों और डाटा का अलगाव सुनिश्चित किया जाएगा। पृथक्कृत स्थापत्य में डाटा को अपने डाटाबेस इंस्टान्स में अलग-अलग किया जाएगा। बहु-पट्टेदारी के लिए ऐसे स्थापत्य और डिजाइन को अपनाया जाएगा जिससे बड़े पैमाने पर काम करने से होने वाली किफायत का लाभ मिले, उपलब्धता, प्रबंधन, अलग-अलग खंडों में विभाजन, अलगाव और परिचालन दक्षता हासिल हो।
- क्लाउड पर नियोजित ऐसे एप्लिकेशन के लिए, जो एप्लिकेशन द्वारा प्रस्तुत देसी बहु-पट्टेदारी विशेषताओं का उपयोग करता हो, अलग-अलग पट्टेदारों या निकायों के डाटा की निजता की सुरक्षा उपयुक्त पहुँच नियंत्रण तंत्रों के माध्यम से सुनिश्चित की जाएगी। एप्लिकेशन द्वारा व्यवसायगत त्रुटियों और परिचालनगत त्रुटियों को स्पष्ट रूप से अलग-अलग लॉग किया जाएगा ताकि व्यवसाय प्रयोक्ताओं और डाटासेंटर परिचालकों के बीच दायित्वों के पृथक्करण में सहयोग मिले।

3.4.6 डाटा वर्गीकरण

डाटा वर्गीकरण में विद्यमान "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.1 – 'डाटा वर्गीकरण'" का अनुसरण किया जाएगा।

3.4.7 एन्क्रिप्शन

जैसा कि विद्यमान "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.12 – 'क्रिप्टोग्राफिक नियंत्रण'" में परिभाषित किया गया है, संगठन डाटा वर्गीकरण नीति में परिभाषित एन्क्रिप्शन अपेक्षाओं के अनुसरण में किए गए वर्गीकरण के आधार पर उपयुक्त क्रिप्टोग्राफिक नियंत्रण लागू करना सुनिश्चित करेगा।

संगठन यह सुनिश्चित करेगा कि विद्यमान "सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.12 – 'क्रिप्टोग्राफिक नियंत्रण'" के अनुसरण में एन्क्रिप्शन की(ज़) के एक अलग और विशिष्ट सेट का उपयोग किया जाए।

संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता की-प्रबंधन अंतर-परिचालनीय प्रोटोकॉल (केएमआईपी) का समर्थन करे। केएमआईपी विविधतापूर्ण अवसंरचनाओं के बीच एन्क्रिप्शन कीज़ के प्रबंधन का एक मानकीकृत तरीका उपलब्ध कराता है।

संगठन, जब भी अनुकूलता हो, फेडरेटेड इनफॉर्मेशन प्रोसेसिंग स्टैंडर्ड (एफआईपीएस) के अनुपालन में हार्डवेयर एन्क्रिप्शन कीज़ को अधिमान देगा। संगठन निम्नलिखित के लिए संगठन की पहले से ही विद्यमान सूचना सुरक्षा नीति के अनुसरण में एन्क्रिप्शन की-प्रबंधन कार्यविधियाँ तैयार करेगा:

- . मार्गस्थ, उपयोग में न लाए जा रहे और बैक-अप मीडिया के डाटा को एन्क्रिप्ट करना;
- . की-भंडार को सुरक्षित रखना;
- . एन्क्रिप्शन कीज़ का संरक्षण करना;
- . एन्क्रिप्शन का उद्योग/ सरकार के मानकों पर आधारित होना सुनिश्चित करना;
- . की-भंडार तक पहुँच को सीमित करना;
- . की-बैक-अप और उसे रिकवर करने की योग्यता;
- . इन कार्यविधियों का परीक्षण करना।

3.4.8 एप्लिकेशन सुरक्षा

संगठन विद्यमान “सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.5 – ‘सूचना प्रणालियों का अधिग्रहण और विकास’ उप-खंड ‘एप्लिकेशन सुरक्षा’” के अनुसरण में क्लाउड पर होस्ट किए जाने वाले एप्लिकेशनों की सुरक्षा सुनिश्चित करेगा।

3.4.9 घटना प्रबंधन

क्लाउड सेवाओं के लिए घटना प्रबंधन में विद्यमान “सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.10 – ‘घटना और समस्या प्रबंधन’” का अनुसरण किया जाएगा।

3.4.10 व्यवसाय निरन्तरता और आपदा रिकवरी

संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाओं की व्यवसाय निरन्तरता के लिए विद्यमान “सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.13 – ‘व्यवसाय निरन्तरता प्रबंधन और आपदा रिकवरी’” का अनुसरण किया जाएगा।

इसके अतिरिक्त, संगठन क्लाउड सेवाप्रदाता की आपदा रिकवरी योजना की लेखापरीक्षा भी करेगा और यह सुनिश्चित करेगा कि योजना संगठन की अपेक्षाओं को पूरा करती है। कम-से-कम निम्नलिखित पर अवश्य विचार किया जाएगा:

- i. डाटा क्षति की घटनाओं के बाद डाटा को वापस प्राप्त करने की क्षमता।
- ii. क्लाउड सेवाप्रदाता एक विस्तृत सांगठनिक आपदा रिकवरी परीक्षण रिपोर्ट उपलब्ध कराएगा जिसमें परीक्षण के दायरे से लेकर अंतिम परिणाम और अनुशंसाओं तक को शामिल किया जाएगा।
- iii. यह सुनिश्चित करना कि आपदा रिकवरी समाधान उस स्तर के सुरक्षा उपाय और नियंत्रण स्थापित करने में समर्थ है जिनका उपयोग सामान्य परिचालन मोड में किया जाता है।
- iv. इसके लिए आश्वस्त करना कि आपदा रिकवरी समाधान पूर्ण रूप से संविदाकर्ता क्लाउड सेवाप्रदाता के स्वामित्व और उसके प्रबंधन में है।

यह अनुशंसा की जाती है कि बीएस25999 या आईएसओ22301 प्रमाणित क्लाउड सेवाप्रदाता का विकल्प चुना जाए।

क्लाउड के स्रोत से ली गई सेवाओं के लिए नियमित बीसीपी पर आधारित व्यवसाय निरन्तरता योजनाएँ स्थापित की जाएँगी और संगठन की संविदाओं में उसके लिए उपबंध शामिल किए जाएँगे।

एक गोपनीय दस्तावेज रखा जाएगा जिसमें व्यवसाय निरन्तरता के प्रयोजन से एकाउंट की जानकारी रखी जाएगी।

3.4.11 अपवाद प्रबंधन

“अपवाद” को ऐसी परिस्थितियों के रूप में परिभाषित किया जाएगा जब कोई विशेष नीति या मानक; सुरक्षा कार्यक्रम अपेक्षा; या सुरक्षा संबंधी सर्वोत्तम कार्यपद्धति पूरी तरह कार्यान्वित नहीं की जा सकती।

संगठन अपवाद के आधार पर अपनी आस्तियों की गोपनीयता, सत्यनिष्ठा और उपलब्धता को पर्याप्त संरक्षण प्रदान करने के प्रयास के क्रम में प्रशासनिक, तकनीकी और भौतिक सुरक्षा उपायों को विकसित, प्रकाशित और कार्यान्वित करेगा।
क्लाउड सेवाओं के लिए अपवाद प्रबंधन में विद्यमान “सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 1.8 – ‘अपवाद’” का अनुसरण किया जाएगा।

3.5 क्लाउड सेवाप्रदाता की ऑफ-बोर्डिंग

संविदा के परिसमापन के बाद बीमा कंपनी द्वारा अंतरित समग्र डाटा या तृतीय पक्षकार द्वारा बीमा कंपनी के लिए जेनरेट किया गया समग्र डाटा संगठन को सौंप दिया जाएगा। संगठन के समक्ष इस बात का साक्ष्य प्रस्तुत करना होगा कि सेवाप्रदाता की सभी साइटों पर डाटा डिलीट कर दिया गया है और डाटा की सभी प्रतियों को साफ कर दिया गया है।

मार्गस्थ डाटा को “सूचना और साइबर सुरक्षा नीति – सुरक्षा विषय-क्षेत्र नीति, खंड 2.1 – ‘डाटा वर्गीकरण’” में निर्धारित डाटा वर्गीकरण के आधार पर कड़े नियंत्रण के अधीन रखा जाएगा।

सेवाओं के परिसमापन के बाद सेवाप्रदाता इस आशय का एक प्रमाणपत्र उपलब्ध कराएगा कि डिकमीशनिंग की प्रक्रिया पूरी कर ली गई है और आगे संगठन के कर्मचारियों को पहुँच उपलब्ध नहीं कराई जाएगी।

3.6 वर्चुअलाइजेशन

क्लाउड कम्प्यूटिंग में अधिकांश तार्किक पृथक्करण नियंत्रण भौतिक नहीं होते, वे पूरे प्लेटफॉर्म पर डाटा के विविध खंडों में विभाजन, उसकी सत्यनिष्ठा सुनिश्चित करने में सहयोग देने के लिए डिजाइन की गई तार्किक प्रणाली और एप्लिकेशन नियंत्रण के माध्यम से लागू कराए जाते हैं। डाटा और सेवाओं के इसी पृथक्करण को उपलब्ध कराने वाले तंत्र को “वर्चुअलाइजेशन” कहते हैं।

3.6.1 क्लाउड सेवाप्रदाता वर्चुअलाइजेशन पर्यावरण

संगठन क्लाउड सेवाप्रदाताओं के वर्चुअलाइजेशन हार्डनिंग दिशानिर्देशों और नीतियों का मूल्यांकन करेगा और साथ ही प्रौद्योगिकी जोखिम आकलन जाँचसूची के समक्ष तृतीय पक्ष अंतराल आकलन का मूल्यांकन करेगा। इसमें निम्नलिखित शामिल हैं लेकिन यह सूची सम्पूर्ण नहीं है:

- . सभी अनावश्यक इंटरफ़ेसों, पोर्टों, उपकरणों और सेवाओं को अक्षम बनाना या उन्हें हटा देना;
- . सभी वर्चुअल इंटरफ़ेसों और भंडारण क्षेत्रों को सुरक्षित तरीके से कन्फ़िगर करना;
- . वीएम संसाधन के उपयोग की सीमा निर्धारित करना;
- . यह सुनिश्चित करना कि वर्चुअल मशीन के भीतर रन कर रही परिचालन प्रणालियों और एप्लिकेशनों को हार्डन किया गया है;
- . क्रिप्टोग्राफ़िक की-प्रबंधन प्रणालियों की सत्यनिष्ठा का वैधकरण करना;
- . व्यक्तिगत वीएम वर्चुअल हार्डवेयर और कंटेनरों को हार्डन करना।

3.6.2 वर्चुअलाइजेशन सुरक्षा

संगठन यह सुनिश्चित करेगा कि क्लाउड सुरक्षा प्रदाता के पास ऐसे नियंत्रण हैं जिसके बल पर वह गारंटी दे सके कि केवल प्राधिकृत सैपशॉट/ इमेज ही लिए जाते हैं और यह कि सैपशॉट/ इमेज स्तरीय वर्गीकरण, भंडारण स्थल और एन्क्रिप्शन में उत्पादन वर्चुअलाइजेशन पर्यावरण का अनुपालन किया गया है।

संगठन इस बात का आश्वासन देगा कि हाइपरवाइजर सुरक्षा के भाग के रूप में निम्नलिखित नियंत्रणों को लागू किया गया है:

- . संगठन हाइपरवाइजर प्रशासनिक पहुँच की लॉग रिपोर्टों तक पहुँच स्थापित कर पाएगा;
- . हाइपरवाइजर पूर्ण लॉगिंग को समर्थ किया गया है।

संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता विश्वसनीय वर्चुअल मशीनों की सहायता उपलब्ध कराता है और वे वर्चुअल मशीनें हार्डवेयर दिशानिर्देशों के अनुपालन में तैयार की गई हैं।

संगठन को क्लाउड सेवाप्रदाता उन विक्रेताओं की सम्पूर्ण सूची उपलब्ध कराएगा जो करार की अवधि के दौरान किसी भी समय संगठन के डाटा तक पहुँच रखेंगे। विक्रेताओं की सूची में किसी भी परिवर्तन से क्लाउड सेवाप्रदाता संगठन को सदा अवगत रखेगा।

वर्चुअलाइजेशन के माध्यम से बहु-पट्टेदारी के लिए,

- क्लाउड के भीतर नियोजित एप्लिकेशन का, वर्चुअलाइजेशन उत्पाद के माध्यम से स्पष्ट परीक्षण किया जाएगा और उसे अर्ह किया जाएगा। वर्चुअलाइज्ड पर्यावरण के अंतर्गत नियोजन को ध्यान में रखते हुए एप्लिकेशन का विक्रेता साइजिंग उपलब्ध कराएगा। वैकल्पिक रूप से विक्रेता भौतिक सर्वरों के आधार पर साइजिंग उपलब्ध कराएगा और निर्दिष्ट वर्चुअलाइजेशन उत्पाद के ओवरहेड का उल्लेख करेगा।
- प्रयुक्त वर्चुअलाइजेशन उत्पाद के लिए एप्लिकेशन इमेज उपलब्ध होगा। प्रत्येक वर्चुअल मशीन को अनुमानित लेनदेन के अनुरूप संसाधन उपलब्ध कराए जाएँगे। वास्तविक लोड के समक्ष संसाधन उपभोग का आवधिक अनुप्रवर्तन किया जाएगा ताकि आवश्यक परिष्कार किए जा सकें।
- एप्लिकेशन के अलग-अलग टीयरों को अलग-अलग भौतिक बॉक्स में रखने से विभिन्न टीयरों से होकर गुजरने वाला संवाद भौतिक नेटवर्क के माध्यम से गुजरेगा और इससे ऐसी फायरवाल नीतियाँ कार्यान्वित करने में सहयोग मिलेगा जिससे केवल एक ही कंपनी की वर्चुअल मशीनों के बीच ही संवाद की अनुमति दी जा सके। इसके साथ ही, अलग-अलग कंपनियों की वर्चुअल मशीनों को अलग करने के लिए अलग-अलग डिस्क संभागों के उपयोग से आगे और पृथक्करण संभव होगा।

3.7 विधिक, विनियामकीय और संविदागत अपेक्षाएँ

3.7.1 संविदागत अपेक्षाएँ

क्लाउड सेवाप्रदाता के कोई सेवा देने के पूर्व संगठन उसके साथ एक अप्रकटन करार (एनडीए) पर हस्ताक्षर करेगा। निजता, गोपनीयता, सुरक्षा और व्यवसाय निरन्तरता से जुड़े सभी पहलुओं को पूर्णतः पूरा किया जाएगा।

यदि विक्रेता क्लाउड सिक्वोरिटी अलायंस ट्रस्ट के अंतर्गत प्रमाणित है या वह क्लाउड ट्रस्ट प्रोटोकॉल के अंतर्गत नियंत्रण सूचना उपलब्ध करा रहा है, और यदि संगठन को प्रदत्त सेवाओं का दायरा प्रमाणन की प्रयोजनीयता के दायरे/ अभिकथन के अंतर्गत शामिल है, तो विक्रेता को संगठन द्वारा आवधिक लेखापरीक्षाओं से छूट मिलेगी। लेकिन ऐसी स्थिति में विक्रेता को निम्नलिखित प्रस्तुत करने होंगे:

- सभी संविदागत आईएस प्रावधानों के अनुपालन का स्व-प्रमाणपत्र;
- एक वैध प्रमाणन की प्रति जिसमें यह प्रदर्शित हो कि संगठन को प्रदत्त सेवाओं का दायरा प्रमाणन की प्रयोजनीयता के दायरे/ अभिकथन के अंतर्गत शामिल है;
- कार्यनिष्पादन, सूचना सुरक्षा और आउटसोर्सिंग जोखिमों के निवारण के लिए अन्य नियंत्रणों को प्रवर्तित करने के उद्देश्य से संगठन लेखापरीक्षा के अधिकार को संविदा में निहित करेगा।

सेवा-स्तरीय करारों (एसएलए) और सेवागत बाध्यताओं को निर्धारित करते समय सूचना सुरक्षा विभाग को शामिल किया जाएगा ताकि यह सुनिश्चित किया जा सके कि सुरक्षागत अपेक्षाएँ संविदा के अंतर्गत प्रवर्तनीय हैं। संगठन द्वारा निम्नलिखित विषयों को ध्यान में रखते हुए सेवा संविदा तैयार की जाएगी:

- . स्थापत्य संरचना

- . संचालन, जोखिम प्रबंधन
- . क्लाउड सेवाप्रदाता की भूमिका और संगठन की भूमिका के संबंध में स्पष्टता
- . ई-डिस्कवरी सर्वेज
- . विशेषज्ञ का साक्ष्य
- . प्राथमिक और द्वितीयक (लॉग) डाटा
- . भंडार की अवस्थिति
- . संविदा का परिसमापन
- . डाटा का स्वामित्व

संगठन यह सुनिश्चित करेगा कि सेवा-स्तरीय करार में संगठन द्वारा परिभाषित योजनाबद्ध और बिना योजना के हुए व्यवधान या बंदी की स्थिति में एप्लिकेशनों और डाटा की उपलब्धता संबंधी अपेक्षाओं, व्यवसाय निरन्तरता और आपदा रिकवरी योजना तथा बैक-अप, और अनावश्यकता की स्थिति में की जाने वाली व्यवस्था का समावेश हो।

व्यवसाय व्यवधान की स्थिति में किए जाने वाले वित्तीय उपायों को संगठन एसएलए में शामिल करेगा।

संगठन और तृतीय पक्ष सेवाप्रदाता के बीच संविदा के हस्ताक्षरित होने के बाद ही सेवाप्रदाता को संगठन की क्लाउड सेवा के लिए पैनल में शामिल किया जाएगा।

संगठन के हितों की सुरक्षा की दृष्टि से संविदागत निबंधनों का प्रारूप तैयार करने और उनका अनुमोदन करने का कार्य संगठन के विधि विभाग द्वारा अनुपालन विभाग, जोखिम विभाग और सूचना सुरक्षा विभाग के परामर्श से किया जाएगा।

स्वचालित टूल्स एसएलए का अनुप्रवर्तन और उसे ट्रैक करेंगे और रिपोर्ट जनरेट करेंगे ताकि लागतों, प्रतिफल दर आदि के संबंध में पूर्वानुमान किया जा सके।

प्रावधान की प्रक्रिया पूर्णतः स्वचालित होगी।

3.7.2 डाटा की निजता पर संविदागत खंड

संगठन आश्वस्त करेगा कि करार की पूरी अवधि के दौरान डाटा का "सम्पूर्ण" स्वामित्व उसी के पास होगा। स्वामित्व में क्लाउड सेवाप्रदाता के पास उपलब्ध डाटा की सभी प्रतियाँ और बैक-अप मीडिया प्रतियाँ, यदि कोई हों, शामिल होंगी। संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता को विज्ञापन या किसी अन्य अप्राधिकृत द्वितीयक प्रयोजन से बीमा कंपनी के डाटा के उपयोग की अनुमति नहीं है। संगठन संविदागत रूप में यह आश्वासन देगा कि किसी भी उल्लंघन की पुष्टि होने पर बिना किसी विलंब के तत्काल उन्हें सूचित किया जाएगा। संदिग्ध उल्लंघन के मामले में संगठन को उल्लंघन का पता चलने के चार घंटे भीतर सूचित किया जाएगा।

संगठन संविदागत रूप में यह अपेक्षा करेगा कि क्लाउड सेवाप्रदाता द्वारा उल्लंघन के कारण उत्पन्न वित्तीय हानि या दंड के लिए क्लाउड सेवाप्रदाता जिम्मेदार होगा। संगठन संविदागत रूप में यह अपेक्षा करेगा और सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता संविदा के परिसमापन के समय डाटा/ सूचना को निःशेष रूप से हटा देगा जैसी कि संविदा में सहमति व्यक्त की गई हो।

संगठन संविदागत रूप में यह अपेक्षा करेगा और सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता डाटा और मीडिया को नष्ट करने और स्वच्छता नियंत्रणों से संबंधित दायित्व को पूरा करेगा।

संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता संगठन को डाटा की वापसी संबंधी अपेक्षा का अनुपालन करता है। क्लाउड सेवाप्रदाता द्वारा कोई वेंडर लॉक-इन नहीं होगा।

5.7.3 विधिक अपेक्षाएँ

संगठन यह सुनिश्चित करेगा कि क्लाउड सेवाप्रदाता की अपनी डाटा निजता नीति संगठन में लागू कानूनों के अनुपालन में है। इसके अतिरिक्त क्लाउड सेवाप्रदाता देश की सभी विनियामकीय और कानूनी अपेक्षाओं का पालन करेगा। यदि क्लाउड सेवा लेने वाले संगठन की उपस्थिति अंतरराष्ट्रीय हो तो क्लाउड कम्प्यूटिंग में डाटा और प्रक्रियाओं को भारतीय और अंतरराष्ट्रीय कानूनों का अनुपालन करना होगा। क्लाउड सेवा का उपयोग करते समय विधिक अनुपालन सुनिश्चित किया जाएगा।

5.7.4 विनियामक स्वतंत्रता

संगठन संविदागत रूप में क्लाउड सेवाप्रदाता के साथ सहमत होगा कि लेखापरीक्षा/ निरीक्षण के लिए देश के विनियामकों को अवसंरचना और एप्लिकेशन उपलब्ध कराए जाएँ। बीमा कंपनी द्वारा उपभुक्त सभी सूचना संसाधनों तक विनियामक की पहुँच होगी, भले ही वे संसाधन भौतिक रूप से संगठन के परिसर में अवस्थित न हों।

5.8 आरएसीआई मैट्रिक्स

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी टीम	सूचना सुरक्षा टीम	सीआरओ/ सीओओ/ विधि	कार्यपालक प्रबंधन

नीति सं.:	2.20
नीति का नाम:	2.20 साइबर अनुकूलता

1 प्रयोजन

साइबर जोखिम द्वारा प्रस्तुत विविधतापूर्ण चुनौतियों का सामना व्यापक प्रतिसाद के माध्यम से करना चाहिए। इस पर समुचित स्तर के उच्च प्रबंधन का ध्यान आवश्यक है, और साथ ही एक प्रभावी संचालन संरचना भी आवश्यक है जो साइबर सुरक्षा घटनाओं को समझ सके, रोक सके, पता लगा सके, प्रतिसाद कर सके और उनका उपचार कर सके।

साइबर सुरक्षा और संबंधित जोखिमों के निवारण और उनके शमन के लिए दिशानिर्देश उपलब्ध कराना।

2 दायरा

यह नीति संगठन द्वारा प्रयुक्त आईटी एप्लिकेशनों, आईटी अवसंरचना और भौतिक सूचना माध्यमों सहित सूचना प्रणालियों, सूचना आस्तियों, व्यवसाय प्रक्रियाओं और कार्यविधियों पर लागू होती है।

3 नीति

इस नीति के उद्देश्य निम्नानुसार हैं:

1. सुरक्षा संबंधी अग्रसक्रिय उपायों के कार्यान्वयन के माध्यम से साइबर घटनाओं को घटित होने और पुनः घटित होने से रोकना।
2. साइबर सुरक्षा संबंधी सर्वोत्तम कार्यपद्धतियों, मानकों और दिशानिर्देशों के साथ अनुरूपता के आकलन और उनके अनुपालन के लिए उपयुक्त अवसंरचना का निर्माण करना।
3. सुरक्षा खतरे की शीघ्र चेतावनी, कमजोरी प्रबंधन और सुरक्षा खतरों पर प्रतिसाद के लिए तंत्र निर्मित करना।
4. विद्यमान और संभावित साइबर सुरक्षा खतरों के लिए आवश्यक पारिस्थितिक परिदृश्य जेनरेट करने और अग्रसक्रिय, निवारणात्मक और संरक्षणात्मक कार्रवाइयों के लिए सही समय पर सूचना साझा करने को संभव बनाने के लिए प्रक्रियाओं, संरचनाओं और तंत्रों का निर्माण करना।
5. साइबरस्पेस की सुरक्षा पर एक समग्रतामूलक जागरूकता कार्यक्रम का संवर्धन और आरंभ करना।

3.1 वर्गीकरण

1. महत्वपूर्ण प्रणालीगत और साइबर सुरक्षा घटनाओं को महत्व और गंभीरता के आधार पर वर्गीकृत किया जाएगा।
2. सूचना और साइबर सुरक्षा घटनाओं के लिए घटना प्रबंधन कार्यविधि के भाग के रूप में घटना वर्गीकरण दिशानिर्देश परिभाषित किए जाएंगे।

3.2 साइबर अनुकूलता कार्यक्रम

प्रतिकूल साइबर परिस्थितियों के बावजूद बिना किसी रुकावट के वांछित परिणाम देने की योग्यता ही साइबर अनुकूलता है। साइबर अनुकूलता संबंधी सर्वोत्तम कार्यपद्धतियों के अनुरूप अच्छी तरह काम करने वाला साइबर सुरक्षा प्रबंधन कार्यक्रम स्थापित किया जाएगा और उसे पर्यवेक्षकीय समीक्षा के माध्यम से सत्यापित किया जाएगा।

साइबर सुरक्षा प्रभावी हो, इसके लिए यह आवश्यक है कि सभी स्तरों पर साइबर सुरक्षा का ध्यान रखा जाए। साइबर सुरक्षा प्रबंधन कार्यक्रम में शामिल हैं- लगातार चलने वाली प्रक्रियाओं और नियंत्रणों में सुधार, घटना प्रबंधन कार्यविधियाँ जैसे कि प्रतिसाद और आपदा रिकवरी, अधुनातन नेटवर्क नीतियाँ और कार्यविधियाँ, प्रयोक्ताओं के विशेषाधिकारों का कठोर प्रबंधन और नियंत्रण, सुरक्षित कन्फिगरेशन के संबंध में मार्गदर्शन, मालवेयर से संरक्षण की उपयुक्त कार्यविधियाँ, रिमूवेबल मीडिया के उपयोग पर निरंतर नियंत्रण, मोबाइल और घर से काम करने की कार्यविधियों का अनुप्रवर्तन, और सभी कार्मिकों के लिए लगातार चलने वाले जागरूकता और शैक्षणिक कार्यक्रम।

साइबर अनुकूलता की सर्वोत्तम कार्यपद्धतियों में निम्नलिखित प्रमुख क्षेत्रों को शामिल किया जाना चाहिए, लेकिन यह सूची सम्पूर्ण नहीं है:

- पहचान
- संरक्षण
- पता लगाना
- प्रतिसाद और रिकवरी
- परीक्षण
- ज्ञानार्जन और रिपोर्टिंग
- पारिस्थितिक जागरूकता

3.2 पहचान .1

संगठन एक साइबर खतरा आसूचना प्रक्रिया, विश्लेषण और सूचना को साझा करने की प्रक्रिया स्थापित करेगा और उसका अनुसरण करेगा जिसमें निम्नलिखित शामिल होंगे लेकिन ये इन्हीं तक सीमित नहीं हैं।

निम्नलिखित साइबर खतरों की पहचान की जाएगी:

1. जो परिचालन निष्पादन को प्रभावित कर सकते हैं;
2. जो बीमा कंपनी के उद्देश्यों और बाध्यकारी दायित्वों को पूरा करने पर उल्लेखनीय प्रभाव डाल सकते हैं; और
3. जो महत्वपूर्ण व्यवसाय प्रक्रियाओं और प्रतिष्ठा के लिए खतरा उत्पन्न कर सकते हैं।

जिन आस्तियों को प्राथमिकता के आधार पर संरक्षण की आवश्यकता है उनकी पहचान के लिए आवश्यक कदम उठाए जाएंगे।

1. उन महत्वपूर्ण आस्तियों, व्यवसाय कार्यों और प्रक्रियाओं की पहचान की जाएगी जिनके दुरुपयोग की संभावना है।
2. सूचना आस्तियाँ (संवेदनशील व्यक्तिगत जानकारी सहित) और संबंधित प्रणाली तक पहुँच, पहचान प्रक्रिया का भाग होंगी।
3. आंतरिक और बाह्य व्यवसाय और प्रणाली सूचना स्रोतों के साथ मिलकर संगठन साइबर खतरे की सूचना एकत्र और विश्लेषित करने के लिए एक प्रक्रिया स्थापित करेगा।
4. ऑन-बोर्डिंग और परिचालन प्रक्रिया के एक भाग के रूप में व्यवसाय प्रक्रिया जोखिम या विक्रेता जोखिम की पहचान और आकलन किया जाएगा।
5. विस्तृत वर्गीकरण के लिए "सूचना और साइबर सुरक्षा नीति" के "आस्ति प्रबंधन" खंड को संदर्भित किया जाएगा।

3.2 संरक्षण**.2**

- नियंत्रण तकनीकी मानकों की तर्ज पर होगा।
- डिजाइन में ही अनुकूलन की व्यवस्था होगी।
- समग्रतामूलक संरक्षण में इंटरकनेक्शनों और आंतरिक और बाह्य खतरों तक पहुँचने के अन्य साधनों का संरक्षण शामिल है। संरक्षण को डिजाइन करते समय "मानवीय कारक" को ध्यान में रखा जाएगा।
- न्यूनतम विशेषाधिकार भूमिकाओं पर उपयुक्त पहुँच नियंत्रण एप्लिकेशन और पहुँच नियंत्रण डिजाइन का हिस्सा होंगे।

3.3 पता लगाना**.3**

महत्वपूर्ण प्रणालियों के लिए साइबर सुरक्षा का अनुप्रवर्तन अनिवार्य है क्योंकि सुरक्षा स्थितियों के अनुप्रवर्तन और/या विश्लेषण से साइबर घटनाओं का पता लगाने और उनके शमन में मदद मिलेगी। कृपया 'अनुप्रवर्तन, लॉगिंग और आकलन नीति' को संदर्भित करें।

**3.3 प्रतिसाद और
.4 रिकवरी**

शीघ्र रिकवरी को संभव बनाने वाले प्रमुख कारक हैं आकस्मिकता योजना, डिजाइन, व्यवसाय एकीकरण और डाटा की सत्यनिष्ठा। प्रभावी आकस्मिकता योजना के लिए आवधिक परीक्षण किए जाएँगे। कृपया "घटना और समस्या प्रबंधन नीति" और "व्यवसाय निरन्तरता प्रबंधन और आपदा रिकवरी नीति" को संदर्भित करें।

3.3 परीक्षण**.5**

परीक्षण कार्यक्रम, कमजोरी आकलन और पैठ (पेनिट्रेशन) परीक्षण – परीक्षण के चरण के महत्वपूर्ण स्तम्भ हैं। एप्लिकेशन के विकास और अनुरक्षण के चक्र के विभिन्न चरणों में सुरक्षा परीक्षण किया जाएगा। विस्तृत विवरण के लिए कृपया "सूचना और साइबर सुरक्षा नीति" के अग्रलिखित खंड देखें – "सूचना प्रणाली अधिग्रहण और विकास", "सूचना प्रणाली अनुरक्षण", "नेटवर्क सुरक्षा", और "अनुप्रवर्तन, लॉगिंग और आकलन"।

**3.3 ज्ञानार्जन और
.6 रिपोर्टिंग**

संगठन समय-समय पर साइबर सुरक्षा प्रबंधन की प्रभावोत्पादकता का पुनर्मूल्यांकन करेगा।

संगठन ऐसी सुरक्षा घटनाओं की रिपोर्ट सम्बंधित विनियामक और अन्य संचालक निकायों को डाटा सम्बन्धी अपेक्षित तत्वों और अन्य उपलब्ध सूचनाओं के साथ सम्बंधित संचालक निकाय द्वारा या सूचना सुरक्षा टीम द्वारा निर्धारित समयसीमा के भीतर करेगा जिनमें महत्वपूर्ण सूचनाओं की गोपनीयता, सत्यनिष्ठा और उपलब्धता के साथ छेड़छाड़ की आशंका हो।

**3.3 पारिस्थितिक
.7 जागरूकता**

जागरूकता से साइबर खतरों की पहचान में सहयोग मिलता है, इसलिए खतरा आसूचना प्रक्रिया की स्थापना से साइबर जोखिम के शमन में सहयोग मिलता है। इस विषय में संगठन सूचना साझा करने के स्थापित प्रयासों में आवश्यकतानुसार सहभागिता करेगा। साइबर सुरक्षा जागरूकता सम्बन्धी परिपत्रों और सलाहों को नियमित रूप से कर्मचारियों, तृतीय पक्ष विक्रेताओं और परामर्शदाताओं को भेजा जाएगा।

**3.4 अपराध-
विज्ञान**

संगठन विधिक या विनियामकीय प्रयोजनों से अन्वेषण की आवश्यकता वाली घटनाओं की और/या गंभीर सूचना सुरक्षा घटनाओं की अपराध वैज्ञानिक जाँच करवाएगा। वे विनियमों और कानूनों के अनुसरण में डिजिटल साक्ष्य एकत्र, प्रसंस्कृत और विश्लेषित करेंगे।

3.5**आरएसीआ
ई मैट्रिक्स**

जिम्मेदार	उत्तरदायी	परामर्श किससे	सूचना किसको
आईटी टीम	सूचना सुरक्षा टीम	जोखिम टीम/ सूचना सुरक्षा टीम	आस्ति का स्वामी/ व्यवसाय/ कार्यपालक प्रबंधन

नीति सं.:**2.21****नीति का नाम:****2.21 ईमेल सुरक्षा**

- | | | |
|------------|--|---|
| 1 | प्रयोजन | संगठन द्वारा प्रयुक्त या नियंत्रित इलेक्ट्रॉनिक मेसेजिंग के संरक्षण के लिए वांछित सुरक्षा आवश्यकताओं को परिभाषित करना। |
| 2 | दायरा | यह नीति उन सभी संचार माध्यमों और नेटवर्क कनेक्शनों पर लागू होती है जिनके माध्यम से संगठन की सूचना अस्तित्वों संप्रेषित की जाती हैं।
संचार माध्यम और नेटवर्क कनेक्शन में ईमेल, इंटरनेट, इंटरनेट और सोशल मीडिया प्लेटफॉर्म शामिल हैं, लेकिन ये इन्हीं तक सीमित नहीं हैं।
सूचना प्रौद्योगिकी का उपयोग करने वाली सभी इकाइयों या विभागों द्वारा इस नीति का अनुपालन अनिवार्यतः किया जाएगा। |
| 3 | नीति | सभी प्रकार की संचार सुविधाओं के उपयोग के माध्यम से सूचनाओं के अंतरण के लिए औपचारिक अंतरण नीतियों, कार्यविधियों और नियंत्रणों की स्थापना की जाएगी। संगठन अनेक प्रकार की संचार सुविधाओं के माध्यम से सूचनाओं का अंतरण कर सकता है, जिनमें इलेक्ट्रॉनिक मेल, वायस मेल, फैसिमिली और वीडियो शामिल हैं। सॉफ्टवेयर अंतरण भी अनेक माध्यमों से हो सकता है जिसमें इंटरनेट से उसे डाउनलोड करना और बने-बनाए उत्पादों के विक्रेताओं से उसकी खरीद शामिल हैं। इलेक्ट्रॉनिक डाटा इंटरचेंज, इलेक्ट्रॉनिक वाणिज्य और इलेक्ट्रॉनिक संचार से सम्बद्ध व्यवसायगत, विधिक और सुरक्षागत निहितार्थों तथा साथ ही नियंत्रणों की आवश्यकता पर विचार किया जाएगा।
इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा। |
| 3.1 | इलेक्ट्रॉनिक मेसेजिंग के लिए विचारणीय सूचना सुरक्षा | <ol style="list-style-type: none"> वैध डोमेन से जाली या आशोधित ईमेल भेजे जाने की आशंका को कम करने के लिए संगठन डोमेन-आधारित सन्देश अधिप्रमाणन, रिपोर्टिंग और अनुरूपता (डीएमएआरसी) नीति और सत्यापन का कार्यान्वयन करेगा जिसकी शुरुआत प्रेषक नीति संरचना (एसपीएफ़) डोमेन कीज़ आयडेंटिफ़ाएड मेल (डीकेआईएम) मानकों के कार्यान्वयन के साथ की जाएगी। पहले से ज्ञात मैलिसस डोमेनों तक पहुँच को बंद करने में सहायता के लिए डीएनएस फिल्टरिंग सेवाओं का उपयोग किया जाएगा। मैलिसस व्यवहार करने वाले आवक ईमेल अटैचमेंट का विश्लेषण करने और उन्हें बंद करने के लिए संगठन सैंडबॉक्सिंग का प्रयोग करेगा। एमएस ऑफिस दस्तावेजों में वीपीए/ मैक्रोज़ के प्रयोग के नियंत्रण और ईमेल प्रणालियों में अटैचमेंट के अनुमति-योग्य प्रकारों के नियंत्रण के लिए उपाय कार्यान्वित किए जाएँगे। |

नीति सं.: 2.22

नीति का नाम: 2.22 दूरस्थ स्थान से कार्य

- | | | |
|----------|----------------|---|
| 1 | प्रयोजन | दूरस्थ स्थानों से कार्य के सन्दर्भ में संगठन की सूचना अस्तित्वों के उपयोग से सम्बंधित भूमिकाओं, दायित्वों और निबंधनों को परिभाषित करना। |
| 2 | दायरा | यह नीति उन सभी कर्मचारियों, संविदाकर्ताओं और तृतीय पक्षकारों पर लागू होगी जो दूरस्थ कनेक्शनों का प्रयोग करते हुए संगठन की सूचना अस्तित्वों तक पहुँचेंगे। सूचना प्रौद्योगिकी का उपयोग करने वाली व्यवसाय इकाइयों या विभागों द्वारा इन सुरक्षा नीतियों का अनिवार्य रूप से पालन किया जाएगा। |
| 3 | नीति | <p>इस नीति के उद्देश्य निम्नानुसार हैं:</p> <ol style="list-style-type: none"> अग्रसक्रिय सुरक्षा उपायों के कार्यान्वयन के माध्यम से साइबर घटनाओं के घटित होने और पुनः घटित होने से रोकना। |

2. साइबर सुरक्षा की सर्वोत्तम कार्यपद्धतियों, मानकों और दिशानिर्देशों से अनुरूपता और उनके अनुपालन के प्रमाणन के लिए अवसंरचना निर्मित करना।
3. सुरक्षा खतरे की शीघ्र चेतावनी, कमजोरी प्रबंधन और सुरक्षा खतरों पर प्रतिसाद के लिए तंत्र निर्मित करना।
4. गोपनीय सूचना के लीकेज को रोकने के लिए तंत्र निर्मित करना।

इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 संरचना

1. बीमाकर्ता के निदेशक मंडल द्वारा अनुमोदित साइबर सुरक्षा नीति में दूरस्थ स्थान से कार्य से सम्बद्ध जोखिमों के निवारण को शामिल किया जाएगा। नीति में पासवर्ड को बार-बार परिवर्तित करना अनिवार्य बनाया जाएगा।
2. कार्यप्रवाह अनुमोदनों, विचलनों या अपवादों को परिवर्तन नियंत्रण नीति – खंड 2.9" के अनुसार कैप्चर किया जाएगा।
3. अप्राधिकृत पहुँच जोखिमों और साइबर खतरों के लिए नियंत्रण के रूप में सांठनिक आईसीटी अवसंरचना पर लेखापरीक्षा लॉग अनुप्रवर्तन और विश्लेषण का प्रावधान किया जाएगा।
4. साक्ष्यों और शिल्प-उपकरणों को वर्गीकृत किया जाएगा तथा सुरक्षित रीति से सम्बंधित हितधारकों के समक्ष प्रदर्शित किया जाएगा और प्राधिकृत डोमेनों से बहार उन्हें साझा नहीं किया जाएगा।
5. परियोजना कार्यान्वयन दस्तावेजों और एमआईएस रिपोर्टों को वर्गीकृत किया जाएगा और उन्हीं के साथ साझा किया जाएगा जिनका उन्हें जानना आवश्यक होगा।
6. बीमा कम्पनियाँ यह सुनिश्चित करेंगी कि व्यवधान की स्थिति में निवेश एप्लिकेशन के प्रयोक्ता पोर्टल, सहयोग डेस्क (फोन) या ईमेल या कार्यालय आकर आईटी सहयोग तक पहुँच सकें।

3.2 नेटवर्क सुरक्षा

1. संगठन दूरस्थ स्थानों पर मजबूत प्रोटोकॉल और वाई-फाई पासवर्ड के साथ सुरक्षित नेटवर्क सुनिश्चित करेगा।
2. प्रयोक्ताओं को उपलब्ध कराई गई संगठन की सूचना आस्तियों को मजबूत पासवर्ड अधिप्रमाणन हेतु निर्धारित सुरक्षा नीति के अनुसार हार्डेन किया जाएगा।
3. सभी सर्वरों, एप्लिकेशनों और नेटवर्कों को मानकीकृत सुरक्षा नीति सेटिंग के अनुसार हार्डेन और सुरक्षित किया जाएगा।
4. अप्राधिकृत इंटरनेट डोमेनों, प्रशासन स्तरीय पहुँच, सॉफ्टवेयर, यूएसबी और अन्य मीडिया तथा पेरीफेरल्स के अप्राधिकृत इंस्टालेशन या उसमें परिवर्तनों की रोकथाम के लिए प्रयोक्ताओं की प्रणालियों, और सूचना तथा संचार प्रौद्योगिकी (आईसीटी) पर उपकरण नियंत्रण कार्यान्वित किए जाएँगे।
5. प्रयोक्ताओं की सभी प्रणालियों पर एंटी-वायरस, अंतिम बिंदु संरक्षण नियंत्रण, डाटा एन्क्रिप्शन, डाटा क्षति निवारण तंत्र स्थापित किए जाएँगे।
6. प्रयोक्ताओं की प्रणालियों और संगठन की अवसंरचना को सुरक्षा पैचों और फिक्सों से नियमित रूप से अद्यतन किया जाएगा।
7. दूरस्थ स्थानों से कार्य करने वाले जो प्रयोक्ता संगठन की डाटा अस्तियों और एप्लिकेशनों तक पहुँच बनाते हैं, उनके लिए वर्चुअल प्राइवेट नेटवर्क (वीपीएन), इंटरनेट प्रोक्सी या वर्चुअल डिवाइस इंटरफेस जैसे सुरक्षित रिमोट पहुँच तंत्र की व्यवस्था की जाएगी।
8. सभी पैचों, एवी, अंतिम बिंदु संरक्षण, डाटा एन्क्रिप्शन की जाँच की जाएगी ताकि यह सुनिश्चित किया जा सके कि वे अच्छी तरह से काम करते हैं।

7. एप्लिकेशनों तक केवल प्राधिकृत प्रयोक्ता सुरक्षित वीपीएन पहुँच के माध्यम से पहुँच सकेंगे।
8. कार्यालय में वापस लाई गई प्रणालियों की जाँच/ स्कैनिंग के लिए हार्डनिंग कार्यविधियाँ स्थापित की जाएँगी।
9. अप्राधिकृत पहुँच, मैलिसस कोड के प्रयोग, संदिग्ध गतिविधियों या व्यवहार, पहचान के प्रमाणों की चोरी, दूरस्थ पहुँच टूलकिट जैसे उन्नत और लगातार खतरों की उपस्थिति और संगठन की अवसंरचना को साइबर जोखिम में डालने वाले तत्वों की पहचान के लिए नियंत्रणों की स्थापना की जाएगी।
10. स्पैम, जाली मेल और मालवेयर से ईमेल सेवाओं को सुरक्षित रखा जाएगा और प्रयोक्ताओं को स्पैम, फिशिंग स्कैम और धोखाधड़ी करने वाले ईमेलों को हैंडल करने का प्रशिक्षण दिया जाएगा।
11. इंटरनेट पर मौजूद संदेहास्पद और मैलिसस डोमेनों का पता लगाया जाएगा और उन्हें नेटवर्क फायरवाल, वेब प्रोक्सी फिल्टरिंग और अनधिकृत प्रवेश प्रणालियों की सहायता से ब्लॉक कर दिया जाएगा।
12. सुरक्षा पैच अपडेट की समीक्षा की जाएगी और डिस्ट्रीब्यूटेड डिनायल ऑफ़ सर्विसेज़ (डीडीओएस) आक्रमणों को रोकने के लिए आईसीटी अवसंरचना पर उन्हें आवधिक रूप से लागू किया जाएगा।
13. व्यवसाय निरंतरता मीट्रिक्स का पालन सुनिश्चित करने के लिए आपदा रिकवरी ड्रिल किए जाएँगे।

3.3 डाटा प्रबंधन

1. जिस अवधि में निकाय द्वारा दूरस्थ स्थान से काम करने की अनुमति दी गई है, उस अवधि में गुम हो गए मोबाइल/ टैबलेट उपकरणों में डाटा से छेड़छाड़ और उनके दुरुपयोग को रोकने के लिए डाटा को अलग-अलग कन्टेनरों में रखने, बहु-कारकीय अधिप्रमाणन और दूर से ही डाटा को पोंछ देने का काम किया जाएगा।
2. प्रयोक्ताओं के लिए यह अनिवार्य होगा कि वे आवधिक रूप से महत्वपूर्ण डाटा का बैक-अप संगठन की प्रणालियों में सुरक्षित स्थानों पर रखें।
3. बैक-अप की आवधिक समीक्षा की जाएगी और कार्यविधियों को डाउनटाइम के प्रभाव को न्यूनतम करने के अनुकूल बनाया जाएगा।

3.4 मानव संसाधन सुरक्षा

1. दूरस्थ स्थान से कार्य करने के अंतर्गत परिचालन की अनुमति देने के पहले कर्मचारी/ परामर्शदाता/ तृतीय पक्ष विक्रेता की ऑनबोर्डिंग के समय अ-प्रकटन करार/ डाटा सुरक्षा और गोपनीयता वचनपत्र पर हस्ताक्षर किए जाएँगे।
2. बीवाईओडी के अंतर्गत प्रयोक्ता के स्वामित्व में स्थित मोबाइल फ़ोनों, टैबलेटों और अन्य उपकरणों से संगठन की डाटा अस्तियों और एप्लिकेशनों तक सुरक्षित पहुँच से सम्बंधित नियंत्रणों और कार्यविधियों को परिभाषित किया जाएगा।
3. प्रशासनिक प्रयोजनों से विशेषाधिकार-प्राप्त प्रयोक्ता पहचान अधिप्रमाणन की लेखापरीक्षा की जाएगी।
4. वाकथू और साक्षात्कार जैसी गतिविधियाँ अनुमोदित दूरस्थ पहुँच सॉफ्टवेयर का उपयोग करते हुए लेखापरीक्षित और लेखापरीक्षक संगठन की सुरक्षित और हार्डन की गई प्रणालियों पर की जाएगी।

नीति.:	2.23
नीति का नाम:	2.23 डीलिंग रूम परिचालन

1 प्रयोजन

डीलिंग रूम में किए जाने वाले परिचालनों के सन्दर्भ में संगठन की सूचना आस्तियों के उपयोग से सम्बंधित भूमिकाओं, दायित्वों और निबंधनों को परिभाषित करना।

यह नीति उन सभी कर्मचारियों, संविदाकर्ताओं और तृतीय पक्षकारों पर लागू होगी जो दूरस्थ कनेक्शनों का प्रयोग करते हुए संगठन की सूचना अस्तित्वों तक पहुँचेंगे। सूचना प्रौद्योगिकी का उपयोग करने वाली व्यवसाय इकाइयों या विभागों द्वारा इन सुरक्षा नीतियों का अनिवार्य रूप से पालन किया जाएगा।

3 **नीति**

इस नीति के उद्देश्य निम्नानुसार हैं:

1. डीलिंग सूचना की सुरक्षित रेकॉर्डिंग के लिए तंत्र निर्मित करना।
2. कोई सौदा किया जाने वाला हो तो प्राधिकार मैट्रिक्स सृजित करना।
3. किसी संविदा के निष्पादन के पूर्व अभिलेख प्रतिधारण और सहमति प्राप्त करने का तंत्र सृजित करना।

इस नीति के किसी भी उल्लंघन को घटना माना जाएगा और उसका उपचार घटना प्रबंधन नीति के अनुसार किया जाएगा।

3.1 **आईवीआर में डाटा संरक्षण**

1. घर से कार्य (डब्ल्यूएफ़एच) के दौरान ब्रोकरों को कॉल करने के लिए डीलरों को एक समर्पित और सुरक्षित रिकॉर्डिंग लाइन उपलब्ध कराई जाएगी।
2. बीमा कम्पनियाँ यह सुनिश्चित करेंगी कि रिकॉर्ड की गई लाइनें काम करती हैं और उनका रखरखाव अच्छा है।
3. मिड-ऑफिस मानक परिचालन कार्यविधि (एसओपी) में परिभाषित प्रक्रिया के अनुसार वॉयस रिकॉर्डिंग की जाँच करेगा।
4. कार्यालय स्थल से किए गए कॉल्स की रिकॉर्डिंग के लिए वॉयस लॉगर का इस्तेमाल किया जाएगा। लेनदेन के प्रमाण के रूप में कॉल रिकॉर्डिंग के बैक-अप/ भंडारण को सक्षम कर दिया जाएगा और उस तक कभी भी पहुँचा जा सकेगा।
5. एसओपी में डीलरों और ब्रोकरों के बीच संचारगत व्यवधान को हँडल करने की प्रक्रिया परिभाषित की जाएगी।
6. डीलरों और ब्रोकरों के बीच संचार को लॉग/ रिकॉर्ड किया जाएगा और मिड-ऑफिस द्वारा उसकी स्वतंत्र समीक्षा की जाएगी।
7. डीलर अपने **समस्त** लेनदेन केवल रिकॉर्डेड टेलीफोन लाइनों के माध्यम से ही करेंगे।
8. महत्वपूर्ण एप्लिकेशनों और सेवाओं के लिए द्वितीयक नेटवर्क कनेक्टिविटी तथा आईटी अवसंरचना की व्यवस्था की जाएगी और उनका परीक्षण किया जाएगा।

3.2 **अधिप्रमाणन**

1. डीलिंग रूम परिचालन कार्यविधियाँ विकसित की जाएँगी।
2. व्यवधान की स्थिति में निवेश कार्य के अधिकारी समुचित अनुमोदनों के साथ लेनदेन का प्रसंस्करण कैसे करें, इस संबंध में उनके मार्गदर्शन के लिए नीतियाँ/ प्रक्रियाएँ परिभाषित की जाएँगी।
3. एसओपी/ डीलिंग रूम नीति में यह निर्दिष्ट किया जाएगा कि डीलर केवल पैनल में सूचीबद्ध किए गए ब्रोकरों के माध्यम से और प्राधिकृत संचार माध्यमों से ही क्रय आदेश देंगे।
4. ब्रोकरों के साथ लेनदेन के प्रसंस्करण के लिए उपयुक्त पूर्वानुमोदन/ प्राधिकार प्राप्त किए जाएँगे।
5. डीलर यह सुनिश्चित करेंगे कि **केवल** संबंधित प्रति-पक्षकारों के पास प्राधिकृत कंपनी के रजिस्टर्ड ईमेल पतों के माध्यम से ही ईमेल साझा किए जाएँ।
6. डीलर यह सुनिश्चित करेंगे कि निवेश एप्लिकेशन के प्रयोक्ता पोर्टल, सहायता डेस्क या कार्यालय आकार आईटी सहयोग प्राप्त करें।
7. पर्यवेक्षकीय अनुप्रवर्तन प्रक्रिया की जाँचसूची स्थापित की जाएगी जिसमें लेनदेन मूल्य अनुप्रवर्तन, व्यापार अनुप्रवर्तन आदि शामिल होते हैं।
8. निवेश लेनदेन का निष्पादन डीलिंग रूम कार्यप्रवाह/ एसओपी के एक भाग के रूप में परिभाषित आवश्यक अनुमोदनों के साथ किया जाएगा।
9. डीलर सभी प्राधिकृत ब्लूमबर्ग टर्मिनलों/ ब्लूमबर्ग की एसएमएस/ चैट सुविधाओं को पूर्ण रूप से अक्षम करेंगे।

10. डीलर सभी लेनदेन रिकॉर्डिड टेलीफोन लाइनों या प्राधिकृत ब्लूमबर्ग टर्मिनलों/ ब्लूमबर्ग एनीवेयर आईडी/ एनडीएस टर्मिनलों/ टीआरआईएस टर्मिनलों/ ईमेल के माध्यम से निष्पादित करेंगे।

3.3 डाटा सुरक्षा

1. वॉयस रिकॉर्डिंग विश्लेषण और रेट स्कैन नियमित आधार पर किए जाएंगे ताकि व्यापारों और लेनदेन मूल्यों का पर्यवेक्षण किया जा सके जैसा कि डीलिंग रूम नीति में परिभाषित है।
2. सभी ब्लूमबर्ग टर्मिनलों के लिए बहु-कारकीय अधिप्रमाणन को सक्षम किया जाएगा।
3. दूरस्थ बैक-अप स्थलों पर एप्लिकेशनों, प्रक्रियाओं और संसाधनों की उपलब्धता के सत्यापन के लिए आपदा रिकवरी ड्रिल का आयोजन किया जाएगा। इन ड्रिलों में सामने आई समस्याओं की पहचान कर उन्हें दूर किया जाएगा और उनका दस्तावेजीकरण भी किया जाएगा।
4. प्रभावी व्यवसाय निरन्तरता के लिए निवेश कार्य के भीतर आकस्मिकता नीति और योजनाएँ, बैक-अप/ वैकल्पिक स्थान और संसाधन आवधिक रूप से चिह्नित, पुनरीक्षित और परीक्षित किए जाएंगे।

नीति सं.:

2.24

नीति का नाम:

2.24 सूचना प्रौद्योगिकी (मध्यस्थ दिशानिर्देश और डिजिटल मीडिया आचार संहिता) नियम, 2021

- | | | |
|----------|----------------|---|
| 1 | प्रयोजन | संगठन के डिजिटल प्लेटफॉर्मों के उपयोग से संबंधित भूमिकाओं, दायित्वों और निबंधनों को परिभाषित करना। |
| 2 | दायरा | यह नीति संगठन की सूचना आस्तियों और सुविधाओं तक पहुँच बनाने वाले सभी कर्मचारियों, संविदाकर्ताओं और तृतीय पक्षकारों पर लागू होगी। |
| 3 | नीति | <p>इस नीति के उद्देश्य निम्नानुसार हैं:</p> <ol style="list-style-type: none"> 1. डाटा की निजता सुनिश्चित करने के लिए प्रक्रियाएँ, संरचनाएँ और तंत्र निर्मित करना। 2. साइबरस्पेस की सुरक्षा पर एक समग्रतामूलक जागरूकता कार्यक्रम का संवर्धन और आरंभ करना। 3. पेटेंट, ट्रेडमार्क, कॉपीराइट अन्य मालिकाना अधिकारों के अतिक्रमण को प्रतिबंधित करना। 4. सोशल मीडिया का उपयोग करते समय यथोचित सावधानी बरतना। |
-
- | | | |
|------------|---------------|---|
| 3.1 | संरचना | <p>संगठन के नियमों और विनियमों, निजता नीति या प्रयोक्ता करार में संगठन के कंप्यूटर संसाधनों के प्रयोक्ताओं को सूचित किया जाएगा कि कोई ऐसी सूचना होस्ट, प्रदर्शित, आशोधित, प्रकाशित, भंडारित, अद्यतनीकृत या साझा न करें -</p> <p>(i) जो किसी अन्य व्यक्ति की हो और जिस पर प्रयोक्ता का कोई अधिकार न हो;</p> <p>(ii) जो निन्दापरक, अश्लील, नम्रता प्रदर्शित करने वाली, बाल-यौन-अपराधमूलक और दैहिक निजता सहित दूसरों की निजता पर आक्रमण करने वाली, लिंग के आधार पर अपमानजनक या उत्पीड़क, मानभंजक, नस्लीय या मानवजातीय दृष्टि से आपत्तिजनक, धनशोधन या द्यूत से सम्बद्ध या उसे प्रोत्साहित करने वाली, या अन्यथा प्रवर्तमान कानून से असंगत या विपरीत हो;</p> <p>(iii) जो बालकों के लिए नुकसानदेह हो;</p> <p>(iv) जो किसी पेटेंट, ट्रेडमार्क, कॉपीराइट या अन्य मालिकाना अधिकार का अतिक्रमण करती हो;</p> <p>(v) जो तत्समय प्रवर्तित किसी कानून का उल्लंघन करती हो;</p> <p>(vi) जो संदेश के मूल के संबंध में प्रेषिती को धोखा देती हो या गलत रास्ते पर डालती हो, या जानबूझकर और ऐसी ही मंशा के साथ कोई सूचना संप्रेषित करती हो जो स्पष्ट रूप</p> |
|------------|---------------|---|

से मिथ्या या पथभ्रष्ट करने वाली प्रकृति की हो लेकिन जिसे तथ्य के रूप में लिए जाने की संभावना हो;

(vii) जो किसी अन्य व्यक्ति का छद्मरूप प्रस्तुत करती हो;

(viii) जो भारत की एकता, अखंडता, प्रतिरक्षा, सुरक्षा या संप्रभुता के लिए, अन्य देशों के साथ मैत्री संबंध के लिए, या सार्वजनिक शांति व्यवस्था के लिए खतरा हो, या किसी अपराध के घटित होने को उत्तेजित करने का कारण बनती हो, या किसी अपराध की जाँच में बाधक हो, या किसी अन्य राष्ट्र के लिए अपमानजनक हो;

(ix) जिसमें ऐसा सॉफ्टवेयर वायरस या कोई अन्य कंप्यूटर कोड, फ़ाइल या प्रोग्राम हो जो किसी कंप्यूटर संसाधन की कार्यक्षमता को बाधित, विनष्ट या सीमित के लिए ही डिजाइन किया गया हो;

(x) जो स्पष्ट रूप से मिथ्या और असत्य हो और जो किसी भी रूप में इस मंशा से लिखित या प्रकाशित हो कि किसी व्यक्ति, निकाय या एजेंसी को, वित्तीय लाभ के लिए या किसी व्यक्ति को चोट पहुँचाने के लिए, बहकाया या उत्पीड़ित किया जाए;

2. संगठन आवधिक रूप से, लेकिन वर्ष में कम-से-कम एक बार अपने प्रयोक्ताओं को यह सूचित करेगा कि नियमों और विनियमों, निजता नीति या ऐसे मध्यस्थ के कंप्यूटर संसाधनों तक पहुँच या उनके उपयोग के लिए निष्पादित करार का अनुपालन न करने पर संगठन को यह अधिकार होगा कि वह तत्काल कंप्यूटर संसाधनों के प्रयोक्ता के पहुँच या उपयोग के अधिकार को समाप्त कर दे या अनुपालन न करने वाली सूचना को हटा दे या यथास्थिति दोनों कर दे।
3. जिस संगठन के कंप्यूटर संसाधन पर सूचना को भंडारित, होस्ट या प्रकाशित किया गया हो, वह सक्षम क्षेत्राधिकार के किसी न्यायालय के आदेश के रूप में या अधिनियम की धारा 79 की उप-धारा (3) के खंड (ख) के अंतर्गत सरकार या उसकी एजेंसी द्वारा अधिसूचित किए जाने पर वास्तविक जानकारी प्राप्त होने पर ऐसी किसी गैर-कानूनी सूचना को होस्ट, भंडारित या प्रकाशित नहीं करेगा जो भारत की संप्रभुता और अखंडता; अन्य देशों के साथ मैत्री संबंध; सार्वजनिक शांति व्यवस्था; शिष्टाचार और नैतिकता; न्यायालय की अवमानना; मानहानि से संबंधित तत्समय प्रवर्तमान किसी कानून में निषिद्ध हो, जो उक्त से संबंधित किसी अपराध को उकसाने वाली हो, या कोई ऐसी सूचना हो जो तत्समय प्रवर्तमान किसी कानून में निषिद्ध हो।
4. संगठन आवधिक रूप से, किन्तु कम-से-कम वर्ष में एक बार प्रयोक्ताओं को अपने नियमों और विनियमों, निजता नीति या प्रयोक्ता करार के बारे में और यथास्थिति, नियमों और विनियमों, निजता नीति या प्रयोक्ता करार में हुए परिवर्तनों के बारे में सूचित करेगा।
5. जो संगठन कंप्यूटर संसाधन पर रजिस्ट्रेशन के लिए प्रयोक्ता से जानकारी एकत्र करते हैं, वह उस जानकारी को, रजिस्ट्रेशन के निरस्त होने या उसे वापस लेने, जैसा भी मामला हो, के बाद एक सौ अस्सी दिनों की अवधि तक प्रतिधारित करेगा।
6. संगठन सूचना प्रौद्योगिकी (युक्तियुक्त कार्यपद्धति और कार्यविधि तथा संवेदनशील व्यक्तिगत सूचना) नियम, 2011 में निर्धारित युक्तियुक्त कार्यपद्धतियों और कार्यविधियों का अनुसरण करते हुए अपने कंप्यूटर संसाधनों और उनमें निहित सूचनाओं को सुरक्षित रखने के लिए सभी युक्तियुक्त उपाय करेगा।
7. संगठन यथासंभव शीघ्रता से, लेकिन किसी भी स्थिति में आदेश प्राप्त होने के बहतर घंटे के भीतर अपने नियंत्रण या कब्जे में स्थित सूचना उपलब्ध कराएगा, या कानूनी तौर पर अन्वेषण या संरक्षण या साइबर सुरक्षा गतिविधियों के लिए प्राधिकृत सरकारी एजेंसी को पहचान के सत्यापन, या तत्समय प्रवर्तमान किसी कानून के अंतर्गत किसी अपराध की रोकथाम, अन्वेषण, या अभियोजन, या साइबर सुरक्षा घटनाओं के प्रयोजन से सहयोग देगा।
8. संगठन आईटी (इन्डियन कंप्यूटर इमरजेंसी रेस्पॉन्स टीम एंड मैनर ऑफ़ परफॉर्मिंग फंक्शंस एंड ड्यूटीज़) रूल्स, 2013 में उल्लिखित नीतियों और कार्यविधियों के अनुसार भारतीय कंप्यूटर इमरजेंसी रेस्पॉन्स टीम को साइबर सुरक्षा घटनाओं की रिपोर्ट करेगा और उसके साथ घटना से जुड़ी जानकारी साझा करेगा।

9. संगठन जानबूझ कर कंप्यूटर संसाधन के तकनीकी कन्फिगरेशन को नियोजित या इंस्टाल या आशोधित नहीं करेगा या किसी ऐसे कृत्य में भाग नहीं लेगा जो कंप्यूटर संसाधन के परिचालन के सामान्य प्रवाह को उसके आशयित कार्यनिष्पादन से इतर दिशा में परिवर्तित करने की संभावना रखता है और इस प्रकार तत्समय प्रवर्तमान किसी कानून को प्रवंचित करता हो।
10. संगठन अपनी वेबसाइट पर या मोबाइल-आधारित एप्लिकेशन या दोनों पर, जैसी भी स्थिति हो, परिवाद अधिकारी का नाम और उसका संपर्क विवरण प्रकाशित करेगा, और साथ ही उस तंत्र के बारे में भी सूचित करेगा जिसका उपयोग करते हुए कोई प्रयोक्ता या कोई शिकार इस नियम के प्रावधानों के उल्लंघन के विरुद्ध या संगठन द्वारा उपलब्ध कराए गए कंप्यूटर संसाधन से संबंधित किसी विषय पर शिकायत कर सकता है, और परिवाद अधिकारी-
 - I. चौबीस घंटे के भीतर शिकायत की प्राप्ति-स्वीकृति देगा और प्राप्ति की तारीख से पंद्रह दिनों के भीतर शिकायत का निपटान करेगा;
 - II. सरकार, उचित सक्षम प्राधिकारी या सक्षम क्षेत्राधिकार वाले किसी न्यायालय से आदेश, नोटिस या निर्देश प्राप्त करेगा और उसकी प्राप्ति-स्वीकृति देगा।
11. संगठन इस उप-नियम के अंतर्गत किसी व्यक्ति या उसकी ओर से किसी अन्य व्यक्ति द्वारा, प्रथमदृष्ट्या किसी ऐसी सामग्री की प्रकृति की, जो ऐसे व्यक्ति के निजी क्षेत्र को प्रकाश में लाती हो, ऐसे व्यक्ति को पूर्ण या आंशिक रूप में नग्न दिखाती हो, या ऐसे व्यक्ति को किसी यौन कृत्य या आचरण में प्रदर्शित या चित्रित करती हो, या इलेक्ट्रॉनिक रूप में किसी व्यक्ति के छद्मरूप की प्रकृति की हो जिसमें ऐसे व्यक्ति की कृत्रिम तरीके से परिवर्तित छवियाँ शामिल हैं, विषय-वस्तु से संबंधित शिकायत की प्राप्ति से चौबीस घंटे के भीतर उसके द्वारा होस्ट की गई, भंडारित, प्रकाशित या संप्रेषित ऐसी विषय-वस्तु हटाने या उस तक पहुँच को अक्षम बनाने के लिए सभी युक्तियुक्त और व्यवहार में लाए जाने योग्य उपाय करेगा।

अनुबंध अ

खंड	व्याख्या
सूचना प्रौद्योगिकी (संशोधन) अधिनियम, 2008	सूचना प्रौद्योगिकी (संशोधन) अधिनियम, 2008 में "संवेदनशील व्यक्तिगत डाटा और सूचना (एसपीडीआई)" के संरक्षण के लिए "युक्तियुक्त सुरक्षा कार्यपद्धतियों और कार्यविधियों" को विनिर्दिष्ट किया गया है। प्रोसेस किए गए एसपीडीआई की पहचान करना और यह सुनिश्चित करना अनिवार्य है कि प्रक्रियाएँ आईटी (संशोधन) अधिनियम 2008 के अनुपालन में हैं।
कंपनी अधिनियम, 1956	इस अधिनियम के अंतर्गत विविध प्रकटनों, फाइलिंग और अभिलेख रखने संबंधी बाध्यताएँ पूरी करनी होती हैं। निरीक्षण, लेखापरीक्षा और समीक्षा करने के लिए उपलब्धता, सत्यापनीयता, प्रामाणिकता, अनुकूलता से संबंधित अनुपालन सुनिश्चित करना।
बीमा अधिनियम	बीमा के सभी रूपों का संचालन करना और बीमा व्यवसाय पर कड़ाई से नियंत्रण करना।
आईआरडीएआई विनियमावली	आचार के समान और स्पष्ट मानकों की स्थापना के मामले में और साधारण बीमा धारक को दक्ष सेवा देने के मामले में साधारण बीमा व्यवसाय करने वाले बीमाकर्ताओं को सहयोग, सलाह और सहायता देना।
संविदा अधिनियम, 1961	ऐसी परिस्थितियाँ निर्धारित करना जिसमें किसी संविदा के पक्षकारों द्वारा किए गए वायदों को पूरा करना उनके लिए कानूनी रूप से बाध्यकारी हो।
फेरा/ फेमा	विदेशी भुगतानों को विनियमित करना, विदेशी मुद्रा और प्रतिभूतियों के सौदों को विनियमित करना और राष्ट्र के लिए विदेशी मुद्रा का संचय करना।

स्टैम्प ड्यूटी अधिनियम	दस्तावेजों पर लगाया जाने वाला कर, जिसमें चेक, रसीदें, मिलिटरी कमीशन, विवाह के लाइसेंस और जमीन के लेनदेन के दस्तावेज शामिल हैं।
कार्मिक कानून	मजदूरी संदाय अधिनियम, ईएसआई अधिनियम, भविष्य निधि अधिनियम आदि कार्मिकों से संबंधित विविध अधिनियमों के अंतर्गत विविध प्रकटनों, फाइलिंग और अभिलेख रखने संबंधी बाध्यताएँ पूरी करनी होती हैं।
डाटा निजता कानून	किसी भी समय एक समग्रतामूलक भारतीय डाटा निजता कानून आने वाला है। कानून के अनुसार डाटा की निजता का संरक्षण अनिवार्य होगा।
आधार अधिनियम	आधार अधिनियम का लक्ष्य आधार विशिष्ट पहचान संख्या परियोजना को विधिक समर्थन देना और उसका संचालन करना है।

अनुबंध आ - आरएसीआई मैट्रिक्स

क्र. सं.	नीति	आस्ति का स्वामी	एचआर	आईटी	सूचना सुरक्षा	प्रशासन	वित्त	व्यवसाय	विधिक व अनुपालन	जोखिम प्रबंधन टीम	विक्रेता/ ओईएम	प्रयोक्ता	परिवर्तन अनुरोधक	कार्यपालक प्रबंधन
1.	डाटा वर्गीकरण	आर /आई		आई	ए/ आई			आई		सी				
2.	आस्ति प्रबंधन	आर	ए		सी	ए/ आई	आई			आई				
3.	पहुँच नियंत्रण			आर	ए/ सी			ए		आई				
4.	मानव संसाधन सुरक्षा		आर /ए	सी	सी			आई		सी				
5.	सूचना प्रणाली अधिग्रहण और विकास			आर/ ए	सी			आई						
6.	सूचना प्रणाली और अनुरक्षण			आर	ए						सी	आई		
7.	परिवर्तन नियंत्रण			ए				आई		सी			आर	
8.	घटना और समस्या प्रबंधन		आर		आर/ आई/ सी	आर		आर/ ए/ आई				आई		
9.	नेटवर्क सुरक्षा			आर/ ए/ आई	सी			ए						
10.	क्रियोग्राफ़िक नियंत्रण			आर/ आई	ए/सी							आई		
11.	व्यवसाय निरन्तरता प्रबंधन			आर	ए			आई		सी				
12.	तृतीय पक्ष सेवा प्रदाता				सी		आई	ए	सी	सी	आर			
13.	भौतिक और पर्यावरण सुरक्षा				ए	आर		सी				आई		
14.	अनुप्रवर्तन, लॉगिंग और आकलन			आर	ए	आर				सी				आई
15.	मोबाइल उपकरण सुरक्षा			आर	ए						सी	आई		
16.	अपना उपकरण लाओ (बीवाईओडी)			सी/ आई	सी			ए		आई		आर		
17.	विधिक और विनियामकीय अनुपालन				ए				आर	सी				आई
18.	पारिस्थितिक जागरूकता			आर	ए					सी				आई

क्र. सं.	नीति	अस्ति का स्वामी	एचआर	आईटी	सूचना सुरक्षा	प्रशासन	वित्त	व्यवसाय	विविध व अनुपालन	जोखिम प्रबंधन टीम	विक्रेता/ ओईएम	प्रयोक्ता	परिवर्तन अनुरोधक	कार्यपालक प्रबंधन
19.	क्लाउड सुरक्षा			आर/सी	ए				सी	सी				आई
20	साइबर अनुकूलता	आई		आर	ए/सी			आई		सी				आई

शब्दावली

संक्षेपाक्षर	पूर्ण विवरण
आईएससीपी	सूचना और साइबर सुरक्षा नीति
आईएस	सूचना सुरक्षा
आईएसआरएमसी	सूचना और साइबर सुरक्षा जोखिम प्रबंधन समिति
आरएमसी	जोखिम प्रबंधन समिति
आईटी अधिनियम	सूचना प्रौद्योगिकी अधिनियम
आरबीआई	भारतीय रिजर्व बैंक
आईटी	सूचना प्रौद्योगिकी
सीआरओ	मुख्य जोखिम अधिकारी
सीआईटीएसओ	मुख्य सूचना प्रौद्योगिकी सुरक्षा अधिकारी
सीआईएसओ	मुख्य सूचना सुरक्षा अधिकारी
सीएसओ	मुख्य सुरक्षा अधिकारी
सीएचआरओ	मुख्य मानव संसाधन अधिकारी
एचआर	मानव संसाधन
सीएफओ	मुख्य वित्त अधिकारी
सीओओ	मुख्य परिचालन अधिकारी
टीआरए	प्रौद्योगिकी जोखिम आकलन
बीसीपी	व्यवसाय निरन्तरता योजना
डीआर	आपदा रिकवरी
आरए	जोखिम आकलन
बीआईए	व्यवसाय प्रभाव विश्लेषण
एसओसी	सुरक्षा परिचालन केंद्र
एलएएम	तार्किक पहुँच प्रबंधन
डीएलपी	डाटा लीक निवारण
वीए	कमजोरी आकलन
पीटी	पैठ परीक्षण
वीएपीटी	कमजोरी आकलन और पैठ परीक्षण
एसएलए	सेवास्तरीय करार
जीआरसी	संचालन जोखिम और अनुपालन
ईआरएम	उद्यम जोखिम प्रबंधन
आईपीआर	बौद्धिक संपदा अधिकार
पीआईआई	व्यक्तिगत रूप से पहचान-योग्य सूचना
एसएमएस	संक्षिप्त संदेश सेवा
एमएसी	मीडिया पहुँच नियंत्रण
सीआई	कन्फिगरेशन मद

आईपी एड्रेस	इंटरनेट प्रोटोकॉल पता
एसपीआई	संवेदनशील व्यक्तिगत सूचना
ओपीआई	अन्य व्यक्तिगत सूचना
आईएमईआई	अंतरराष्ट्रीय मोबाइल केंद्र उपकरण पहचान
एमसी	वार्षिक रखरखाव संविदा
एनडीए	अ-प्रकटन करार
एमबीएसएस	न्यूनतम आधार-स्तरीय सुरक्षा मानक
ओएस	परिचालन प्रणाली
सीईआरटी	कंप्यूटर आपातकालीन प्रतिसाद टीम
आईएम	मूल उपकरण विनिर्माता
सीआर	परिवर्तन अनुरोध
एसएटी	प्रणाली स्वीकरण परीक्षण
एसआईटी	प्रणाली एकीकरण परीक्षण
यूएटी	प्रयोक्ता स्वीकरण परीक्षण
एमपीएलएस	मल्टीप्रोटोकॉल लेबल स्विचिंग
वीपीएन	वर्चुअल प्राइवेट नेटवर्क
वाईफ़ाई	वायरलेस फाइडेलिटी
आईडीएस	अनधिकृत प्रवेश अन्वेषण प्रणाली
आईपीएस	अनधिकृत प्रवेश निवारण प्रणाली
आईएसडीएन कार्ड	डिजिटल नेटवर्क के लिए एकीकृत सेवाएँ
सीडी	कंपैक्ट डिस्क
डीवीडी	डिजिटल वीडियो डिस्क या डिजिटल वर्सेटाइल डिस्क
ईआरटी	आपातकालीन प्रतिसाद टीम
बीएमएस	भवन/ निर्माण प्रबंधन प्रणाली
सीसीटीवी	क्लोज सर्किट टेलीविजन

शब्दावली

संक्षेपाक्षर	पूर्ण विवरण
बीमा कंपनी	संगठन लिमिटेड
आईएससीपी	सूचना और साइबर सुरक्षा नीति
आईएस	सूचना सुरक्षा
आईएसआरएमसी	सूचना और साइबर सुरक्षा जोखिम प्रबंधन समिति

**INSURANCE REGULATORY AND
DEVELOPMENT AUTHORITY OF INDIA**

**INFORMATION AND CYBER SECURITY
GUIDELINES**

**VER- 1.0
APRIL, 2023**

TABLE OF CONTENTS

1.	General Guidelines.....	6
1.1.	Purpose	6
1.2.	Scope.....	6
1.3.	Principles and Objectives	7
1.4.	Applicability.....	8
1.5.	Governance.....	8
1.6.	Roles and Responsibilities	10
1.7.	Acceptable Usage.....	19
1.8.	Risk Management	22
1.9.	Exceptions.....	25
1.10.	Compliance	27
2.0	Security Domain Policies	29
2.1.	Data Classification.....	29
2.2.	Asset Management.....	40
2.3.	Access control.....	47
2.4.	Human resource security.....	56
2.5.	Information Systems acquisition and development	61
2.6.	Information systems maintenance	69
2.7	Mobile security policy	78
2.8	Bring your own device (BYOD) policy.....	80
2.9	Change Control.....	85
2.10	Incident and problem management.....	89
2.11	Network Security	96
2.12	Cryptographic Controls.....	103

2.13 Business Continuity Management and Disaster Recovery.....	107
2.14 Third party service providers.....	114
2.15 Physical and environmental security	121
2.16 Monitoring, Logging and Assessment.....	133
2.17 Legal and Regulatory Compliance	139
2.18 Situational Awareness.....	142
2.19 Cloud Security Policy.....	143
2.20 Cyber Resilience	155
2.21 Email Security	159
2.22 Work from Remote Location	161
2.23 Dealing room operations	164
2.24 IT [Intermediary Guidelines and Digital Media Ethics Code] Rules, 2021	166
Annexure A.....	170
Annexure B- RACI Matrix.....	171
Glossary	174
Glossary	175

DISTRIBUTION LIST

NO.	NAME OF THE USER
1.	Chief Risk Officer (CRO) - Insurance Company
2.	Chief Information Systems Officer (CISO) - Organization
3.	Members of The Control Management Committee
4.	Information Technology (IT) Team
5.	Any other User / Entity authorized by CISO
6.	End Users

GENERAL GUIDELINES

1. General Guidelines

1.1. Purpose

Organization's Information and Cyber Security Policy (ICSP) identifies responsibilities and establishes the goals for consistent and appropriate protection of the organization's Critical data and Information Assets. Implementing this policy shall reduce risk of accidental or intentional disclosure, modification, destruction, delay, or misuse of Information Assets. This policy enables the Information Security Office to provide direction for implementing, maintaining and improving the security of Critical data and Information Assets

Implementing this policy shall also protect information and information infrastructure in cyberspace, build capabilities to prevent and respond to cyber threats, reduce vulnerabilities and minimize damage from cyber incidents through a combination of institutional structures, people, processes, technology. By implementing this policy, the organization will be able to consistently establish and maintain controls for ensuring confidentiality, integrity and availability of all information assets. Additionally, it also safeguards working environment for its employees and partners who facilitate and support the goals in services.

Vision: To provide a user-centric trusted and secure set of resources and environment to employees to conduct business, while ensuring protection of organization's information assets including customer data.

Mission: Ensuring the security of all Organization's information assets through implementation of up-to-date security mechanisms for prevention and monitoring of threats; governance of information security related activities and awareness of all employees.

1.2. Scope

Information Assets comprise data or information recorded in electronic, printed, written, facsimile or other systems as well as the 'system' itself, required for Organization's business purpose or operations. Information Assets include business data, system logs, servers, desktops, network equipment, network media, storage media, paper, people etc.

Organization's Information and Cyber Security Policy applies to Information Assets throughout their lifecycle, including creation, distribution, transmission, storage and disposal; such as:

- Information Assets in all forms: electronic, printed, written, facsimile, or spoken etc.
- Individuals or organization accessing the information assets like vendors, service providers, distributors, franchisee, customers, service providers, etc.

1.3. Principles and Objectives

This policy and supporting procedures shall be based on the following principles and objectives as set below:

1. **Information Protection** - Information Assets will be protected at a level commensurate with their value and the risk of loss to the organization. Protection should stress the confidentiality, integrity, and availability of Information Assets.
2. **User Authentication and Authorization** - All Users must be uniquely identifiable with access permissions specifically and individually authorized based on their business needs. User access methods should stress strong authentication, appropriate authorization and reliable audit-ability
3. **Accountability** - Users and Custodians of Organization's Information Assets are responsible for the appropriate use, protection and privacy of these assets. All Organization's system will generate and maintain appropriate audit trails to identify Users, IT assets and document security-related events and processes.
4. **Availability** - Information Assets must be available to support Organization's business objectives. Appropriate measures must be taken to ensure the timely recovery of all information and access by authorized individuals
5. **Integrity** - Information Assets must be adequately protected to ensure completeness and accuracy. Validation measures will allow detection of inappropriately modified, deleted, or corrupted information
6. **Trust** - Partners, vendors and service providers must demonstrate ability to meet or exceed Organization's security requirements and justify confidence in their ability to secure Organization's Information Assets. Trust becomes increasingly important when Organization's Information Assets are shared with business partners and service providers
7. **Continuity** - Organization must demonstrate the ability to maintain continuity of operations from business and technology perspectives. All information assets and related policies and procedures of Insurance Company, shall be evaluated from a continuity perspective to support Organization's business objectives. Partners, vendors and service providers must all demonstrate the ability to meet or exceed Organization's continuity objectives at all times
8. **Cyber Security Resilience**- To enable effective prevention, investigation and prosecution of cybercrime and enhancement of law enforcement capabilities through appropriate legislative intervention

9. Regulatory Compliance- To strengthen the Regulatory framework for ensuring a Secure Cyberspace ecosystem

1.4. Applicability

These guidelines are applicable to all Insurers including Foreign Re-Insurance Branches (FRBs) and Insurance Intermediaries regulated by the Insurance Regulatory and Development Authority of India (IRDAI).

Insurance Agents, Micro-Insurance Agents, Point of Sale Persons and Individual Surveyors will not fall under purview of these guidelines. However, it is responsibility of Insurers to ensure that these entities follow minimum security framework as defined under Insurers' Board approved policy in this regard.

These guidelines are applicable to all data created, received or maintained by regulated entities wherever these data records are and whatever form they are in, in the course of carrying out their designated duties and functions.

The Applicability of NIST Framework to All Regulated Entities is provided in Annexure – I.

The classification of Insurance Intermediaries based on gross insurance revenue is provided in Annexure- II.

The Auditors report comprising of Audit Summary, overall findings, non-compliances, risk rating and the Audit checklist is provided in Annexure – III.

The Eligibility Criteria for the Audit firm is provided in Annexure- IV.

The Text of Audit Certificate to be certified by the Audit Firm is provided in Annexure – V.

The Text of Audit Certificate to be certified by the Audit Firm for FRBs is provided in Annexure – VI.

1.5. Governance

I. Target Audience

The target audience for the Organization's policy is the employees of Organizations, contractors, and third-party service providers who have access to or use Organization's Information systems and Information in any form.

The implementation of this policy shall be the responsibility of various departments named in specific sections of this policy such as IT, Administration, Human Resources and the respective Business departments. However, irrespective of specific roles being assigned, all departments must be aware of and comply with this policy.

II. Governing Board

The Information and Cyber Security Policy (ICSP) of Organization shall be governed by the Information Security Risk Management Committee (ISRMC) comprising of the Chief Risk Officer (CRO), Chief Information Security Officer (CISO), Chief IT Security Officer (CITSO), Chief Security Officer (CSO), Chief Human Resource Officer (CHRO), Chief Technology Officer (CTO), Function heads of Operations, Finance, Legal, Compliance. The ISRMC shall be responsible for changes to the policy and approvals thereof. It shall also be responsible to ensure that the policy remains updated at all times. The ISRMC meeting shall require CISO and at least two members to participate with all members meeting at least twice in a year.

The implementation and enforcement of the ICSP shall be facilitated by the CISO and governed by the ISRMC.

III. Ownership and interpretation

The ICSP is owned by the CISO and shall be maintained by the Organization's "Information Security Team" (hereafter referred to as "IS Team") comprising of the CISO.

CRO will assume the responsibilities of the CISO in case decision needs to be made in the absence of the CISO.

IV. Review Frequency

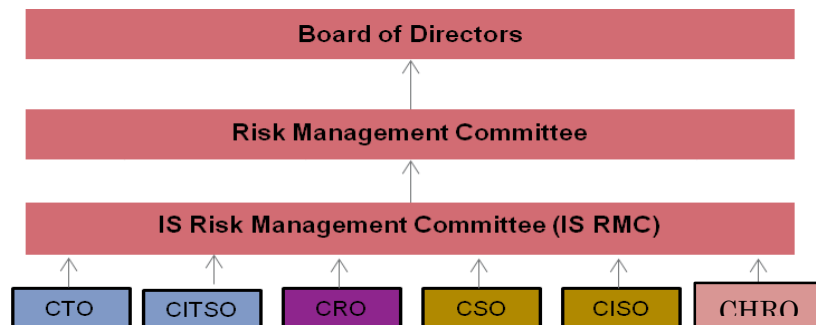
This policy shall be reviewed on an annual basis and if required updated by the CISO and approved by the ISRMC. The following aspects shall be considered for review of this policy:

- Changes in the regulatory or legal provisions relating to Information Security
- Changes or additions of industry standards
- New Business operations commenced by an organization in the past one year
- Changes to methods of operating business including changes in the HR policy
- New Channels of business / customer outreach expected to be used by business teams
- New Technologies introduced in the past one year
- Incidents reported within or outside organization relating to Information Security
- Any other considerations as mandated by senior management or board

The renewal of the policy and changes therein shall be notified to all employees of the organization through appropriate means such as emails, intranet notification, annual refresher IS training, educational posters and through the chain of command

1.6. Roles and Responsibilities

The following organization structure would be created and shall remain in existence for the governance, implementation and monitoring of information security.



1. Board of Directors

The Board shall

- Play a proactive role in ensuring an effective Information and Cyber Security governance and shall be ultimately responsible for the information security of the organization.
- Approve appointment of Chief Information Security Officer [CISO] who shall be responsible for driving and managing Information and Cyber security program.
- Receive quarterly inputs on matters related to Information Security
- Approve Information and Cyber Security Policy
- Approve and review the IT framework

2. Chief Risk Officer [CRO]

The CRO shall

- Be responsible for the overall risk management functions of the organization which shall include Information Security Risk Management in its purview.
- Obtain regular updates from the CISO regarding IS related issues / incidents, updates, new initiatives and corrective / preventive actions taken, remain involved in IS related initiatives such as IS awareness and training, IS assessments and escalation of critical IS incidents.
- The CRO, along with the CISO shall represent information security related event / issues and initiatives at the Control Management Committee.

3. Chief Information Security Officer [CISO]

A sufficiently senior level official with requisite technical background and expertise shall be designated as CISO. The CISO should have a reasonable minimum term. The CISO should report directly to the top executive overseeing the risk management function or in his absence to the CEO directly and shall assume overall responsibility for governance and monitoring of Information Security. The CISO shall be responsible for carrying out the following functions:

- Definition and periodic review of the ICSP after due approvals from the ISRMC
- Definition and periodic review of IS standards
- Conducting and coordinating both internal and external IS reviews and assessments
- Briefing to the ISRMC
- Be responsible for ensuring reporting of critical or high severity information and cyber security incidents to relevant regulators
- The CISO shall be responsible for setting IS Standards such as:
 - IS procedures and any supporting templates
 - Standards for Technology Risk Assessments (TRA) for any process / technology change or new technology sourcing
 - Methodology / checklist for performing the TRA and approval matrix based on the results of the TRA
 - BCP / DR standards including methodology for conducting Risk Assessment (RA) and Business Impact Analysis (BIA)
 - Project Governance and Project risk management standards including methodology for assessing project risks and reporting project risks to IS Team
 - Application security and Vendor risk assessment standards
 - IS related trainings standards including frequency for IS related trainings for employees / contractors and the IT / IS teams
 - Vendor classification standards based on information security requirements including vendor risk assessment standards and periodicity of risk assessment for each classification of vendors, appointment of a third party or an internal team to conduct risk assessment based on vendor criticality.
- Security testing baselines for conducting Vulnerability Assessment and Penetration Testing of IT systems (infrastructure and applications) including mandating the use of internal and external vendors based on asset classification
- Liaising with the business teams to define the roles within each application under their purview depending upon the business requirements
- CISO may engage external forensic experts who are certified as well as competent for the job as and when required.
- Shall review the training / skill set requirements for the SOC / LAM / DLP teams
- CISO shall be responsible for presenting / escalating the budgetary requirements for resources as well as IS reviews to the CRO

- CISO in consultation with senior management shall inform Chief Risk Officer about any security incidents and breaches, deemed necessary for notifying relevant regulatory authorities
- CISO shall review and approve requested exceptions to information security policies, standards and procedures
- The CISO shall be responsible to analyze the TRA results provided to him / her on a periodic basis.
- The CISO shall also review role definitions defined by the Logical Access Management (LAM) Team in consultation with Business teams to ensure that Segregation of Duties and other relevant Information Security aspects are considered. Any inconsistencies highlighted by the CISO will be resolved by the LAM team in consultation with the relevant Business Team.
- The CISO shall provide guidance for closure of all incidents highlighted to them by the IS Operations team and oversee the tracking and closure of incidents. IS team shall highlight any high level / critical / incidents remaining open beyond the defined SLAs to CRO and ISRMC.
- Forensics responsibilities

IS Team

- The IS team shall be responsible for and empowered to conduct IS reviews by defining the frequency and sample size for a detailed log review of various security solutions managed by IS Operations team
- Shall be responsible to define vendor classification standards based on information security requirements.
- Appointment of any third party IS reviewers for concurrent / periodic review and defining the scope of review for the third party
- Engaging with internal audit team to conduct periodic reviews based on a scope defined by the internal audit team
- Conducting risk assessment of security solutions (including perimeter devices) at any point in time managed by the IS Operations team at their discretion
- Results of reviews conducted by or through the IS team would be tabled at the ISRMC, as applicable based on the scope of the review.
- In addition to setting standards and carrying out IS reviews, the IS Team shall be directly involved in the incident management processes of the organization.

Security Operations Center (SOC)

- The CISO shall receive escalations from SOCs on critical / open IS incidents based on their monitoring activities. Also, the CISO shall provide guidance and oversee the tracking and closure of such incidents. The CISO shall be responsible to highlight the status of critical incidents to ISRMC.

- Standards for monitoring, analyzing and reporting of incidents by IT Security Operations team including the frequency of reporting based on severity of the incidents
- Incidents reported by SOC team need to be analyzed and necessary action to be taken.

Logical Access Management (LAM)

- Defining and maintaining an access approval matrix;
- liaising with the business teams to define Role Based access control matrix for applications with appropriate oversight and approval of the IS team;
- Reviewing the role definitions managed by the LAM Team to make sure that access matrix principles are maintained

Data Leakage Prevention (DLP)

- Data classification standards including data privacy requirements
- Liaison with business for understanding business processes and data classification

4. Chief Technology Officer

- CTO shall be responsible for the information security related technology implementation of the organization.
- CTO shall ensure information security considerations are integrated into planning and budgeting cycles, enterprise architectures, Information Systems design, development and acquisition/system development life cycles.
- CTO shall ensure Information Security processes are adhered and complied based on inputs from IS/Risk team
- CTO shall oversee mitigation of security vulnerabilities identified through internal/external audits or Risk Assessment in timely manner

5. Chief IT Security Officer (CITSO)

- The CITSO shall report to the CTO and will primarily be responsible for IT related Information Security Operations.
- The implementation and management of the IT Security Operations related tools shall be overseen by CITSO and s/he shall have a responsibility to ensure that any incidents identified through these tools are reported to the CISO.
- The CITSO shall oversee the Technology Risk Assessments (TRAs), and implementation of security related technology solutions such as the Security Operations Centre (SOC), Logical Access Management (LAM) and Data Leakage Prevention (DLP) and Governance Risk and

Compliance (GRC) tools and the overall management and maintenance of perimeter security devices.

- The CITSO shall ensure that IT security Operations are run as per the IS Policy and in line with guidelines and standards defined by the IS Team.

6. IT Security Operations Team

The IT Security Operations Team shall consist of sub-teams managing security tools such as Security Operations Centre (SOC), Logical Access Management (LAM), Data Leakage Prevention (DLP), Technology Risk Assessment (TRA) etc. which shall report to the CITSO for implementation and management of IT Security Operations and through the CISO for all incident reporting and management. The responsibilities of the various sub-teams of IT Security Operations shall be as follows:

1. SOC

The Security Operations Center shall be responsible for:

- real time monitoring, reporting security incidents to the CISO, assisting the CISO in doing analysis (i.e. forensics and investigation) and record keeping;
- First level analysis should be done by SOC team and false positives need to be identified. SOC team need to report incident to IS team in case they think the event identified as potential incident.
- tracking and closure of security incidents based on the incident monitoring and management standards set by the IS team;
- Providing CISO with required information directly from the source systems during IS reviews.
- Logs of application IT infrastructure shall be collected and analysed by 24X7 Security Operation Centre (SOC) team

2. LAM

The Logical Access Management (LAM) team shall be responsible for provisioning / de-provisioning and review of user access based on the logical access management standards set by the IS team. The LAM team shall be responsible for:

- receiving and acting upon requests for granting / modification and deactivation of user access on applications / domain, as per the defined access control matrix;

- conducting periodic user re-certification process by providing business teams with access rights register and obtaining approval from them for its validity;
- obtaining exception approval from the CISO prior to granting access rights which are not as per the defined access controls matrix;
- handling and Reporting of access control related incidents to CISO;
- Providing CISO with required information directly from the source systems, during IS reviews.

3. DLP

The Data Leakage Prevention team shall be responsible for implementation of data leakage prevention mechanisms based on the data classification and privacy standards set by the IS team

The DLP team shall be responsible for:

- facilitating implementation of information classification policy and procedures in the DLP tool;
- facilitating the training and awareness regarding existence and usage of DLP tool;
- Reporting data leakage incidents to CISO and tracking them to closure;
- Manage data leakage events and incident and report to risk management / investigation team for appropriate action
- Providing CISO with required information directly from the source systems, during IS reviews.

4. TRA

- The IT security Operations team shall be responsible for performing Technology Risk Assessment (TRA) prior to introduction of a new process or technology or implementing changes to an existing process and technology based on the TRA standard set by the IS team. Based upon the results of the TRA performed, the CISO shall be notified for approvals required.

7. Chief Security Officer (CSO) / Admin / Head Administration

The Chief Security Officer shall be responsible for:

- Admin with adequate support from IT / IS team shall be responsible for implementing and maintenance of physical and environmental security controls
- Assist the ISPMC and CRO in all aspects of Physical security.
- Ensure physical security processes are adhered to and report all incidents of importance to the CRO.
- Conduct training of the Security staff.
- Run sensitization programs, security week and allied training activities for sensitization of employees.

8. Human Resources

- The HR team shall play a crucial role in Information Security related initiatives of the organization
- HR shall make sure that all new employees are made aware of their InfoSec related responsibilities by including that as a part of the new joiner induction program. HR shall sensitize new joiners on the importance of complying with the information security related requirements and the repercussions of not doing the same.
- HR shall also make all new joiners sign a declaration / undertaking of having understood and accepting the information security related requirements of the organization and maintain these declarations as a part of the personnel files
- HR shall in conjunction with the IS team roll out periodic refresher trainings for all employees / critical vendor personnel and track the completion of these courses
- HR shall conduct / appoint an external agency to conduct background checks for new joiners to ensure that the people with the right background and a healthy perspective join the organization
- HR shall cooperate with the CISO to drive the organization towards building a pro-InfoSec environment and also assist them in obtaining relevant certifications related to the same.
- HR shall inform organization and employee role / location / joining and exit related information with IS and IT team for necessary changes in the role of information systems.
- HR shall document, incorporate and communicate a formal disciplinary process to take action against employees / critical vendor employees who have committed an information security breach.
- HR shall ensure that InfoSec responsibilities of employees and vendor employees at time of termination / change of employment are clearly defined and communicated.

9. Administrative / Admin Team

- The Admin team shall play a crucial role in Information Security related initiatives of the organization
- The Admin team shall ensure that relevant policies / procedures from an information security perspective are appropriately implemented and adhered to such as-
 - Physical security policy
 - Clean / clear desk policy
 - Visitor management policy
- Admin shall work closely with HR and IT to ensure that all physical access to the office premises for separated employees is revoked on or before the last working day

- Admin shall also ensure that appropriate devices such as shredders / filing cabinets secured with lock and key etc. are made available so as to ensure the confidentiality of critical data
- Admin shall carryout surprise visits on a periodic basis to ensure that no confidential documents / media is lying on any desks
- Admin shall cooperate with the CISO to drive the organization towards building a pro-InfoSec environment and also assist them in obtaining relevant certifications related to the same.

10. ERM

- ERM shall provide the CISO with periodic updates of the status of the current IS Risks and actions needed if any.
- ERM team shall work with IS team for investigations of information security incidents.
- ERM team shall share feedback on business frauds which can be input for Information and Cyber Security Policy / control revision.

11. Internal Audit

- The internal audit and information security functions shall work synergistically: the information security function shall design policies and procedures to protect the organization's information resources, and internal audit shall provide feedback concerning effectiveness of the implementation of these along with suggestions for improvement.
- The Internal audit function shall provide an independent review and analysis of the organization's information security initiatives and objective assurance to the board and executive management on how effectively the organization assesses and manages its risks, including the effectiveness the IT Security Operations and Information Security Risk management structure and roles.
- The Internal audit function shall keep the audit committee apprised of emerging risks and effective ways to address them and it shall identify weaknesses in policies and controls in place to mitigate these risks.
- The Internal audit function shall carry out independent assessments reviewing the following aspects of Information Security:
- Key information security risks faced by the organization and policies put in place to defend against them
- Effectiveness of the IT Security Operations and Information Security Risk management structure and roles
- Controls put in place by the management to comply with the policies
- Whether existing controls are being used by the functional managers
- Effectiveness of operation of the controls in operations

12. Legal & Compliance Team

- Compliance team shall ensure that the organization is conducting its business in compliance to IRDAI and other applicable regulations

- Compliance team shall communicate applicable regulatory/legal guidelines and requirements including any changes related to Information and Cyber Security with Board/Risk team/CISO/CRO
- Legal & Compliance team shall be responsible for engagement with Legal, Statutory, Local enforcement agencies and Government agencies for communicating cyber security status and incidents. Necessary details with regards to the incident will be provided by information security team and IT team

13. Functional Head/Business Owner

- Have primary ownership to comply with specific security policies, which will be applicable.
- Functional teams shall designate a suitable and qualified team member who will be responsible for reporting the incidents & effectiveness of security control to Information Security Function
- Function Head designated SPOC shall hold the primary responsibility for defining the value and classification of assets within their control by participating in the risk assessment process and undertaking business impact assessment.
- Be primarily responsible for risk, data security and access of their respective Third-party partners and vendors
- Be responsible for conducting security assessments and audits of their respective Third-party processes / sites
- Shall review and ascertain that the respective business processes are carried out in line with defined IS Policies and Procedures.

14. ISRMC

- The Committee shall refer to the RMC on any matters related to IS Risk Management that come to its attention that are relevant for the RMC
- The CISO shall represent the IS Governance related areas at the ISRMC while the CITSO shall represent the IT Security Operations related areas at the ISRMC
- The ISRMC shall obtain periodic inputs from the CISO and CITSO which shall include list of security incidents – root cause for the same as well as remediation actions taken.
- The ISRMC shall also receive information regarding new initiatives proposed and the evaluation of the same performed from an Information security perspective by the CISO/ CITSO
- The Committee shall provide relevant periodic assurances to the Control Management Committee [CMC]
- The Committee shall monitor and provide recommendations to the CMC on the organization's IS risk profile, appetite and ensure that an appropriate level of internal controls in line with its risk appetite and oversees the identification, management and reporting of IS risks to the appropriate Committees.

15. Control Management Committee

- The Committee shall refer to the Board any matters related to Risk Management that comes to its attention that is relevant for the Board.
- The Control Committee shall receive periodic inputs on matters related to IS Risk from the ISRMC.
- The Committee shall provide relevant periodic assurances to the Board
- At the discretion of the members of the Committee matters considered to be of major importance shall be referred to the Board for its attention.
- The Committee shall monitor and provide recommendations to the Board on the organization's risk profile, appetite and ensure that an appropriate level of internal controls in line with its risk appetite and oversees the identification, management and reporting of risks to the appropriate Committees.
- The Board shall have the responsibility to provide appropriate resources, budgetary approval and direction to the Control Management Committee from time to time.
- Commitment of Senior Management is ensured.

1.7. Acceptable Usage

I. Acceptable usage of Organization provided IT assets

Organization shall ensure that the employees, contractors and third parties follow the guidelines for the acceptable use of all the information assets provided by Organization. Assets shall be used for business purposes and may not be used for carrying out activities which are unlawful in nature including but not limited to hacking, cyber-theft, identity-theft, piracy and pornography.

II. Acceptable usage of personal devices for official purposes

In the event of a personal device belonging to an employee, contractor or third party being used to access Organization's information, the following shall apply:

- a. Access to Organization's information using personal devices shall be subject to adherence to Organization's IS policy
- b. Organization may access corporate information, applications, and data stored on personal devices while they are enrolled with the Company
- c. Organization has rights to monitor the device while it is connected to company's IT environment
- d. The employee is responsible for protection of all forms of Organization's data that is contained in the personal device

- e. In any of the following events, Organization has the authority to remotely wipe Company data on personal devices (and personal data if requested by employees)
 - Loss/ misplacement of device
 - Replacement or disposal of device
 - If employment is terminated by either party
- f. In case of violation of the company's policy, Organization may take any or all of the following steps, among others:
 - Disconnection of service and corporate access of the device to be revoked
 - Discontinuation of reimbursements related to personal device
 - Surrender of device and/or remote wiping of the device
 - Measures as decided by the Management

III. Acceptable usage of intellectual property

Appropriate controls shall be implemented to ensure compliance with legislative, regulatory and contractual requirements related to intellectual property rights and use of proprietary software products.

IV. Acceptable usage of company email facility

Company email facility must be used as per guidelines laid by organization. Disciplinary action may be taken for any willful violation to the guidelines.

V. Prevention of misuse of information processing facilities

Information processing facilities must be used as per policies detailed in the Information Security Policy, User Policies and guidelines. Disciplinary action may be taken for any willful violation to the policy.

VI. Acceptable usage of social media

a. Usage of social media by corporate employees for corporate purposes:

Those authorized to use social media in the workplace have a responsibility to use the tools in an appropriate manner as mentioned in "Acceptable usage of Social Media".

- Employees should not use any social media tool for business unless they have received appropriate training recommended or approved by corporate communication team

- Unless previously authorized in writing by an appropriate authority as per “Social Media Policy”, the employees are categorically restricted, during office hours & while on duty or while using the office network or the officially provisioned means of communications.
- Employees shall refrain from disseminating any unverified and confidential information related to Organization on any Blogs/Chat forums/Discussion forums/Messenger sites/Social networking sites.
- Any information received, accessed or obtained by an employee, either in his/her official mail/personal mail/Media Forums or in any other manner, if proposed to be disseminated or shared in any Media Forum, should be forwarded to the Organization’s Compliance team and corporate communication team for prior approval.
- Media Forum should not be used to report a service fault or to make a complaint
- All online participation must be attributable and transparent i.e. no anonymous posts or posts using a pseudonym

b. Guidelines for usage of social media by employees for personal purposes:

Organization’s reputation is closely linked to the behavior of its employees, and everything published reflects on how Organization is perceived. Social media should be used in a way that adds value to the Organization’s business. Considering the following points may help avoid any conflict between personal use of social media and an employee’s employment at Organization-

- When subscribing to or posting information to an online/internet networking service, Organization personnel must not use their Organization email address or other Organization details, unless use is required for genuine business and professional purposes.
- Any personal internet posting or communication [for example blogs, messages, posting or tweets] of any sort should be identified as your own individual and personal interactions. These personal interactions should not in any way be assigned to Organization or written in such a way that they could be interpreted as corporate Organization communications, unless explicitly approved by compliance team, corporate communication team or marketing Team.

Any personal internet posting or communication which implies that you work for Organization must include a simple and visible disclaimer such as “The postings on this service are my own personal views and not those of Organization and are not intended to be interpreted as such”.

- The personal image projected in social media affects an individual’s reputation and may affect the reputation of Organization. No form of critique or comment on Organization or its business should be made on personal websites or social networking platforms.
- When using social media for personal purposes, employees must not imply they are speaking for Organization. The use of the official e-mail address, official logos or other identification

should be avoided, and it should be made clear that what is said is not representative of the views and opinions of Organization.

- Employees should comply with other Organization policies when using social media. For example, staff should be careful not to breach Organization's Confidentiality and Information Security, or the Employee Code of Conduct. If in doubt, don't post it.
- Staff should be mindful of their privacy settings.
- Employees should be aware that if they break the law using social media (for example by posting something defamatory), they will be personally responsible.
- Employees should be aware that by revealing certain details they might be more vulnerable to identity theft.
- The CISO shall conduct training and awareness programs along with corporate communication team to educate the employees about information security related social media guidelines and existence and usage of enterprise DLP tools by the Organization.

1.8. Risk Management

IS Risk Management is necessary in order to maintain Organization's competitive advantage via positive image and reputation as a secure, discreet, and trustworthy organization. Risk must be managed to prevent financial loss, loss of customer confidence, and/or loss of operating licenses. Risk Management has the following objectives:

- a. To analyze and recommend particular configurations of technology corresponding with levels of information risk acceptable to the business.
- b. To identify and oversee the development of new security technology enabling new business processes without increasing unacceptable security risk.
- c. To monitor deployed information assets to ensure that they maintain the recommended security configurations consistent with the accepted level of risk.
- d. To educate Organization's employees, partners and management on the information security risk present in their areas of responsibility.
- e. To analyze and manage information security risks incurred by any given business area in such a way that it does not expose further Organization to unacceptable levels of risk

The Information Security risks associated with business processes and systems changes will be assessed for the impact and the cost of implementing various controls to mitigate them. Decisions with respect of acceptance of risks and implementation of controls will be made at an appropriate level in the organization as defined in the process below:

I. Risk Assessment Scenarios

Organization shall perform Risk Assessment at least annually and prior to the following scenarios/circumstances:

- Introducing major new technologies and initiatives.
- Using the services of external service providers (e.g. when outsourcing, off shoring or using cloud service providers)
- Permitting access to organization's critical systems (including those under development) by external individuals (e.g. consultants, contractors and employees of external parties)
- Granting access from external locations (e.g. employees' homes, external party premises or public places)

II. Target Environments

Risk Assessment shall be performed for the following environments:

- Business environments (e.g. administration offices, operating floors, call centres etc.)
- Business processes (e.g. processing high value transactions, handling customer records)
- Business applications (including those under development and being used in production)
- Information systems and networks that support business processes
- Specialist systems that are important to Organization (e.g. systems that support or enable critical infrastructure)
- Employees, staffs, third party vendors

Target environments shall be subject to risk assessment:

- At early stage of in their development
- Prior to significant changes
- When considering if they need to be outsourced to an external party

III. Technology Risk Assessment Process:

- a. The IS team shall define Technology risk assessment templates and/or checklists for assessment of various types of information assets and IS processes.
- b. The technology risk assessment template shall be designed such that the output of the assessment reflects the following:
 - i. Information security risks resulting from introduction of the new technology / process or change.

- ii. Controls for mitigation of the risks identified. This includes: Applying a reputable control framework, evaluating the strength and weaknesses of security controls, selecting security controls that will reduce the likelihood of serious information security incidents occurring and reduce their impact if they do occur, assessing the costs of implementing security controls, identifying specialised security controls required by particular business environments, identifying and obtaining sign-off for any residual risk
 - iii. Residual risks post identification of controls classified as per the nature of the residual risks viz. Financial, Operational, Regulatory or technology
- c. Based on the nature of residual risks appropriate approvals shall be taken from the risk owners as defined below:
- i. Financial – CFO
 - ii. Operational – COO and Business Process Owner
 - iii. Enterprise / Information Security – CISO/CRO
 - iv. Regulatory – CRO
 - v. Technology – CTO
- d. All information security risk assessment templates / checklists shall be reviewed by the IS team for the appropriateness of the assessments.
- e. The IS Team shall also review the signed off risks on a periodic basis to identify appropriate solutions being available in consultation with the risk owners

IV. Information Security Risk Management Process:

The information security risk management process shall be iterative in nature, involving the following steps:

- a. Analyzing the planned application of technology to the business requirements.
- b. Identifying the corresponding information security risks using applicable Technology Risk Assessment (TRA) standards.
- c. Together with the relevant business and support areas, analyzing the cost and effort of implementing security controls to target the appropriate risk level.
- d. Implementing security technologies, controls and processes to properly mitigate information security risk to the agreed upon level.
- e. Where necessary, initiating objective measurements and tests of the security controls as implemented.
- f. Monitoring security controls after deployment to ensure their stability and adequacy.

V. Risk Treatment

- a. Information risk treatment actions (together with residual risk) shall be detailed in Risk Treatment Plan, that is Communicated to the relevant business owner, Signed off by the relevant owner and at least one representative of executive management, compared with information risk assessments conducted in other areas of Insurance Company
- b. Results from information risk assessments conducted across Organization shall be reported to owners of business environments and executive management (or equivalent), used to help determine programmes of work in information security (e.g. developing an information security management system (ISMS), performing remedial actions and establishing new security initiatives), integrated with wider risk management activities (e.g. managing operational risk)

VI. Continuous Monitoring and review

- a. Organization shall perform risk assessment at least annually according to the risk assessment methodology report.
- b. Reviews shall be conducted at regular intervals to verify the adequacy of existing controls, residual risk and acceptable level of risks.
- c. Implemented controls shall be monitored and control effectiveness measured
- d. Any new risks arising due to significant changes made to the assets or business processes shall be identified.

1.9. Exceptions

I. Need for exceptions:

When situations that require an exception to the Information and Cyber Security Policies arise, the decision whether to accept the risk of not following the applicable Technology Risk Assessment standard must be made at senior management level. Prior to such a decision, the TRA shall be performed and appropriate approvals need to be obtained as mentioned in “Risk Management” section. Exceptions shall not be universal but shall be agreed on a case-by-case basis, upon official request made by the information owner. The purpose of such a process is to ensure adequate analysis and conscious acceptance of the risk represented by non-compliance with a policy.

II. Exception grant and risk assessment methodology

Risk Assessment Process - A risk assessment must be completed and approved to support any decision not to comply with any requirement of Organization’s Information Security Policy. All policy exceptions must be fully documented, approved by as mentioned in “Risk Management” section, and retained by the Information Security Team as long as the exception exists. The documentation must be completed and maintained by the IS Team and must address:

- i. The value and sensitivity of the information asset at risk, including the business consequences of its disclosure, destruction, modification, delay, or misuse.
- ii. The policy (or policies) to which the exception applies.
- iii. A description of the risk and exposure that results from non-compliance
- iv. Acceptance of the risks identified
- v. The business reason for non-compliance.
- vi. Any compensating controls that will reduce the risk to an acceptable level.
- vii. Any actions, that will lead to compliance, and a schedule to implement those actions

III. Executive Approval

Any changes to the Information Security environment of Insurance Company, which expose the organization towards inordinate risks which cannot be mitigated by putting in place appropriate controls, should be approved by IS team as defined in various sections of this policy. Executive approval signifies:

- i. Understanding of the risk factors involved in the decision not to comply with policy or standards.
- ii. Concurrence with the decision to accept resulting risk.
- iii. If corrective action is planned, the projected time frame for correction should be identified and actions should be tracked to closure.

IV. Emergency exceptions

Events such as Pandemic, War, Emergencies and Natural Disasters etc. unfold odd and exceptional situations necessitating workaround solutions so that services to customers and other stakeholders such as the Government, Revenue Authorities, Regulators and Public at large are not impacted. This necessitates careful deliberations on the new / revised emergency processes, personnel and technological changes that may pose challenges to the existing security policies of the Companies. A Crisis Management Committee needs to be formed during such events by drawing up resources from all key functions of the organization and deliberate on the revised processes, technology and personnel to operate and execute decisions. The Risk management function including the Information security function shall collate the risks in such situations and present the same for the approval of the Crisis Management Committee. The same shall be presented to the Risk Management Committee of the Board for ratification and further directions, if any.

The Crisis Management Committee under the overall directions and guidance of the Board Risk Management committee shall be vested with powers to devise changes to processes, systems, personnel and technology controls to ensure continuity of services. Information security compromises should be dealt with as exceptions and the enterprise shall devise risk mitigation controls to bring down the risks and shall eliminate such compromises once the business / affairs come into normalcy.

1.10.Compliance

An independent Assurance Audit shall be carried out by the Auditor every year. The annual Audit plan and the reports shall be presented to the Audit Committee / Board of Directors / Principal Officer, as applicable, of the organization.

The Insurance Intermediary shall submit the Annexure – III along with compliance thereto and the comments of the board to the Insurer/s annually.

The Insurer shall ensure that the Insurance Intermediaries engaged by them comply with these guidelines during the currency of their engagement. Insurer shall have a Board approved policy in this regard.

The maximum risk rating for entering into or continuing business with Insurance Intermediary as per Part-C under Section-I in Annexure III shall be as per the Board approved policy of the Insurer.

In case of Insurance Intermediaries which retain only insurer's data in physical form and do not hold any electronic database of the insurers' data or do not access insurer's systems, the Insurer shall obtain the necessary self-certifications in this regard on annual basis before entering into or continuing to carry on business with it.

The Foreign Reinsurance Branches (FRBs) where IT Systems are interfaced with overseas parent companies shall comply with Cyber Security Guidelines. The Auditor shall certify the same as per Annexure – VI and the same shall be submitted to IRDAI at the end of every financial year.

The Insurers shall submit their Audit Report (Annexure III) duly signed by the Auditor along with comments of the Board to IRDAI within 90 days from the end of financial year or within 30 days of completion of Audit, whichever is earlier.

Regulated Entities shall adhere to directions issued by Cert-In from time to time relating to information security practices, procedures, prevention, response and reporting of cyber incidents for Safe & Trusted Internet.

Regulated Entities shall ensure compliance to each of the Laws and Acts relevant to its operations wherever applicable. These will include but not limited to Information Technology (IT) Act, Insurance Regulatory and Development Authority of India (IRDAI) or any other laws or acts as applicable.

SECURITY DOMAIN POLICIES

2.0 Security Domain Policies

Policy No.:	2.1
Policy Name:	2.1. Data Classification

1	Purpose	To provide a framework for information owners to determine and classify the sensitivity levels for the information that Organization uses, processes, and stores. The unauthorized disclosure, modification, accidental or intentional damage, or loss of sensitive Organization information could constitute a violation of laws and/or regulations, may negatively affect customers, and impact Organization's image as well as competitiveness in the market. Hence data needs to be classified based on its criticality to enable implementation of security controls commensurate with its criticality.
2	Scope	This policy applies to information systems, including IT applications, IT infrastructure and physical information channels, and the information assets that Organization uses, process, and stores using those systems. It also applies to the business processes and procedures at Organization regarding data processing. This policy applies to all individuals handling data as well as technology systems where Organization's information assets are stored or processed. Technology Systems, communications and network connections include but are not limited to network devices such as routers and firewalls, storage devices such as USB drives, and disk drives, servers and mainframes, operating systems, databases and applications. All Business Units or Departments shall comply with this information security policy.

3	Policy	The Information Owner shall only classify information assets within their purview using one of the following four classification levels: • Public • Internal • Restricted • Confidential Classification levels shall be defined based on the information asset's relative risk, value, and sensitivity. Further, any personally identifiable information (PII), shall be identified and classified as PII in addition to being classified as per above data classification policy. Organization shall employ reasonable and appropriate safeguards to protect the integrity, confidentiality, and security of all PII. Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.
3.1	Data Ownership	All information assets within Organization shall have a designated owner. Managers responsible for business processes that utilize information assets are considered the owners of that information. Information owners may delegate ownership of some or all of their information systems to other persons; however, owners shall remain accountable and oversee that delegated owners fulfill their responsibilities.
3.3	Data Classification Process	Information owners shall ensure that the information assets for which they are responsible are assigned a classification rating (Confidential, Restricted, Internal, and Public) that properly indicates its business value and criticality to the organization. Owners shall review the assigned classification label at least every two years to address changed business value and risks, or as required by laws and regulations that impact Organization.
3.3.1	Confidential:	Personal or company information that is classified as highly sensitive by senior management or laws and regulations that impact Organization. Normally this concerns personally identifiable information (PII) about customers, business partners such as agents, distributors, suppliers etc., or employees, or information that is of vital or strategic importance to

		the success of the organization (e.g., financial statements) and can provide it with a significant competitive edge (e.g., new product designs). Unauthorized disclosure of confidential information could substantially impact Insurance Company, its brand and/or reputation, and its customers.
3.3.2	Restricted:	Will constitute of Information assets, which, if disclosed, would result in significant adverse impact, embarrassment, financial penalties, loss of stakeholder confidence and compliance penalties.
3.3.3	Internal Use Only:	Will constitute of Information that is not intended for use by the public. This can include information posted on company intranet for employee use, such as phone directories or the Employee Handbook. Unauthorized disclosure of Internal Use Only information could moderately impact Insurance Company, its brand and/or reputation, and its customers.
3.3.4	Public:	Will constitute of Information that is approved for release to the public by Organization's senior management. Examples include information that is available from public or government sources, advertising, or information posted on official; website. Disclosure of Public information will likely have little or no impact on Insurance Company, its brand and/or reputation, and its customers.
3.3.5	Technical Standards	Technical standards should be based on the life cycle process defined below in this document. Section 3.5 'Lifecycle Processes' outlines the specific controls to protect the confidentiality and integrity of Organization's information assets.
3.4	Lifecycle Processes	
3.4.1	Confidential Information	

3.4.1.1	Labeling Requirements	A label of “CONFIDENTIAL” shall, at a minimum, be legible on every page of the physical or electronic document 1. Any device or object (including portable devices) that contains CONFIDENTIAL information shall be labelled as “CONFIDENTIAL”. 2. Systems that contain CONFIDENTIAL information shall be identified and mentioned in “Asset Library”. 3. Storage repositories that maintain CONFIDENTIAL information shall be known and controls implemented to effectively protect the information 4. Emails that contain CONFIDENTIAL information shall, at a minimum, contain “CONFIDENTIAL” in the subject line, header, or footer.
3.4.1.2	Storage Requirements	1. Storage environments shall require user authentication that can uniquely identify each user or administrator. 2. Storage environments shall be periodically reviewed and audited to help ensure that information is sufficiently secured. 3. Storage environments shall be monitored to help ensure that access control systems are functioning properly. 4. CONFIDENTIAL information shall be stored on company owned or controlled systems or on equivalently secured systems with which Organization has an approved partnership.
3.4.1.3	Transfer Requirements	1. When CONFIDENTIAL information is transmitted outside of the Organization network, including the Internet, it shall be sent in encrypted form or via a secured channel. Encryption keys shall be managed and protected by authorized resources as defined in the Cryptographic Security policy. 2. CONFIDENTIAL information entrusted to Organization by a third party shall be encrypted when sent over external network systems. 3. CONFIDENTIAL designations shall appear on the cover sheet of transmitted documents (i.e., facsimile transmissions). 4. Phone calls, SMS or electronic communications that discuss CONFIDENTIAL information shall be preceded by a statement about the sensitivity of the information involved. 5. When distributing CONFIDENTIAL information via physical format (paper, disks, etc.), enclose the information in an envelope labelled “CONFIDENTIAL” even when delivered by hand.

		6. Intellectual Property shall not be transmitted without prior authorization from the Information Owner.
3.4.1.4	Tracking Requirements	1. Tracking techniques, systems capabilities, or manual efforts shall indicate who has accessed the CONFIDENTIAL information, from where is it access (e.g. MAC ID, IP address) and when it was accessed. 2. This access shall be audited by the Information Owner and deficiencies corrected in a timely manner
3.4.1.5	Disposal Requirements	CONFIDENTIAL information shall be completely and securely destroyed at the end of its retention period OR at the release of a litigation or audit hold, if such hold extends beyond the retention period. Sensitive data or systems not regularly accessed by the Organization shall be removed from the network. These systems shall only be used as stand-alone systems (disconnected from the network) by the business unit needing to occasionally use the system or completely virtualized and powered off until needed
3.4.2	Restricted Information	
3.4.2.1	Labeling Requirements	1. A label of "RESTRICTED" shall, at a minimum, be legible on every page of the physical or electronic document. Any device or object that contains RESTRICTED information shall be labelled as "RESTRICTED". 2. Systems, applications, and databases that contain RESTRICTED information shall provide a legible label of "RESTRICTED" on appropriate output or displays. 3. Storage repositories that maintain RESTRICTED information shall be known to the Information Owner and controls implemented to effectively protect the information (i.e., physical locks, door locks). 4. Communications that contain RESTRICTED information, at a minimum, shall contain a statement that helps ensure the recipient understands the sensitivity of RESTRICTED information and the handling procedures for RESTRICTED information. 5. Emails that contain RESTRICTED information shall, at a minimum, contain "RESTRICTED" in the subject line, header, or footer

3.4.2.2	Storage Requirements	1. Portable media, hard copy documents, diskettes, or tapes containing RESTRICTED information shall be secured at all times [either through lock and key or electronic authorization processes] and shall be kept under direct control by authorized personnel. 2. Storage environments shall require user authentication wherever possible that can uniquely identify each user or administrator, even for portable electronic devices. 3. RESTRICTED information shall be stored on company owned or controlled systems, or on equivalently secured systems with which Organization has an approved partnership. 4. Storage environments shall be periodically reviewed and audited to help ensure they are sufficiently secured. 5. Storage environments shall be monitored to help ensure that access control systems are functioning properly. 6. Hard copy RESTRICTED information shall be stored in a secured container, such as a locked cabinet or locked desk when not in use or when not under direct visual supervision.
3.4.2.3	Transfer Requirements	1. When RESTRICTED information is transmitted electronically outside of the Organization's network, including the Internet, it shall be sent over a secured channel or in encrypted form. 2. Encryption keys shall be managed and protected by authorized resources as defined in the Cryptographic Security policy. 3. RESTRICTED information transmitted electronically shall be accompanied by a caution to the recipient as to how the RESTRICTED information shall be handled and protected. 4. When transmitting RESTRICTED information via physical format [paper, disks, etc.], enclose the RESTRICTED information within double envelopes. The internal envelope shall be labelled "RESTRICTED". The external envelope shall have no special markings and shall be delivered by hand or as appropriate. 5. RESTRICTED designations shall appear on the cover sheet of transmitted documents (ex. facsimile transmissions). 6. RESTRICTED information shall not be discussed with anyone, including associates, contractors, or other third parties who do not have a "need-to-know" and have not been expressly authorized by the Information Owner 7. RESTRICTED information shall not be verbally communicated within insecure facilities. Individuals shall ensure that there are no unauthorized persons within earshot before conversation begins.

3.4.2.4	Tracking Requirements	1. Tracking techniques, systems capabilities, or manual efforts shall indicate who has accessed the RESTRICTED information, from where is it accessed (e.g. MAC ID, IP address) and when it was accessed. 2. This access shall be audited by the Information Owner and deficiencies corrected in a timely manner
3.4.2.5	Disposal Requirements	1. RESTRICTED information and all related copies and back-ups shall be completely and securely destroyed at the end of its retention period OR at the release of a litigation or audit hold, if such hold extends beyond the retention period
3.4.3	Internal use only Information	
3.4.3.1	Labeling Requirements	1. INTERNAL USE ONLY information does not have any specific labelling requirements. However, if information or an information source is not labelled, at a minimum it shall be treated as INTERNAL USE ONLY. 2. A label of "INTERNAL USE ONLY" shall be legible on the first page of the file, document, or on the front of the device.
3.4.3.2	Storage Requirements	1. The storage environment shall require user authentication that can uniquely identify each user who accesses the information. 2. Appropriate controls shall be put in place to ensure that only authorized users get access to "INTERNAL USE ONLY" information.
3.4.3.3	Transfer Requirements	Generally, INTERNAL USE ONLY information is only transferred to and from those parties requiring use of its content. It is the responsibility of the Information Owner to define and communicate procedures and controls governing the transfer of INTERNAL USE ONLY information
3.4.3.4	Disposal Requirements	INTERNAL USE ONLY information shall be disposed of at the end of its retention period OR at the release of a related litigation or audit hold, if such hold extends beyond the retention period
3.4.4	Public Information	

3.4.4.1	Labeling Requirements	No labels required
3.4.4.2	Storage Requirements	No specific storage requirements
3.4.4.3	Transfer Requirements	No specific transfer requirements
3.4.4.4	Disposal Requirements	PUBLIC information shall be disposed off at the end of its retention period OR at the release of a related litigation or audit hold
3.5	Data Privacy	Personally Identifiable Information (PII) is information about a person that contains some unique identifier, including but not limited to name, email, contact details or unique identification number, from which the identity of the person can be determined. PII may be further bifurcated into – 1. Sensitive Personal Information 2. Other Personal Information Any incident of data privacy violation must be reported immediately to the concerned authority so that the exposure can be contained. Refer to Incident and Problem Management Policy.
3.5.1	Identification of Personally Identifiable Information (PII)	Sensitive personal data or information of a person shall include information collected, received, stored, transmitted or processed by body corporate or intermediary or any person, consisting of: 1. Password 2. User details as provided at the time of registration or thereafter 3. Information related to financial information such as Bank account / credit card / debit card / other payment instrument details of the users 4. Physiological and mental health condition 5. Medical records and history 6. Biometric information 7. Information received by body corporate for processing, stored or 8. Processed under lawful contract or otherwise 9. Call data records 10. Any PII which is not considered SPI as per the above categorization will be treated as OPI.

3.5.2	Collection of PII	Organization or any person on its behalf shall obtain consent of the provider of the information regarding purpose, means and modes of uses before collection of such information Organization or any person on its behalf shall not collect sensitive personal information unless – The information is collected for a lawful purpose connected with a function or activity of the agency The collection of the information is necessary for that purpose While collecting information directly from the individual concerned, Organization or any person on its behalf shall take such steps as are, in the circumstances, reasonable to ensure that the individual concerned is aware of – The fact that the information is being collected; and 1. The purpose for which the information is being collected; and 2. The intended recipients of the information 3. Organization or any person on its behalf holding sensitive personal information shall not keep that information for longer than is required for the purposes for which the information may lawfully be used. 4. The information collected shall be used for the purpose for which it has been collected 5. Organization or any person on its behalf shall permit the users to review the information they had provided and modify the same, wherever necessary.
3.5.3	Storage, Transfer & Destruction of PII	1. SPI will be accorded the same level of security as confidential information irrespective of the classification of such information. Please refer to Lifecycle Processes for Confidential Information for storage, transfer and destruction of SPI. 2. OPI will be accorded the same level of security as Restricted Information irrespective of the classification of such information.

		Please refer to Lifecycle Processes for Restricted Information for storage, transfer and destruction of OPI			
3.5.4	Processing of PII	1. The entire customers' / employees' data shall be classified as per "Asset Management Procedure" 2. Personal data of customers/employees shall be securely stored, in manual or electronic form, and in accordance with the IT Act. 3. Personal data of customers/employees shall not be stored for longer than is required unless otherwise mandated by any law. 4. Personal data of customers/employees shall be used for the purpose for which it has been collected. 5. Access to the sensitive data shall be provided strictly on the basis of need to know. 6. Backup of sensitive data on a removable storage media shall be kept in safe and secure environment.			
3.5.5	Disclosure of PII	1. If any of the Organization's customer/employee requests to view his/her own sensitive information collected, it shall be made available. 2. Organization shall not disclose an individual's personal data outside Organization except: • When Organization expresses consent to do so, or in circumstances as agreed between Organization and the individual • When necessary, to our regulatory bodies and auditors • When Organization is required or permitted to do so by law • To any persons, including insurers and lenders who supply benefits or services to the individual • To fraud prevention agencies where required 3. Data protection tools like data loss prevention, digital rights management etc. shall be implemented to prevent unauthorized disclosure of sensitive data.			
3.6	RACI Matrix	Responsible	Accountable	Consulted	Informed

		Asset Owner	IS, IT Security Operation Team	Risk Management Team	IT, Business Department, IS, Asset Owner
--	--	-------------	---	----------------------------	--

Policy No.:	2.2
Policy Name:	2.2. Asset Management

1	Purpose	To define practices for identification and cataloguing of Information Systems involved in usage, maintenance and disposal of information assets in order to protect information used by Organization and achieve efficient and effective service delivery.
2	Scope	This policy applies to all information systems being used by Organization or involved in creation, storage, transmission or destruction of Organization's information, which includes but is not limited to the following: ▪ Software assets ▪ Physical assets ▪ People ▪ Services such as computing and communication services, air condition, power and document storage ▪ Information – Digital asset & non-digital assets Any individual handling Organization's information assets in any form shall comply with this policy.
3	Policy	Organization's information assets including hardware, software and physical assets used in the Company's physical environment and virtual premises such as hosting sites, service provider premises etc. shall be managed in accordance with the information asset protection asset i.e. from acquisition to its disposal. Any breach of this policy shall be considered as an incident and shall be treated objectives established in this policy throughout the lifecycle of the as per the incident management policy.
3.1	Information asset profiling	Information assets shall be classified using either quantitative or qualitative methodology chosen by the management, considering the below mentioned aspects: 1. Data Information systems/equipment containing the data including paper format on which data might be stored in printed form.

		2. Data will be classified as per data classification policy. 3. Other information assets will be classified to reflect business needs, legal-regulatory-certificatory requirements and confidentiality-integrity-availability concerns, based on the following criteria: • classifications of data contained in the asset • criticality of the asset to business operations • value of the asset exclusive of the value of data contained • form of data (hard copy/electronic) contained • usage of the asset (asset used to store, process, transmit data) • volume of data contained / transmitted through the asset
3.2	Lifecycle Processes	
3.2.1	Asset Acquisition / Purchase	All assets shall follow a formal acquisition / purchase procedure. Assets shall be procured only after appropriate approvals are obtained from authorized personnel. All assets that have been procured shall be classified as per the asset profiling guidelines mentioned in this policy.
3.2.2	Asset Tracking	
3.2.2.1	Asset Labeling	Every asset shall be marked for identification and inventory control. An appropriate set of procedures for asset labelling and handling shall be developed and implemented in accordance with the classification scheme(s). This shall include: • responsibility of the asset owner to assure/confirm classification and labelling, and subsequent handling consistent with that label; • classifications that cover all information processing facilities and information in all forms and media; • procedures for establishing ownership and chain of custody; and • procedures for logging and reporting security incidents associated with the asset. Determination of the frequency for periodic review to ensure that classifications appropriately reflect business needs legal-regulatory-certificatory requirements and balance confidentiality-integrity-availability concerns against other organizational goals.

3.2.2.2	Asset Inventory and Documentation	1. A comprehensive inventory of all information assets shall be maintained. 2. Each asset shall be clearly identified individually and (if appropriate) collectively in combination with other assets to form an identifiable information asset. 3. The asset inventory shall include all information necessary in order to recover from a disaster. 4. The information asset inventory shall contain the following information as a minimum: • Identification • Description • Location • Owner • Custodian • Business value of the asset • Asset classification • Validity of the classification • Asset Support information • Hardware assets – Annual Maintenance Contract details • Software assets – Software License details • Physical Assets (documents) – Archival /storage arrangement 5. Software inventory tools shall be utilised throughout the organization to automate the documentation of all software on business systems. 6. Software applications or operating systems currently supported by the software's vendor shall be added to the organization's authorized software inventory and unsupported software shall be tagged as unsupported in the inventory system. 7. The asset inventory shall be accurate, up to date, consistent and aligned with other inventories 8. For every asset Organization shall define service components or other items [Configuration Items] which are required to deliver or support one or more IT services. 9. Configuration Items [CI] shall be grouped, classified and identified in a way such that they are manageable and traceable throughout the service life cycle. 10. Methods shall be included to track CIs from ordering to depreciation. Change of data shall be controlled to ensure that it can only be altered by authorized individual.
---------	-----------------------------------	---

		11. Status maintenance of CIs shall be consistently recorded and kept updated. 12. Organization's Configuration Items shall be listed in a configuration management database which shall contain all relevant details of each Configuration Items and details of the important relationships between Configuration Items
3.2.2.3	Authorization Inventory	1. The asset inventory shall contain details of authorization mechanism for all information assets 2. For Organization-owned assets, the authorization record shall consist of the owner and the features of the asset used to authorize the asset to the Organization's network such as the network interface media access control (MAC) address or the IMEI number. 3. For non Organization-owned assets, the authorization record shall consist of parameters used for two factor authentication such as username and password, token ID or biometric record.
3.2.3	Asset Use	1. All Organization assets shall be used as per the 'Acceptable Usage' of assets covered in Section 1.7 of General Guidelines. 2. Organization's assets shall be used by authorized personnel for valid business purposes only and shall be stored in a physically secure manner at all times including when not in use. 3. Assets shall be allocated to users based on job functions / business requirements. A record of such allocations shall be maintained by the IT / Admin teams. 4. Assets shall be transferred among Organization's users however a formal procedure for the same shall be followed. A register of such transfers shall be maintained and updated by the IT / Admin teams. 5. Each user of end user assets and owners of enterprise assets shall be responsible for the assets owned / used by them and any activity done using these assets. 6. Assets assigned to consultant/temporary staff/third party vendor shall be linked to them as primary user and an Organization's employee as secondary user. However, it is the responsibility of the secondary user to monitor the activities of primary user. 7. Insurance companies shall use client certificates to authenticate hardware assets connecting to the organization's trusted network.

		8. Port level access control shall be utilised, following 802.1x standards, to control the devices that can authenticate to the network 9. The authentication system shall be tied into the hardware asset inventory data to ensure only authorized devices can connect to the network. 10. To minimize the risk of theft, destruction and/or misuse all asset owners / users / custodians shall exercise good judgement and safeguard the assets that are being used by them / are in their custody and the information contained therein. 11. Assets shall not be taken out of Organization's premises without appropriate authorizations. In scenarios where the asset may need to be taken out of Organization's premises for repairs / replacement appropriate authorizations shall be taken after ensuring that the data contained in the assets has been securely erased. 12. Employees who are possessing company provided mobile devices such as laptops, tablets, smart phones will have authorization to carry asset outside office premises. 13. IT assets shall be hardened as per the hardening guidelines laid down in the 'Information Systems Acquisition and Development' section of this policy – 3.1.1.1' 14. All assets requiring periodic maintenance shall be covered under appropriate Annual Maintenance Contracts (AMCs) which shall be renewed and kept current at all times. 15. Physical assets sent out of Organization's premises for maintenance purposes shall be checked against the gate pass. 16. IT team shall ensure that internal hard drives are either removed and kept securely or data is backed up and securely wiped from the hard drive before physical assets/hardware is sent out of Organization's premises to asset maintenance vendors
3.2.4	Return of Assets	1. All employees and external party users shall return all organization assets in their possession upon termination of their employment, contract or agreement. 2. The termination process shall be formalised to include the return of all previously issued physical and electronic assets owned by or entrusted to the organization. 3. Provide clearance for relieving once assets are received and access deactivated
3.2.5	Transfer of physical media	

3.2.6	Asset Disposal	1. To prevent the unauthorized disclosure/dissemination of critical business information assets while in transit, the respective custodian shall ensure by verifying that: ○ Reliable transport and Controls are in place to ensure integrity and confidentiality of physical media. ○ A list of authorized couriers should be agreed with management; ○ Packaging is sufficient to protect the contents from physical damage. ○ All employees and third-party staff carrying media are required to ensure its protection from theft, weather conditions and damage during transit. ○ Logs shall be kept, for identifying the content of the media, the protection applied as well as recording the times of transfer to the transit custodians and receipt at the destination. 2. Information asset owners shall be responsible for ensuring the implementation of the specified security controls on all the assets owned by them.
3.2.7	Management of removable media	1. All assets and media containing critical and sensitive information shall be disposed in a secure manner by incineration or shredding, or erasure of data for use by another application within the organization; 2. Assets shall be disposed if: ○ The asset has reached end of life ○ The asset does not suit the environment 3. Critical infrastructure elements which need to be disposed off shall be approved with valid justification by the CTO and CFO. 4. Finance department shall also be informed as and when an asset is disposed off. 5. Any information that resides in the asset shall be removed from the equipment before disposal using secure erase / disposal techniques that have been approved by the Management. 6. A register for all disposed / scrapped assets shall be maintained. 7. A process shall be put in place for media formatting 8. Damaged devices containing sensitive data shall require a risk assessment to determine whether the items should be physically destroyed rather than sent for repair or discarded

		1. Asset custodians shall ensure media is physically protected to prevent interruptions to business activities and damage to critical business information assets. 2. Media shall be stored in a safe and secure environment. 3. A listing of all official media in use shall be maintained and reviewed on a regular basis. 4. Physical media containing information related to Organization shall be strictly monitored during active use and securely disposed as per the Asset Management Procedure when no longer needed. 5. Authorization shall be required for media removed from the organization and a record of such removals shall be kept in order to maintain an audit trail; 6. In case of confidential data, cryptographic techniques shall be used to protect data on removable media;					
3.3	Loss / Theft of asset	1. In case of loss / theft of personal device with access to Organization's Information assets, the employee shall report the same immediately. 2. The IT function shall be responsible to immediately revoke all access to Organization's Information Assets through the device and shall attempt to remotely wipe off Organization data from the device. 3. In case the device loss / theft is reported after more than 4 hours, or if the remote wipe is unsuccessful, the same shall be recorded as an incident and incident management procedures as described in this policy shall be followed.					
3.4	RACI Matrix		Responsible	Accountable	Consult ed	Informed	
			Asset Owner	IT, Admin, All respective functions	CISO	All respective functions, Risk, Finance, Admin	

- 1 PURPOSE**

To provide a set of practices for access to Organization's information and information systems (Operating Systems, Applications, Databases, Network Equipment and others).
Access controls pertaining to Organization's information and information systems shall be based on principles of 'User Authorization' and 'Accountability' and support the security concepts of 'least privilege access' 'need-to-know', 'segregation of duties' and 'individual accountability'.
- 2 SCOPE**

This policy shall apply to all environments requiring logical access to information assets such as systems where information is stored or processed, communication and network connections through which information is transmitted or applications through which information is accessed.
Communications and network connections include but are not limited to network devices such as routers and firewalls; systems shall include but are not limited to servers and mainframes, storage tapes or drives, databases and applications.
Both physical and logical access controls shall be implemented and maintained to protect information assets against unauthorised access.
This policy applies to all users such as employees, contractors, service providers / visitors accessing Organization's information assets.
- 3 POLICY**

All user accesses to Organization's information assets shall be specifically and individually authorized based on business need. Security controls shall ensure that only authorized individuals can access Organization's information assets.
Procedures shall be administered to ensure that appropriate level of access control is applied to protect the information in each system from unauthorized access, modification, disclosure or destruction to ensure that the information remains accurate and confidential and is available when required.
Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.

**3.1 User
Identification
and Accounts**

1. A User-ID or account shall be assigned to each individual to authorize a defined level of access to information assets and shall be protected by authenticating the user to the User-ID upon requesting access.
2. Each User-ID or account on Organization's information systems shall uniquely identify only one user or process. Every individual user shall be accountable for all actions associated with his /her User-ID. User-IDs shall not be utilized by anyone other than the individuals to whom they have been issued. Users shall not allow others to perform any activity with their User-IDs. Similarly, users shall be forbidden from performing any activity with User-IDs belonging to other users.
3. Where it is not possible to implement individual User-IDs and passwords within the system due to technology limitations or process design, alternative solutions for restricting and auditing access privileges shall be evaluated for feasibility and shall be implemented.

**3.2 Group/
Generic User-
IDs**

1. The use of generic and group User-IDs shall be avoided wherever possible. Wherever there is no alternative available / it is absolutely essential a group account shall be used; however, it shall follow the Exception grant and risk assessment methodology requiring the prior authorization of the appropriate authorities and clear accountability to one individual (Group ID owner) shall be established. The use of Group-ID shall be short term in nature having an expiration date.
2. Generic User-IDs shall not be created unless necessitated by technology limitations or under business exigencies. An owner shall be identified for every generic User-ID created and the owner shall be held accountable for all actions associated with the generic User-ID. Where it is required for a generic User-ID to be shared between multiple individuals, alternative solutions for assigning and ascertaining accountability at all times shall be evaluated for feasibility and shall be implemented.

3.3 User-ID Creation and Maintenance

1. User-IDs shall be non-transferrable, and individuals shall not have multiple accounts within the same computing environment.
2. Access to Organization's environment such as the network shall be granted only upon intimation received from HR. All users shall be granted access to the information systems and services through a formal user registration process that shall include the approval of access rights from authorized personnel before granting access.
3. All users shall follow a formal de-registration process for revocation of access to all information systems and services which shall include automated or timely intimation and revocation of access rights. Intimation for revocation of access rights shall come from HR. A confirmation of the access revocation shall be sent to HR as a part of the exit clearance process.
4. Levels of access granted to all Users shall enforce segregation of duties and adhere to the "need to know" principle. Where segregation of duties cannot be enforced by logical access controls, other non-IT-related controls shall be implemented.
5. An initial password shall be provided to the users securely during the user creation process and the system shall be configured to force the users to change the initial password immediately after the first logon.
6. Appropriate procedures shall be put in place for storing and management of administrative passwords for critical information systems. All user passwords shall be encrypted while in transmission and storage.
7. The password requirements for all user accounts shall follow the password standards as defined in the Password Standard. Any exceptions to the password standard shall follow the Exception grant and risk assessment methodology requiring the prior authorization of the appropriate authorities and counter measures shall be implemented to mitigate the resulting risk.
8. Users shall be required to change their passwords at the first log-on and change their passwords once in 45 days

9. A record of previously used passwords shall be maintained to prevent re-use. Further, password files shall be stored separately from application system data.
10. The respective Department Heads for all individual users or user groups shall review the access rights or privileges assigned to the corresponding system periodically. Any exceptions noted shall be addressed at the earliest.
11. The department heads shall maintain a central record of access rights granted to a user ID to access information systems and services
12. In case of transfer of an employee from one function to another, access rights of the user shall be revoked for previous functional role and access need to be provided for new functional role.

3.4 User Authorization

1. Users shall be authorized on Organization's information systems at the following levels:
 - Physical access
 - Network
 - Infrastructure
 - Endpoints
 - Applications
 - Cloud (where applicable)
2. User authorization mechanisms at each level shall be independent of authorization at a previous or subsequent level – for example, applications shall perform assessment of user authorization request independent of the operating system authorization process.
3. Users shall be authenticated and authorised by a domain policy server.
4. Management and employees shall be responsible for controlling access to all facilities and ensuring that people entering or accessing those facilities are properly identified and authorized.
5. All network and network services in Organization shall be identified and documented. Logical access to all network equipment shall be restricted to authorized users only. Appropriate security controls shall be used to restrict access to the IT systems of Organization.

6. Access to all endpoints and applications shall be permitted only after authorization of the user credentials by the host operating system or the application itself.
7. Applications shall support integration with the enterprise identity management system
8. If the authorization request comes from a Organization-owned asset (device/network), single factor authentication will suffice. In case the authorization request comes from a non-Organization asset (device/network) two-factor authentication will be mandatory.
9. Applications hosted on the Cloud shall accept a user authorization record validated by a Organization-owned authorization service or require two factor authorization as stated in [6] above.
10. The access requirements shall be identified by Business Owner.
11. Respective Business Heads shall ensure that level of access granted is appropriate to Organization's purpose.
12. Users shall be required to re-authenticate themselves after a specific period of inactivity.
13. Organization shall establish process for granting access based on emergency.
14. Organization shall establish methods to prevent unauthorized access by other groups into individual files and department-shared files.

3.5 Privileged User Accounts

- 1 Privileged user accounts are accounts with administrative access to applications, operating systems, network devices, databases components and other information systems enabling a user to modify system configurations including metadata, user records and other functions and override security and controls within the system to which administrative access applies. Privileged user account includes (but not limited to), system default administration account, 'Administrator' or 'root' or equivalent operating system accounts or any User-IDs capable of creating, modifying or deleting other User-IDs or their privileges or access logs.
- 2 Privileges associated with each type of information system such as Operating System, Business Applications,

Databases, and Network elements shall be identified and documented.

- 3 Privileged user accounts shall be limited to individuals with specific business justification for this level of access. Such access shall only be granted upon authorization from appropriate personnel.
- 4 Privileges shall be allocated to individuals on a 'need-to-have' basis in strict adherence to the authorization process for privilege access.
- 5 Individuals granted this level of access shall have appropriate skill levels to perform security or administration duties for the system to which privileged access is granted.
- 6 Use of the Privileged User ID shall be minimized to the extent possible. Activity from all logons with Privileged User ID shall be securely logged. Refer to 2.16 Monitoring, Logging and Assessment for further details on logging and monitoring of privileged User-IDs.
7. Where feasible separate mechanisms shall be provided for logging-on to systems for privileged activities and routine activities. Where such mechanisms are available individuals with privilege user IDs shall logout out of privilege environment for performing routine day to day task which do not require such privileged access.
8. Audit logging of system activities performed by privileged users, shall be maintained. Audit or management review of the logs shall be conducted
9. Sharing of privileged IDs and their access codes shall be prohibited
10. Vendors and contractors shall be disallowed from gaining privileged access to systems without close supervision and monitoring. Business justification for the same shall be documented.
11. An authorization process and a record of all privileges allocated shall be maintained
12. Rules governing the installation of software by users shall be established and implemented.

3.6 Secure log-on

1. The Log-on process shall not provide any information that would aid an unauthorized user to successfully Log-on.
2. Log-on data shall only be validated after it has all been entered.

3. The log-on process shall not reveal which part of the log-on data is valid or invalid.
4. Account lockout shall be enforced by the log-on process after the retry limit is reached.
5. Log on process shall display a general notice warning that the computer should only be accessed by authorized user
6. Log of unsuccessful and successful attempts shall be maintained.
7. The log-on process shall not transmit passwords in clear text over a network
8. The log-on process shall terminate inactive sessions after a defined period of inactivity, especially in high risk locations such as public or external areas outside the organization's security management or on mobile devices;

3.6.1 Review of access rights

1. User access rights shall be reviewed at regular intervals and after any changes, such as promotion, demotion or termination of employment.
2. User access rights shall be reviewed and re-allocated when moving from one role to another within the same organization
3. Authorizations for privileged access rights shall be reviewed at more frequent intervals and changes to privileged accounts shall be logged for periodic review.
4. Privilege allocations shall be checked at regular intervals to ensure that unauthorized privileges have not been obtained

3.7 Remote access

1. Remote access to employees/ vendors/ contractors shall be provided on need to know and need to do basis only.
2. Remote access request for third party vendor/consultant shall be raised by the Organizationemployee responsible for the vendor /consultant engagement along with proper business justification. The request needs to be approved by sponsoring functional manager, Head – IT and Group CISO. If access is provided from non-Organizationendpoints an exception shall be taken in this regards Head-IT and Group CISO.
3. Use of remote access software shall be restricted
4. No vendor user or general Organizationuser shall be assigned administrative privileges on the SSL VPN

appliance. If third parties require privileged ID, monitoring of their activities shall be performed and the access shall be revoked immediately on their termination of association with Insurance Company

5. An expiration of not more than 15 days or lesser shall be placed on all third party user-IDs unless appropriate approval is given. Expiration of IDs will occur in the authenticating database. After the expiration, third parties who wish to continue working for Organization should obtain approval in order to regain the User-ID.
6. Remote access solutions must support strong, end-to-end encryption as mentioned in Organization's policy for Cryptographic Controls.
7. A remote log-on procedure shall be designed with consideration of encryption of information during its transmission. A secure network channel shall be established for remote access.
8. Organization security solutions and controls shall not be disabled or circumvented.

3.8 Compliance and audit

1. Periodic audits shall be carried out to ensure compliance with this policy.
2. Remote Access System Owners shall maintain evidence of all requests for granting remote access.
3. All notifications for initiating the revoking of remote access.
4. All evidence for granting, revoking, or changing remote access privileges shall be maintained in a repository such as Change Management System
5. SOP's and System Design documents for the remote access systems.
6. All changes to the remote access system configuration.
7. Patch upgrades performed on remote access systems.
8. On a monthly basis, the system owner's shall ensure that the accounts active within the Remote access solutions are accurate. All discrepancies shall be resolved quickly.

3.9 Access to program source code

1. Access to program source code and associated items (such as designs, specifications, verification plans and validation plans) shall be strictly controlled, in order to prevent the introduction of unauthorized functionality and to avoid unintentional changes as well as to maintain the confidentiality of valuable intellectual property.
2. Program source libraries shall not be held in operational systems. The program source code and the program source libraries shall be managed according to established procedures.
3. IT Support personnel shall not have unrestricted access to program source libraries.
4. The updating of program source libraries and associated items and the issuing of program sources to programmers shall only be performed after appropriate authorization has been received.
5. An audit log shall be maintained of all accesses to program source libraries and program listings shall be held in a secure environment.

3.10 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT	IS, Business Departments	IS	Risk Management

Policy No.:	2.4	
Policy Name:	2.4.	Human resource security

1 PURPOSE

- To define Organization's desired practices concerning human resource security to ensure that:
- The Human Resources function meets its requirements within the context of the corporate framework for the security of its information and equipment.
- Employees, contractors and third party users are aware of information security threats and concerns, understand their responsibilities and liabilities with regard to information security, and are equipped to support organizational security policy in the course of their normal work.
- Employees, contractors and third-party user's entry, exit or change employment in an orderly manner.

2 SCOPE

Human resources are an integral element of Organization's security framework. The security of information resources requires the integration of knowledgeable and aware personnel, with appropriate technology enabled controls. Weak human resource security processes can result in security breaches, financial frauds, company reputation and regulatory non-compliance in not meeting customer confidentiality.

This policy shall apply to all employees, contractors and third-party users using Organization's Information Technology resources.

Human resource (HR) security is a part of personnel management and applies to pre-employment, duration of employment and termination of employment.

3 POLICY

Organization shall ensure that all users joining, moving within or leaving the Organization's network (employees, contractors and third-party service providers), shall be aware of their roles and responsibilities with regard to information security. The HR practices of Organization shall support its information security objectives at all times i.e. prior to employment, at the time of on-boarding, during the employment tenure and at the time of exit.

The policy aims to reduce risks arising from theft, fraud, or misuse of information and network assets/ facilities.

Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.

3.1 Prior to Employment

All job roles and responsibilities shall be documented and shall include general as well as specific responsibilities for implementing or maintaining information security. All employees, contractors and third-party service providers of Organization shall understand their job roles and responsibilities.

Background checks shall be performed on all personnel (including temporary and contract personnel) performing sensitive or critical job roles before they are selected for the position or transferred to the position. Further, personnel who are third party service providers shall have undergone a background check by their respective organizations and the assurance of the same shall be provided to Organization. Information provided by the personnel, at the time of recruiting shall be subjected to verification procedures.

3.2 On-Boarding and During Employment

1. All employees, contractors and third party users of Organization's information assets shall sign their employment contract which shall include confidentiality agreements / non-disclosure agreements (NDA) and shall be an indication of their acceptance to the terms and conditions of the contract which shall include protection of Organization's confidential and sensitive data. These terms and conditions shall state the organization's as well as the employee's responsibilities towards information security.
2. In some cases, an authorized representative shall sign an agreement on behalf of all contractors and third-party users which shall appropriately address security considerations. If the information security provisions laid out in the agreement differ from the standard employee / contractor/ third party contracts, the same shall need to be taken through the Exception grant and risk assessment methodology.
3. Processes and procedures shall be defined for reporting the violations of confidentiality agreements.

4. All supervisory roles shall be responsible for the performance and conduct of the staff personnel reporting to them including the information security requirements laid down as a part of the employment contracts and the organization's policies. Managers or Supervisors shall be required to monitor the performance and conduct of each of their staff, as well as to assess their impact on the security of the information assets to which the staff has access.
5. All employees and contractors shall be properly briefed on their information security roles and responsibilities prior to being granted access to confidential information or information systems. Users shall understand and comply with the Information Security Management Policy and the other allied policies, as relevant to their roles and responsibilities.
6. Insurance companies shall ensure that employees and wherever relevant third-party users receive appropriate awareness/skills training and regular updates in organizational policies and procedures, as relevant to their job function.
7. All end users shall report suspected information security incidents and vulnerabilities as soon as possible to their controllers, designated official/system official. Unless required by law to disclose security incidents, employees shall not report incidents to external entities without authority.
8. Job rotation shall be enforced for employees in computer-related positions of trust.
9. Reliance/dependency on single person on key areas shall be avoided. Succession plans shall be developed for technical personnel deployed at critical locations. Adequate second line shall be ensured for development/maintenance activities
10. The punitive actions to be taken for violation of the information security requirements in the employment contract or the information security policy shall be as per the 'punitive actions' laid down as a part of the compliance section of the general information security policy.
11. Information Security Training and Awareness Programs shall be provided to all the employees, contractors and

relevant third-party users of Organization systems in order to create consciousness about the information security policies and processes.

12. Organization Shall Periodically Participate in national/ sectoral/ organizational Cyber Security Exercises.
13. The information security function shall develop an Information Security Training and Awareness Programs which shall define, in addition to the content of the program, a timeline and periodicity for attendance to the program.
14. Mechanisms shall be established to track the attendance of each staff for the training and awareness program. Any employee who fails to attend the training and awareness session as per defined periodicity shall be given a stipulated time to attend the same, failing which it will be considered non-compliance to this policy. History and versions of training content shall be maintained.
15. Additional training shall be provided for leaders to understand their roles in the event of a security incident
16. Employees shall be periodically informed of their rights and duties in the organization in the form of Do's and Don'ts. This should also advise employees to refrain from using company assets for personal use.
17. Organization shall consider the higher level of monitoring the activities (particularly e-mail, administration and critical systems) of those users who are in the process of leaving the company.
18. All employees shall be provided with an anonymous reporting channel to report violations of information security policies or procedures

3.3 Exit procedures

1. Organization shall ensure that termination of employees, contractors and third-party users is performed in an orderly manner, and responsibilities are defined and communicated within Organization to ensure the same.
2. The assets of Organization available with terminated individuals shall be taken back and all their access rights (physical and logical) shall be removed immediately.
3. Organization shall take into consideration the changes of responsibility or transfer of employees, contractors and third-party users and assess the appropriateness of their access when such occasions arise.
4. All employees, contractors and third-party users shall return all of the organization's assets in their possession, upon termination of their employment, contract or agreement.
5. Mechanisms shall be put in place to ensure that access granted to any employee or contractor is revoked prior to the termination of their employment / contract period with Organization. Controls shall be put in place to ensure that any failures to remove access for terminated employees or contractors is detected in a timely manner and acted upon immediately.
6. Any IS violations during the tenure of the employee shall be reviewed before the final sign off.

3.4 RACI Matrix

Responsible	Accountable	Consulted	Informed
HR	HR	IS, IT, Risk	Business Department

Policy No.:	2.5
Policy Name:	2.5. Information Systems acquisition and development

1	PURPOSE	To define the desired practises and ensure that information security is an integral part of information systems across their entire lifecycle.
2	SCOPE	This policy shall apply to all information systems where Organization's information assets are stored or processed and all communication and network connections through which Organization's information assets are transmitted. All Business Units or Departments using information technology shall comply with this information security policy. This shall apply to developing new software, customizing software and developing software that can be accessed or presented on a website.
3	POLICY	Organization's Information systems shall provide for maintenance of confidentiality, integrity and availability, of data contained within them, by design. This shall be achieved by processes, throughout the System Development Life Cycle beginning at acquisition through development and maintenance. Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.
3.1	Technology Standards	
3.1.1	Infrastructure standards	
3.1.1.1	Security requirement analysis and specifications	1. Security requirements in an information system shall be identified and documented during the requirements gathering and analysis phase of acquisition, development or change of information systems. They shall be justified and agreed with business process owners. 2. Systems security requirements shall reflect the business value of the information assets involved

and the potential damage that may be caused due to absence of sufficient security.

3. Minimum Baseline Security Standards (MBSS) shall be developed and maintained and all information systems shall be configured as per such standards.
4. The MBSS shall include protection of data contained in the information system as well as system software used for operation of the information system itself.
5. All information systems (server, routers, and firewalls) shall undergo hardening as per the MBSS before being commissioned for usage in the production environment.
6. The clocks of all relevant Information Systems within Organization's security domain shall be synchronized with an agreed accurate time source.

3.1.2 Application security standards

3.1.2.1 Security requirement analysis and specifications

1. Applications shall be assessed for their security posture through security reviews before being commissioned for usage in the production environment.
2. Application security reviews shall be conducted based on application security standards defined by the information security team which shall cover the aspects to be addressed in such reviews and provide guidance on requirements for conducting such reviews by external agencies.

3.1.2.2 Application development

1. A formal software development security framework shall be developed by the IS team.
2. The software development security framework shall define a software risk assessment process to ensure that software security requirements are assessed considering associated business and technology risks.
3. A library of secure design patterns shall be built. Their consistent usage across projects shall be

enforced, and it shall be ensure that new pattern requirements drive pattern development. Security reviews shall be focused on reviewing patterns and enforcement of their use.

4. Modifications to software packages shall be discouraged. Vendor-supplied software packages shall be used with minimum modification unless they impact security posture of the software package vis-à-vis the information security policy.
5. All modifications (including configuration changes, changes to reports, etc.) to software packages shall be made in accordance with formal Program Change Control Procedures.
6. If the software is developed by a third – party, the following shall be done –
 - Organization shall ensure that software development processes followed by the third-party are in compliance to Organization's Information Systems Acquisition, Development policy.
 - As far as possible and practicable, vendor-supplied software packages shall be used without modification
 - Organization shall have appropriate licensing agreements and contractual requirements for quality and functionality of the application exist.
 - Appropriate documentation in form of product manuals or data sheets should be obtained from the third party to ensure that the security requirements of the Information Security policy are adhered to.
 - The consent of the vendor shall be obtained where a software package needs to be modified and the impact if the organization becomes responsible for the future maintenance of the software as a result of changes shall be assessed
 - The ownership of the source code shall be transferred to Organization or appropriate escrow arrangement shall be set up to ensure

availability of source code to Organization during the usage of the provided software.

- Appropriate testing shall be carried out prior to the software being put in commissioned for usage in the production environment, to ensure that the requested functionality including security requirements are met by the software.
- A formal methodology shall be defined and documented including security requirements for application development and maintenance process when done in-house.
- contractual right to audit development processes and controls shall be ensured. Acceptance testing shall be carried out for the quality and accuracy of the deliverables
- Security thresholds shall be used to establish minimum acceptable levels of security and privacy quality;

3.1.2.3 Correct Processing in Applications

1. Data input to applications shall be validated to ensure that this data is correct and appropriate.
2. Validation checks shall be incorporated into applications to detect any corruption of information through processing errors or deliberate acts.
3. Requirements for ensuring authenticity and protecting message integrity in applications shall be identified, and appropriate controls identified and implemented.
4. Data output from an application shall be validated to ensure that the processing of stored information is correct and appropriate to the circumstances
5. Installation of unapproved software and utilities shall be barred by centrally enforced policy
6. Users shall use only organization approved collaboration software

3.1.3 Availability standards

1. Information systems classified as critical for business operations shall be designed to support

high availability operations by design of the system or the deployment of the same.

2. For all information systems requiring high availability, management shall carry out the following functions:
 - When an asset is procured, it shall be ensured that the asset configuration provides for fault tolerance.
 - After procurement, system shall be configured at an availability mode depending on the level of criticality.
 - Develop a plan for availability monitoring, reporting and management.
 - Optimize availability through monitoring and reporting of equipment performance.

3.2 Risk Assessment of new technology

3.2.1 Scenarios

1. Technology Risk assessment shall be carried out for the following scenarios:
 - a) Introduction of new process or technology
 - b) Changes to existing process or technology
2. Technology risk assessment shall be performed by the respective IT or business team responsible for introducing the new process / technology or changes to them.
3. Technology Risk assessment shall be carried out based on technology risk assessment templates and/or checklists defined by the IS team.

3.2.2 Technology risk assessment Process

Technology risk assessment shall be performed as per guidelines provided in 'IS Policy - General Guidelines 1.8 Risk Management'

3.2.3 Architecture and Interdependencies

1. Technical and functional architecture for any new Information Systems developed / procedure by Organization shall be reviewed and approved by the IS team from an information security perspective
2. Interdependencies of the new information system being developed / procedure shall be assessed

with the overall Organization environment from an information security perspective.

3.2.4 System changes control and procedures

1. Formal change control procedures shall be documented and enforced to ensure the integrity of system, applications and products, from the early design stages through all subsequent maintenance effort.
2. Introduction of new systems and major changes to existing systems shall follow a formal process of documentation, specification, testing, quality control and managed implementation.
3. The change control procedures shall include but not be limited to:
 - a) maintaining a record of agreed authorization levels;
 - b) ensuring changes are submitted by authorized users;
 - c) reviewing controls and integrity procedures to ensure that they will not be compromised by the changes;
 - d) identifying all software, information, database entities and hardware that require amendment;
 - e) identifying and checking security critical code to minimize the likelihood of known security weaknesses;
 - f) obtaining formal approval for detailed proposals before work commences;
 - g) ensuring authorized users accept changes prior to implementation;
 - h) ensuring that the system documentation set is updated on the completion of each change and that old documentation is archived or disposed of;
 - i) maintaining a version control for all software updates;
 - j) maintaining an audit trail of all change requests;

3.2.5 Technical review of applications

1. Review of application control and integrity procedures shall be performed to ensure that they have not been compromised by the operating platform changes.
2. Ensure that notification of operating platform changes are provided in time to allow appropriate tests and reviews to take place before implementation.
3. Ensuring that appropriate changes are made to the business continuity plan

3.2.6 System security testing

1. New and updated systems shall require thorough testing and verification during the development processes, including the preparation of a detailed schedule of activities and test inputs and expected outputs under a range of conditions.
2. For in-house developments, such tests shall be initially performed by the development team. Independent acceptance testing shall then be undertaken (both for in-house and for outsourced developments) to ensure that the system works as expected and only as expected.
3. System acceptance testing shall include testing of information security requirements and adherence to secure system development practices. The testing shall also be conducted on received components and integrated systems.
4. Testing shall be performed in a realistic test environment to ensure that the system does not introduce vulnerabilities to the organization's environment and that the tests are reliable.
5. The use of operational data containing personally identifiable information or any other confidential information for testing purposes shall be avoided.

3.3 RACI Matrix

Responsible	Accountable	Consulted	Informed
-------------	-------------	-----------	----------

IT	IT	IS	Business Users
----	----	----	-------------------

Policy No.:	2.6
Policy Name:	2.6. Information systems maintenance

- 1 **PURPOSE** To define desired practices for maintenance of information systems with respect to protecting confidentiality, privacy and availability. Security has to be considered during operation of an information system including maintenance and retirement in order to:
 - a. Ensure conformance with all appropriate security requirements
 - b. Protect information assets contained in the information system
 - c. Protect the system against new emerging risks
 - d. Prevent the introduction of new risks when the system is modified
 - e. Ensure proper removal of data when the system is retired.

This policy shall provide guidance to ensure that information security is considered during the maintenance of an information system's life cycle.

This policy defines Organization's desired practices concerning Information Systems Maintenance.
 - 2 **SCOPE** This policy applies to all information systems where Organization's information assets are stored or processed, and all communication and network connections through which Organization's information assets are transmitted.
 - 3 **POLICY** Technology systems, communications and network connections shall include but are not limited to network devices such as routers and firewalls, servers and mainframes, and systems, databases and applications.
- All Business Units or Departments using information systems shall comply with this policy.
- Appropriate maintenance shall be carried out to protect the confidentiality and integrity of information contained within and maintain availability of information systems.
- Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.

3.1 Backup and Restoration

1. The frequency of backup, frequency of restoration testing and requirements for storage of the backup shall be defined based on the classification of the data being backed up, in a backup and restoration standard defined by the IS team. Data restoration testing must be performed at a minimum of six months or more frequently, as required by the business.
2. All applications and operating systems software, data (including databases), application and operating systems configuration information, hardware configuration information (where applicable) and log files that require to be backed up shall be identified and documented along with the medium and storage of the backup, location of the offsite media (if required) for the required system.
3. All backup media shall be encrypted.
4. A log of backed data restored from backup media shall be maintained.
5. The number of backup sets to be maintained shall be decided based on the criticality of the information residing in the information systems.
6. In addition to the scheduled backups, backups shall be taken in case of:
 - Configuration changes in any of the systems
 - Upgrade of an operational system.
7. All movement of tapes between offsite and onsite locations shall be tracked and recorded.
8. To verify the readability of the backup media, mock restoration tests shall be carried out as defined in the backup and restoration standard, on the test systems periodically. The process shall be documented detailing the test plan, the activities carried out and the test results. Exception identified during the testing process shall be documented and reported.
9. Testing the ability to restore backed-up data shall be performed onto dedicated test media, not by overwriting the original media in case the backup or restoration process fails and causes irreparable data damage or loss;
10. The contents of the Web site of Organization shall be backed-up to ensure an orderly recovery, if the site is corrupted

11. Backups shall be reviewed periodically and procedures aligned to minimize downtime impact.
12. Operational procedures shall monitor the execution of backups and address failures of scheduled backups to ensure completeness of backups according to the backup policy.
13. The retention period for essential business information shall be determined, taking into account any requirement for archive copies to be permanently retained.

3.2 Patch Management

- The team responsible for maintenance and monitoring of Information systems shall maintain an inventory of software components comprising the IT environment. Refer to Asset management policy on asset inventory.
- The team responsible for maintenance and monitoring of Information systems shall monitor announcements from providers of software (including application and system software such as operating systems and databases) for software 'patches' made available to remove security vulnerabilities.
- Each patch identified shall be taken through the following process.
- The patch shall be evaluated for their relevance to Insurance Company, and determine whether it represents a normal or emergency change.

- A process shall be defined to determine the days within which the identified patches would be fixed.
- Perimeters shall be defined for classifying patches
- All patches shall be tested in the Organization operated test environment for feasibility of their application in Organization's production environment.
- If there is a need for hot fix/priority/critical security patches to be applied to the systems as directed by regulator/ advisories /product OEMs, Organization may assess and take necessary approval from CISO and CTO for the exception.
- Business critical applications shall be reviewed and tested prior to installation of OS or database patches, in a test environment, in order to ensure that there is no adverse impact the application due to the changes in the operating system.
- Application of patches or updates for end-computing devices shall be performed such that the patches are effectively deployed on them, within reasonable time of the device gaining access to the Organization's network or enterprise information assets.

3.3 Job Scheduling

1. A comprehensive inventory of scheduled jobs including daily, weekly, monthly, quarterly, and yearly batch runs or backup scheduled to be run on the production environment shall be maintained, including the interdependencies between jobs.
2. All jobs that are run in the production environment shall be approved by the information system owners.
3. All scheduled jobs shall be monitored for their performance, success/ failure, and the results shall be documented.
4. The results of a scheduled job shall be reviewed within reasonable time and action shall be taken based for any non-standard behaviour including failure of the scheduled job or it part thereof.

5. Schedules shall be subject to change either through planned or emergency requests.
6. The team responsible for maintenance and monitoring of information systems shall be responsible for scheduling and monitoring jobs with respect to the schedule.
7. Any non-standard behaviour including failures shall be raised as incidents and tracked for closure as per the incident management policy.
8. All scheduled jobs shall be designed to delete any temporary files generated during the performance of the job, and not required after completion of the same.
9. Controls shall be put in place to ensure that dependencies between various jobs are considered and failures impacting the dependencies are highlighted as alerts which can be monitored.

3.4 Capacity and Performance Management

Controls shall be put in place for monitoring the utilization and performance of information systems to ensure that availability requirements are met at all times.

- a) The results and logs of the monitoring activity should be analyzed for occurrence of security incidents and incidents shall be tracked for closure as per the incident management policy.
- b) The results and logs of the monitoring activity shall also be used to identify trends which might require changes to the IT environment or augmentation of IT resources. The results of the analysis shall be used to develop a Capacity Management plan intended to help Organization meet or exceed the performance targets.
- c) A capacity plan shall take into account aspects such as normal workloads, special contingencies and storage requirements.
- d) Insurance companies shall identify trends in usage, particularly in relation to business applications or information systems management tools.
- e) Thresholds shall be documented and monitored.
- f) Future capacity requirements shall be projected to ensure that adequate processing power and storage are available.
- g) System tuning and monitoring shall be applied to ensure and, where necessary, improve the availability and efficiency of systems.

3.5 Malicious Software Management

1. Organization shall develop formal and documented procedures for controlling and managing malicious code or malicious software such as viruses, Trojans, worms, logic bombs, etc. The procedures shall also include prevention, detection and recovery controls for malicious codes or malicious softwares.
2. All servers, desktops, workstations, hand-held devices, gateways and any other access points to Organization's network shall be protected against malicious activities (this shall include viruses, trojans, malware, adware, spyware and the like).
3. Anti-virus application and processes shall be put in place to facilitate early detection, efficient containment and eradication of malicious code. Adequate user awareness measures shall be implemented for the same.
4. Controls shall be considered to prevent unauthorized software execution.
5. Protection software such as anti-virus anti-malware, anti-spyware, and anti-adware needs to be installed on information systems controlled / used by Organization and and regular update of malware detection and repair software to scan computers and media as a precautionary control shall be ensured
6. The software shall be capable of being updated on a periodic basis from an authentic source of malicious software information.
7. The software must provide real time protection.
8. Malicious activity detected by the software shall be reported to an enterprise system which shall be monitored, and unresolved malicious activity shall be raised as incidents and tracked for closure as per the incident management policy
9. Regular reviews shall be conducted of the software and data content of systems supporting critical business processes and the presence of any unapproved files or unauthorized amendments shall be formally investigated.
10. Appropriate business continuity plans shall be developed for recovering from malware attacks, including all necessary data and software backup and recovery arrangements

11. Procedures shall be implemented to regularly collect information, such as subscribing to mailing lists or verifying websites giving information about new malware

3.6 Vulnerability Management

1. Organization shall identify technical vulnerabilities of information systems and network equipment. Vulnerabilities shall be identified periodically through scanning of the systems.
2. Organization shall define and establish the roles and responsibilities associated with technical vulnerability management, including vulnerability monitoring, vulnerability risk assessment, patching, asset tracking and any coordination responsibilities required
3. In addition to software based automated protection, the IS Operations team shall be responsible for keeping track of new vulnerabilities that could lead to a worm or virus attack by subscribing to security mailing lists of OS and application vendors, tracking virus alerts from anti-virus vendors and keeping track of advisories from independent security organizations like CERT, NCIIPC, IRDAI.
4. Organization should track mapping of cybersecurity notifications and advisories from security bodies like CERT-IN, NCCC, NCIIPC, IRDAI.
5. A timeline shall be defined to react to notifications of potentially relevant technical vulnerabilities
6. Organization's IS Operations team shall assess the risk and impact level of the vulnerabilities and also evaluate actual risk and impact level of a vulnerability striking. Appropriate measures shall be taken to mitigate the associated risks.
7. Client system's vulnerabilities shall be measured and Appropriate measures shall be taken to mitigate the associated risks
8. Organization shall perform periodic Red Team exercises to test organizational readiness to identify and stop attacks or to respond quickly and effectively.
9. Red Team results shall be documented using open, machine-readable standards (e.g., SCAP). A scoring method shall be devised for determining the results of

Red Team exercises so that results can be compared over time.

10. An audit log shall be kept for all procedures undertaken
11. The technical vulnerability management process shall be regularly monitored and evaluated in order to ensure its effectiveness and efficiency
12. Technical vulnerability management process shall be aligned with incident management activities, to communicate data on vulnerabilities to the incident response function and provide technical procedures to be carried out should an incident occur

3.7 IT Service Management

1. Organization shall have a defined and documented service catalogue for its IT services containing information about the currently available IT services at Organization to provide a single source of consistent information of Organization's agreed IT services to all authorized users.
2. Service levels shall be defined for each information system based on the business requirements.
3. Mechanism shall be established to monitor service levels and analyse breaches of service levels. Any service level breaches impacting information security shall be raised as incidents and tracked for closure as per the incident management policy.

3.7 Separation of development, testing and operational environments

1. Development, testing, and operational environments should be separated to reduce the risks of unauthorized access or changes to the operational environment.
2. Rules for the transfer of software from development to operational status shall be defined and documented.
3. Development and operational software shall run on different systems or computer processors and in different domains or directories.
4. Changes to operational systems and applications shall be tested in a testing or staging environment prior to being applied to operational systems.
5. Compilers, editors and other development tools or system utilities shall not be accessible from operational systems when not required.

6. Sensitive data shall not be copied into the testing system environment unless equivalent controls are provided for the testing system.
7. Users shall use different user profiles for operational and testing systems, and menus should display appropriate identification messages to reduce the risk of error.

3.8 Control of operational software

1. Procedures shall be implemented to control the installation of software on operational systems.
2. The updating of the operational software, applications and program libraries shall only be performed by trained administrators upon appropriate management authorization.
3. A configuration control system shall be used to keep control of all implemented software as well as the system documentation.
4. A rollback strategy shall be in place before changes are implemented and an audit log shall be maintained of all updates to operational program libraries.
5. Previous versions of application software shall be retained as a contingency measure and old versions of software shall be archived, together with all required information and parameters, procedures, configuration details and supporting software for as long as the data are retained in archive

3.8 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT team	IS Team	Software vendors and OEMs	End Users

Policy No.:	2.7
Policy Name:	2.7 Mobile security policy

- 1 **PURPOSE** The purpose of this policy is to ensure sensitive and critical data of Organization that is accessible by the employees onto their mobile devices are protected against unauthorized access and prevent unauthorized information disclosure.
- 2 **SCOPE** This policy applies to:
 - Employee's personal mobile devices like smartphones and tablet computers that can access Organization's networks, data and systems.
 - Applications used by employees on devices, whether owned by Organization or by employee, which store or access company's data.
 - Portable devices such as flash drives, external hard disks, CDs etc.
- 3 **POLICY** Access to business information shall be provided only after users have signed an end user agreement acknowledging their duties (physical protection, software updating, etc.), waiving ownership of business data, allowing remote wiping of data by the organization in case of theft or loss of the device or when no longer authorized to use the service. This policy shall take account of privacy legislation.
The policy also covers separation of private and business use of the devices, including using software to support such separation and protect business data on a private device.

3.1 Mobile Device Management

1. Mobile Device Registration- All mobile devices shall be registered and authenticated before being allowed to connect to and access Organization's infrastructure and applications.
2. Device Physical Protection- The user shall be responsible for physical protection of the mobile device. Refer BYOD security policy for BYOD security requirements.
3. Centralized mobile device management- System administrators shall use a centralized mobile device management (MDM) solution for the management of all registered mobile devices.
4. User Access Profiles – Access to Organization's resources shall be granted based on business need.
5. Lost / Stolen Devices – When Mobile Devices or Removable Media containing Sensitive Data or Organization's connection information is lost or stolen, a report shall be filed immediately. Refer to section 'Incident Management' in this policy for details.
6. MDM Software Features- The MDM solution shall, at minimum, have the following features:
 - Deletion (often known as remote wipe) to securely destroy all information stored on the device and any attached storage.
 - Data Encryption- Mobile devices shall use hardware encryption and deploy file-based encryption software.
 - Training shall be arranged for personnel using mobile devices to raise their awareness of the additional risks resulting from this way of working and the controls that should be implemented

3.2 Incident reporting

1. MDM users shall report immediately to system administrator for data wiping, in case of their device being misplaced or stolen.
2. In case an owner device is hacked for manipulation or deletion of stored data, device owner shall take action and report to the system administrator.

3.3 Log management

Detailed logs shall be recorded and managed for MDM.

3.8 RACI matrix

Responsible	Accountable	Consulted	Informed
IT team	IS Team	Software vendors and OEMs	End Users

Policy No.:	2.8
Policy Name:	2.8 Bring your own device [BYOD] policy

1 PURPOSE

The Bring Your Own Device ('BYOD') Policy governs the use of employee-owned devices (e.g. tablets, smart phones/ equivalent) for accessing corporate emails, applications and data.

The purpose of this policy document is to:

- i) Define employee eligibility for using personal-owned smart phones/tablets to access corporate data
- ii) Define the responsibilities, guidelines, and terms of use for personal-owned devices.

This policy has been defined under the provisions of the Organization Information security policies as referred in various sections below. However, in the event of any conflict between this policy and the information security policies, the CISO shall be responsible for resolution of the same; Refer to 'General Guidelines: Governance' iii) Ownership and interpretation' for further information.

2 SCOPE

This policy applies to:

- All mobile devices, owned by employees inclusive of smartphones, mobile or cellular phones, PDAs and tablet computers, that have access to Organization's networks, data and system
- Applications used by employees on their own personal devices which store or access corporate data
- Use of device both during and outside office hours and whether or not use of the device takes place at normal place of work

This policy does not apply to laptops.

3 POLICY

This document provides policies and rules of behaviour for the use of personally-owned smart phones and/or tablets by Organization employees to access Organization resources and/or services. Access to and continued is granted on condition that each user reads, signs, respects and follows the Organization's policies concerning the use of these resources and/or services. This policy is intended to protect the security and integrity of Organization's data and technology infrastructure. Limited expectations in the policy may occur due to variations in the devices and platforms.

3.1 Eligibility and ownership

1. All full time employees shall be allowed to configure their personally owned devices for corporate email, application and data access (BYOD program).
2. Contractors or third party employees can enroll their personal devices under BYOD program after due management approvals (on case to case basis).

3.2 Acceptable devices

1. Organization's IT function shall maintain a 'white-list' of device models, which can be configured under the BYOD program, as per the technology compatibility and security considerations. This list would be updated by IT function periodically.
2. Organization shall support devices with following OS platforms but not limited to -
 - a. Android - OS version 8.0 and above
 - b. Apple - iOS version 12 and above
 - c. Windows - OS version 8 and above
3. Organization BYOD program does not support personal devices (mobiles/laptops) using customized, "rooted", or "jail broken" versions of operating systems.
4. The device must have a licensed version of the Operating System installed.

3.3 Device setup

Organization's IT functions would setup a self-configuration portal for BYOD enrolment. Eligible employees shall be provided access to this portal to setup and configure their devices. Organization's IT function shall support in configuration in case of any issues

- 3.4 Ongoing support and device maintenance**
1. Organization's IT functions shall provide support for corporate applications and corporate data on devices enrolled as part of BYOD program.
 2. Organization's IT functions would not own the support for managing employee's personal device hardware/ non-corporate software issues.

- 3.5 Employee/ Device Exit Process**
1. In case of employee resignation/ exit from Organization— Refer to 'Security Policies: Human Resource Security.'
 2. In case of absconding employee, HR shall inform IT function at the earliest. The latter shall perform remote wipe of corporate data from the device. In case the remote wipe is not possible, the same shall be reported as an Information Security incident as per 'Security Policies: Incident and Problem Management'.
 3. In case of loss of device, the employee shall inform IT function within 4 hours. IT function shall perform remote wipe of corporate data from the device as per Annexure 1 as defined below. In case the remote wipe is not possible, the same shall be reported as an Information Security incident as per 'Security Policies: Incident and Problem Management'.
 4. Organization shall deploy appropriate information security controls on the devices enrolled under BYOD program to enforce appropriate access controls defined in the 'Security Policies: Access Control.'
 5. This may include installation of a Mobile Device Management (MDM) tool.

- 3.6 Periodic audit and non-compliance remediation**
- IT function will be authorized to monitor or periodically review the device configurations [as per the 'General Guidelines: Acceptable Usage – (II). Acceptable usage of personal devices for official purposes. Point (c)'] to identify any exceptions to Organization's policies. The monitoring and logging of activities on the mobile device shall be performed in compliance with 'Security Policies: Monitoring, Logging and Assessment'.

3.7 Annexure 1

3.7.1 Key definitions

3.7.1.1 Data

classification

1. Corporate Data – means applications and data belonging to Organization or its affiliates, including but not limited to emails, calendar, contact data, corporate applications, documents, images etc. The same shall be classified as per the ‘Security Policies: Data Classification.’
2. Personal Data – any data/ applications other than Corporate Data, present on the employee’s device

3.7.1.2 Device type

1. Smart Phone – is a mobile phone built on a mobile operating system, with more common features of a handheld computer/ PDA and with more advanced computing capability and connectivity than a feature phone.
2. Tablet – is a wireless, portable personal computer with a touch screen interface. The tablet form factor is typically larger than a smart phone.
3. Mobile Device Management (MDM) – refers to specialized software intended to distribute mobile applications, data, configuration settings and implement IT Governance in mobile devices, including mobile phones, Smart phones, and tablet computers. The intent of MDM is to provide real-time management capabilities including convenient configuration, self-service and robust security while minimizing cost and downtime.

3.7.2 Security of personal devices

- of Following minimum security controls shall be configured on the personal devices having access to corporate data:

3.7.2.1 Device security

1. Device Pass-code: Access to devices shall be protected by either a 4-digit device pass code or pattern recognition system. The corporate data on device shall be automatically wiped after 10 unsuccessful logon attempts.
2. Access to Organization applications / data: As defined in the 'Security Policies: Access control', access to all Organization application and/or data will be based on two-factor authentication.
3. Device Locking: The device shall be locked after 5 minutes of inactive time.
4. Device Tracking: To determine the location of an employee's handset, devices shall be installed with software to track the same.
5. Remote Locking: In the case of a lost or stolen phone or tablet, employees or Organization's IT function shall be able to remotely lock or, erase the specified device.
6. Jailbreak Detection: Detection tools shall be installed in the devices to perform a comprehensive search for evidence that the built-in system protections on the device have been disabled.

3.7.2.2 Data security

1. Remote data wipe: Devices enrolled under this policy shall be configured for remote erase capability through appropriate means such as an MDM software
2. Data encryption and containerization: Please refer to 'Security Policies: Cryptographic Controls.'
3. Application blacklisting: Organization's IT function shall maintain a list of applications that are to be denied system access and shall prevent them from installing or running.

3.8 Acceptable use Refer to 'General Guidelines: Acceptable Usage policy.'

3.9 RACI Matrix

Responsible	Accountable	Consulted	Informed
Employees	Business process owners	IS & IT	CRO/ CTO

Policy No.: 2.9

Policy Name: 2.9 Change Control

- | | | |
|-----|------------------------------|---|
| 1 | PURPOSE | To define consistent and systematic practices for efficient and prompt handling of all changes to Organization's information resources in order to minimize the impact of the changes on information assets. |
| 2 | SCOPE | <p>Any change to Organization's information systems that may affect the resources upon which the organization relies to conduct normal business is within the scope of this policy. The following non-exhaustive list depicts common type of changes:</p> <ul style="list-style-type: none">▪ Software upgrades, updates or additions▪ IT Infrastructure changes▪ Preventative maintenance▪ Security patches▪ System architecture and configuration changes▪ Hardware upgrades▪ Product management |
| 3 | POLICY | <p>All changes to Organization's information resources shall be performed in a controlled manner to ensure that the risks associated with such changes are managed to an acceptable level. Formal procedures for change management shall be documented and all changes to Organization's information assets shall follow the standard change management procedure.</p> <p>Appropriate procedures shall be put in place for all changes requiring emergency actions and response process, which bypass the Policies and Procedures outlined.</p> <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Change Governance | Change governance will be followed as per IT governance framework. |
| 3.2 | Change Classification | <ol style="list-style-type: none">1. All changes shall be classified based on the following factors:<ul style="list-style-type: none">• Data impacted by the change• Impact of the change on Organization's IT environment.2. All changes shall follow the change lifecycle mentioned below and require appropriate approvals based on the |

classification of the change. Major changes and “Identified CR types” shall be put through a Technology Risk Assessment (TRA) which shall be performed by the IT Team based on TRA standards defined by the IS team. Results of TRA shall be reviewed by the IS team on periodic basis.

3.3 Change life cycle

1. Separate environments shall be created and maintained for development and testing of changes to information systems
 2. The test and development environments shall, at a minimum, be physically or logically segregated from production systems while ensuring that no user has access to both environments simultaneously.
 3. Production data shall preferably not be transferred to the test / development environments. In situations where the production data needs to be transferred to the test / development environments the same level of protection as the production environment shall be applied to these environments; else production data shall not be moved to these environments.
1. All changes to Organization’s information assets shall adhere to the following change lifecycle:
 - Request for change – request for the change shall be formally raised and recorded. This shall be followed by a formal business requirement definition, impact and feasibility analysis as applicable.
 - Impact analysis shall need to be performed by the change requestor and include assessment of potential Financial, Operational, regulatory, technology and other impacts.
 - Change approval – all changes shall be duly approved by appropriate individuals as per the change authorization matrix defined by the IS team.
 - Prioritization of changes – changes shall be prioritized by the change implementation team(s) based on the criticality of the change and the impact of the change on the information asset.
 - Testing of changes – all changes shall be tested in the test environment. This shall include different levels of testing such as System Acceptance Testing (SAT), System Integration

Testing (SIT), User Acceptance Testing (UAT) etc. depending upon the type of change, as defined in the change management procedure by the IS team.

- Roll Back – All changes should include a rollback procedure for aborting and recovering from failed changes.
 - Migration- All changes shall be migrated to the production environment after appropriate approvals and by authorized individuals. Restrictions shall be maintained to ensure that access to the production and development / test environments is duly segregated.
 - Documentation update – All relevant documentation shall be updated to reflect the impact of the change. All records of testing shall be formally documented and maintained.
2. Emergency changes as defined in the change management procedure shall be exempted from following the change lifecycle mentioned above due to the urgent nature of the change.
 3. All updates to the web site shall be independently reviewed, approved and tested
 4. All emergency changes shall however be appropriately documented and post-facto approvals from relevant authorities shall be obtained.
When changes are made, an audit log containing all relevant information shall be retained.
 5. Document the emergency control procedures to capture the approvals from Head of Operations on an email post any verbal approval being given.

3.4 Release Management

1. Releases to both packaged and bespoke applications within Organization shall follow the formal release management process.
2. The release management process of Organization shall have the following considerations:
3. For releases issued by third parties, appropriate delay shall be allowed before a new release is implemented to allow for any initial problems with the release to be known and sorted out by the provider.

4. All release related communication shall be sent to the relevant stakeholders well in advance of the release.
5. Appropriate version control procedures shall be followed to ensure the release and its supporting documentation is version controlled.
6. A release document shall be prepared and provided along with every release which shall contain details about the release such as goals and objectives, process flows, release planning, release building, acceptance testing, release preparation, release deployment and roles and responsibilities.

3.5 RACI Matrix

Responsible	Accountable	Consulted	Informed
Change Requestor	IT	Risk Management Team	Business Users

Policy No.: 2.10

Policy Name: 2.10 Incident and problem management

1 **PURPOSE** An Incident is defined as the occurrence of any exceptional situation that could compromise the Confidentiality, Integrity or Availability of Information assets of Organization. Problem Management includes the activities required to diagnose the root cause of incidents and to determine the resolution to those problems.

This policy defines Organization's desired practices concerning Incident and Problem Management.

2 **SCOPE** This policy shall apply to all incidents resulting from violation of Information Security policies or processes / standards defined by the IS team based on the policy. These include but are not limited to:

- attempts (either failed or successful) to gain unauthorized access to a system or its data
- unwanted disruption or denial of service
- the unauthorized use of a system for the processing or storage of data
- changes to system hardware, firmware, or software characteristics without the owner's knowledge, instruction, or consent

All Business Units or Departments using information technology must comply with these Information Security Policies.

3 **POLICY** Organizations shall implement procedures for detecting, reporting and responding to incidents in routine administration of information security and for analyzing and tracking their closure.

Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.

3.1 **Definitions**

1. **Security/ Operational incident:**

A "Security/Operational incident" is an adverse event where:

- the IT resource is attacked or threatened with an attack;
- accessed/monitored/modified without authorisation; and
- used in a manner inconsistent with the established organization's/regulatory policy resulting in a real or

possible loss of confidentiality, integrity or availability of the IT resource or information.

Examples of Security incidents are:

- internal or external attempts (either failed or successful) to gain unauthorised access to the IT system or its data;
- DLP violations
- Attempts (either failed or successful) to gain access to blocked sites as per proxy rules
- denial of service (DoS) or unauthorised disruption to IT system and infrastructure;
- actual or suspected loss of proprietary, confidential or entrusted information of the organization;
- changes to system hardware, firmware or software characteristics without the department head knowledge, instruction or consent;
- malicious code (virus, Trojan horse) attacks;
- social engineering (tricking someone to disclose confidential/proprietary information like passwords that could compromise system security);
- signature update failure; and
- hoaxes (deliberate trickery intended to gain an advantage e.g. false virus warnings may lead some user to ignore all virus warning messages, leaving them vulnerable to a genuine, destructive virus).

Examples of Operational incidents are:

- firewall hardware failure;
- anti-virus appliance hardware failure; and
- IDS hardware failure.

2. Problem/ Event:

An event is an observed or observable occurrence in a system, a network or daily operations.

An event will be termed as an incident if it is considered to have “adverse” impact on the IT system/infrastructure or through pre-positioned criteria that describes the circumstances under which events will automatically be deemed adverse.

An event will be an incident when it is analysed and classified to be adverse by the incident response team.

Until events are classified not adverse, they are considered as “suspected incidents”.

3. Incident Response Team (IRT)

The Incident Response Team (IRT) is formed to address any incidents and initiate immediate action to resolve the same. The Incident Response Team issues guidelines proactively to address potential threats/ risks arising out of incidents. While incidents shall be handled at various levels based on the severity and impact of the incidents; however, most incidents are to be handled at the Incident Response team leader level.

The team shall consist of the following members:

- Incident Management Leader (IML):

The CRO and COO together play the role of IML at Organization. The Incident Management Coordinator shall keep IML informed about the proceedings of the incidents and the same shall be reported to the Control Management Committee

The IML or a person designated by him/her only can officially communicate with the media in case of any incidents.

- Incident Management Coordinator (IMC):

The CISO and CTO together play the role of IMC at Organization. The IMC shall work with the Incident Response Team Leaders to contain the damage caused by the incident and they shall be the focal point for recovery efforts.

- Incident Response Team Leaders (IRTL):

BCM Manager shall be the Incident Response Team leader for all Business continuity related incidents. For all issues and incidents related to IT shall be handled by IT Manager. CISO shall be the team leader for all IS related incidents. Non-IT incidents like physical security shall be managed by Admin head. IRTL shall delegate action on incidents to Incident Response Team members.

- Incident Response Team Members:

The members of the Incident Response Team should get detailed briefing from IRTL before acting on any incident. They should also meet the person reporting the incident for obtaining further information. IRTL and IR Team members must have the list of all

emergency contact details of the entire Incident Response Team, Vendors, Suppliers, Service providers, etc. An emergency pocket sized card can be prepared containing contact numbers of the Incident Response Team members and distributed to all the employees.

- Help Desk Team:

It is the responsibility of helpdesk team to:

- Answer, evaluate, and prioritize the incoming telephone, e-mail, and in-person requests for assistance from users experiencing problems with hardware, software, networking, security and other computer-related technologies;
- Escalate problems to help desk support engineers;
- Escalate any security incidents/problem to the IT and system security departments promptly;
- Call software and hardware vendors to request service regarding defective products; and
- Log and track calls using remedy problem management database and maintains history records/related problem documentations.

-

3.1 Reporting IS Event and Weaknesses

1. All users shall be expected to report incidents in a timely manner. Mechanisms shall be established for all users of information systems to report incidents.
2. Mechanisms shall be established for monitoring of information systems to detect any malfunctions (any abnormality or deviation in functioning); all such malfunctions shall be recorded and analyzed, and those resulting in violations of Organization's security policies and procedures shall be considered incidents.
3. Incidents shall be reported through the established mechanisms only in reasonable time.
4. All contractors and third parties shall also be made aware of the procedures for reporting different types of incidents (like security breach, threat, weakness, or malfunction) that might have an impact on the security of information assets.
5. All reported incidents shall be logged, analyzed and classified according to predefined criteria.

3.2 Incident recording and classification

1. All incidents reported shall be recorded along with details mandated by the IS team, which shall include (but not limited to):
 - Source of the incident – user reported or through monitoring mechanism
 - Impacted information asset(s)
 - Incident description (details such as malfunction report, alerts and internal communications)
 - Time and date of the incident occurred, detected and recorded
2. All incidents shall be classified into High, Medium or Low severity, based on the following criteria as per standards defined by the IS team:
 - Impact on information assets (breach of confidentiality, integrity or availability)
 - Scope of the impact (users, departments, locations, information systems)
 - Classification of data impacted
3. All incidents shall be categorized as IS incident, IT incident, Non-IT Incidents.
4. Information security incidents shall be responded to by a nominated point of contact and other relevant persons of the organization or external parties
5. Post-incident analysis shall take place, as necessary, to identify the source of the incident

3.3 Escalations and Tracking

1. Appropriate contacts with relevant authorities shall be maintained to escalate to the respective authorities as required.
2. All high, medium and low severity incidents shall be reported to the CISO.
3. Enterprise wide monitoring of Information security incidents shall be done by SOC team on 24X7 basis
4. Continuous monitoring of IT logs to review unauthorized Login/Logout by users, access violations etc. shall be done through Security Information and Event Monitoring (SIEM) and monitored by Security Operations Centre (SOC)

5. All involved response activities shall be properly logged for later analysis;

3.4 Management of IS Incidents and Improvement

1. Management responsibilities and procedures shall be established to ensure a quick, effective, and orderly response to information security incidents.
1. Mechanisms shall be established to analyze all incidents in reasonable time and contain the impact of the incidents to the least possible scope.
2. Mechanisms shall be established to resolve all incidents within timelines defined by IS teams for the incident's respective classification.
3. Mechanisms shall be established to recover any loss or damage to information assets as a result of the incident.
4. Mechanisms shall be put in place to learn from incidents and enable the types, impacts, and costs of incidents and malfunctions to be quantified and monitored.
5. The CISO should ensure that one or more of the following measures are implemented to identify events that could result in an incident:
 - Logging and monitoring established on all critical infrastructure information systems
 - Detective controls such as File Integrity Monitors, MD5 hash implemented on critical files and systems

3.5 Notification to regulatory authorities

1. Organization shall identify how incident shall be reported to internal parties and external organizations (e.g. Regulators, media, law enforcement, customers, IRDAI, CERT-In, CSIRT-Fin, Cyber Swachhta Kendra).
2. The timelines prescribed for reporting incidents to external organizations shall be strictly adhered to.
3. Organization shall mandatorily report cyber incidents to Cert-In within 6 hours of noticing or being brought to notice about such incidents with a copy to IRDAI and other concerned regulators / authorities. The details regarding methods and formats of reporting cyber incident is published on Cert-In website.

4. Organization shall ensure that contact details of Ministries, stakeholders, vendors and agencies like NCIIPC & CERT-In for incident resolutions are up to date and documented.

3.6 Root Cause Analysis and Problem Management

1. Incident records shall be analyzed on a periodic basis to identify problems to proactively identify trends or to diagnose the root cause and any contributing causes for incidents in order to take preventive measures reducing the chance of reoccurrence of incidents
2. Internal procedures shall be developed and followed when dealing with evidence for the purposes of disciplinary and legal action.
3. Problems identified shall be assigned to individuals for resolution for identification of solutions within timelines agreed based on criticality of source incidents for the problems.
4. Upon determination of the resolution to identified problems, corrective steps shall be implemented through the appropriate control procedures, especially Change Management processes.

3.6 Knowledge Management

1. Mechanisms shall be established to record the resolution and known causes of incidents and problems in a knowledge base.
2. Incident management teams shall be provided access to the knowledge base to reduce the time to respond to incidents.
3. The information gained from the evaluation of information security incidents shall be used to identify recurring or high impact incidents.

3.7 RACI Matrix

Responsible	Accountable	Consulted	Informed
IS, IT, respective Business functions, Admin, HR	Respective business function	CRO	Business Functions, IS

Policy No.: 2.11

Policy Name: 2.11 Network Security

- | | | |
|-----|-----------------------------|---|
| 1 | PURPOSE | To define Organization's desired security requirements for protection of the IT network used or controlled by Organization. |
| 2 | SCOPE | <p>This policy shall apply to all communication and network connections through which Organization's information assets are transmitted.</p> <p>Communications and network connections include but are not limited to network devices such as routers and firewalls, servers and mainframes.</p> <p>All Business Units or Departments using information technology must comply with these Information Security Policies</p> |
| 3 | POLICY | <p>Networks (connectivity infrastructure and related devices) used for Organization's communication or under Organization's control shall be appropriately secured to prohibit unauthorized access, disclosure, duplication, modification, diversion, destruction, loss, misuse, or theft of Organization's information.</p> <p>Organization's network shall be used for valid business purposes only. This means that access privileges shall not be authorized for an individual unless a legitimate business justification exists. The facility to access Organization's network shall be provided to users only after formal approvals. Network resources belonging to or under control of third parties that has been entrusted to Organization shall be protected in the same manner as Organization's network resources and in accordance with other agreement. Should there be a conflict between this policy and an agreement signed with a third party, appropriate provisions need to be made in the agreement to mitigate the risks and the agreement shall prevail thereafter.</p> <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Network Connectivity | <ol style="list-style-type: none">1. Responsibilities and procedures for the management of networking equipment shall be established.2. Special controls shall be established to safeguard the confidentiality and integrity of data passing over public networks or over wireless networks and to protect the connected systems and applications. |

3. Appropriate logging and monitoring shall be applied to enable recording and detection of actions that may affect, or are relevant to, information security.
4. Systems on the network should be authenticated and systems connection to the network shall be restricted
5. The ability of the network service provider to manage agreed services in a secure way shall be determined and regularly monitored, and the right to audit shall be agreed

3.1.1 Modes of Connectivity

1. The modes of connectivity to Organization's Internal Network from an external location shall be only through authorized MPLS Cloud, Point to Point or through the Virtual Private Network. An authorized user shall be able to connect to the network via either of the below mentioned mechanisms:
 - MPLS
 - Broadband & VPN
 - Wi-Fi
 - Wired Network
2. Any network connection allowing access to Organization's information asset shall be protected using perimeter devices such as firewalls or routers or other equivalent infrastructure to ensure that computer connections and information flows do not breach the access control requirements of Organization's policy.
3. Network engineers shall use a dedicated machine for all administrative tasks or tasks requiring elevated access. The machine shall be segmented from the Organization's primary network and not be allowed Internet access. The machine shall not be used for reading e-mail, composing documents, or surfing the Internet

3.1.2 Types of Connectivity

1. Only trusted entities shall be allowed full access to the Organization's network.
2. All entry points to the Organization's network shall be reviewed and approved.
3. Access to the network shall be via a secure log-on procedure, designed to minimize the opportunity for unauthorized access.

4. All policies within the Access Control Policy shall apply to network connectivity.
5. All connections via corporate computer and communication system shall be protected by authenticating connected users, devices or services.
6. Any connection to Organization's IT Assets classified as business transaction systems and high severity systems from outside Organization-owned or controlled network (ex. remote connections), shall require two factor authentication as defined in the access control policy and compliance check validates the device connecting.
7. Only authorized scripting languages shall run in all web browsers and email clients.
8. Insurance companies shall ensure that only fully supported web browsers and email clients are allowed to execute within the organization, ideally only using the latest version of the browsers and email clients provided by the vendor.
9. Organization shall segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).
10. Preventive control shall be put in place to block Unauthorized Collaboration tools on the firewall/network security devices.

3.2 Perimeter Security

3.2.1 Identification of perimeter devices

1. Organization shall deploy perimeter security systems (Firewall, IDS, etc) and develop and implement procedures, to protect all information assets from unauthorized or illegal access at the network level.
2. An inventory of all perimeter devices shall be maintained and procedures set up to update the same on a periodic basis and upon every change in the network configuration.

3.2.2 **Baseline
security
standards**

1. Minimum Baseline Security Standards (MBSS) shall be defined for all types of perimeter security devices for all variants (make / model / versions) of the devices.
2. Any changes to the baseline security standards shall be subject to the Change management policy.
3. Mechanisms shall be implemented to ensure that network security resources adhere to the baseline security standards and any deviations in actual configurations and baseline security standards are detected and addressed or approved as exception where required to be retained.
4. Baseline security standards shall be reviewed periodically
5. Application whitelisting software shall ensure that only authorized software libraries (such as *.dll, *.ocx, *.so, etc.) are allowed to load into a system process.
6. Application whitelisting software shall also ensure that only authorized, digitally signed scripts (such as *.psl, *.py, macros, etc.) are allowed to run on a system.

3.3 **Network
Management**

1. All network equipment and communication lines shall be identified, documented and updated regularly.
2. Network diagrams for local and wide area networks shall be maintained and updated regularly.
3. Security systems operating within and across public and Organization networks shall be protected against internal and external intruders. The systems shall be installed in a physically secured and access-restricted area.
4. The use of personal communications equipment (modems, ISDN cards, data cards, 3G data SIM etc.) attached directly to personal computers with remote control software shall be prohibited.
5. Access to all communication equipment shall be subject to the access control policy, including the avoidance of generic user accounts.
6. An active discovery tool shall be utilised to identify all sensitive information stored, processed, or transmitted by the Organization's technology systems, including those located on-site or at a remote service

provider, and update the sensitive information inventory.

3.4 External Networks

7. Adequate measures shall be taken to isolate and secure the perimeter and connectivity of the servers running monetary transactions applications/process.
1. Network traffic directed towards public networks such as the Internet shall pass through gateway systems such as the Proxy server, in addition to appropriate perimeter security systems, for implementation of access controls and related security mechanisms as per the access control policies.
2. Access to external network resources shall be based on business requirements which shall include adherence to access control procedures.
3. Connecting Organization mobile assets to unauthorized Wi-Fi access points and Hot spots shall be prohibited.
4. User awareness training shall include acceptable use and cautions, copyright issues and disciplinary action for violation of acceptable use policy and general Internet ethics.
5. Organization shall reserve the right to monitor user actions on public networks, when such networks are accessed through information systems owned or controlled by Insurance Company, in order to protect the confidentiality of Organization's information assets.
6. Organization shall implement adequate controls or contractual provisions for adherence to the network policy by third parties involved in providing network related services or having access to (or part thereof) Organization's network resources.
7. Organization shall protect web applications by deploying web application firewalls (WAFs) that inspect all traffic flowing to the web application for common web application attacks. For applications that are not web-based, specific application firewalls shall be deployed if such tools are available for the given application type. If the traffic is encrypted, the device shall either sit behind the encryption or be capable of decrypting the traffic prior to analysis. If neither

option is appropriate, a host-based web application firewall shall be deployed.

8. Organization shall subscribe to URL categorization services to ensure that they are up-to-date with the most recent website category definitions available. Uncategorized sites shall be blocked by default.

3.5 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT	IT and business departments	IS	Enterprise Assets – CTO Other Cases – End Users/Owner of key

Policy No.:	2.12
Policy Name:	2.12 Cryptographic Controls

- | | | |
|---|----------------|--|
| 1 | PURPOSE | To define the desired practices for use of cryptographic controls for protection of confidentiality and integrity of Organization's organizational assets. |
| 2 | SCOPE | <p>Cryptography is the practice of techniques for secure communication in the presence of third parties and utilizes encryption as a mechanism to encode information in such a way that eavesdroppers cannot read it, but authorized parties can.</p> <p>This policy shall apply to all forms of cryptography applied either to encrypt information in transit or at rest.</p> <p>This policy shall apply to all information systems where Organization's information assets are stored or processed, and all communication and network connections through which Organization's Information Assets are transmitted which utilize cryptography as a mechanism for security of the information asset.</p> |
| 3 | POLICY | <p>Organization shall ensure that appropriate cryptographic controls are applied to data depending upon its classification as per encryption requirements defined in the data classification policy.</p> <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |

3.1 Use of Cryptographic Controls

1. The management approach towards the use of cryptographic controls across the organization, including the general principles under which business information shall be protected
2. Risk assessment shall be carried out to identify the needs, methodology, business areas and usage of encryption or cryptography.
3. Cryptographic controls shall be used for securing information that is confidential and restricted and transported by mobile or removable media devices or across communication lines;
4. The definition of Confidential and Restricted Information will be based upon the respective classification ascertained by the Information Owner as per the Data Classification Policy.
5. Critical information that is not actively used, when stored or transported in computer-readable storage media (such as servers, magnetic tapes, floppy disks or CDs, hard disk of mobile assets such as laptops and memory chips of mobiles), shall be in encrypted form wherever feasible and applicable.
6. Information used to verify the identification of remote terminals shall be appropriately protected. Static or reusable authentication information shall be encrypted during storage and while passing through the network using encryption software or hardware.
7. The approach to key management, including methods to deal with the protection of cryptographic keys and the recovery of encrypted information in the case of lost, compromised or damaged keys shall be defined.

3.2 Key Management

1. A policy on the use, protection and lifetime of cryptographic keys shall be developed and implemented through their whole lifecycle
2. All cryptographic keys shall be protected against modification and loss
3. Type and strength of the encryption algorithm to be used in a given situation shall be based on the criticality of the business information handled.
4. The length of the cryptographic keys shall comply with contractual requirements and regulations laid down by competent authorities.
5. Where possible, encryption keys shall not be transmitted over the network. If the keys used to govern the encryption process are to be transmitted over the network then they shall be transmitted through secure communication channels.
6. Activation and deactivation dates for keys shall be defined so that the keys can only be used for the period of time defined in the associated key management policy.
7. Key management life cycle shall be comprised of the six stages. Each component represents a set of processes that shall be addressed both in documentation and in practice:
 - a. Creation - Key creation shall be conducted in a secure environment (hardened system), and may include the need to conform to requirements for separation of duties.
 - b. Backup - The backup shall imply writing the key to external media (e.g., CD, DVD, USB drive) and storing it in a physical vault.
 - c. Deployment - The new key shall be deployed and tested for a pre-determined period of time to ensure that operations with the new key are successful before risking a data outage.
 - d. Monitoring — Monitoring for unauthorized administrative access to crypto systems shall take place to ensure that unapproved key management operations are not performed.
 - e. Expiration - The chosen strength of an encryption key shall primarily take into consideration the length of time for which the data may be valid.

f. Destruction - Key destruction shall follow secure deletion procedures so as to ensure that it is properly obliterated.

g. Logging and auditing of key management related activities

3.3 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT	IS	IS	Enterprise Assets: CTO Other Cases: End User/owner of the Key

Policy No.:	2.13
Policy Name:	2.13 Business Continuity Management and Disaster Recovery

- 1 **PURPOSE** Organization's ability to continue operating as a viable business entity depends on having proper contingency plans and procedures in place. If a business disruption occurs, Organization must be able to resume operations in a reasonable time frame without compromising security.
This policy defines Organization's desired disaster recovery practice to ensure adequate mitigation of risks from interruption of Information Technology services.
- 2 **SCOPE** This policy shall apply to all office locations and systems through which Organization's information assets are stored or processed, and all communication and network connections through which Organization's information assets are transmitted.
Technology systems, communications and network connections include, but are not limited to, network devices such as routers and firewalls, servers and mainframes, all operating systems, databases and applications.
- 3 **POLICY** All Organization's information systems and assets shall be protected against potential failure or disruption of service through a formal business continuity plan and disaster recovery plan that:
 - Restores assets in accordance with system or asset criticality to Organization business processes
 - Maintains the required level of security over Organization's information assets in the event of a disruption. Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.
- 3.1 **IT Availability Management**
- 3.1.1 **Capacity monitoring and planning** Organization shall continuously monitor the utilization and make projections for future requirements of information processing resources and plan accordingly to ensure that adequate information processing resources are available to meet the business requirements of Organization.

3.1.2 System acceptance

1. Acceptance criteria for new information systems, upgrades and new versions shall include their ability to be resistant to disruptions or faults through appropriate design and configuration and suitable tests to determine such capability shall be carried out prior to acceptance.
2. Where resistance to disruptions is not provided for through appropriate design and configuration, alternative mechanisms to provide for resistance to disruptions shall be evaluated for feasibility and implemented where feasible.

3.2 IT Continuity Management

3.2.1 Data backup

All data shall be backed up on a regular basis as per the Backup and recovery policy and the backups must be available for timely restoration in the event of information loss or disruption to ensure continuity of Organization's operations. Refer to Information Systems maintenance policy for details on backup management and restoration. The DR environment shall be kept in sync with the production environment at all times. All changes being applied to the production environment shall be applied to the DR environment as well to ensure the environments are in sync.

3.2.2 IT Continuity planning

An IT Continuity plan or disaster recovery plan shall be developed for each Organization or system based on appropriate risk assessment and business requirements and shall be approved by the ISRMC.

3.3 BCM Framework

Organization's BCM framework shall consist of documented business continuity and disaster recovery plans. A single framework shall be maintained to ensure all plans, across businesses and processes are consistent, to consistently address information security requirements, and to identify priorities for testing and maintenance. The BCP/DR plans shall address at a minimum:

- Enterprise-wide business continuation
- Continuation of critical applications
- Organization's Data Center Disaster Recovery Plans
- Network connection / link

- Roles and responsibilities of all individuals in the Business Continuity and Disaster Recovery Plans

I. Business Impact Analysis

- RTO and RPO shall be defined for all applications based on the business requirements.
- All dependencies on IT systems by the business functions shall be clearly documented.

II. Risk Management and Evaluation

- Organization shall ensure that adequate coverage is provided in the identification of threat that may cause disruption to the availability of the IT assets supporting the business operations.
- A defined and documented Risk Assessment Methodology shall be used to conduct the Risk Assessment Exercise.
- Risk Analysis shall be performed at least on an annual basis.
- The acceptable levels of risk shall be defined, documented and approved by the management.
- Existing controls shall be assessed for their strength and effectiveness. The mitigation of a risk due to the presence of existing controls shall factor in the control strength and control effectiveness values.
- Control assessment may be undertaken on a sampling basis as required. In such cases, the sampling frequency shall be clearly documented.
- All risks having a risk rating above the acceptable level of risk shall have risk mitigation plans. These plans shall be approved by the management.
- Risk Mitigation plans shall have clearly defined ownership for the action points.
- The Risk Mitigation plan shall be reviewed and tracked to closure on a quarterly basis.

III. IT DR Strategies

- The IT DR strategy must ensure minimal data loss during exigencies and enable quick recovery and continuity of critical business operations.
- The strategies chosen shall be capable of supporting and integration with the business continuity of Organization.
- Strategic options shall be evaluated for the technology components and appropriate strategies shall be defined for recovery and restoration of IT systems as per recovery priority.
- External (third party) products and services shall be covered by the strategic options chosen where appropriate.
- To prevent the synchronization issue among inter-related applications during disaster, the IT DR plan shall include continuous operation-data mirroring to offsite location and stand-by computing and telecommunication

IV. IT DR Recovery Planning

- The response and recovery plan shall be concise and accessible to those responsible.
- The purpose and scope of each IT DR plan shall be defined, approved and understood.
- The plan shall set out prioritized objectives in terms of:
 - Critical IT services to be recovered.
 - Time span in which they are recovered.
 - The situation for invoking plans.
 - The recovery levels for each critical IT service.
- The IT DR Plan shall ensure that configuration of servers, network devices and other products at the DC and DR are identical at all times.
- The IT DR plan shall include periodic checks with reference to ensuring data and transaction integrity between DC and DR.
- The IT DR plan shall ensure that support infrastructures at DC and DR have no single point of failure and building management and monitoring systems are present to constantly and continuously monitor the resources.
- The data replication mechanism to be followed in IT DR plan shall ensure RPO compliance for critical applications.

- Stages of escalation and trigger events (interruption, single point of failure) shall be clearly defined.
- Specific IT DR Plans shall be documented and approved for each application. IT DR shall provide detailed instructions on the recovery and restoration of IT processes and systems for each application.
- Technology Recovery Procedures for recovering the IT services shall be developed and coverage shall be given to the following areas:
 - Detailed procedures to restore the application, databases and the associated hardware at the alternate location, taking into account the changed environment.
 - Detailed procedures to restore the network accessibility
 - Procedures for data synchronization and handling of the backlog of information resulting from the disruption.
 - Changes required from the end user to access the application.
- IT DR plans shall be reviewed at least on an annual basis.

V. Training and Awareness

- A formal training program comprising of targeted courses and awareness sessions for the relevant staff shall be developed.
- A process shall be established for evaluating the training requirements for the staff identified to play a key role in the recovery of the IT systems. Appropriate training programs shall be conducted based on the level of skillset and proficiency determined to enable the person to perform the task.
- DR Drill shall be performed to ensure adherence to Business Continuity metrics.
- Alternative site options and resource availability shall be planned as a part of Business Continuity and tested for the same.
- Periodic Participation of organization in national/ sectoral/ organizational Cyber Security Exercises.

3.3.1 Outsourced relationship management All information and applications outsourced to a third-party service provider shall include adequate plans for continuity of service developed and tested by the third-party service provider and approved by Organization. An Organization liaison with the third party service provider shall supervise execution of the disaster recovery activities in the event of a disruption of service to the Organization.

3.3.2 IS consideration in BCM

1. A managed process shall be developed and maintained for business continuity throughout the organization that addresses the information security requirements needed for the organization's business continuity.
2. A comprehensive Business Continuity Plan (BCP) shall be developed and implemented in order to maintain or restore business operations in the required time scales following interruption to, or failure of, critical business processes. The BCP shall include effective Disaster Recovery procedures for quickly recovering from an emergency with minimum impact to the company's operations.
3. Business Continuity Plan shall be developed based on critical business processes and the likely disruptive events along with their probability, impact and consequences for information security identified through Business Impact Analysis.
4. It shall be ensured that any new application introduced in the IT environment of Organization shall have a documented ITDR processes based on its criticality and shall integrate with the existing recovery processes. It shall also have a business defined RTO and RPO.
5. Any changes made that may have an impact on the developed recovery procedures shall be duly identified as a part of the change control process and shall be approved by the ITDR Manager before implementation.

3.3.3 Testing of BCP

1. The business continuity and DR plans shall be tested at least once annually or when significantly changed to identify incorrect assumptions, oversights, or changes in equipment or personnel.
2. Test results shall be reported to the ISRMC and shall be used to revise the BCP / DRP

3. IT DR testing framework shall include DR drills that represent not only plan shutdown but also real disaster scenarios.
4. All IT DR tests shall be conducted after careful planning to ensure no disruption to the business operations. All risk factors shall be documented and communicated to all affected persons prior to test.

3.3.4 Review of BCP

6. BCP shall be reviewed as per periodicity defined in the BCP itself and after each test and updated to ensure that the BCP considers the effectiveness of the current nature of business processes, infrastructure, personnel, etc

3.4 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT	IS	Risk	Business Users

Policy No.: 2.14
2.14 Third party service providers

Policy Name:

- | | | |
|---|----------------|--|
| 1 | PURPOSE | To define desired practices concerning the selection, enrolment, and termination of third parties and operations handled by them. |
| 2 | SCOPE | <p>This policy is applicable to all third party service providers such as contractors, vendors and consultants who handle, store or transmit Organization's information and information resources in any form.</p> <p>This policy also applies to all information systems information assets and all communication and network connections owned, operated or managed by third parties, through which Organization information assets are transmitted, stored or processed.</p> <p>Technology systems, communications and network connections include, but are not limited to, network devices such as routers and firewalls, servers and mainframes, all operating systems, databases and applications.</p> <p>All Business Units or Departments utilizing the services of a third party for business operations shall comply with this policy.</p> |

3

POLICY

All contracts with Third Party service providers shall require that the third-party service providers provide controls to comply with provisions of the Information security policy for Organization information assets accessible to them, This shall be deemed to conclude that the third party shall provide security at a level at least as secure as Organization would provide internally. In addition:

- If confidential information is involved, a nondisclosure agreement shall be signed.
- Assessment of the third-party service provider for compliance shall be included in the agreement. Exchanges of information assets between Organization and any third party may not proceed unless and until a written agreement has been reviewed and signed.
- All third-party service providers and contractors shall be under signed contract with Organization before access to Organization information assets can be granted.
- Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.

3.1

Vendor IS classification

1. All third party service providers shall be classified with respect to Information Security based on a third party service provider classification standard defined by the IS team. The third party service provider classification standard shall consider the following parameters:
 - Nature of the activity performed by the service provider
 - Classification of information assets accessed by the third party.
 - Access to non-information assets including Organization premises
 - Criticality of operations of the third party
 - Access to Organization's Intellectual property
 - Providing services having a regulatory significance
 - Exclusivity and availability of multiple service providers in that line of service or geography
2. The third party service providers' classification standard shall define the information security requirements, periodicity and mechanism of

compliance assessment and contractual requirements (such as escrow or service level requirements), for each class of third party vendors.

3.2 IS provisions in contracts and SLAs

1. All third party service providers shall be empaneled for the services of Organization only after a contract is signed between Organization and the service provider.
2. The contracted terms and condition shall be drafted by the Legal department of Organization for safeguarding the interest of Organization in consultation with Compliance, Risk and IS departments.
3. All agreements/documents with third parties shall be digitally signed using a special tool
4. The contract shall define, in addition to the services to be performed by the service provider, information security requirements to be adhered to while performing the service depending upon the classification of third party service provider as defined in the third party service provider standard.
5. The service level agreement shall be drafted by business department at time of empanelment of service provider and shall be monitored on a periodicity defined in the third party service provider standard.
6. In order to be able to enforce performance, information security and other controls to address outsourcing risks, Organization shall build the right to audit as part of contract with vendors.
7. If the vendor is certified under the ISO27001 standard, and if the scope of services provided to Organization is included under the scope / statement of applicability for the certification, the vendor may be accepted from the requirement for periodic audits by Organization. However, in such a scenario, the vendor will be required to furnish the following:
 - a self-certificate of compliance to all IS provisions in the contract
 - Copy of a valid ISO27001 certification demonstrating that the scope of services provided to Organization is

3.3

Enrolment and change

included under the scope / statement of applicability for the certification

1. The business department proposing to outsource an activity shall perform appropriate due diligence on the shortlisted vendor to assess the capability to comply with information security obligations in the contractual agreement. The due diligence shall be performed based on the classification of the third party service provider standard through either the following means:
 - Self-appraisal by the vendor;
 - On-site visit by Organization personnel
 - Information collected from other public sources.
2. Due diligence process shall involve evaluation of all available information about the service provider such as:
 - Past experience and competence to implement and support the proposed activity over the contractual period;
 - Business reputation and culture, compliance, complaints and outstanding or potential litigation;
 - Security policy, procedures and internal control, audit coverage, reporting and monitoring environment, Business continuity management;
 - External factors like political, economic, social and legal environment of jurisdiction in which the service provider operates and other events that may impact security posture of the service provider;
 - Procedures in place for ensuring due diligence of its employees by the service provider
3. The due diligence shall be performed at the time of enrolment of a new service provider or in event of changes to the services being provided by an existing service provider.
4. Appropriate Due diligence shall be performed to verify sub-contracting arrangements of third party vendors

3.4**Periodic
assessment**

1. Every third party service provider shall be assessed on a periodic basis to ensure that they remain compliant with the requirements of the agreements and information security requirements of Insurance Company, as per the periodicity defined in the third party service provider standard.
2. The periodic assessment shall cover:
 - Services mentioned as part contract are performed as per SLA;
 - Personnel employed by service providers:
 - are competent with knowledge of product and processes handled
 - are not barred by regulator or other legal authorities;
 - Adequate infrastructure to perform the services;
 - Adequate documentation of customers, bank and service records;
 - Potential conflict of interest
 - IS provisions as defined in the contract
 - Confidentiality and non-disclosure agreements as defined in the contract

3.5**Termination**

1. Organization shall reserve the right to terminate the services of any third party service provider on non-performance or non-conformity to any of Organization's contractual requirements including information security requirements. The clauses for termination shall be clearly laid out in the contract with the service provider.
2. Upon termination or expiry of the contract, through natural expiry of the period of the contract or due to invocation of termination clauses by either party, the following requirements shall be adhered to:
3. The service provider shall be expected to return any assets that belong to Organization which are in the possession of the service provider during its tenure of service.
4. Access to Organization's Information assets and premises, provided to the third party service provider's personnel or systems shall be revoked with

immediate effect or on the date of contract expiry to ensure the service provider does not continue to access Organization's information systems / premises.

3.6 Data Sharing and retention

1. Valid business purpose must be defined for the data that needs to be shared with the Third Party Service Provider.
2. Any data generated by the third party in the course of its operations performed for Organization shall belong to Organization and shall follow Organization's policies.
3. Organization Data, when it is in control of the third party will have to be subjected to the same or more stringent controls based on the classification of the data as per the requirements laid down in the IS policy.
4. Organization shall have the right to delete company related information from the vendor assets used for the activity, and certify it as per the data retention policy.
5. Upon the termination of the contract all data transferred by Organization or generated by the third party for Insurance Company, shall be handed-over to Organization.
6. Data, when in transit shall be subjected to the same or more stringent controls, based on the classification of the data as per the requirements laid down in the IS policy.
7. Data will not be shared by the third party with any other entity apart from Organization without explicit approval from Organization and without an explicit contract which mandates compliance with Organization policies.

3.6 RACI Matrix

Responsible	Accountable	Consulted	Informed
Third party service provider	Business units proposing to outsource services	Legal, Compliance, IS, Risk	Finance

Policy No.:	2.15
Policy Name:	2.15 Physical and environmental security

- | | | |
|-------|--|---|
| 1 | PURPOSE | <p>To define the desired practices concerning physical and environmental security at Organization for ensuring a secure environment for its employees as well as its tangible and intangible assets.</p> <p>The physical security policy of Organization shall aim at ensuring a secure environment for its employees as well as its tangible and intangible assets.</p> |
| 2 | SCOPE | <p>Physical Security provides the fundamental layer of control on safety, security and maintenance of People and Assets (including premises and infrastructure). Physical threats are important business risk as continuity of business operations depends on safety of people and infrastructure (including operating premises and information systems).</p> <p>This policy applies to all assets of Organization i.e.</p> <ul style="list-style-type: none"> • People such as employees, contractors, service providers / visitors accessing the Organization facilities. • Infrastructure such as building premises, furniture and fixtures, office equipment, physical documents and other electro-mechanical installations |
| 3 | POLICY | <p>All assets of Organization (People and Infrastructure) shall be protected from unauthorized or illegal access as well as business and environmental threats.</p> <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Zoning and Perimeter Definition | <p>Facilities of Organization shall be categorized into different zones based on the activities performed in them or the installations found in them. Correspondingly each zone shall have different levels of security. The classification into zones is detailed in sub-sections below:</p> |
| 3.1.1 | Zone 1 or Semi-Public Zone | <p>Zone 1 shall essentially be the area within building premises between the entry gate and the point of entry protected by an access control system. The same shall be accessed with minimal restrictions. In general, the front hall, meeting rooms and reception which are open to the general public shall be considered semi-public zones.</p> |

3.1.2	Zone 2 or Controlled Zone	Zone 2 shall be the primary work area which can be accessed only after a thorough verification of the identity of the individual. Zone 2 shall be open only to authorized individuals who have been duly identified and have a business purpose to enter this area.
3.1.3	Zone 3 or Secured Zone	Zone 3 shall be a demarcated zone containing confidential data, sensitive or valuable assets (non-electronic) which require enhanced protection. Access to Zone 3 shall be highly restricted and shall be granted only on an absolute need basis. The specific individuals having access to this Zone could be: • A special team within Insurance Company • External service providers required to access the Secured Zone for business purposes • Some of the areas within Zone 3 would include: • Dealing Room/ Trading Floor • Operating areas where cash and valuables are kept • Compactor rooms
3.1.4	Zone 4 or Electronically Sensitive Zone	1. Zone 4 shall be a demarcated electronically sensitive zone containing electronic assets which may host Organization's data. This may include sensitive assets or systems which require enhanced protection. Access to Zone 4 shall be highly restricted and shall be granted only on an absolute need basis. The specific individuals having access to this Zone could be: • A special team within Insurance Company • External service providers required to access the Secured Zone for business purposes • Areas within Zone 4 would include: • Server rooms • Datacenters • Hub Rooms 2. Organization shall ensure that Zone 3 and Zone 4 spaces are away from the entry/exit points in the building. Their location must not be displayed explicitly. 3. Each Secured Zone shall have a designated owner. The Secured Zone owner shall be responsible for

- Identifying the persons (internal staff and outside contractor, suppliers and visitors) authorized to access the Secured Zone
 - Validating the list of persons authorized to enter the Secured Zone on a periodic basis
 - Revoking all unnecessary / unauthorized access rights to the Secured Zones
4. If an employee is found breaching the policy laid down for Zone 3 and 4 by the security personnel, the incident shall be reported to the site in charge (admin personnel) and CISO for taking actions as mandated by the procedure followed at the particular site. In case there is no procedure defined, the CISO shall escalate the matter to the ISRMC and shall thereafter take appropriate action as deemed necessary and also establish a formal procedure if felt necessary.

3.2 Physical Access Standards for Zones

3.2.1 ZONE 1

1. Building / Premises [referred to as 'Premises' henceforth] shall refer to areas under the direct management control of Organization management as defined below:
 - In case the entire structure is owned or leased by Organization management, premises starting from the entry / exit gates to the structure from the public access street level shall be referred to as Premises under management control of Organization.
 - In case where Organization has leased parts / owns only part of a building, Premises under management control shall refer to the Floor / Wing or any specific work area physically segregated from the rest of the building for purpose of ownership. Organization shall request the premises authority to comply with its policies to the extent possible to ensure safety of its own assets.

2. Access to Premises shall be granted to all people requiring access to them for professional reasons such as carrying out duties of work (employees / contractors / service providers) or seeking services from any Organization entity (clients).
3. Entry to Premises shall not by default entitle access to work areas or restricted areas but shall only allow access to Zone 1 (areas accessible to general public for professional purposes). This shall include (not exhaustively) the following:
 - Lobby / Reception
 - Meeting rooms in the entrance lobby
 - Cafeteria if it is outside the perimeter requiring access badges for entry / exit
4. Access to Zone 1 shall be protected from unauthorized access by safeguards such as security guards stationed at entry / exit gates of the Premises.
5. Security guards shall be stationed at the main entrance to protect against unauthorized access to the location premises. The guard shall be on duty 24x7. An administration team member shall be appointed as 'in-charge' for each Organization Premises and shall be responsible to implement the policy for the Premises. In case of premises not having dedicated person, the respective branch manager / Head of the Business, shall be responsible to implement the policy for the premises.
6. Certain individuals notified by Organization Management can also be restricted from accessing the Premises open to general public. Such a restriction shall need to be notified by the CISO and the in-charge of Premises for each building and shall need to be approved by ISRMC.
7. For Employees / and Long Term Contractors:
All employees of Organization and contract staff who are authorized to enter the premises shall be provided with access cards (badges) identifying them to the organization. Access to Premises shall

be granted upon display of identification badges issued to the employee / long term contractors. The access cards possessed by the employees / contractors shall grant them access to the premises by default.

8. For Service Providers/ Visitors:

Service providers and Visitors requiring access into the premises for official purposes shall approach the reception staff / security guards at the reception and shall need to identify themselves. They shall need to declare the purpose of their visit and shall then be granted access.

3.2.2 ZONE 2

1. Work areas shall refer to areas that can be accessed only after a thorough verification of the identity of the individual and shall include the sections where the employees carryout their daily activities.
 2. Access to these areas shall be granted to individuals only for professional reasons and only once they have been duly identified.
 3. Entry to work area shall not by default entitle access to sensitive areas or restricted areas but shall only allow access to areas that can be accessed by all employees or long term contractors but not by the general public by default.
 4. Access to work areas shall be controlled by access cards (badges) or equivalent security measures. The access cards shall duly identify the individual and grant him / her access to the permitted areas based on the individual's job profile and responsibilities.
 5. Preferred mechanism for Zone 2 shall be automated access controls (for example, displayable badges combined with proximity based access control) for restricting access to work areas. In absence of an automated system, access to work area shall be controlled by way of security guards stationed at entry / exit points.
- a) For Employees / Long Term Contractors
- I. All employees of Organization entities and contract staff who are authorized to enter the premises on a long term basis shall be provided

with Personalized Identification Card access cards (badges) identifying them to the organization. Access to Premises shall be granted upon display of identification badges issued to the employee / long term contractors.

- II. Certain long term contractors shall also have individual access cards with their name and photograph printed on the face of the card. Other long term contractors will be issued General Purpose Long Term Cards.
- III. In general, access cards for Zone 2 shall not be transferrable. However, when required to be transferrable for contractors working in shift duties an offline record of the ownership of the card will be maintained in the shift entry register to establish accountability for usage of these cards.
- IV. The badge holder shall be responsible for:
 - Using the badge to gain access to the controlled/secured zone
 - Wearing the badge noticeably
 - Not entrusting the badge to another person
 - Not using the badge to allow access to any other person (tailgating)
 - Surrendering the badge on expiry of the rights justifying its possession.

b) For Service Providers / Entities Authorized to Enter for A Limited Period

- I. Service providers requiring access to the premises for official purposes for a period of more than a single work-day shall be issued General Purpose Long Term Cards with 'C' marked on them.
- II. Entities authorized to enter the premises for a limited period shall be issued visitor badges with 'V' marked on them.
- III. In both cases the period of grant of access shall be configured on the badge itself. In general, the access shall be configured for the main entrance, the cafeteria and the floor that the contractor /other visitor shall need access to.

- IV. Access to Premises shall be granted upon display of identification badges issued to the individual and in addition through appropriate configuration in the automated access control system, if implemented for contractors.
- c) For Visitors Authorized to Enter the Premises On a One-Time Basis
1. All visitors requiring access to the premises on a one-time basis shall be issued General Purpose One Time Visit Card. The visitors shall need to identify themselves and the purpose of their visit to the reception staff or security guards stations at the entry/exit to Organization Premises. Access to work areas shall be granted to visitors as follows:
 - a) The reception/ Security staff shall make an entry of the visitor and capture details of the visitors such as name, Date& time of visit, whom to visit (host), purpose of visit, details of items carried such as laptops, mobiles, pen drives and other portable media.
 - b) Upon identification and verification, the reception staff / guard shall verify the purpose of visit with the concerned staff, and provide the visitor with a temporary visitor pass.
 - c) Unless specifically requested and approved, this "V" card will be without Access rights.
 - d) The host shall be informed by the reception staff who shall escort the visitors into the areas as required.
 2. The responsibilities of the visitor shall include:
 - a) Wearing the badge noticeably
 - b) Not moving around in the company's buildings without being accompanied by the host.
 - c) Surrendering the visitor pass / badge on exit once the purpose of the visit has been accomplished
 3. The responsibilities of the host shall include:
 - a) Announcing his/her visitors in advance if already known
 - b) Requesting the appropriate physical access rights for his/her visitors

- c) Escorting the visitor in and out of the premises and accompanying his/her visitors throughout their presence in the company's buildings
- d) Informing his/her visitors of the company's rules relating to moving around in the premises
- e) Ensuring that his/her visitors surrender their badges when the visit is over.

3.2.3 SENSITIVE AREAS (ZONE 3 AND 4)

1. Sensitive areas shall refer to the areas that can be accessed only after a thorough verification of the identity and purpose of the individual. Access to these areas shall be extremely restricted and granted to individuals only on an absolute need basis.
 2. Due to the nature of the activities performed in these areas or the tangible and intangible value of the assets stored in these areas the level of security controls implemented to access these areas shall be high.
 3. Access to these areas shall be granted for strictly professional reasons. Visitors shall not have access to these areas unless required for business purposes
 4. Preferred mechanism for access to sensitive areas shall be the use of an automated access control system. In absence of automated access control assets in sensitive areas shall be secured by the use of lock and key. In absence of an automated system or lock and key, access to sensitive area shall be controlled by way of security guards stationed at entry / exit points.
 5. Access shall be granted only on an absolute need basis. For anyone other than the individuals authorized to access the sensitive areas, on a perpetual basis, due to the nature of their work, an explicit approval shall be required from the designated sensitive area owner.
- I. For Employees / Long Term Contractors**

Employees or long term contractors who need to have access to these areas due to the nature of their work shall be granted access to these areas using access badges. The access badges of such employees and contractors (typically technical maintenance staff etc.) shall be configured to grant them access to these areas. The access rights for such individuals shall be reviewed by the designated manager / secured area owner on a half yearly basis to ensure that the access rights remain as required.

II. For Service Providers

Service providers requiring one-time access to the sensitive area shall have to identify themselves at the reception. Upon identification and an explicit approval shall be required from the designated sensitive area owner they shall be granted temporary access pass. The service providers shall be escorted throughout their duration of visit by an employee authorized to enter the sensitive area.

III. For Visitors

Visitors shall not be granted access to the sensitive areas. Any exceptions to this shall require an explicit approval from the designated sensitive area owner. Also any such cases shall need to be escorted throughout their visit to the sensitive areas by an employee authorized to enter the sensitive area.

3.3 Environmental Standards for Zones

Environmental security controls shall be implemented by Organization to protect its People and Infrastructure from physical and environmental threats. The protection of the People and Infrastructure is essential for the overall effectiveness of the overall security support structure. This policy shall ensure that appropriate measures are taken to safeguard the People and Infrastructures from incidents such as fire, flood, electrical supply, temperature extremes and earthquakes.

The administration teams shall be responsible for the design and implementation of environmental controls

and the CISO shall be responsible to ensure their adherence and compliance.

3.3.1 Zone 1

1. Buildings shall have minimal points of entry to avoid unauthorized personnel gaining access to building
2. Fire exits shall not be locked and shall have one-way crash bar, easy opening mechanism and where possible trigger an appropriately loud alarm when opened to prevent misuse of the same. If it is locked key should be provided next to it in Breakable Glass box, which can be used by the employees for opening the door in emergency situation.
3. Buildings shall have appropriate lightning protection which shall be tested on periodic basis
4. Buildings shall have a backup power source to continue minimum necessary operations. The preferred mechanism for the same shall be installation of DG sets in case of power failure. Where feasible, a UPS power backup shall be installed for critical resources to provide uninterrupted power supply in case DG sets are not operational.
5. A technical team shall be available to monitor environmental parameters / respond to anomaly reported by the monitoring staff particularly if the anomaly pertains to server rooms / data centers.

3.3.2 Zone 2

1. Work Areas shall be accessed through access control cards to restrict unauthorized entry of any personnel.
2. Work areas shall be monitored for any leakage or any water intrusion.
3. Work areas temperature shall be monitored by the monitoring staff and administered by a person in charge.
4. Work areas shall have sufficient number of fire exit points and employees shall be given training of fire evacuation procedure in case of emergency. Evacuation drills shall be performed at least on an annual basis.

5. Fire extinguishers shall be positioned at each floor. ERT members present at every floor shall be trained to operate the fire extinguisher in case of any emergency situation.
6. Work areas shall have smoke detectors positioned all over to detect any instance of fire and give warning alarm immediately.
7. Floor plans shall be displayed at specific locations on each floor.
8. Employees are expected not to carry inflammable items.

**3.3.3 Environmental
Security For
Sensitive Areas
(Zone 3 And
Zone 4)**

1. Sensitive areas shall be protected from any water leakage and will be monitored by the BMS team.
2. Smoke detectors shall be positioned to detect any instance of fire.
3. Alarms and Intrusion detection systems shall be installed to notify of any unwanted object/personnel. All physical intrusions shall be treated at par with information security breaches and thus be investigated accordingly. Corrective and punitive action shall be taken and promulgated to all in case of such an intrusion / breach.
4. Sensitive areas (Data Centers, Server Rooms) shall have appropriate fire prevention equipments installed. Preference shall be given to automated fire detection and suppression equipments. Sensitive areas shall have fire-resistant doors, walls to safeguard against fire damage.
5. Temperature for sensitive areas shall be monitored more frequently. Sensitive areas shall have proper electricity backup.
6. Precision air-conditioning systems to support information systems and equipment like server rooms, network rooms, and disaster recovery sites shall be in place.
7. Dual power supply controls to ensure continuous power supply shall be implemented.

3.4 Security Transit in Appropriate measures shall be implemented by Organization to enable secure transit of information assets stored in Zone 3 or 4.

Organization equipment, data or software must not be taken off-site without proper authorization.

Provision for safe exchange of information assets shall be considered at all times.

The transportation facility shall be managed by a service provider contracted and approved by Organization.

Employees and security personnel shall be expected to adhere to the guidelines provided and be equally responsible to ensure the safety of the assets during the transfer.

3.5 RACI Matrix

Responsible	Accountable	Consulted	Informed
Administration	IS team	Business Function	Employees

Policy No.:	2.16
Policy Name:	2.16 Monitoring, Logging and Assessment

- | | | |
|-----|-------------------------------|---|
| 1 | PURPOSE | To define the Organization desired practices regarding monitoring, auditing and assessment of logs. |
| 2 | SCOPE | This policy applies to all information systems information assets and all communication and network connections through which Organization Information Assets are transmitted, stored or processed. Information systems, communications and network connections include, but are not limited to, network devices such as routers and firewalls, servers and mainframes all operating systems, databases and applications. |
| 3 | POLICY | <p>All critical information systems deployed by Organization for information processing, storage or security shall be monitored through the following means:</p> <ul style="list-style-type: none"> • Real time monitoring through manual means or technology systems capable of generating alerts • Logging of all activities or transactions performed on information systems and periodic analysis of logs • Periodic or one-time security posture assessment exercises including but not limited to device configuration review, security testing of information systems and review of IT processes set up for real time or periodic monitoring. <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Logging and Monitoring | <p>All information systems shall be classified based on the asset management policy and monitoring processes shall be set up as below:</p> <ul style="list-style-type: none"> • Real-time automated detection facilities shall be implemented for systems to monitor significant deviations from normal activity and to alert security administrators of those systems. • Logging shall be enabled for all business transactions, high risk systems and processes shall be set up for real time or periodic manual or automated review of logs. • Logging shall be considered and implemented based on performance implications for low-risk systems and processes shall be set up for periodic review of logs. |

3.2 Physical access
and activity

3.2.1 ZONE 1

3.2.2 ZONE 2

3.2.3 ZONE 3 and
ZONE 4

3.3 Information
systems logging
and monitoring

1. All information systems will be configured to log system activities and generate alerts for any unusual activity to system administrators.
2. The activities of privileged users such as system administrators and system operators shall be logged and independently reviewed on a regular basis.
3. Mechanisms shall be put in place to detect and report activity which violates the information security policy with respect to access, acceptable usage and / or any other aspect addressed by the policy.
4. In absence of automated alerts, a process shall be set up to perform manual review of activity logs, on a frequency defined based on the criticality of the information system.
5. The clocks of all relevant information processing systems within Organization or security domain shall be synchronized with an agreed accurate time source.
6. External and internal requirements for time representation, synchronization and accuracy shall be documented.
7. A standard reference time for use within the organization shall be defined.
8. The IS Operations team responsible for monitoring the network equipment and network activity shall analyze the alerts and logs and any activity requiring action shall be raised as incidents as per the incident management policy before taking such action except in emergencies.
9. Where the action to be taken requires changes to the information system configurations, such changes shall be subject to the change management policy.
10. The activity logs and audit trails shall be stored/retained based on the record retention

requirements and applicable regulatory compliance requirements.

11. Logging facilities and log information shall be protected against tampering and unauthorized access.
12. Logs shall be made available to the Law Enforcement Agencies, IRDAI, Cert-In and CSIRT-Fin as and when required.
13. ICT infrastructure logs shall be maintained as per regulatory guidelines
14. ICT infrastructure logs shall be maintained for a rolling period of 180 days and within the Indian jurisdiction as per directions issued by Cert-In from time to time.
15. Monitor attempts to access deactivated accounts through audit logging.
16. System administrator and system operator activities shall be logged and the logs protected and regularly reviewed.

- 3.3.1 Network access and activity**
1. All communication to or from external networks shall be logged and the logs reviewed periodically or real time automated monitoring mechanisms shall be established for the purpose.
 2. Mechanisms such as internet access filters shall be set up for adherence to acceptable usage policy of Organization with respect to access to external networks; and the same shall be monitored and reviewed.

- 3.3.2 Application access & activity**
- User activities, exceptions, and security events on all applications shall be logged and monitored. Logs must include the following:
1. System starting and finishing times.
 2. System errors or Faults and corrective action taken.
 3. Confirmation of the correct handling of critical data files and computer output.
 4. The name of the person/process / system making the log entry.
 5. Source address from where data or system is being accessed (this might be either IP address or MAC ID).

6. Application shall prohibit users from logging into the application on more than one workstation at the same time with the same user ID.
7. Secondary Network Connectivity and IT infrastructure shall be provisioned and tested for the critical applications and services.

3.4 Transfer and Movement of assets

Organization shall either transfer assets from one Organization entity to the other or move them in and out of Organization facilities when either being procured or sent for destruction.

Procedures shall be developed for entry /exit to and from Organization premise regarding new assets which have been procured or assets which are sent to the vendor premises for repair / sent for destruction / sale

3.5 User activity monitoring

1. User accounts shall be monitored regularly to detect any unwanted privileges, orphan accounts, and dormant accounts. Any accounts detected in violation of Organization's policies shall be suspended or terminated.
2. Redundant/dormant user IDs shall not be issued to other users.
3. A periodic account review shall be conducted and respective managers shall be required to match the current user rights with the business requirements.

3.6 Information Security assessment

3.6.1 Security assessments for infrastructure and applications

1. The IS team will define standards for conducting Vulnerability assessments and security review of infrastructure. The standards shall include:
 - a) Frequency of conducting assessments based on criticality of applications
 - b) Coverage of security assessments
 - c) Approach [internal vs. external] for conducting security assessments based on criticality of applications
2. VAPT of internet-facing applications or infrastructure components to be conducted periodically atleast once in a year.
3. Mandatory security testing shall be conducted for all changes to internet facing information assets or

systems and reported gaps should be closed before moving into production.

4. Business applications including APIs or Web Services etc. shall undergo VAPT Testing including secure code review periodically & before go live.
5. External Blackbox Penetration Testing (PT) should be conducted for all internet facing information assets and systems once in 6 months.
6. Business applications including APIs or Web Services etc. shall undergo Security Audit or VAPT Testing including secure code review periodically & before go live.
7. Network and application vulnerability assessments shall be performed on an ongoing basis by competent personnel. The risks identified shall be documented in the assessment report.
8. The results of the assessment report shall be analyzed and acted upon by the team responsible for maintaining required the information system.
9. High risk gaps, reported from the VAPT, should be closed within a period of one month followed by validation testing.
10. Priority for closure of audit gaps should be based on the risk associated with each gap; however, the outer time limit for closure of all the audit gaps is two months.
11. All security assessments report and the actions taken shall be reviewed by the Information security team.
12. Risks identified through security assessments which remain unmitigated due to technology limitations or business requirements shall be highlighted to the notice of the ISRMC for resolution or exception approval.
13. The results of the assessment shall be communicated to vendors/third party service providers.

3.6.2 Internal IS assessment by IS Team

1. Organization shall conduct annual review of information security practices either by the IS team or by competent independent party appointed by the IS team to ensure compliance with the information

security policies, procedures and internal standards defined by the IS team.

2. Formal procedures shall be developed by the IS team for planning and reporting of reviews findings and ensuring the implementation of a prompt and accurate remedial action.

3.6.3 External IS assessment

1. Organization shall conduct formal external IS reviews by competent independent party to ensure compliance with the information security policies, procedures, external industry standards as per frequency defined by the Information Security team.
2. Formal procedures shall be developed by the Information Security team for planning and reporting audits and audit findings and ensuring the implementation of a prompt and accurate remedial action.
3. The Information Security team shall be responsible for defining the scope of the review and coordinating with the business and support teams.
4. Audit requirements and activities involving checks on operational systems shall be carefully planned and agreed to minimize the risk of disruptions to business processes.
5. Independent assurance auditor shall be rotated every three years.

3.7 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT and Administration team	IS	CRO	Executive Management

Policy No.: 2.17
Policy Name: 2.17 Legal and Regulatory Compliance

- | | | |
|-----|--|--|
| 1 | PURPOSE | <ul style="list-style-type: none">• To ensure compliance with all relevant legislation and laws (criminal and civil), regulations, standards/guidelines and codes; simultaneously fulfilling the requirements for statutory, regulatory and contractual obligations.• To avoid breaches of legal, regulatory, statutory or contractual obligations impacting information security and of any security requirements.• This policy requires Organization to ensure that employees and third parties (including vendors & contractors) understand and adhere to legal, statutory, regulatory, contractual, and security requirements that may have an impact on the business. |
| 2 | SCOPE | <p>The policy applies to all areas and all activities of Organization. Every employee, contractor, sub-contractor, agent and supplier of Organization is required to comply with all aspects of the law and to act ethically, at all times:</p> <p>In this policy, a reference to the law includes:</p> <ul style="list-style-type: none">• Acts, regulations, codes, and other subordinate legislations;• Operating licenses and other authorizations;• Government and industry guidelines and practice statements;• Conditions imposed on approvals and other licenses;• Any new relevant guidelines issued in the future |
| 3 | POLICY | <p>Organization is committed to complying with laws as they apply to it and to demonstrating ethical behaviour. Organization will:</p> <ul style="list-style-type: none">• comply with all relevant legislation, laws, standards, codes, and internal policies;• monitor compliance with its legal and ethical obligations; and• take appropriate corrective action to prevent recurrence of compliance failures |
| 3.1 | Legal and Regulatory Requirements | <ol style="list-style-type: none">1. All relevant legislative statutory, regulatory, contractual requirements and the organization's approach to meet these requirements shall be explicitly identified, documented and kept up to date. (Please refer Annexure A) |

2. Appropriate procedures shall be implemented to ensure compliance with legislative, regulatory and contractual requirements related to intellectual property rights and use of proprietary software products.
3. Regulations backed by statute shall be made compulsory.
4. Formal risk analysis shall be done that will enable controls to be selected from policy that address the applicable controls that are required by the principal regulators and legal obligations.
5. It shall be ensured that the local legislative, regulatory and contractual control requirements are identified and included in the list of all Identified legal, regulatory and contractual requirements.
6. Advice and approval on the statutory, regulatory and contractual requirements of Organization Office shall be sought from the legal department. The CISO shall document the requirements in a register with the corresponding controls associated with each regulatory and legal requirement.
7. The legal department shall instruct the employees on the legal requirements and the compliance to such legal requirements.
The legal department shall also ensure that the controls are implemented immediately to ensure compliance. Regular review to the compliance shall be carried out by the legal department

- 3.2 Adherence to IRDAI guidelines**
1. Circulars are issued by IRDAI stating the amendments in security requirement / working procedure. Organization shall adhere to all applicable guidelines issued by IRDAI.
 2. Guidelines issued by IRDAI circulars shall be incorporated in the operation of Insurance Company

- 3.3 Adherence to IT Act ,2000 and Rules, IT (Amendment) Act2008 & Other applicable Acts**
1. Organization shall take preventive steps to protect the confidentiality of customers' data / information as per the act. Amendments have been done in IT Act 2000, latest amendments have been incorporated in it, Organization shall adhere to the guidelines stated in IT Act 2008.
 2. The issues relating to e-mail messages, Internet Banking and Communication network in the light of IT Act 2000 shall be adequately addressed.
 3. The provisions in the IT Act 2000 shall be clearly understood to protect the data environment in Organization and for prevention of frauds.
 4. Procedures shall be devised to comply with amendments to IT Act, 2000 or enactment of supporting Cyber laws or Privacy laws
 5. Organization shall adhere to the applicable guidelines stated in the Aadhaar Act guidelines, rules, acts and amendments thereto

3.4 RACI Matrix

Responsible	Accountable	Consulted	Informed
Legal team	CISO (Information Security)	Risk, Audit & Compliance team	Executive management

Policy No.: 2.18
Policy Name: 2.18 Situational Awareness

- 1 PURPOSE** Situational awareness refers to the Organization's understanding of its cyber threat environment and the adequacy of its cyber risk mitigation measures.
- 2 SCOPE** This policy applies to Insurance Company's cyber security controls which is already in place or planned to be implemented in order to mitigate the evolving cyber risks
- 3 POLICY** Organization shall establish and follow a cyber-threat intelligence process, analysis and information sharing process including but not limited:
- 3.1 Identification of Potential Cyber Threats**
1. The following Cyber threats shall be identified:
 - That could affect the operational performance
 - Cause significant impact to meet Organization's objectives and obligations
 - Cause threat to critical business, processes and reputation
- 3.2 Threat Intelligence Process**
2. Organization shall establish a process to gather and analyze cyber threat information in conjunction with internal and external business and system information sources
- 3.3 Information Sharing**
1. A plan shall be defined for information-sharing through trusted channels when an incident occurs as part of organization's response programmes for cyber-attack
 2. Organization shall actively participate in information-sharing groups to receive and share indicators relating to cyber incidents.
 3. Information sharing arrangements shall be documented in Cyber Crisis Management Plan [CCMP] in case of a large incident to facilitate sector-wide response. Cert-In / NCIIPC guidelines may be used for preparing Cyber Crisis Management Plan including information sharing arrangements.

3.4 RACI Matrix

Responsible	Accountable	Consulted	Informed
Information Security Team	CISO [Information Security]	CRO	Executive management

Policy No.: 2.19
2.19 Cloud Security Policy

Policy Name:

1 **PURPOSE** To define the Organization desired practices regarding Cloud Security.

2 **SCOPE** This policy applies to all business functions and its information systems, information assets and all communication and network connections that use or plan to use cloud computing services or cloud infrastructure services. Information systems, communications and network connections include, but are not limited to network devices such as routers and firewalls, servers and mainframes and operating systems, databases and applications.

- a. Data
- b. Application
- c. Functions
- d. Process
- e. Network connections
- f. Underlying Hardware

The assets are to be evaluated on the following factors:

- I. Determine how important the data or function is to Insurance Company
- II. Analyze the impact of the scenarios:
 - i. The asset becoming widely public and widely distributed
 - ii. An employee of the Cloud service provider accessing the asset
 - iii. The process or function being manipulated by an outsider
 - iv. The process or function failing to provide expected results
 - v. The information/data being unexpectedly changed
 - vi. The asset being unavailable for a period of time

3 **POLICY** The objectives of this policy are:

- a. To ensure that the cloud service is in accordance with the business and security requirements and relevant laws and regulations for:
- b. Provisioning and Commissioning of Cloud Services.

- c. Operations and Management of Cloud Services.
- d. De-commissioning of Cloud Services.
- e. To evaluate the following factors in cloud adoption decisions:
 - i. Technical adequacy for porting the application to the Cloud – Assess the application profile to ensure it is a right fit to be ported to the Cloud.
 - ii. Risk including availability requirements, regulatory, compliance and statutory requirements, data sensitivity.
 - iii. Control over intrusion decisions, vulnerability monitoring, denial of service attacks.

Any deviation from this policy shall be treated through risk management and exception management as defined in the ICSP

3.1 Cloud Service Models Cloud service delivery is divided among Four archetypal models

Cloud Software as a Service (SaaS)

1. The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure.
2. The applications are accessible from various client devices through a thin client interface such as a web browser [e.g., web-based email].
3. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user specific application configuration settings.

Cloud Platform as a Service (PaaS)

1. The capability provided to the consumer is to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages and tools supported by the provider.
2. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, or storage, but has control over the deployed applications and possibly application hosting environment configurations.

Cloud Infrastructure as a Service (IaaS)

1. The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources where the consumer is able to deploy and run arbitrary software, which can include operating systems and applications.
2. The consumer does not manage or control the underlying cloud infrastructure but has control over operating systems, storage, deployed applications, and possibly limited control of selected networking components

Business Process as a Service (BPaaS)

1. The capability provided which includes, business process outsourcing (BPO) services that are sourced from the cloud and constructed for multitenancy
2. The Services are often automated, and where human process actors are required, there is no overtly dedicated labor pool per client

3.2 Cloud Deployment Models

1. **Public Cloud-** Cloud infrastructure owned and operated by a third-party organization selling cloud services and available on a rental basis to the general public or a large industry group
2. **Private Cloud** - Cloud infrastructure is owned and operated solely for a single organization. It may be managed by the organization or a third party and may exist on-premises or off premises.
3. **Hybrid Cloud-** Cloud infrastructure is a composition of two or more different cloud infrastructures (private, community, or public) that remain separate entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., load balancing between clouds).

3.3 Compliance

Organization shall ensure compliance with various IRDAI guideline and related laws, regulations and guidelines issued by the regulating authority in India as applicable

3.4	Cloud security lifecycle	Governance and risk management, while the deployment model may define accountability and expectations. Organization shall ensure before signing an agreement with the cloud service provider, to the complete approval of all the mandatory controls.
3.4.1	Authentication	It shall be ensured that the Cloud Service Provider supports various Multi-factor authentication mechanisms. Authorization shall be followed as per the existing “Information and Cyber Security Policy, Security Domain Policy, Section 2.2 – ‘Asset management’, subsection 3.2.2.3 – ‘Authorization Inventory’”. Organization shall affirm that the cloud service providers authentication process, access control, accountability and logging is in line with applicable regulatory and legal requirements.
3.4.2	Physical Security Controls	Customer data shall be protected from any unauthorized access. The Physical Security Controls shall be followed according to the existing “Information and Cyber Security Policy, Security Domain Policy, Section 2.15 – ‘Physical and Environment Security’”. The additional physical security controls are mentioned as follows: • Organization shall ensure that the Cloud Service Provider complies with the appropriate security controls of the infrastructure. Effective physical security shall ensure that centralized management system allows for correlation of inputs from various sources, including property, authorized employees. • It shall be recommended to opt for Cloud service providers that conform to the ISO 27001 standard for physical and environmental security.
3.4.3	Infrastructure Security [for private cloud and IaaS for public cloud]	Design of the Cloud environment shall be based on appropriate security guidelines such Cloud Security Matrix by Cloud Security Alliance or as per guidelines defined by IS Team. The IS team shall perform an assessment of private Cloud services prior to roll out based on industry standards and IS policy provisions. An infrastructure standard shall be defined and implemented for commissioning of cloud infrastructure including servers and network equipment. The standard shall consider legacy infrastructure or provision for reuse or retiring the same if

required. The standard shall also include minimum security baseline standard.

Appropriate tools / procedures shall be put in place for managing and monitoring infrastructure operations including Cloud characteristics such as storage utilization, provisioned allocation vs. actual utilization, host machine uptime, virtual machine uptime, network uptime and infrastructure and application response times, patch management, change management, incident management, antivirus management.

Infrastructure integration architecture shall be defined for integration within the data center and across multiple data center. All applications and infrastructure elements shall be evaluated for their suitability to operate on the Cloud environment prior to migration, including checks for compatibility and information security baseline. A procedure document shall be made available for performing such a migration. Necessary approvals from Security and Business shall be obtained at various stages during migration as defined in the existing "Information and Cyber Security Policy, Security Domain Policy, section 2.5 - Information Systems acquisition and development. Cloud infrastructure shall follow the existing Organization's Information Systems Maintenance policy including access control, change management, Data security, backup and restoration, patch management, job scheduling, capacity and performance management, malicious software management, vulnerability management, and IT service management.

3.4.4 Network Security

Network security consists of security services that restrict or allocate access and distribute, monitor, log, and protect the underlying resources services.

It shall be followed according to the existing "Information and Cyber Security Policy, Security Domain Policy, Section 2.11. 'Network Security'".

Also, Organization shall ensure that the cloud service provider has documented and tested processes for:

- a. Access controls, for management of the network infrastructure
- b. Traffic filtering provided by firewalls
- c. Creating secure Virtual Private Networks (if VPN is offered)
- d. Intrusion detection / prevention

- e. Mitigating the effects of DDoS (Distributed Denial of Service) attacks
- f. Logging and notification, so that systematic attacks can be reviewed.

3.4.5 Data Isolation

In case of utilization of cloud services, Organization shall ensure that its data is adequately isolated in the cloud environment. Organization's data on the cloud shall be isolated such that it can operate as a separately managed entity/entities.

Mechanisms shall be established to ensure appropriate isolation exists at the network, operating system, application layer and database.

For a multi-tenant cloud environment, the following shall be ensured:

- Mechanisms shall be defined for separating the usage of storage, memory, and routing. The isolation of applications and data shall be ensured. In an isolated architecture, the data shall be segregated into its own database instance. For multi-tenancy, an architectural and design approach shall be adopted to economies of scale, availability, management, segmentation, isolation, and operational efficiency.
- For the application deployed on the Cloud using native multi-tenancy features offered by the application, privacy of data across tenants or entities shall be ensured through appropriate access control mechanisms. Application shall clearly log business errors and technical errors separately to support separation of duties between business users and data center operator.

3.4.6 Data Classification

Data Classification shall be followed in accordance with the existing "Information and Cyber security policy, Security Domain Policy, Section 2.1 – 'Data Classification'".

3.4.7 Encryption

As defined in the existing "Information and Cyber Security Policy, Security Domain policy, Section 2.12 – 'Cryptographic Controls'", Organization shall ensure that appropriate cryptographic controls are applied to data depending upon its classification as per encryption requirements defined in the data classification policy. Organization shall ensure that a unique set of encryption key(s) are utilized, in accordance with the existing "Information and

Cyber Security Policy, Security Domain Policy, Section 2.12 – ‘Cryptographic Controls’.

Organization shall ensure that the cloud service provider support Key Management Interoperability Protocol (KMIP). KMIP provides a standardized way to manage encryption keys across diverse infrastructures.

Organization shall prefer Hardware encryption keys, in compliance with the Federated Information Processing Standard (FIPS) 140 2-3 and above, whenever compatible.

Organization shall devise encryption, key management procedures in accordance with the already existing Organization’s information security policy for the following:

- a. To encrypt data in transit, at rest, backup media
- b. To Secure key store
- c. To protect encryption keys
- d. To ensure encryption is based on industry/ government standards
- e. To Limit access to key stores
- f. Key backup and recoverability
- g. To test these procedures

3.4.8 Application Security

Organization shall ensure Application Security for applications hosted over the Cloud in accordance with the existing “Information and Cyber Security Policy, Security Domain Policy, Section 2.5 – ‘Information Systems acquisition and development’, subsection –‘Application Security’”.

3.4.9 Incident Management

The incident management for cloud services shall be followed in accordance with the existing “Information and Cyber Security Policy, Security Domain policy, Section 2.10 - ‘Incident and Problem Management’”.

3.4.10 Business Continuity and Disaster Recovery

Organization shall ensure Business Continuity for cloud services shall be in accordance with the existing “Information and Cyber Security Policy, Security Domain Policy, Section 2.13 – ‘Business Continuity Management and Disaster Recovery’”.

In addition, Organization shall also audit the Cloud service provider’s disaster recovery plan and ensure it meets Organization’s requirements. At minimum, the following shall be considered:

- i. The ability to retrieve and restore data following data loss incidents.
- ii. The cloud service provider shall provide Organizational disaster recovery testing report that would be extensive,

covering from exercise scope to the final outcome and recommendations.

- iii. Make sure the DR (Disaster Recovery) solution is capable of maintaining the same levels of security measures and controls utilized in normal operation mode.
- iv. Assure that the Disaster recovery solution is owned and managed completely by the contracted Cloud Service Provider.

It is recommended to opt for cloud service providers who are BS25999 or ISO 22301 certified.

Business Continuity Plans shall be in place for cloud sourced services based on regular BCP and provisions for the same shall be included in Organization contracts.

A confidential document containing account information for business continuity purposes shall be maintained

3.4.11 Exception Management

An “exception” shall be defined as circumstances when a particular policy or standard; security program requirement; or security best practice cannot be fully implemented.

Organization shall develop, publish and implement administrative, technical and physical safeguards in an effort to adequately protect the confidentiality, integrity and availability of its assets on an exception basis.

The Exception Management for Cloud Services shall be followed in accordance with the existing “Information and Cyber Security Policy, General Guidelines, Section 1.8 –‘Exceptions’”.

3.5 Off boarding of cloud service provider

Upon termination of contract, all data transferred by Insurance Company, or generated by the third party for Insurance Company, shall be handed over to Organization. Evidence shall be provided to Organization for deletion and purging of all copies of data at service provider site/s

When in transit, data shall be subject to stringent controls based on the classification of data as laid down in the Information and Cyber Security Policy: Security Domain Policy, Section 2.1 – ‘Data Classification’.

Upon termination of services, the service provider shall provide a certificate to ensure that de-commissioning has been carried out and further access shall not be provided to Organization employees.

3.6 Virtualization

In cloud computing, majority of logical separation controls are not physical, it is enforced through logical system and application controls designed to help ensure data segmentation and integrity across the

platform. The mechanism for providing this separation of data and services is “virtualization”.

3.6.1 Evaluation of Cloud Service Provider virtualization environment

Organization shall evaluate the Cloud service providers’ virtualization hardening guidelines and policies and evaluate the third-party gap assessment against technology risk assessment checklist. This includes but not limited to:

- a. Disable or remove all unnecessary interfaces, ports, devices and services;
- b. Securely configure all virtual network interfaces and storage areas;
- c. Establish limits on VM resource usage;
- d. Ensure all operating systems and applications running inside the virtual machine are hardened;
- e. Validate the integrity of the cryptographic key- management operations;
- f. Harden individual VM virtual hardware and containers;

3.6.2 Virtualization Security

Organization shall ensure that the Cloud security provider has controls to guarantee that only authorized snapshots/ images are taken and that these snapshots’/ images’ level of classification, storage location and encryption is in compliance with the production virtualization environment.

Organization shall assure the following controls are applied as a part of hypervisor security:

- a. Organization can access the Hypervisor administrative access log reports.
- b. Hypervisor complete logging is enabled.

Organization shall ensure that the cloud service provider gives assistance of trusted Virtual Machines (VM) and those VMs were made in compliance with the hardening guidelines.

The cloud service provider shall provide Organization with its complete vendor list that will have access to Organization’s data; at any point throughout the duration of the agreement. The Cloud Service Provider shall update Organization about any change in the vendor list.

For multi-tenancy through virtualization,

- Application shall be explicitly tested and qualified using virtualization product that is deployed within the Cloud. Application vendor shall provide sizing considering deployment under virtualized environment. Alternatively, vendor shall provide sizing based on physical servers and state the overhead with specific virtualization product.

- Application image shall be available for the virtualization product used. Each virtual machine shall be allocated resources commensurate with projected transaction. Resource consumption shall be periodically monitored against actual load so that necessary refinements can be carried out.
- Putting different tiers of the application onto separate physical boxes shall allow passing communication between tiers to go through physical network and facilitate implementation of firewall policies to allow communication only between VMs belonging to the same company. Also, using different disk partitions to isolate VMs belonging to different companies can provide further isolation.

3.7 Legal, Regulatory and Contractual Requirements

3.7.1 Contractual Requirements

Organization shall sign a non-disclosure agreement (NDA) with the cloud service provider before providing any service. All aspects relating to privacy, confidentiality, security and business continuity shall be fully met.

If the vendor is certified under the Cloud Security Alliance Trust or is providing control information under the Cloud Trust Protocol, and if the scope of services provided to Organization is included under the scope / statement of applicability for the certification, the vendor shall be exempt from the requirement for periodic audits by Organization. However, in such a scenario, the vendor will be required to furnish the following:

- A self-certificate of compliance to all IS provisions in the contract
- Copy of a valid certification demonstrating that the scope of services provided to Organization is included under the scope / statement of applicability for the certification
- In order to be able to enforce performance, information security and other controls to address outsourcing risks, Organization shall build the right to audit as part of contract with vendors.

Information Security department shall be engaged during the establishment of Service level agreements (SLAs) and contractual obligations to ensure that security requirements are contractually enforceable.

Organization shall prepare a service contract addressing the following domains:

- a. Architectural Framework
- b. Governance, Risk Management
- c. Clarity on Cloud service provider's role and Organization's role
- d. e-Discovery searches
- e. Expert testimony
- f. Primary and secondary[logs] data
- g. Location of storage
- h. Contract termination
- i. Ownership of data

Organization shall ensure that the Service Level Agreement(SLA) reflect the applications and data availability requirements in the occurrence of planned or unplanned disruptions or outages, business continuity and disaster recovery planning and backup and redundancy mechanisms defined by Organization.

Organization shall include the financial remedies in the event of a business disruption in the SLA.

Third party service providers shall be empaneled for the cloud services of Organization only after a contract is signed between Organization and the service provider.

The contracted terms and condition shall be approved and drafted by the Legal department of Organization for safeguarding the interest of Organization in consultation with Compliance, Risk and Information Security departments.

Automated tools shall monitor and track SLA's and generate reports to project the impact on costs, ROI etc.

The provisioning process shall be completely automated.

3.7.2 Contractual clauses on Data Privacy

Organization shall assure that it retains the "Exclusive" right to data ownership throughout the duration of the agreement. Ownership includes all copies of data available with cloud service provider including the backup media copies, if any. Organization shall ensure that the cloud service providers are not permitted to use Insurance Company's' data for advertising or any other non-authorized secondary purpose Organization shall contractually assure that they are informed of any confirmed breach immediately without any delay. For suspected breach, Organization shall be informed within 4 hours from the time of breach discovery.

Organization shall contractually require that the cloud service provider be responsible for any financial losses or penalties that may occur in event of a cloud service provider breach.

Organization shall contractually require that the cloud service provider will completely eliminate any trace of data/ information at the termination of the Contract as agreed in the contract.

Organization shall contractually require and ensure that the cloud service provider will fulfill the data and media destruction and sanitization controls.

Organization shall ensure that the cloud service provider complies with the requirement of return of data to Organization. There shall be no Vendor-lock in by the cloud service provider.

5.7.3 Legal Requirements

Organization shall ensure that the Cloud service provider's own data privacy policy is in compliance with the applicable laws in Organization. Also, the cloud service provider shall adhere to all regulatory and legal requirements of the country.

Data and processes in Cloud Computing shall comply with both Indian and international laws when Organization availing the Cloud service has an international presence. Legal compliance shall be ensured when using the Cloud service.

5.7.4 Regulator Independence

Organization shall contractually agree with the cloud service provider that the infrastructure and applications are made available for audit/ inspection by the regulators of the country. Regulator shall have access to all information resources that are consumed by Insurance Company, though the resources are not physically located in the premises of Organization.

5.8 RACI Matrix

Responsible	Accountable	Consulted	Informed
IT Team	Information Security Team	CRO/COO/Legal	Executive management

Policy No.: 2.20

Policy Name: 2.20 Cyber Resilience

1 PURPOSE The varied challenges presented by cyber risk should be met with a broad response. Appropriately high-level management's attention is a necessity, as is an effective governance structure able to understand, prevent, detect, respond to, and address Cyber security incidents.

To provide guidelines for addressing cyber security and related risks and the mitigation of such risks.

2 Scope This policy applies to information systems, including IT applications, IT infrastructure and physical information channels, information assets that Organization uses, business processes and procedures.

3 Policy The objectives of this policy are to:

1. Prevent occurrence and recurrence of cyber incidents by implementing security proactive measures.
2. Create infrastructure for conformity assessment and certification of compliance to cyber security best practices, standards and guidelines
3. Create mechanisms for security threat early warning, vulnerability management and response to security threats
4. Create processes, structures and mechanisms to generate necessary situational scenario of existing and potential cyber security threats and enable timely information sharing for proactive, preventive and protective actions.
5. Promote and launch a comprehensive awareness program on security of cyberspace.

3.1 Classification 1. Critical Systems and Cyber Security Incidents shall be classified based on criticality and severity

2. Incident classification guideline shall be defined as a part of Incident Management Procedure for Information & Cyber Security Incidents

3.2 Cyber Resilience program

Cyber resilience is ability to continuously deliver the intended outcome despite adverse cyber events. Well-functioning cyber security management program consistent with cyber resilience best practices shall be in place and verified through supervisory review. To be effective, cyber security needs to be addressed at all levels. Cyber security management program includes on-going processes and control improvements, incident management procedures such as response and disaster recovery, state-of-the-art network policies and procedures, rigorous management and control of user privileges, secure configuration guidance, appropriate malware protection procedures, consistent control of removable media usage, monitoring of mobile and home working procedures, and ongoing awareness and educational initiatives for all personnel. Best practices for cyber resilience should include but not limited to below key areas:

- Identification
- Protection
- Detection
- Response and Recovery
- Testing
- Learning and Reporting
- Situational Awareness

3.2.1 Identification

Organization shall establish and follow a cyber-threat intelligence process, analysis and information sharing process including but not limited:

The following Cyber threats shall be identified:

1. That could affect the operational performance
 2. Cause significant impact to meet Insurance Company" objectives and obligations
 3. Cause threat to critical business, processes and reputation
- Necessary steps shall be taken to identify assets that need to be protected on priority.
1. Critical assets, business functions and processes shall be identified that shall be protected against compromise.

2. Information assets (including sensitive personal information) and related system access shall be part of the identification process.
3. Organization shall establish a process to gather and analyze cyber threat information in conjunction with internal and external business and system information sources
4. Business process or Vendor risk shall be identified and assessed as a part of on-boarding and operations process.
5. For detailed classification “Asset Management” section of “Information and Cyber Security policy” shall be referred.

3.2. Protection
2

1. Controls shall be in line with technical standards.
2. Resilience shall be provided by design.
3. Comprehensive protection entails protecting interconnections and other means of access to insider and outsider threats. When designing protection, the “human factor” shall be taken into consideration.
4. Appropriate access controls on least privileges roles shall be part of application and access control design.

3.3. Detection
3

For critical systems cyber security monitoring is essential, as performing security events monitoring and or analytics shall assist in detection and mitigation of cyber incidents.

Please refer to ‘Monitoring, Logging and Assessment Policy.’

3.3. Response and
4 Recovery

Contingency planning, design, and business integration as well as data integrity are key enablers for fast recovery.

For effective contingency planning, periodic testing shall be conducted

Please refer “Incident And Problem Management Policy” and “Business Continuity Management and Disaster Recovery Policy”

3.3. Testing
5

Testing programmes, vulnerability assessments and penetration tests are cornerstones in the testing phase. Security testing shall be carried at different stages of application development and maintenance cycle. For detail please refer “Information Systems Acquisition and Development”, “Information Systems Maintenance”, “Network Security” and “Monitoring, Logging and Assessment” sections of “Information and Cyber Security Policy”.

3.3. Learning and
6 Reporting

Organization shall continually re-evaluate the effectiveness of Cyber security management.

Organization shall report information security incidents, where the confidentiality, integrity, or availability of critical information is potentially compromised, to respective regulator and other governing bodies with the required data elements, as well as any

other available information, within timelines defined by respective governing bodies by Information Security Team.

**3.3. Situational
7 Awareness**

Awareness contributes to the identification of cyber threats. Accordingly, the establishment of a threat intelligence process helps to mitigate cyber risk. In this regard, Organization shall participate in established information sharing initiatives as may require. Cybersecurity awareness circulars and advisories shall be regularly sent to employees, third party vendor and consultants

3.4 Forensics

Organization may perform forensic investigations for incidents requiring investigation for legal or regulatory purposes and/or severe information security incidents. They may collect, process, store and analyze digital evidence in accordance with the regulations and laws

**3.5 RACI
Matrix**

Responsible	Accountable	Consulted	Informed
IT Team	Information Security Team	Risk Team/ Information Security Team	Asset Owner/Business/Executive Management

- | | | |
|-----|---|---|
| 1 | PURPOSE | To define Organization's desired security requirements for protection of the electronic messaging used or controlled by Organization. |
| 2 | SCOPE | <p>This policy shall apply to all communication channels and network connections through which Organization's information assets are transmitted.</p> <p>Communications channels and network connections include but are not limited to E-mail, Internet, intranet and social media platforms</p> <p>All Business Units or Departments using information technology must comply with these Information Security Policies</p> |
| 3 | POLICY | <p>Formal transfer policies, procedures and controls should be in place to protect the transfer of information through the use of all types of communication facilities.</p> <p>Organization may transfer information transfer through the use of a number of different types of communication facilities, including electronic mail, voice, facsimile and video. Software transfer may occur through a number of different mediums, including downloading from the Internet and acquisition from vendors selling off-the-shelf products. The business, legal and security implications associated with electronic data interchange, electronic commerce and electronic communications and the requirements for controls shall be considered.</p> <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Information security considerations for electronic messaging | <ol style="list-style-type: none">1. Organization shall to lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the Domain Keys Identified Mail (DKIM) standards.2. DNS filtering services shall be used to help block access to known malicious domains.3. Organization shall use sandboxing to analyse and block inbound email attachments with malicious behaviour.4. Measures shall be implemented to control use of VBA/macros in MS office documents, control permissible attachment types in email systems |

Policy No.: 2.22
2.22 Work from Remote Location

Policy Name:

- | | | |
|-----|------------------|---|
| 1 | PURPOSE | To define the roles, responsibilities and terms of use of Organization's information assets concerning Work from remote locations. |
| 2 | SCOPE | <p>This policy shall apply to all employees, contractors and third-party who shall access Organization's information assets and facilities using remote connections.</p> <p>All Business Units or Departments using information technology must comply with these Information Security Policies</p> |
| 3 | POLICY | <p>The objectives of this policy are to:</p> <ol style="list-style-type: none">1. Prevent occurrence and recurrence of cyber incidents by implementing security proactive measures.2. Create infrastructure for conformity assessment and certification of compliance to cyber security best practices, standards and guidelines3. Create mechanisms for security threat early warning, vulnerability management and response to security threats4. Create mechanism to prevent leakage of confidential information. <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Framework | <ol style="list-style-type: none">1. Board approved Cyber Security Policy (Policy) of the Insurer shall address risks associated with Work from Remote Location (WFRL) risks. The policy shall mandate the need to change passwords frequently.2. Workflow approvals, deviations or exceptions shall be captured as per "<i>Change control policy- Section 2.9</i>"3. Audit log monitoring and analysis shall be provisioned on organizational ICT infrastructure as a control for unauthorized access risks and cyber threats.4. Evidences and artefacts shall be classified, securely demonstrated to concerned stakeholders and shall not be shared out of authorized domains.5. Project implementation documents, MIS reports shall be classified and shared on Need-to-know basis. |

3.2 Network security

6. Insurance companies shall ensure that in the case of disruption IT support shall be accessed by investment application users through portal, help desk (phone) or email or visit to office.
1. Organization shall ensure a secure network with strong protocols and Wi-Fi passwords at remote location.
2. Authorized assets of the Organization provided to the users shall be hardened as per security policy for strong password authentication.
3. All servers, applications and networks shall be hardened and secured as per standardized security policy settings.
4. Device controls shall be implemented on user systems and Information and Communication Technology (ICT) infrastructure systems to block unauthorised internet domains, admin level access, unauthorized installation or changes to software, USB and other media, peripherals.
5. All user systems shall be enabled with Antivirus, Endpoint protection controls, data encryption and Data Loss Prevention mechanisms.
6. User systems and organization's ICT infrastructure shall be regularly updated with security patches and fixes.
7. Secure remote access mechanisms of Virtual Private Network (VPN), Internet Proxy or Virtual Device Interface (VDI) shall be provisioned for WFRL users accessing Organization data assets and applications
7. All patches, AV, End Point Protection, Data Encryption mechanisms shall be checked to ensure its appropriate functioning.
8. Applications shall be accessible ONLY to authorised users through a secured VPN access
9. Hardening procedures shall be put in place to check / scan systems brought back to office.
10. Controls shall be in place to identify unauthorized access, malicious code execution, suspicious activities or behaviour, credential theft, presence of advance persistent threats like remote access toolkits and such cyber risks to organizational infrastructure.
11. Email services shall be secured to prevent spam, spoofed mails and malware filtering and users shall be trained to handle spam, phishing scam and fraudulent emails.
12. Suspicious or malicious domains on the internet shall be detected and blocked on network firewall, web proxy filtering, intrusion prevention systems
13. Security patch updates shall be reviewed and periodically applied on ICT infrastructure to prevent Distributed Denial of Services (DDoS) attacks.

14. DR Drill shall be performed to ensure adherence to Business Continuity metrics.
- 3.3 Data management**
1. Data containerization, Multifactor authentication and remote data wipe shall be done to prevent data tampering and misuse of lost mobile/tablet devices during the period when WFRL has been permitted by the entity.
 2. Users shall be mandated to back-up critical data periodically on secure location in organization systems.
 3. Backups shall be reviewed periodically and procedures shall be aligned to minimize downtime impact.
- 3.4 Human resource security**
1. Non-disclosure agreements / Undertaking on data security and confidentiality shall be signed at the time of employee/ consultant/ third-party vendor on boarding before permitting Operations to be commenced at WFRL.
 2. Controls and procedures relating to secure access of Organization's data assets and applications from user-owned devices like mobile phones, tablets or other Bring Your Own Device (BYOD) shall be defined.
 3. An audit of Privileged user identity access authentication shall be conducted for administrative purposes.
 4. Activities like walkthrough and interviews shall be performed using approved remote access software over secure and hardened systems of auditee and auditor organizations.

- | | | |
|-----|-------------------------------|---|
| 1 | PURPOSE | To define the roles, responsibilities and terms of use of Organization's information assets concerning operations in dealing room. |
| 2 | SCOPE | <p>This policy shall apply to all employees, contractors and third-party who shall access Organization's information assets and facilities using remote connections.</p> <p>All Business Units or Departments using information technology must comply with these Information Security Policies</p> |
| 3 | POLICY | <p>The objectives of this policy are to:</p> <ol style="list-style-type: none">1. Create mechanism for secure recording of dealing information.2. Create authorisation matrix in case of any deals to be carried out.3. Create mechanism for record retention and consent to be obtained before entering into any contract. <p>Any breach of this policy shall be considered as an incident and shall be treated as per the incident management policy.</p> |
| 3.1 | Data protection in IVR | <ol style="list-style-type: none">1. Dealers shall be provided with a dedicated and secured recording line during WFH for placing the calls to the brokers.2. Insurance companies shall ensure that recorded lines are working and well maintained.3. The Mid-office shall check voice recording as per a defined process in Standard Operating Procedure.4. Voice logger shall be used for recording of calls made from office location. Back up/storage of such call recordings shall be enabled as a part of proof of transaction and the same shall be accessed anytime.5. SOP shall define process to handle disruption in communication links between the dealers and brokers.6. Communications between the dealers and brokers shall be logged/recorded and the same shall be independently reviewed by the Mid-office.7. Dealers shall execute ALL transactions only through recorded telephone lines8. Secondary network connectivity and IT infrastructure shall be provisioned and tested for the critical applications and services. |
| 3.2 | Authorization | <ol style="list-style-type: none">1. Dealing room operation procedure should be developed. |

2. Policies / processes shall be defined to guide the officials of the Investments Function to process transactions with appropriate approvals in the event of disruption.
3. The SOP/Dealing room policy shall specify the dealers to place the orders only through empanelled brokers via authorized communication modes.
4. Appropriate prior approvals / authorisations shall be taken to process transactions with the brokers
5. Dealers shall ensure that emails are shared ONLY through authorized company email addresses registered with concerned counterparties.
6. Dealers shall ensure that IT support shall be accessed by Investment application users by way of portal, helpdesk or visit to office.
7. Supervisory monitoring process checklist which includes transaction price monitoring and trade monitoring etc shall be put in place.
8. Investment transactions shall be executed with requisite approvals defined as a part of Dealing Room Work flow / SOP.
9. Dealers shall completely disable the SMS / Chat facilities of all authorized Bloomberg terminals / Bloomberg.
10. Dealers shall execute all transactions via recorded telephone lines or authorized Bloomberg terminals / Bloomberg anywhere ID's / NDS terminals/TREPS terminals/Emails.

3.3 Data security

1. Voice recording analysis and rate scan shall be carried out on a regular basis to supervise trades and transaction price as defined in dealing room policy,
2. multi-factor authentication shall be enabled for all Bloomberg terminals.
3. Disaster Recovery (DR) Drills shall be performed to verify the availability of applications, processes and resources at remote backup site. The issues identified during such drills shall be addressed and documented.
4. Contingency policy and plans, Backup/Alternative locations and resources shall be identified, revised and tested within Investment function periodically for an effective business continuity.

Policy No.:	2.24
	2.24 Information Technology
Policy Name:	[Intermediary Guidelines and Digital Media Ethics Code] Rules, 2021

- | | | |
|-----|------------------|---|
| 1 | PURPOSE | To define the roles, responsibilities and terms of use of Organization's digital platforms |
| 2 | SCOPE | This policy shall apply to all employees, contractors and third-party who shall access Organization's information assets and facilities . |
| 3 | POLICY | <p>The Objectives of this policy are to:</p> <ol style="list-style-type: none"> 1. Create processes, structures and mechanisms to ensure data privacy. 2. Promote and launch a comprehensive awareness program on security of cyberspace. 3. Restrict any infringement of patent, trademark, copyright or other proprietary rights. 4. Due diligence to be considered while using social media |
| 3.1 | Framework | <p>The rules and regulations, privacy policy or user agreement of the Organization shall inform the user of its computer resource not to host, display, upload, modify, publish, transmit, store, update or share any information that</p> <p>(i) belongs to another person and to which the user does not have any right;</p> <p>(ii) is defamatory, obscene, pornographic, pedophilic, invasive of another privacy including bodily privacy, insulting or harassing on the basis of gender, libelous, racially or ethnically objectionable, relating or encouraging money laundering or gambling, or otherwise inconsistent with or contrary to the laws in force;</p> <p>(iii) is harmful to child;</p> <p>(iv) infringes any patent, trademark, copyright or other proprietary rights;</p> <p>(v) violates any law for the time being in force;</p> <p>(vi) deceives or misleads the addressee about the origin of the message or knowingly and intentionally communicates any information which is patently false or misleading in nature but may reasonably be perceived as a fact;</p> <p>(vii) impersonates another person;</p> |

(viii) threatens the unity, integrity, defense, security or sovereignty of India, friendly relations with foreign States, or public order, or causes incitement to the commission of any cognizable offence or prevents investigation of any offence or is insulting other nation;

(ix) contains software virus or any other computer code, file or program designed to interrupt, destroy or limit the functionality of any computer resource;

(x) is patently false and untrue, and is written or published in any form, with the intent to mislead or harass a person, entity or agency for financial gain or to cause any injury to any person;

2. The Organization shall periodically inform its users, at least once every year, that in case of non-compliance with rules and regulations, privacy policy or user agreement for access or usage of the computer resource of such intermediary, it has the right to terminate the access or usage rights of the users to the computer resource immediately or remove non-compliant information or both, as the case may be.
3. The Organization on whose computer resource the information is stored, hosted or published, upon receiving actual knowledge in the form of an order by a court of competent jurisdiction or on being notified by the Appropriate Government or its agency under clause (b) of sub-section (3) of section 79 of the Act, shall not host, store or publish any unlawful information, which is prohibited under any law for the time being in force relation to the interest of the sovereignty and integrity of India; security of the State; friendly relations with foreign States; public order; decency or morality; in relation to contempt of court; defamation; incitement to an offence relating to the above, or any information which is prohibited under any law for the time being in force.
4. The Organization shall periodically, and at least once in a year, inform its users of its rules and regulations, privacy policy or user agreement or any change in the rules and regulations, privacy policy or user agreement, as the case may be.
5. The Organization which collects information from a user for registration on the computer resource, shall retained his information for a period of one hundred and eighty days

after any cancellation or withdrawal of his registration, as the case may be.

6. The Organization shall take all reasonable measures to secure its computer resource and information contained therein following the reasonable security practices and procedures as prescribed in the Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Information) Rules, 2011).
7. The Organization shall as soon as possible, but not later than seventy-two hours of the receipt of an order, provide information under its control or possession, or assistance to the Government agency which is lawfully authorized for investigative or protective or cybersecurity activities, for the purposes of verification of identity, or for the prevention, detection, investigation, or prosecution, of offences under any law for the time being in force, or for cyber security incidents.
8. The Organization shall report cyber security incidents and share related information with the Indian Computer Emergency Response Team in accordance with the policies and procedures as mentioned in the Information Technology (The Indian Computer Emergency Response Team and Manner of Performing Functions and Duties) Rules, 2013.
9. The Organization shall not knowingly deploy or install or modify technical configuration of computer resource or become party to any act that may change or has the potential to change the normal course of operation of the computer resource than what it is supposed to perform thereby circumventing any law for the time being in force.
10. The Organization shall publish on its website, mobile based application or both, as the case may be, the name of the Grievance Officer and his contact details as well as mechanism by which a user or a victim may make complaint against violation of the provisions of this rule or any other matters pertaining to the computer resources made available by it, and the Grievance Officer shall -
 - I. acknowledge the complaint within twenty-four hours and dispose off such complaint within a period of fifteen days from the date of its receipt;
 - II. receive and acknowledge any order, notice or direction issued by the Appropriate Government, any

competent authority or a court of competent jurisdiction.

- II. The Organization shall within twenty-four hours from the receipt of a complaint made by an individual or any person on his behalf under this sub-rule, in relation to any content which is prima facie in the nature of any material which exposes the private area of such individual, shows such individual in full or partial nudity or shows or depicts such individual in any sexual act or conduct, or is in the nature of impersonation in an electronic form, including artificially morphed images of such individual, take all reasonable and practicable measures to remove or disable access to such content which is hosted, stored, published or transmitted by it.

Annexure A

Clause	Explanation
Information Technology (Amendment) Act, 2008	IT (Amendment) Act 2008 has specified “reasonable security practices and procedures” to protect “sensitive personal data or information” (SPDI). It is mandatory to identify the SPDI processed and ensure all the process are compliant with IT (Amendment) Act 2008
Companies Act, 1956	This act requires various disclosures, filling and record keeping obligations to be fulfilled. Ensure compliance as regards availability, verifiability, authenticity, amenability to inspect, audit and review.
Insurance Act	To govern all form of insurance and to provide strict control over insurance business.
IRDAI Regulations	To aid, advise and assist insurers carrying on general insurance business in the matter of setting up equitable and clear standards of conduct and sound practice and in the matter of rendering efficient service to holder of general insurance guidelines.
Contract Act 1961	Determines the circumstances in which promises made by the parties to a contract shall be legally binding on them.
FERA/FEMA	Regulate the foreign payments, regulate the dealings in Foreign Exchange & securities and conservation of Foreign exchange for the nation
Stamp Duty Act	A tax that is levied on documents. Historically, this included the majority of legal documents such as cheques, receipts, military commissions, marriage licenses and land transactions.
Personnel Laws	Various personnel laws like the Payment of Wages Act, the ESI Act, Provident Funds Act etc. require various disclosures, filling and record keeping obligations to be fulfilled.
Data Privacy Law	A full-fledged Indian data privacy law is expected any time. It will be mandatory to protect data privacy as per this law.
Aadhaar Act	Aadhaar act aims to provide legal backing and governance to the Aadhaar unique identification number project.

Annexure B- RACI Matrix

Sr. N o.	Policies	Asset	HR	IT	Information Security	Admin	Finance	Business	Legal and Compliance	Risk Management	Vendors/	Users	Change Requestor	Executive Management
1.	Data Classification	R/I		I	A/I			I		C				
2.	Asset Management	R	A		C	A/I	I			I				
3.	Access Control			R	A/C			A		I				
4.	Human Resource Security		R/A	C	C			I		C				
5.	Information System Acquisition and development			R/A	C			I						
6.	Information system and Maintenance			R	A						C	I		
7.	Change Control			A				I		C			R	
8.	Incident and problem management		R		R/I/C	R		R/A/I				I		
9.	Network Security			R/A/I	C			A						
10.	Cryptographic Controls			R/I	A/C							I		
11.	Business Continuity Management			R	A			I		C				

Sr. N o.	Policies	Asset	HR	IT	Information Security	Admin	Finance	Business	Legal and Compliance	Risk Management	Vendors/	Users	Change Requestor	Executive Management
12.	Third Party service provider				C		I	A	C	C	R			
13.	Physical and environmental security				A	R		C				I		
14.	Monitoring, logging and assessment			R	A	R				C				I

Sr. No.	Policies	Asset	HR	IT	Information	Admin	Finance	Business	Legal and Compliance	Risk	Management	Vendors	Users/ Employees	Change Request	Executive
15.	Mobile Device Security			R	A							C	I		
16.	BYOD			C/I	C			A		I			R		
17.	Legal and regulatory compliance				A				R	C					I
18.	Situational Awareness			R	A					C					I
19	Cloud Security			R/C	A				C	C					I
20	Cyber Resilience	I		R	A/C			I		C					I

Glossary

Term	Description
Insurance Company	Organization Ltd
ISCP	Information and Cyber Security Policy
IS	Information Security
ISRMC	Information Security Risk Management committee
RMC	Risk Management Committee
IT Act	Information Technology (IT) Act
RBI	Reserve Bank of India
IT	Information Technology
CRO	Chief Risk Officer
CITSO	Chief IT Security Officer
CISO	Chief Information Security Officer
CSO	Chief Security Officer
CHRO	Chief Human Resource Officer
HR	Human Resources
CFO	Chief Finance Officer
COO	Chief Operating Officer
TRA	Technology Risk Assessments
BCP	Business Continuity Planning
DR	Disaster Recovery
RA	Risk Assessment
BIA	Business Impact Analysis
SOC	Security Operations Center
LAM	Logical Access Management
DLP	Data Leak Prevention
VA	Vulnerability Assessment
PT	Penetration Testing
VAPT	Vulnerability Assessment and Penetration Testing
SLA	Service Level Agreement
GRC	Governance Risk and Compliance
ERM	Enterprise Risk Management
IPR	Intellectual Property Rights
PII	personally identifiable information
SMS	Short Message Service
MAC	Media Access Control
CI	Configurations Item
IP address	Internet Protocol address

SPI	Sensitive Personal Information
OPI	Other Personal Information
IMEI	International Mobile Station Equipment Identity
AMC	Annual Maintenance Contracts
NDA	non-disclosure agreements
MBSS	Minimum Baseline Security Standards
OS	Operating System
CERT	Computer Emergency Response Team
OEM	Original Equipment Manufacturer
CR	Change Request
SAT	System Acceptance Testing
SIT	System Integration Testing
UAT	User Acceptance Testing
MPLS	Multiprotocol Label Switching
VPN	Virtual Private Network
WiFi	wireless fidelity
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
ISDN cards	Integrated Services for Digital Network
CD	Compact Disk
DVD	Digital Video Disc or Digital Versatile Disc
ERT	Emergency Response Team
BMS	Building Management System
CCTV	Close circuit television

Glossary

Term	Description
Insurance Company	Organization Ltd
ISCP	Information and Cyber Security Policy
IS	Information Security
ISRMC	Information Security Risk Management committee